

PELINDUNGAN DATA PRIBADI PASIEN

**Panduan Kesadaran Keamanan Informasi bagi Pegawai
dan Pihak Ketiga di RSUD Kabupaten Brebes**



Hendrawan Aprillia Ashari, S.T., M.Kom

**DINAS KOMUNIKASI, INFORMATIKA, DAN STATISTIK
KABUPATEN BREBES
2026**

PELINDUNGAN DATA PRIBADI PASIEN

Panduan Kesadaran Keamanan Informasi bagi Pegawai dan Pihak Ketiga di RSUD Kabupaten Brebes

Penulis:

Hendrawan Aprillia Ashari, S.T., M.Kom

© 2026 Hendrawan Aprillia Ashari

Hak cipta dilindungi sesuai dengan ketentuan peraturan perundang-undangan.

Dilarang memperbanyak, mendistribusikan, menerbitkan kembali, atau mengubah sebagian maupun seluruh isi buku ini untuk tujuan komersial tanpa izin tertulis dari pemegang hak cipta, kecuali penggunaan yang diperbolehkan berdasarkan ketentuan peraturan perundang-undangan.

Buku ini disusun sebagai materi **kesadaran keamanan informasi (security awareness)** bagi pegawai dan pihak ketiga di lingkungan RSUD Kabupaten Brebes, khususnya dalam perlindungan data pribadi pasien dan penggunaan sistem informasi secara aman.

Pembahasan dalam buku ini berfokus pada aspek **cybersecurity, keamanan informasi, perlindungan data pribadi, pengamanan credential, Tanda Tangan Elektronik, keamanan perangkat, pertukaran data, social engineering, akses pihak ketiga, serta penanganan insiden keamanan informasi.**

Buku ini **bukan merupakan pedoman pelayanan medis atau klinis.** Informasi mengenai pasien, rekam medis, dan sistem pelayanan kesehatan yang digunakan dalam buku ini hanya dibahas dalam konteks keamanan informasi dan perlindungan data.

Contoh nama, akun, alamat surel, nomor identitas, alamat IP, ilustrasi insiden, serta data lain yang digunakan untuk kepentingan pembelajaran harus diperlakukan sebagai **data contoh atau data yang telah disamarkan**, kecuali dinyatakan lain.

Dinas Komunikasi, Informatika, dan Statistik Kabupaten Brebes
Kabupaten Brebes, Jawa Tengah

KATA PENGANTAR

Perkembangan penggunaan sistem elektronik telah memberikan kemudahan dalam pengelolaan dan pertukaran informasi di lingkungan organisasi. Di sisi lain, penggunaan teknologi informasi juga menghadirkan risiko terhadap kerahasiaan, keutuhan, dan ketersediaan informasi apabila tidak disertai dengan penerapan keamanan informasi yang memadai.

Di lingkungan RSUD Kabupaten Brebes, data pasien merupakan salah satu aset informasi yang harus dilindungi. Pelindungan tersebut tidak hanya bergantung pada teknologi dan sistem keamanan yang digunakan, tetapi juga pada perilaku setiap orang yang memperoleh akses terhadap sistem dan informasi.

Penggunaan credential secara tidak tepat, pemberian password kepada orang lain, penyerahan passphrase Tanda Tangan Elektronik (TTE), kesalahan pengiriman data, penggunaan perangkat pribadi, phishing, social engineering, serta akses pihak ketiga merupakan beberapa contoh risiko yang dapat menyebabkan terjadinya insiden keamanan informasi.

Buku **Pelindungan Data Pribadi Pasien: Panduan Kesadaran Keamanan Informasi bagi Pegawai dan Pihak Ketiga di RSUD Kabupaten Brebes** disusun sebagai materi kesadaran keamanan informasi (*security awareness*) yang memberikan pemahaman praktis mengenai perilaku yang aman dalam mengakses, menggunakan, menyimpan, dan membagikan data pasien.

Pembahasan buku difokuskan pada aspek cybersecurity dan keamanan informasi. Buku ini tidak dimaksudkan untuk membahas aspek klinis maupun pelayanan kesehatan, melainkan membantu pegawai dan pihak ketiga memahami peran dan tanggung jawabnya dalam menjaga keamanan data pasien.

Diharapkan buku ini dapat menjadi salah satu sarana untuk membangun budaya keamanan informasi di lingkungan RSUD Kabupaten Brebes, sehingga pelindungan data tidak hanya dipandang sebagai tanggung jawab pengelola teknologi informasi, tetapi menjadi bagian dari tanggung jawab bersama setiap pengguna sistem informasi.

Brebes, 2026

Hendrawan Aprillia Ashari, S.T., M.Kom

DAFTAR ISI

BAB 1 DATA PASIEN ADALAH ASET INFORMASI YANG HARUS DILINDUNGI	1
1.1 Mengapa Data Pasien Harus Dilindungi?.....	1
1.2 Data Pasien sebagai Aset Informasi	3
1.3 Kebocoran Data Tidak Selalu Disebabkan oleh Peretas	7
1.4 Peran Manusia dalam Keamanan Informasi	10
1.5 Tanggung Jawab Pegawai dan Pihak Ketiga	13
1.6 Prinsip Dasar: Akses dan Gunakan Data Sesuai Kewenangan	17
BAB 2 MENGENAL DATA PRIBADI PASIEN.....	21
2.1 Apa yang Dimaksud dengan Data Pribadi?	21
2.2 Data Kesehatan sebagai Data Pribadi yang Bersifat Spesifik.....	24
2.3 Contoh Data Pribadi Pasien.....	27
2.4 Rekam Medis dan Rekam Medis Elektronik sebagai Informasi yang Harus Dilindungi	30
2.5 Data Pasien dalam SIMRS dan Sistem Elektronik Lainnya	34
2.6 Data Pasien dalam Bentuk Dokumen, File, Foto, dan Percakapan	38
2.7 Mengidentifikasi Data Pribadi Sebelum Menggunakan atau Membagikannya	42
BAB 3 AKSES DATA PASIEN: TIDAK SEMUA ORANG BOLEH MELIHAT SEMUA DATA.....	47
3.1 Hak Akses Bukan Hak untuk Melihat Semua Data.....	47
3.2 Prinsip Need-to-Know.....	52
3.3 Prinsip Least Privilege	57
3.4 Gunakan Akses Hanya untuk Kepentingan Pekerjaan.....	62
3.5 Dilarang Mengakses Data karena Rasa Ingin Tahu.....	68
3.6 Risiko Penggunaan Akun Bersama	73
3.7 Logging dan Audit Trail	79
3.8 Akses Pegawai, Administrator, Vendor, dan Pihak Ketiga	86
BAB 4 PASSWORD DAN CREDENTIAL ADALAH MILIK PRIBADI ..	94
4.1 Apa yang Dimaksud dengan Credential?	94
4.2 Username dan Password Tidak Boleh Dipinjamkan	97
4.3 Jangan Memberikan Password kepada Rekan Kerja	99
4.4 Bagaimana Jika Atasan Meminta Password?	102
4.5 Bagaimana Jika Administrator, Teknisi, atau Vendor Meminta Password?....	104
4.6 OTP dan Kode Verifikasi Tidak Boleh Diberikan kepada Orang Lain	107
4.7 Bahaya Mengirim Password melalui WhatsApp atau Media Komunikasi Lain	109
4.8 Jangan Menuliskan Password di Tempat Terbuka	111
4.9 Gunakan Password yang Kuat dan Berbeda.....	114
4.10 Multi-Factor Authentication.....	116
4.11 Apa yang Harus Dilakukan Jika Credential Diketahui Orang Lain?	118

BAB 5 LINDUNGI PASSPHRASE TANDA TANGAN ELEKTRONIK 121

5.1 Mengenal Tanda Tangan Elektronik	121
5.2 Sertifikat Elektronik dan Identitas Pemilik.....	122
5.3 Apa yang Dimaksud dengan Passphrase?.....	125
5.4 Passphrase Tanda Tangan Elektronik Bersifat Rahasia.....	127
5.5 Dilarang Menyerahkan Passphrase kepada Orang Lain.....	129
5.6 Jangan Menitipkan Proses Penandatanganan Elektronik	132
5.7 Staf atau Operator Tidak Boleh Menggunakan TTE Milik Orang Lain.....	134
5.8 Risiko Penyalahgunaan Tanda Tangan Elektronik	136
5.9 Apa yang Harus Dilakukan Jika Passphrase Diduga Telah Diketahui Orang Lain?.....	138
5.10 Tanggung Jawab Pemilik Tanda Tangan Elektronik	141

BAB 6 HATI-HATI MEMFOTO, SCREENSHOT, DAN MENGIRIM DATA PASIEN..... 144

6.1 Screenshot SIMRS Dapat Mengandung Data Pribadi	144
6.2 Risiko Memfoto Layar Komputer	146
6.3 Foto Dokumen dan Data Pasien.....	148
6.4 Dokumen Identitas dan Dokumen Pendukung Pasien	150
6.5 Jangan Menyimpan Data Pasien pada Galeri Ponsel Pribadi	153
6.6 Minimalkan Data Sebelum Membagikannya	155
6.7 Periksa Data dan Penerima Sebelum Mengirim.....	157
6.8 Salah Kirim Data Merupakan Insiden Keamanan.....	159
6.9 Apa yang Harus Dilakukan Jika Terlanjur Salah Mengirim?	162

BAB 7 WHATSAPP, EMAIL, CLOUD, DAN MEDIA SOSIAL..... 165

7.1 Risiko Pertukaran Data melalui Aplikasi Pesan Instan	165
7.2 Data Pasien dalam Grup WhatsApp	167
7.3 Penggunaan Email untuk Pertukaran Data	169
7.4 Risiko Menggunakan Email Pribadi.....	172
7.5 Penyimpanan Cloud Pribadi	174
7.6 Berbagi Tautan Dokumen dan Risiko Kesalahan Hak Akses	177
7.7 Data Pasien dan Media Sosial.....	180
7.8 Foto Pasien dan Risiko Pengungkapan Data	182
7.9 Periksa Penerima Sebelum Menekan Tombol Kirim	185

BAB 8 AMANKAN KOMPUTER DAN PERANGKAT KERJA 188

8.1 Kunci Komputer Ketika Meninggalkan Tempat Kerja	188
8.2 Jangan Membiarkan SIMRS dalam Keadaan Login Tanpa Pengawasan	190
8.3 Jangan Memasang Aplikasi Sembarangan	193
8.4 Penggunaan Flashdisk dan Media Penyimpanan Eksternal.....	195
8.5 Jangan Menyalin Data Pasien ke Perangkat Pribadi	198
8.6 Risiko Kehilangan Laptop dan Perangkat Kerja	201
8.7 Malware dan Ransomware	203
8.8 Pembaruan Sistem dan Perangkat Lunak Keamanan.....	206
8.9 Keamanan Fisik Perangkat dan Dokumen.....	208
8.10 Penghapusan Data secara Aman	211

BAB 9 WASPADA PHISHING DAN SOCIAL ENGINEERING 215

9.1 Tidak Semua Serangan Siber Menggunakan Teknik Peretasan	215
9.2 Apa yang Dimaksud dengan Social Engineering?	217
9.3 Apa yang Dimaksud dengan Phishing?	219
9.4 Penyerang Dapat Menyamar sebagai Atasan	222
9.5 Penyerang Dapat Menyamar sebagai Administrator TI	224
9.6 Penyerang Dapat Menyamar sebagai Vendor atau Teknisi	227
9.7 Jangan Memberikan Password, OTP, atau Passphrase melalui Telepon dan Pesan	230
9.8 Waspada Tautan, Lampiran, dan QR Code	233
9.9 Verifikasi Permintaan yang Mencurigakan melalui Kanal Terpercaya	236
9.10 Laporkan Percobaan Phishing dan Social Engineering	238

BAB 10 KEAMANAN AKSES VENDOR DAN PIHAK KETIGA 242

10.1 Pihak Ketiga Juga Wajib Melindungi Data Pasien	242
10.2 Akses Pihak Ketiga Harus Berdasarkan Kebutuhan	244
10.3 Hindari Penggunaan Akun Pegawai oleh Vendor	247
10.4 Setiap Pengguna Harus Memiliki Identitas dan Akun yang Dapat Dipertanggungjawabkan	249
10.5 Larangan Menyalin Database Tanpa Kewenangan	252
10.6 Penggunaan Data untuk Pengujian dan Troubleshooting	254
10.7 Remote Access ke Sistem Rumah Sakit	258
10.8 Pengamanan Credential untuk Akses Pihak Ketiga	260
10.9 Logging dan Pemantauan Aktivitas Pihak Ketiga	263
10.10 Pengakhiran Akses Setelah Pekerjaan Selesai	266
10.11 Kerahasiaan Data oleh Vendor dan Pihak Ketiga	268

BAB 11 JIKA TERJADI INSIDEN ATAU KEBOCORAN DATA 272

11.1 Apa yang Dimaksud dengan Insiden Keamanan Informasi?	272
11.2 Contoh Insiden Keamanan Data di Lingkungan Rumah Sakit	274
11.3 Credential Diketahui atau Digunakan Orang Lain	277
11.4 Passphrase TTE Diketahui Orang Lain	280
11.5 Salah Mengirim Data Pasien	282
11.6 Perangkat Hilang atau Dicuri	284
11.7 Komputer Diduga Terinfeksi Malware	287
11.8 Akun Menunjukkan Aktivitas yang Mencurigakan	289
11.9 Segera Laporkan Insiden	292
11.10 Jangan Menutupi Insiden atau Menghapus Bukti	294
11.11 Simpan Informasi yang Diperlukan untuk Penanganan Insiden	297
11.12 Containment, Recovery, dan Pencegahan Kejadian Berulang	299

BAB 12 MEMBANGUN BUDAYA KEAMANAN DATA PASIEN 303

12.1 Keamanan Informasi Adalah Tanggung Jawab Bersama	303
12.2 Peran Pengguna Sistem Informasi	305
12.3 Peran Pejabat dan Pimpinan	308
12.4 Peran Pengelola Teknologi Informasi	310
12.5 Peran Administrator Sistem	313

12.6 Peran Vendor dan Pihak Ketiga.....	315
12.7 Biasakan Memverifikasi Sebelum Memberikan Akses atau Data.....	318
12.8 Laporkan Aktivitas yang Mencurigakan.....	320
12.9 Security Awareness sebagai Pertahanan terhadap Serangan Siber	322
12.10 Dari Kepatuhan Menuju Budaya Keamanan Informasi	325
DAFTAR PUSTAKA	328

BAB 1 DATA PASIEN ADALAH ASET INFORMASI YANG HARUS DILINDUNGI

1.1 Mengapa Data Pasien Harus Dilindungi?

Data pasien merupakan informasi yang memiliki nilai penting dan harus dilindungi selama data tersebut dikumpulkan, digunakan, disimpan, dikirimkan, maupun diproses melalui sistem elektronik. Dalam lingkungan rumah sakit, data pasien tidak hanya terdapat di dalam Sistem Informasi Manajemen Rumah Sakit (SIMRS) atau Rekam Medis Elektronik, tetapi dapat muncul dalam berbagai bentuk, seperti dokumen elektronik, hasil cetak, berkas digital, foto, tangkapan layar (*screenshot*), surat elektronik, maupun informasi yang dipertukarkan melalui sarana komunikasi elektronik.

Undang-Undang Republik Indonesia Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi membedakan data pribadi menjadi data pribadi yang bersifat umum dan data pribadi yang bersifat spesifik. Data dan informasi kesehatan termasuk dalam kategori **data pribadi yang bersifat spesifik** (Republik Indonesia, 2022). Kedudukan tersebut menunjukkan bahwa data kesehatan bukanlah informasi yang dapat digunakan atau dibagikan secara bebas hanya karena seseorang memiliki kemampuan untuk mengaksesnya.

Pelindungan terhadap data pasien juga berkaitan erat dengan penyelenggaraan Rekam Medis Elektronik. Peraturan Menteri Kesehatan Republik Indonesia Nomor 24 Tahun 2022 tentang Rekam Medis menyatakan bahwa salah satu tujuan pengaturan Rekam Medis adalah menjamin **keamanan, kerahasiaan, keutuhan, dan ketersediaan data Rekam Medis**. Peraturan tersebut juga mewajibkan setiap fasilitas pelayanan kesehatan untuk menyelenggarakan Rekam Medis Elektronik (Kementerian Kesehatan Republik Indonesia, 2022).

Dari perspektif keamanan informasi, ketentuan tersebut memiliki hubungan yang sangat erat dengan prinsip perlindungan informasi.

Kerahasiaan berkaitan dengan upaya memastikan informasi hanya dapat diakses oleh pihak yang memiliki kewenangan. Keutuhan berkaitan dengan upaya menjaga data agar tidak diubah secara tidak sah atau tidak semestinya. Sementara itu, ketersediaan berkaitan dengan kemampuan pihak yang berwenang untuk memperoleh informasi ketika informasi tersebut diperlukan.

Pelindungan data pasien karena itu tidak hanya menjadi persoalan teknologi. Rumah sakit dapat menggunakan *firewall*, antivirus, enkripsi, autentikasi, pencatatan aktivitas (*logging*), pembatasan hak akses, dan berbagai mekanisme keamanan lainnya. Namun, mekanisme tersebut dapat kehilangan efektivitas apabila pengguna tidak menerapkan perilaku keamanan informasi yang benar.

Sebagai contoh, seorang pegawai dapat memiliki akun dan hak akses yang sah untuk membuka suatu sistem. Akan tetapi, hak akses tersebut tidak berarti bahwa pegawai tersebut diperbolehkan memberikan *username* dan *password* kepada rekan kerja, menggunakan akun secara bersama-sama, memotret layar yang menampilkan data pasien, menyalin data ke perangkat pribadi, atau mengirimkan informasi kepada pihak yang tidak memiliki kewenangan.

Risiko serupa dapat terjadi ketika seseorang mengambil *screenshot* dari SIMRS untuk meminta bantuan kepada orang lain. Apabila gambar tersebut masih menampilkan nama pasien, nomor rekam medis, Nomor Induk Kependudukan (NIK), atau informasi lainnya yang tidak diperlukan, pengiriman gambar tersebut dapat menyebabkan data tersebar lebih luas daripada yang dibutuhkan. Karena itu, pengguna harus mempertimbangkan data apa yang benar-benar diperlukan sebelum menyalin, memotret, atau mengirimkan informasi.

Prinsip yang sama berlaku bagi vendor, teknisi, konsultan, maupun pihak ketiga yang memperoleh akses ke sistem rumah sakit. Akses yang diberikan untuk melakukan pemeliharaan, pengembangan, atau *troubleshooting* tidak berarti memberikan

kewenangan untuk melihat, menyalin, menyimpan, atau menggunakan seluruh data yang tersedia di dalam sistem. Akses harus digunakan sesuai dengan kebutuhan pekerjaan dan kewenangan yang diberikan.

Hal penting yang harus dipahami adalah bahwa **kemampuan untuk mengakses data tidak selalu berarti kewenangan untuk menggunakan data tersebut**. Sistem mungkin secara teknis memungkinkan pengguna membuka suatu informasi, tetapi pengguna tetap harus mempertimbangkan kewenangan, kebutuhan pekerjaan, dan tujuan penggunaan data.

Dalam praktik sehari-hari, perlindungan data pasien dapat dimulai dari tindakan yang sederhana. Menjaga kerahasiaan *credential*, tidak memberikan *password* atau kode OTP kepada orang lain, mengunci komputer ketika meninggalkan tempat kerja, memastikan penerima sebelum mengirimkan data, tidak memindahkan data ke perangkat pribadi tanpa kewenangan, serta segera melaporkan kejadian yang mencurigakan merupakan bagian dari perilaku keamanan informasi.

Dengan demikian, perlindungan data pasien membutuhkan kombinasi antara **teknologi, prosedur, dan perilaku manusia**. Teknologi menyediakan mekanisme pertahanan, prosedur memberikan aturan mengenai bagaimana informasi harus dikelola, sedangkan pengguna menentukan bagaimana mekanisme dan aturan tersebut diterapkan dalam aktivitas sehari-hari.

INGAT: Memiliki akses ke data pasien bukan berarti bebas menggunakan atau membagikannya. Akses dan penggunaan data harus dilakukan sesuai kewenangan dan kebutuhan pekerjaan.

1.2 Data Pasien sebagai Aset Informasi

Dalam keamanan informasi, data merupakan salah satu aset yang harus dilindungi karena memiliki nilai bagi organisasi dan mendukung pelaksanaan proses bisnis. Dalam konteks rumah sakit, data pasien memiliki nilai yang sangat penting karena digunakan dalam berbagai sistem dan proses yang saling terhubung. Oleh

karena itu, data pasien perlu diperlakukan sebagai **aset informasi** yang pengelolaannya memerlukan pengamanan secara konsisten.

Data pasien tidak hanya berbentuk Rekam Medis Elektronik. Data dapat tersebar pada berbagai sistem, perangkat, dokumen, dan media penyimpanan. Peraturan Menteri Kesehatan Republik Indonesia Nomor 24 Tahun 2022 tentang Rekam Medis mendefinisikan Rekam Medis sebagai dokumen yang berisikan data identitas pasien, pemeriksaan, pengobatan, tindakan, dan pelayanan lain yang telah diberikan kepada pasien. Rekam Medis Elektronik merupakan Rekam Medis yang dibuat menggunakan sistem elektronik yang diperuntukkan bagi penyelenggaraan Rekam Medis (Kementerian Kesehatan Republik Indonesia, 2022).

Dalam praktik penggunaan teknologi informasi, data pasien dapat berada pada SIMRS, Rekam Medis Elektronik, sistem penunjang, basis data (*database*), komputer pengguna, server, media penyimpanan, berkas hasil ekspor, dokumen hasil cetak, maupun media lain yang digunakan dalam proses kerja. Kondisi tersebut menyebabkan perlindungan data tidak dapat dilakukan hanya pada satu aplikasi atau satu server.

Sistem elektronik yang digunakan dalam penyelenggaraan Rekam Medis Elektronik juga memiliki fungsi yang luas. Regulasi mengenai Rekam Medis menjelaskan bahwa sistem elektronik dapat menjalankan proses mempersiapkan, mengumpulkan, mengolah, menganalisis, menyimpan, menampilkan, mengumumkan, mengirimkan, dan/atau menyebarkan informasi elektronik (Kementerian Kesehatan Republik Indonesia, 2022). Dengan demikian, data dapat berpindah dari satu proses ke proses lainnya dan dari satu sistem ke sistem lainnya selama digunakan oleh organisasi.

Kondisi tersebut menimbulkan konsekuensi dari perspektif cybersecurity: **semakin banyak lokasi, sistem, akun, dan perangkat yang dapat mengakses suatu data, semakin banyak pula titik yang perlu diamankan.** Pengamanan tidak cukup hanya dilakukan pada pusat data atau server. Komputer pengguna, akun,

jaringan, media penyimpanan, proses pertukaran data, serta perilaku pengguna juga menjadi bagian dari lingkungan yang harus dilindungi.

Sebagai contoh, sebuah *database* dapat ditempatkan pada server yang telah dilengkapi dengan mekanisme keamanan. Namun, apabila seorang pengguna mengeksport data dari aplikasi ke dalam berkas *spreadsheet*, kemudian menyimpannya pada laptop pribadi atau mengirimkannya melalui media komunikasi yang tidak diperuntukkan untuk pertukaran data tersebut, maka salinan data telah keluar dari lingkungan pengamanan awal.

Risiko serupa dapat terjadi ketika administrator atau vendor membuat salinan *database* untuk keperluan *troubleshooting*. Salinan tersebut tetap mengandung informasi yang perlu dilindungi. Memindahkan data dari server produksi ke komputer lain tidak menghilangkan kebutuhan untuk melindungi data tersebut. Justru, setiap salinan baru dapat menambah lokasi yang harus dikendalikan dan diamankan.

Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi mengatur bahwa data pribadi terdiri atas data pribadi yang bersifat umum dan data pribadi yang bersifat spesifik. Data dan informasi kesehatan termasuk data pribadi yang bersifat spesifik (Republik Indonesia, 2022). Selain data kesehatan, lingkungan rumah sakit juga dapat memproses data pribadi lain yang dapat digunakan untuk mengidentifikasi seseorang.

Peraturan mengenai Rekam Medis memberikan contoh yang lebih konkret. Dalam proses registrasi pasien, data identitas paling sedikit memuat nomor Rekam Medis, nama pasien, dan Nomor Induk Kependudukan (NIK). Selain itu, terdapat data sosial yang paling sedikit meliputi agama, pekerjaan, pendidikan, dan status perkawinan (Kementerian Kesehatan Republik Indonesia, 2022).

Dari perspektif keamanan informasi, kondisi tersebut menunjukkan bahwa satu sistem dapat menyimpan beberapa jenis informasi sekaligus. Kebocoran sebuah berkas atau akun karena itu tidak selalu hanya mengungkap satu jenis data. Sebuah akun yang

disalahgunakan, misalnya, dapat memberikan akses terhadap kombinasi identitas dan informasi lain yang terdapat di dalam sistem.

Memperlakukan data pasien sebagai aset informasi juga berarti organisasi perlu mengetahui **di mana data berada, siapa yang dapat mengaksesnya, untuk tujuan apa data digunakan, dan bagaimana data berpindah**. Pertanyaan-pertanyaan tersebut penting karena pengamanan akan sulit dilakukan apabila organisasi tidak mengetahui lokasi dan aliran informasi yang dimilikinya.

Bagi pengguna, konsep aset informasi dapat diterapkan melalui prinsip yang lebih sederhana. Setiap kali menerima, membuka, menyalin, mengunduh, mencetak, memotret, atau mengirimkan data pasien, pengguna sedang berinteraksi dengan aset informasi milik organisasi yang harus dijaga sesuai dengan kewenangannya.

Hal tersebut juga berlaku bagi pihak ketiga. Akses yang diberikan kepada vendor untuk pemeliharaan aplikasi atau infrastruktur tidak mengubah kedudukan data menjadi bebas digunakan. Data yang terlihat ketika melakukan *remote access*, *troubleshooting*, pemeliharaan *database*, pencadangan, atau pengujian sistem tetap harus diperlakukan sebagai informasi yang dilindungi.

Oleh karena itu, keamanan data pasien harus mengikuti data tersebut selama masih disimpan, digunakan, dipindahkan, atau diproses. Perubahan media maupun lokasi penyimpanan tidak menghilangkan kebutuhan terhadap pengamanan.

INGAT: Data pasien merupakan aset informasi. Menyalin atau memindahkan data tidak menghilangkan kewajiban untuk melindunginya. Setiap salinan data menciptakan lokasi baru yang juga harus diamankan.

1.3 Kebocoran Data Tidak Selalu Disebabkan oleh Peretas

Ketika mendengar istilah kebocoran data, sebagian orang mungkin langsung membayangkan seorang peretas yang berhasil menembus *firewall*, mengeksploitasi kerentanan aplikasi, atau mengambil data dari sebuah server. Serangan siber memang merupakan salah satu ancaman terhadap keamanan data, tetapi kebocoran data tidak selalu terjadi akibat keberhasilan peretas menyerang sistem.

Data dapat terekspos atau sampai kepada pihak yang tidak berwenang melalui berbagai kejadian yang jauh lebih sederhana. Kesalahan mengirim dokumen, membagikan *password*, menggunakan akun secara bersama-sama, meninggalkan komputer dalam keadaan *login*, menyimpan data pada perangkat pribadi, atau mengirimkan tangkapan layar yang masih menampilkan identitas pasien merupakan contoh tindakan yang dapat menimbulkan risiko terhadap kerahasiaan data.

Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi menggunakan istilah **kegagalan Pelindungan Data Pribadi**. Kegagalan tersebut didefinisikan sebagai kegagalan dalam melindungi Data Pribadi seseorang dalam hal kerahasiaan, integritas, dan ketersediaan Data Pribadi, termasuk pelanggaran keamanan, baik yang disengaja maupun tidak disengaja, yang mengarah pada kerusakan, kehilangan, perubahan, pengungkapan, atau akses yang tidak sah terhadap Data Pribadi yang dikirim, disimpan, atau diproses (Republik Indonesia, 2022).

Definisi tersebut penting dalam membangun kesadaran keamanan informasi karena menunjukkan bahwa insiden terhadap data tidak harus selalu diawali dengan serangan dari luar organisasi. Tindakan yang tidak disengaja juga dapat mengakibatkan data hilang, berubah, terungkap, atau dapat diakses oleh pihak yang tidak berwenang.

Sebagai contoh, seorang pegawai bermaksud mengirimkan sebuah dokumen kepada rekan kerja yang memang memiliki kewenangan. Namun, karena salah memilih nama penerima pada aplikasi komunikasi, dokumen tersebut terkirim kepada orang lain. Tidak ada peretas yang menyerang sistem dalam kejadian tersebut, tetapi informasi telah terkirim kepada pihak yang tidak seharusnya menerima data.

Contoh lain dapat terjadi ketika pengguna memberikan *username* dan *password* kepada rekan kerja dengan alasan mempermudah pekerjaan. Tindakan tersebut mungkin dilakukan tanpa maksud untuk membocorkan data. Namun, penggunaan akun oleh orang lain menyebabkan identitas pengguna tidak lagi dapat menjadi dasar yang andal untuk mengetahui siapa yang sebenarnya melakukan aktivitas menggunakan akun tersebut.

Risiko juga dapat muncul ketika komputer ditinggalkan dalam keadaan tidak terkunci. Orang lain yang berada di sekitar perangkat dapat melihat informasi yang sedang ditampilkan atau menggunakan aplikasi yang masih dalam keadaan *login*. Dalam kondisi tersebut, penyerang tidak perlu mengeksploitasi kerentanan teknis karena akses terhadap informasi tersedia melalui sesi pengguna yang masih aktif.

Peraturan Pemerintah Nomor 71 Tahun 2019 tentang Penyelenggaraan Sistem dan Transaksi Elektronik mengatur bahwa pemrosesan Data Pribadi harus dilakukan dengan melindungi keamanan Data Pribadi dari kehilangan, penyalahgunaan, akses dan pengungkapan yang tidak sah, serta pengubahan atau kerusakan Data Pribadi. Peraturan tersebut juga mewajibkan setiap orang yang bekerja di lingkungan penyelenggaraan Sistem Elektronik untuk mengamankan dan melindungi sarana dan prasarana Sistem Elektronik atau informasi yang disalurkan melalui Sistem Elektronik (Republik Indonesia, 2019).

Ketentuan tersebut memperlihatkan bahwa keamanan informasi tidak hanya berkaitan dengan perangkat keamanan yang

ditempatkan pada jaringan atau server. Manusia yang menggunakan sistem juga merupakan bagian penting dari lingkungan pengamanan.

Kesalahan manusia bahkan dapat dimanfaatkan oleh penyerang. Dalam serangan *phishing* dan *social engineering*, misalnya, penyerang tidak selalu berusaha membobol sistem secara langsung. Penyerang dapat mencoba meyakinkan pengguna agar memberikan *password*, kode OTP, informasi tertentu, atau melakukan tindakan yang memberikan keuntungan kepada penyerang. Aspek ini akan dibahas lebih khusus pada BAB 9.

Karena itu, pemasangan *firewall*, antivirus, sistem deteksi ancaman, autentikasi, dan mekanisme keamanan teknis lainnya tidak dapat menjadi satu-satunya bentuk perlindungan. Pengamanan teknis perlu didukung oleh prosedur dan perilaku pengguna yang tepat. Peraturan Pemerintah Nomor 71 Tahun 2019 bahkan mewajibkan Penyelenggara Sistem Elektronik melakukan edukasi kepada pengguna sistem elektronik. Penjelasan peraturan tersebut antara lain memberikan contoh edukasi mengenai pentingnya merahasiakan dan tidak memberitahukan PIN atau *password* kepada siapa pun, termasuk kepada petugas penyelenggara (Republik Indonesia, 2019).

Dalam lingkungan rumah sakit, prinsip tersebut berarti setiap pegawai dan pihak ketiga harus memahami bahwa tindakan sehari-hari dapat memengaruhi keamanan data pasien. Seseorang tidak harus menjadi administrator sistem atau tenaga teknologi informasi untuk berperan dalam mencegah kebocoran data.

Sebelum mengirimkan data, pengguna perlu memastikan penerimanya benar. Sebelum meninggalkan komputer, pengguna perlu mengunci perangkat. *Credential* tidak boleh diberikan kepada orang lain. Data pasien tidak boleh dipindahkan ke perangkat atau media lain tanpa kewenangan. Apabila terjadi kesalahan yang berpotensi menyebabkan data terungkap, kejadian tersebut perlu segera dilaporkan agar dapat ditangani.

Budaya keamanan informasi karena itu tidak dibangun hanya dengan mengajarkan pengguna untuk mewaspadaai peretas.

Kesadaran juga perlu dibangun terhadap tindakan sederhana yang dilakukan setiap hari. Semakin sensitif informasi yang dikelola, semakin penting bagi pengguna untuk berhati-hati ketika mengakses, menggunakan, menyimpan, dan membagikannya.

INGAT: Kebocoran data tidak selalu dimulai dari serangan peretas. Salah kirim, berbagi *credential*, komputer yang tidak dikunci, penggunaan akun bersama, dan tindakan sederhana lainnya dapat membuka akses data kepada pihak yang tidak berwenang.

1.4 Peran Manusia dalam Keamanan Informasi

Keamanan informasi sering kali dikaitkan dengan teknologi seperti *firewall*, antivirus, enkripsi, *intrusion detection system*, autentikasi, dan berbagai mekanisme pengamanan lainnya. Teknologi tersebut memiliki peran penting dalam melindungi sistem dan data, tetapi efektivitasnya tetap dipengaruhi oleh manusia yang menggunakan, mengelola, dan berinteraksi dengan sistem tersebut.

Dalam aktivitas sehari-hari, pengguna membuat berbagai keputusan yang dapat memengaruhi keamanan informasi. Pengguna menentukan bagaimana *credential* disimpan, apakah komputer dikunci ketika ditinggalkan, kepada siapa data dikirimkan, apakah sebuah tautan aman untuk dibuka, apakah permintaan informasi dapat dipercaya, serta bagaimana data disimpan atau dipindahkan. Keputusan-keputusan sederhana tersebut dapat menjadi bagian dari mekanisme pertahanan organisasi atau justru membuka peluang terjadinya insiden keamanan.

Peraturan Pemerintah Nomor 71 Tahun 2019 tentang Penyelenggaraan Sistem dan Transaksi Elektronik memberikan perhatian terhadap peran pengguna dalam keamanan Sistem Elektronik. Penyelenggara Sistem Elektronik diwajibkan melakukan edukasi kepada Pengguna Sistem Elektronik mengenai hak, kewajiban, dan tanggung jawab para pihak terkait (Republik Indonesia, 2019).

Dalam penjelasan peraturan tersebut, edukasi kepada pengguna antara lain mencakup pentingnya menjaga keamanan PIN dan *password*. Pengguna perlu merahasiakan dan tidak memberitahukan PIN atau *password* kepada siapa pun, termasuk kepada petugas penyelenggara (Republik Indonesia, 2019). Ketentuan ini menunjukkan bahwa keamanan Sistem Elektronik tidak hanya bergantung pada pengamanan teknis, tetapi juga membutuhkan pemahaman dan perilaku yang benar dari pengguna.

Perspektif serupa diterapkan dalam praktik cybersecurity modern. National Institute of Standards and Technology (NIST) melalui *NIST Special Publication 800-50 Revision 1: Building a Cybersecurity and Privacy Learning Program* menempatkan pembelajaran cybersecurity dan privasi sebagai bagian dari pengelolaan risiko organisasi. Program pembelajaran tersebut diarahkan untuk mendorong perubahan perilaku serta membantu membangun budaya keamanan dan privasi di dalam organisasi (Merritt et al., 2024).

Hal tersebut penting karena pengguna tidak hanya berperan sebagai pihak yang harus dilindungi oleh teknologi. Pengguna juga merupakan bagian dari sistem pertahanan organisasi. Pegawai yang mampu mengenali pesan *phishing*, menolak memberikan *password*, memverifikasi permintaan yang mencurigakan, mengunci komputer ketika meninggalkan tempat kerja, dan segera melaporkan insiden dapat membantu mencegah ancaman berkembang menjadi insiden yang lebih besar.

Sebaliknya, kontrol keamanan yang baik dapat kehilangan efektivitas apabila prosedur keamanan diabaikan. Sebuah akun dapat dilindungi dengan *password*, tetapi perlindungan tersebut menjadi lemah apabila *password* diberikan kepada orang lain. Komputer dapat dilengkapi antivirus dan berbagai perangkat lunak keamanan, tetapi risiko tetap muncul apabila pengguna memasang aplikasi yang tidak sah atau membuka lampiran mencurigakan. Sistem dapat mencatat aktivitas pengguna melalui *logging*, tetapi

akuntabilitas menjadi sulit apabila satu akun digunakan secara bersama-sama.

Penyerang juga dapat menjadikan manusia sebagai sasaran untuk memperoleh akses terhadap sistem atau informasi. Melalui *social engineering*, penyerang dapat menyamar sebagai orang yang dipercaya, menciptakan situasi mendesak, atau menggunakan informasi tertentu untuk meyakinkan korban agar melakukan tindakan yang sebenarnya tidak aman. Dalam kondisi seperti ini, penyerang berusaha melewati kontrol keamanan dengan memengaruhi keputusan pengguna.

Contoh sederhana dapat terjadi ketika seseorang menghubungi pegawai dan mengaku sebagai administrator teknologi informasi. Orang tersebut menyampaikan bahwa akun pegawai sedang mengalami masalah dan meminta *password* atau kode OTP untuk melakukan perbaikan. Permintaan tersebut mungkin terdengar meyakinkan, terutama apabila pelaku mengetahui nama pegawai, unit kerja, atau informasi lain yang membuat identitasnya terlihat dapat dipercaya.

Dalam situasi tersebut, pengguna memiliki peran penting sebagai lapisan pertahanan. Pengguna tidak seharusnya memberikan *password*, OTP, maupun informasi autentikasi lainnya hanya karena permintaan berasal dari seseorang yang mengaku sebagai administrator, atasan, teknisi, atau vendor. Identitas dan kewenangan pihak yang meminta informasi perlu diverifikasi melalui mekanisme yang dapat dipercaya.

Peran manusia dalam keamanan informasi juga tidak terbatas pada pegawai biasa. Administrator sistem, pengelola teknologi informasi, pejabat, pimpinan, vendor, teknisi, konsultan, dan pihak ketiga memiliki tanggung jawab sesuai dengan akses dan kewenangan masing-masing. Semakin besar hak akses yang dimiliki seseorang, semakin besar pula dampak yang dapat terjadi apabila akses tersebut disalahgunakan atau tidak dilindungi dengan baik.

Karena itu, *security awareness* tidak seharusnya dipandang sebagai kegiatan yang dilakukan sekali kemudian dianggap selesai.

Ancaman, teknologi, sistem, dan cara pengguna berinteraksi dengan informasi dapat berubah. NIST SP 800-50 Rev. 1 menggunakan pendekatan siklus hidup dalam program pembelajaran cybersecurity dan privasi sehingga program dapat dievaluasi dan diperbarui mengikuti kebutuhan serta perubahan risiko organisasi (Merritt et al., 2024).

Bagi pegawai dan pihak ketiga, tujuan utama kesadaran keamanan bukan menjadikan setiap orang sebagai ahli cybersecurity. Tujuannya adalah membangun kemampuan untuk mengenali risiko, mengambil keputusan yang aman, mengikuti prosedur yang berlaku, dan mengetahui kapan suatu kejadian harus dilaporkan kepada pihak yang bertanggung jawab.

Teknologi, prosedur, dan manusia karena itu harus bekerja sebagai satu kesatuan. Teknologi menyediakan kontrol keamanan, prosedur menentukan cara kontrol tersebut digunakan, sedangkan manusia menjalankan dan mematuhi mekanisme pengamanan dalam aktivitas sehari-hari.

INGAT: Manusia bukan sekadar pengguna sistem, tetapi bagian dari pertahanan keamanan informasi. Satu keputusan yang tepat dapat mencegah terjadinya insiden, sedangkan satu tindakan yang tidak aman dapat melemahkan berbagai kontrol keamanan yang telah diterapkan.

1.5 Tanggung Jawab Pegawai dan Pihak Ketiga

Pelindungan data pasien merupakan tanggung jawab yang melibatkan setiap pihak yang memperoleh akses terhadap sistem, perangkat, maupun informasi di lingkungan rumah sakit. Tanggung jawab tersebut tidak hanya berada pada pengelola teknologi informasi atau administrator sistem. Pegawai, pejabat, tenaga pendukung, vendor, teknisi, konsultan, pengembang aplikasi, dan pihak ketiga lainnya juga memiliki peran sesuai dengan akses dan kewenangan yang diberikan.

Peraturan Pemerintah Nomor 71 Tahun 2019 tentang Penyelenggaraan Sistem dan Transaksi Elektronik menyatakan bahwa setiap orang yang bekerja di lingkungan penyelenggaraan Sistem Elektronik wajib mengamankan dan melindungi sarana dan prasarana Sistem Elektronik atau informasi yang disalurkan melalui Sistem Elektronik (Republik Indonesia, 2019). Ketentuan tersebut menunjukkan bahwa pengamanan informasi merupakan bagian dari tanggung jawab setiap orang yang bekerja dan berinteraksi dengan Sistem Elektronik, bukan hanya personel yang memiliki tugas khusus di bidang teknologi informasi.

Dalam pelaksanaan tugas sehari-hari, bentuk tanggung jawab tersebut dapat dimulai dari penggunaan akun secara benar. Akun yang diberikan kepada seorang pengguna merupakan identitas yang digunakan sistem untuk memberikan akses dan mencatat aktivitas. Oleh karena itu, *username*, *password*, kode OTP, dan faktor autentikasi lainnya tidak boleh diberikan kepada orang lain. Pengguna juga tidak diperbolehkan menggunakan akun milik orang lain hanya karena memiliki hubungan kerja atau berada pada unit yang sama.

Tanggung jawab juga berlaku ketika pengguna memperoleh akses terhadap data pasien. Kemampuan untuk membuka sebuah data melalui aplikasi tidak berarti pengguna bebas melihat seluruh informasi yang tersedia. Data hanya boleh diakses apabila diperlukan untuk melaksanakan tugas dan sesuai dengan kewenangan yang diberikan. Prinsip ini penting untuk mengurangi kemungkinan akses yang tidak diperlukan serta membatasi dampak apabila sebuah akun disalahgunakan.

Pengguna juga bertanggung jawab terhadap perangkat yang digunakan untuk mengakses informasi. Komputer yang ditinggalkan dalam keadaan *login*, misalnya, dapat digunakan oleh orang lain tanpa harus mengetahui *password* pemilik akun. Karena itu, pengguna perlu mengunci perangkat ketika meninggalkan tempat kerja dan melakukan *logout* apabila penggunaan sistem telah selesai, terutama pada perangkat yang digunakan secara bergantian.

Tanggung jawab terhadap keamanan informasi tidak berhenti ketika data dikeluarkan dari aplikasi. Ketika data diunduh, diekspor, dicetak, disalin, difoto, atau dikirimkan kepada pihak lain, pengguna tetap harus memastikan bahwa data tersebut diperlakukan secara aman. Salinan data tidak menjadi bebas digunakan hanya karena telah berubah bentuk dari informasi yang tersimpan di dalam sistem menjadi berkas, dokumen cetak, atau gambar.

Perhatian yang sama diperlukan ketika menggunakan media komunikasi. Sebelum mengirimkan dokumen atau informasi, pengguna perlu memastikan bahwa penerima memang memiliki kewenangan untuk menerima data tersebut. Kesalahan memilih penerima, mengirimkan data ke grup yang tidak sesuai, atau membagikan tautan dengan hak akses yang terlalu luas dapat menyebabkan informasi diterima oleh pihak yang tidak seharusnya memperoleh akses.

Tanggung jawab keamanan juga berlaku bagi pihak ketiga. Vendor atau teknisi dapat memperoleh akses ke server, aplikasi, *database*, jaringan, maupun perangkat tertentu untuk melakukan pemeliharaan atau *troubleshooting*. Akses tersebut diberikan untuk tujuan tertentu dan tidak dapat dianggap sebagai kewenangan untuk menggunakan seluruh informasi yang dapat dilihat selama pekerjaan berlangsung.

Peraturan Pemerintah Nomor 71 Tahun 2019 mengatur bahwa Penyelenggara Sistem Elektronik harus menjamin tersedianya perjanjian keamanan informasi terhadap jasa layanan teknologi informasi yang digunakan. Untuk Penyelenggara Sistem Elektronik Lingkup Publik yang menggunakan layanan pihak ketiga, regulasi tersebut juga mengatur kewajiban melakukan klasifikasi data sesuai dengan risiko yang ditimbulkan (Republik Indonesia, 2019).

Dalam praktiknya, pihak ketiga harus menggunakan akses sesuai dengan ruang lingkup pekerjaan yang diberikan. Vendor tidak seharusnya menggunakan akun milik pegawai untuk memperoleh akses apabila organisasi telah menyediakan mekanisme akses tersendiri. Penggunaan identitas yang berbeda untuk setiap

pengguna membantu organisasi mengetahui siapa yang melakukan suatu aktivitas dan mendukung proses audit apabila terjadi insiden.

Pihak ketiga juga tidak boleh menyalin *database* atau data pasien ke laptop, perangkat penyimpanan, layanan *cloud*, maupun lingkungan pengujian miliknya tanpa kewenangan. Kebutuhan untuk melakukan *troubleshooting*, pengembangan, atau pengujian tidak secara otomatis memberikan kewenangan untuk membawa salinan data keluar dari lingkungan yang telah ditentukan.

Dari perspektif keamanan informasi, aktivitas pihak ketiga perlu diperlakukan sebagai bagian dari pengelolaan akses organisasi. NIST SP 800-53 Rev. 5 menempatkan kontrol akses, identifikasi dan autentikasi, audit dan akuntabilitas, keamanan personel, serta manajemen risiko rantai pasok sebagai bagian dari keluarga kontrol keamanan dan privasi yang digunakan untuk melindungi sistem dan organisasi (Joint Task Force, 2020).

Tanggung jawab pegawai maupun pihak ketiga juga mencakup pelaporan ketika menemukan kejadian yang mencurigakan. Apabila *password* diketahui orang lain, perangkat hilang, data salah terkirim, ditemukan aktivitas akun yang tidak dikenali, atau terdapat dugaan malware, kejadian tersebut tidak seharusnya disembunyikan. Pelaporan yang cepat memberikan kesempatan kepada pihak yang bertanggung jawab untuk melakukan pembatasan dampak dan mengambil tindakan pengamanan.

Tanggung jawab keamanan informasi dengan demikian mengikuti **akses yang diberikan kepada seseorang**. Semakin luas akses yang dimiliki, semakin besar pula tanggung jawab untuk menjaga akses tersebut. Administrator yang memiliki akses terhadap banyak sistem, misalnya, memiliki risiko yang berbeda dibandingkan pengguna dengan akses terbatas. Prinsip yang sama berlaku bagi vendor yang memperoleh akses administratif atau *remote access* ke infrastruktur organisasi.

Pelindungan data pasien pada akhirnya membutuhkan pembagian tanggung jawab yang jelas. Organisasi bertanggung jawab menyediakan kebijakan, prosedur, kontrol keamanan,

pengelolaan hak akses, edukasi, dan mekanisme pelaporan. Sementara itu, pegawai dan pihak ketiga bertanggung jawab menggunakan akses secara benar, menjaga *credential*, mengikuti prosedur keamanan, serta melaporkan kejadian yang dapat membahayakan sistem atau informasi.

INGAT: Akses merupakan kewenangan sekaligus tanggung jawab. Gunakan akun dan data hanya untuk kepentingan pekerjaan yang sah, jangan meminjamkan akses kepada orang lain, dan segera laporkan apabila terjadi atau dicurigai terjadi insiden keamanan informasi.

1.6 Prinsip Dasar: Akses dan Gunakan Data Sesuai Kewenangan

Salah satu prinsip penting dalam perlindungan data pasien adalah bahwa **akses terhadap data harus digunakan sesuai dengan kewenangan dan kebutuhan pekerjaan**. Keberadaan akun, kemampuan membuka aplikasi, atau kemampuan teknis untuk melihat suatu informasi tidak secara otomatis memberikan hak kepada pengguna untuk mengakses dan menggunakan seluruh data yang tersedia di dalam sistem.

Dalam lingkungan rumah sakit, setiap pengguna dapat memiliki tugas dan tanggung jawab yang berbeda. Perbedaan tersebut perlu diikuti dengan pemberian hak akses yang sesuai. Pengguna hanya memerlukan akses terhadap sistem, fungsi, dan informasi yang diperlukan untuk melaksanakan pekerjaannya. Pembatasan ini membantu mengurangi kemungkinan data diakses oleh pihak yang tidak memiliki kepentingan terhadap informasi tersebut.

Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi mengatur bahwa pemrosesan Data Pribadi harus dilakukan secara terbatas dan spesifik, sah secara hukum, serta transparan. Pengendali Data Pribadi juga wajib memastikan akurasi, kelengkapan, dan konsistensi Data Pribadi sesuai dengan ketentuan peraturan perundang-undangan (Republik Indonesia, 2022).

Dalam konteks penggunaan sistem informasi, prinsip tersebut berarti data tidak seharusnya diakses atau digunakan tanpa tujuan yang berkaitan dengan pelaksanaan tugas dan kewenangan. Rasa ingin tahu, hubungan pribadi dengan pasien, permintaan informal dari rekan kerja, atau sekadar kemampuan untuk membuka informasi bukan merupakan alasan yang cukup untuk mengakses data.

Sebagai contoh, seorang pengguna mungkin secara teknis dapat mencari nama pasien melalui SIMRS. Namun, apabila informasi tersebut tidak diperlukan dalam pelaksanaan tugasnya, pengguna tidak seharusnya melakukan pencarian hanya karena mengenal pasien atau ingin mengetahui informasi mengenai pasien tersebut. Kemampuan sistem untuk menampilkan data tidak dapat dijadikan dasar untuk menganggap bahwa seluruh penggunaan akses tersebut diperbolehkan.

Prinsip pembatasan akses seperti ini dikenal dalam keamanan informasi sebagai **least privilege**. NIST mendefinisikan *least privilege* sebagai prinsip keamanan yang memberikan kepada pengguna atau proses hanya kewenangan dan sumber daya minimum yang diperlukan untuk menjalankan fungsi yang diberikan (Joint Task Force, 2020). Prinsip ini akan dibahas lebih mendalam pada BAB 3.

Penerapan *least privilege* dapat dilakukan dengan membedakan hak akses berdasarkan fungsi pekerjaan. Pengguna yang hanya memerlukan fungsi tertentu tidak perlu diberikan hak administratif. Vendor yang hanya memerlukan akses terhadap satu aplikasi untuk melakukan *troubleshooting* tidak perlu memperoleh akses ke seluruh server atau *database*. Demikian pula, akses sementara seharusnya tidak dibiarkan tetap aktif setelah pekerjaan yang menjadi dasar pemberian akses telah selesai.

Pembatasan akses juga mendukung akuntabilitas. Sistem keamanan akan lebih efektif apabila setiap pengguna menggunakan identitasnya sendiri. Aktivitas seperti *login*, perubahan data, akses terhadap fungsi tertentu, maupun tindakan administratif dapat

dicatat melalui mekanisme *logging* dan *audit trail*. Catatan tersebut dapat membantu organisasi melakukan pemeriksaan apabila terjadi aktivitas yang tidak semestinya.

Sebaliknya, penggunaan akun bersama dapat mengurangi kemampuan organisasi untuk mengetahui siapa yang sebenarnya melakukan suatu tindakan. Apabila sebuah akun digunakan oleh beberapa orang, catatan aktivitas hanya menunjukkan identitas akun, sedangkan orang yang berada di balik aktivitas tersebut menjadi lebih sulit ditentukan. Oleh karena itu, pengguna tidak seharusnya meminjamkan akun hanya untuk mempermudah orang lain memperoleh akses.

Kewenangan terhadap data juga tidak berhenti pada tindakan melihat informasi. Pengguna perlu mempertimbangkan kewenangan ketika melakukan tindakan lain seperti mengunduh, mencetak, menyalin, mengambil *screenshot*, mengekspor, mengubah, menghapus, atau mengirimkan data kepada pihak lain.

Seseorang mungkin memiliki kewenangan untuk **melihat** suatu informasi, tetapi belum tentu memiliki kewenangan untuk **menyalin** atau **membagikannya**. Demikian pula, kewenangan untuk melakukan perubahan terhadap data tidak selalu berarti memiliki kewenangan untuk menghapus data. Setiap tindakan harus mengikuti fungsi pekerjaan, hak akses, prosedur, dan ketentuan yang berlaku.

Prinsip tersebut juga berlaku terhadap pihak ketiga. Vendor, teknisi, konsultan, dan pengembang aplikasi dapat memperoleh akses untuk tujuan tertentu. Akses untuk melakukan *troubleshooting*, misalnya, tidak secara otomatis memberikan kewenangan untuk membuat salinan *database*, membawa data ke lingkungan pengembangan, atau menyimpannya pada perangkat milik vendor.

Apabila pekerjaan membutuhkan akses tambahan, mekanisme yang tepat adalah meminta pemberian atau perubahan hak akses melalui prosedur yang berlaku, bukan menggunakan akun milik

orang lain atau meminta *password* pengguna yang memiliki hak akses lebih tinggi.

Dari perspektif keamanan informasi, pendekatan tersebut memiliki manfaat lain, yaitu membatasi dampak apabila sebuah akun berhasil disalahgunakan. Apabila setiap akun hanya mempunyai akses sesuai kebutuhannya, penyerang yang berhasil mengambil alih satu akun tidak serta-merta memperoleh akses terhadap seluruh sistem dan data organisasi.

Karena itu, sebelum mengakses atau menggunakan data pasien, pengguna dapat membiasakan diri mengajukan tiga pertanyaan sederhana:

Apakah saya berwenang mengakses data ini?

Apakah data ini diperlukan untuk pekerjaan yang sedang saya lakukan?

Apakah tindakan yang akan saya lakukan terhadap data ini diperbolehkan?

Apabila jawabannya tidak jelas, pengguna sebaiknya tidak melanjutkan akses atau penggunaan data sampai memperoleh kepastian dari pihak yang berwenang.

Prinsip akses sesuai kewenangan bukan dimaksudkan untuk menghambat pekerjaan. Pembatasan tersebut justru membantu memastikan bahwa informasi tersedia kepada pihak yang membutuhkannya sekaligus mengurangi kemungkinan akses, penggunaan, atau pengungkapan data yang tidak semestinya.

Dengan demikian, perlindungan data pasien dapat dimulai dari kebiasaan sederhana: **akses seperlunya, gunakan sesuai tujuan, dan jangan melampaui kewenangan yang diberikan.**

INGAT: Dapat melihat bukan berarti boleh mengakses. Dapat mengakses bukan berarti boleh menyalin. Dapat menyalin bukan berarti boleh membagikan. Gunakan data pasien hanya sesuai kewenangan dan kebutuhan pekerjaan.

BAB 2 MENGENAL DATA PRIBADI PASIEN

2.1 Apa yang Dimaksud dengan Data Pribadi?

Sebelum membahas bagaimana data pasien harus dilindungi, pegawai dan pihak ketiga perlu memahami terlebih dahulu apa yang dimaksud dengan **data pribadi**. Pemahaman ini penting karena data pribadi tidak selalu berupa informasi yang secara langsung terlihat sensitif. Sebuah informasi yang tampak sederhana dapat menjadi data pribadi apabila informasi tersebut dapat digunakan untuk mengenali seseorang.

Undang-Undang Republik Indonesia Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi mendefinisikan Data Pribadi sebagai data tentang orang perseorangan yang teridentifikasi atau dapat diidentifikasi secara tersendiri atau dikombinasi dengan informasi lainnya, baik secara langsung maupun tidak langsung melalui sistem elektronik atau nonelektronik (Republik Indonesia, 2022).

Berdasarkan pengertian tersebut, terdapat dua kondisi penting yang perlu diperhatikan. Pertama, informasi dapat secara langsung menunjukkan identitas seseorang. Kedua, informasi yang secara sendiri belum cukup untuk mengenali seseorang dapat menjadi data pribadi ketika dikombinasikan dengan informasi lainnya.

Sebagai contoh, nama lengkap dapat digunakan untuk mengenali seseorang secara langsung dalam kondisi tertentu. Namun, apabila terdapat beberapa orang dengan nama yang sama, informasi tambahan seperti tanggal lahir, alamat, nomor telepon, atau Nomor Induk Kependudukan (NIK) dapat memperjelas identitas orang yang dimaksud.

Konsep tersebut penting dalam lingkungan sistem informasi. Data tidak selalu tersimpan sebagai satu dokumen lengkap yang berisi seluruh identitas seseorang. Informasi dapat tersebar pada beberapa tabel *database*, aplikasi, berkas, atau sistem yang berbeda. Ketika informasi tersebut dapat dihubungkan sehingga

mengidentifikasi seseorang, informasi tersebut tetap perlu diperlakukan sebagai data pribadi.

UU Pelindungan Data Pribadi membagi Data Pribadi menjadi dua kategori, yaitu **Data Pribadi yang bersifat spesifik** dan **Data Pribadi yang bersifat umum** (Republik Indonesia, 2022).

Data Pribadi yang bersifat umum meliputi nama lengkap, jenis kelamin, kewarganegaraan, agama, status perkawinan, dan/atau Data Pribadi yang dikombinasikan untuk mengidentifikasi seseorang. Sementara itu, Data Pribadi yang bersifat spesifik meliputi data dan informasi kesehatan, data biometrik, data genetika, catatan kejahatan, data anak, data keuangan pribadi, dan/atau data lainnya sesuai dengan ketentuan peraturan perundang-undangan (Republik Indonesia, 2022).

Pembagian tersebut sangat relevan dalam lingkungan rumah sakit. Sistem informasi rumah sakit dapat memproses berbagai jenis data pribadi secara bersamaan. Sebuah sistem dapat memuat nama, jenis kelamin, agama, atau status perkawinan yang termasuk Data Pribadi yang bersifat umum, sekaligus memuat data dan informasi kesehatan yang termasuk Data Pribadi yang bersifat spesifik.

Dari perspektif keamanan informasi, pengguna karena itu tidak seharusnya hanya berhati-hati terhadap dokumen yang secara jelas diberi label sebagai data pasien atau rekam medis. Informasi yang muncul pada layar aplikasi, hasil pencarian, *spreadsheet*, laporan, *database*, berkas ekspor, foto, tangkapan layar (*screenshot*), maupun dokumen cetak juga dapat mengandung data pribadi.

Sebagai contoh, tangkapan layar aplikasi mungkin dibuat hanya untuk menunjukkan pesan kesalahan kepada administrator atau vendor. Namun, pada bagian lain layar tersebut dapat terlihat nama pasien, NIK, nomor rekam medis, atau informasi lain yang tidak diperlukan untuk proses *troubleshooting*. Tanpa disadari, pengguna dapat membagikan data pribadi bersamaan dengan informasi teknis yang sebenarnya ingin disampaikan.

Hal yang sama dapat terjadi pada *database*. Administrator atau pengembang aplikasi mungkin berfokus pada struktur tabel, kesalahan aplikasi, atau hasil *query*. Akan tetapi, data yang tampil dalam proses tersebut dapat merupakan data pribadi. Kebutuhan teknis untuk melakukan pemeriksaan sistem tidak menghilangkan kebutuhan untuk melindungi informasi yang terlihat selama pekerjaan dilakukan.

Karena itu, sebelum menyalin, mengunduh, mencetak, mengambil *screenshot*, atau mengirimkan suatu informasi, pengguna perlu mengenali apakah informasi tersebut mengandung data pribadi. Jika data pribadi tidak diperlukan untuk tujuan pekerjaan yang sedang dilakukan, data tersebut sebaiknya tidak ikut disalin atau dibagikan.

Pemahaman mengenai data pribadi juga membantu mencegah anggapan bahwa informasi aman untuk dibagikan hanya karena tidak memuat data kesehatan. Identitas seseorang sendiri dapat merupakan data pribadi. Ketika identitas tersebut dikombinasikan dengan informasi lainnya, risiko terhadap pemilik data dapat meningkat.

Bagi pegawai dan pihak ketiga, pendekatan yang paling aman adalah menganggap informasi yang dapat mengidentifikasi seseorang sebagai informasi yang harus diperlakukan secara hati-hati. Apabila terdapat keraguan apakah suatu informasi termasuk data pribadi, pengguna sebaiknya tidak membagikannya sebelum memastikan kebutuhan dan kewenangannya.

INGAT: Data pribadi bukan hanya data kesehatan atau rekam medis. Informasi yang dapat mengidentifikasi seseorang, baik secara langsung maupun setelah dikombinasikan dengan informasi lain, merupakan data pribadi yang harus diperlakukan secara hati-hati.

2.2 Data Kesehatan sebagai Data Pribadi yang Bersifat Spesifik

Data yang dikelola di lingkungan rumah sakit tidak seluruhnya memiliki karakteristik yang sama. Sebagian informasi dapat berupa data identitas, sedangkan sebagian lainnya berkaitan dengan kondisi kesehatan seseorang. Dalam perlindungan data pribadi, perbedaan tersebut penting karena Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi secara tegas memasukkan **data dan informasi kesehatan** ke dalam kategori Data Pribadi yang bersifat spesifik (Republik Indonesia, 2022).

Data Pribadi yang bersifat spesifik menurut UU Pelindungan Data Pribadi tidak hanya mencakup data dan informasi kesehatan. Kategori tersebut juga meliputi data biometrik, data genetika, catatan kejahatan, data anak, data keuangan pribadi, dan/atau data lainnya sesuai dengan ketentuan peraturan perundang-undangan (Republik Indonesia, 2022).

Dalam lingkungan rumah sakit, data dan informasi kesehatan dapat berada bersama dengan berbagai informasi lain yang digunakan untuk mengidentifikasi pasien. Oleh karena itu, pengguna sistem tidak boleh hanya memperhatikan satu jenis informasi ketika mempertimbangkan keamanan data. Sebuah tampilan aplikasi, dokumen, laporan, atau berkas elektronik dapat mengandung beberapa jenis data pribadi sekaligus.

Peraturan Menteri Kesehatan Nomor 24 Tahun 2022 tentang Rekam Medis mendefinisikan Rekam Medis sebagai dokumen yang berisikan data identitas pasien, pemeriksaan, pengobatan, tindakan, dan pelayanan lain yang telah diberikan kepada pasien. Sementara itu, Rekam Medis Elektronik merupakan Rekam Medis yang dibuat dengan menggunakan sistem elektronik yang diperuntukkan bagi penyelenggaraan Rekam Medis (Kementerian Kesehatan Republik Indonesia, 2022).

Regulasi tersebut juga menunjukkan bahwa data yang dikelola dalam Rekam Medis Elektronik tidak terbatas pada informasi klinis.

Dalam registrasi pasien, misalnya, data identitas paling sedikit berisi nomor Rekam Medis, nama pasien, dan Nomor Induk Kependudukan (NIK). Data sosial paling sedikit meliputi agama, pekerjaan, pendidikan, dan status perkawinan (Kementerian Kesehatan Republik Indonesia, 2022).

Dari perspektif keamanan informasi, kondisi tersebut berarti sebuah akun atau sistem dapat memberikan akses terhadap kumpulan informasi yang memiliki karakteristik berbeda. Apabila akses tersebut jatuh kepada pihak yang tidak berwenang, informasi yang terekspos dapat berupa kombinasi identitas pasien dan data kesehatan.

Risiko tersebut perlu diperhatikan ketika data ditampilkan pada layar komputer. Pengguna mungkin hanya membutuhkan satu bagian informasi untuk menyelesaikan pekerjaan, tetapi layar aplikasi dapat menampilkan nama pasien, nomor Rekam Medis, NIK, dan informasi lain secara bersamaan. Apabila layar tersebut difoto atau dibuat menjadi *screenshot*, seluruh informasi yang terlihat dapat ikut tersalin.

Hal serupa dapat terjadi ketika data diekspor dari aplikasi. Sebuah berkas *spreadsheet* yang dibuat untuk kebutuhan tertentu dapat memiliki kolom lebih banyak daripada yang sebenarnya diperlukan. Apabila berkas tersebut kemudian dikirimkan kepada pihak lain, informasi yang tidak diperlukan juga dapat ikut terungkap.

Prinsip yang sama berlaku dalam pekerjaan teknis. Administrator sistem, pengembang aplikasi, maupun vendor dapat berinteraksi dengan data ketika melakukan *troubleshooting*, pengujian, pemeliharaan, pencadangan, atau pemeriksaan *database*. Kebutuhan teknis untuk memperbaiki sistem tidak mengubah kedudukan data yang terdapat di dalamnya. Data pribadi tetap harus dilindungi selama proses pekerjaan berlangsung.

Karena itu, ketika bantuan teknis membutuhkan contoh data, pengguna perlu mempertimbangkan apakah seluruh informasi pasien benar-benar harus ditampilkan. Jika identitas pasien tidak diperlukan untuk menjelaskan masalah, informasi tersebut

sebaiknya disamarkan atau tidak disertakan. Pendekatan ini membantu mengurangi jumlah data pribadi yang tersebar selama proses komunikasi dan penyelesaian masalah.

Perhatian juga perlu diberikan terhadap salinan data. Ketika data dari sistem produksi disalin ke komputer, media penyimpanan, lingkungan pengembangan, atau sistem lain, salinan tersebut tetap mengandung data pribadi. Perubahan lokasi penyimpanan tidak mengubah sifat informasi yang terdapat di dalamnya.

Permenkes Nomor 24 Tahun 2022 menempatkan keamanan informasi sebagai bagian penting dalam penyelenggaraan Rekam Medis. Salah satu tujuan pengaturan Rekam Medis adalah menjamin **keamanan, kerahasiaan, keutuhan, dan ketersediaan data Rekam Medis**. Peraturan tersebut juga mewajibkan setiap Fasilitas Pelayanan Kesehatan menyelenggarakan Rekam Medis Elektronik (Kementerian Kesehatan Republik Indonesia, 2022).

Bagi pegawai dan pihak ketiga, status data kesehatan sebagai Data Pribadi yang bersifat spesifik harus membentuk kebiasaan untuk lebih berhati-hati ketika berinteraksi dengan data pasien. Sebelum mengakses, menyalin, mengambil *screenshot*, mencetak, mengunduh, atau mengirimkan data, pengguna perlu memastikan bahwa tindakan tersebut memang diperlukan dan dilakukan sesuai dengan kewenangannya.

Pelindungan tersebut tidak hanya berlaku ketika data berada di dalam SIMRS atau Rekam Medis Elektronik. Data yang telah diekspor menjadi berkas, dicetak menjadi dokumen, ditampilkan dalam laporan, atau disalin ke media lain tetap membutuhkan pengamanan. Media dapat berubah, tetapi kebutuhan untuk melindungi informasi tetap ada.

INGAT: Data dan informasi kesehatan merupakan Data Pribadi yang bersifat spesifik. Ketika data pasien disalin, dicetak, diekspor, difoto, atau dipindahkan ke media lain, kebutuhan untuk melindunginya tidak ikut hilang.

2.3 Contoh Data Pribadi Pasien

Data pribadi pasien tidak hanya berupa informasi mengenai kondisi kesehatan atau Rekam Medis. Dalam penyelenggaraan sistem informasi rumah sakit, berbagai informasi yang dapat mengidentifikasi seorang pasien juga dapat termasuk data pribadi. Informasi tersebut dapat berada dalam satu sistem atau tersebar pada beberapa aplikasi, dokumen, dan media yang berbeda.

Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi menjelaskan bahwa Data Pribadi adalah data tentang orang perseorangan yang teridentifikasi atau dapat diidentifikasi secara tersendiri atau dikombinasikan dengan informasi lainnya, baik secara langsung maupun tidak langsung melalui sistem elektronik atau nonelektronik (Republik Indonesia, 2022).

Berdasarkan pengertian tersebut, sebuah informasi tidak harus selalu memuat nama lengkap agar dapat berkaitan dengan seseorang. Kombinasi beberapa informasi dapat memungkinkan seseorang untuk diidentifikasi. Oleh karena itu, pengguna perlu berhati-hati terhadap berbagai jenis data yang terdapat pada aplikasi, dokumen, laporan, maupun berkas elektronik.

UU Pelindungan Data Pribadi membagi Data Pribadi menjadi Data Pribadi yang bersifat umum dan Data Pribadi yang bersifat spesifik. Data Pribadi yang bersifat umum meliputi nama lengkap, jenis kelamin, kewarganegaraan, agama, status perkawinan, dan/atau Data Pribadi yang dikombinasikan untuk mengidentifikasi seseorang. Sementara itu, Data Pribadi yang bersifat spesifik antara lain meliputi data dan informasi kesehatan, data biometrik, data genetika, data anak, serta data keuangan pribadi (Republik Indonesia, 2022).

Dalam lingkungan rumah sakit, contoh data pribadi pasien dapat ditemukan pada proses registrasi. Peraturan Menteri Kesehatan Nomor 24 Tahun 2022 tentang Rekam Medis mengatur bahwa kegiatan registrasi pasien merupakan kegiatan pendaftaran berupa pengisian data identitas dan data sosial pasien. Data identitas paling sedikit berisi nomor Rekam Medis, nama pasien, dan Nomor Induk

Kependudukan (NIK). Data sosial paling sedikit meliputi agama, pekerjaan, pendidikan, dan status perkawinan (Kementerian Kesehatan Republik Indonesia, 2022).

Dengan demikian, beberapa contoh informasi yang perlu dikenali dan dilindungi dalam lingkungan rumah sakit antara lain:

- nama pasien;
- Nomor Induk Kependudukan (NIK);
- nomor Rekam Medis;
- jenis kelamin;
- agama;
- status perkawinan;
- pekerjaan;
- pendidikan;
- data dan informasi kesehatan;
- data lain yang secara tersendiri atau setelah dikombinasikan dapat digunakan untuk mengidentifikasi seseorang.

Daftar tersebut bukan berarti bahwa setiap jenis data memiliki klasifikasi hukum yang sama. Sebagian merupakan Data Pribadi yang bersifat umum, sedangkan data dan informasi kesehatan termasuk Data Pribadi yang bersifat spesifik. Bagi pengguna sistem, hal terpenting adalah mampu mengenali bahwa informasi tersebut tidak boleh diperlakukan sebagai data bebas hanya karena muncul pada layar komputer atau terdapat di dalam berkas kerja.

Dalam praktiknya, beberapa jenis data dapat muncul secara bersamaan. Sebuah tampilan SIMRS, misalnya, dapat menampilkan nama pasien, nomor Rekam Medis, NIK, serta informasi lainnya dalam satu layar. Apabila pengguna mengambil *screenshot*, seluruh informasi yang terlihat pada layar dapat ikut tersalin meskipun tujuan awalnya hanya untuk menunjukkan satu bagian tertentu.

Risiko serupa terdapat pada berkas hasil ekspor. Sebuah *spreadsheet* yang digunakan untuk pekerjaan tertentu dapat memiliki banyak kolom yang berasal dari sistem. Pengguna mungkin hanya membutuhkan beberapa kolom, tetapi informasi lain yang

tidak diperlukan tetap ikut tersimpan dalam berkas tersebut. Apabila berkas kemudian dikirimkan kepada pihak lain, jumlah data yang dibagikan dapat menjadi lebih banyak daripada yang sebenarnya diperlukan.

Administrator sistem dan vendor juga perlu memperhatikan kondisi serupa ketika bekerja dengan *database*. Hasil sebuah *query* dapat menampilkan data sebenarnya yang terdapat pada sistem produksi. Ketika hasil tersebut disalin ke aplikasi lain, dimasukkan ke dalam dokumen, atau dikirimkan untuk keperluan *troubleshooting*, data pribadi dapat ikut berpindah bersama informasi teknis.

Karena itu, data pribadi perlu dikenali berdasarkan **isi informasinya**, bukan hanya berdasarkan nama berkas atau aplikasi tempat data tersebut berada. Berkas dengan nama yang terlihat umum seperti *error.xlsx*, *data.xlsx*, *backup.sql*, atau sebuah gambar *screenshot* tetap dapat mengandung data pribadi apabila isinya memungkinkan seseorang untuk diidentifikasi.

Nama berkas yang tidak mencantumkan nama pasien juga tidak menjadikan berkas tersebut anonim. Demikian pula, menghapus satu informasi seperti nama belum tentu cukup apabila informasi lain di dalam data masih memungkinkan seseorang untuk dikenali.

Bagi pegawai dan pihak ketiga, kebiasaan sederhana yang dapat diterapkan adalah memeriksa isi informasi sebelum data disalin atau dibagikan. Apabila tujuan pekerjaan hanya membutuhkan sebagian informasi, data lain yang tidak diperlukan sebaiknya tidak ikut disertakan. Dalam pekerjaan teknis, informasi identitas pasien juga sebaiknya tidak digunakan sebagai contoh apabila permasalahan dapat dijelaskan tanpa menampilkan identitas tersebut.

Pemahaman mengenai contoh data pribadi pasien menjadi dasar bagi pembahasan selanjutnya. Sebelum seseorang dapat melindungi data dengan benar, ia harus terlebih dahulu mampu mengenali informasi apa yang sedang ditangani.

INGAT: Jangan hanya mencari nama pasien ketika memeriksa apakah sebuah dokumen atau *screenshot* mengandung data pribadi.

NIK, nomor Rekam Medis, data kesehatan, dan kombinasi informasi lainnya juga dapat mengidentifikasi seseorang.

2.4 Rekam Medis dan Rekam Medis Elektronik sebagai Informasi yang Harus Dilindungi

Rekam Medis merupakan salah satu bentuk informasi penting yang dikelola di lingkungan rumah sakit. Informasi di dalamnya tidak hanya berkaitan dengan identitas pasien, tetapi juga memuat informasi mengenai pelayanan yang telah diberikan kepada pasien. Oleh karena itu, dari perspektif keamanan informasi, Rekam Medis harus diperlakukan sebagai informasi yang membutuhkan pengamanan selama dibuat, digunakan, disimpan, dipertukarkan, maupun diakses melalui sistem elektronik.

Peraturan Menteri Kesehatan Republik Indonesia Nomor 24 Tahun 2022 tentang Rekam Medis mendefinisikan Rekam Medis sebagai dokumen yang berisikan data identitas pasien, pemeriksaan, pengobatan, tindakan, dan pelayanan lain yang telah diberikan kepada pasien. Sementara itu, Rekam Medis Elektronik adalah Rekam Medis yang dibuat dengan menggunakan sistem elektronik yang diperuntukkan bagi penyelenggaraan Rekam Medis (Kementerian Kesehatan Republik Indonesia, 2022).

Perubahan dari dokumen konvensional menuju Rekam Medis Elektronik memberikan kemudahan dalam pengelolaan dan pertukaran informasi. Namun, digitalisasi juga membuat data dapat diproses melalui berbagai komponen teknologi, seperti aplikasi, *database*, server, jaringan, komputer pengguna, dan sistem lain yang saling terhubung. Karena itu, pengamanan Rekam Medis Elektronik tidak cukup hanya dilakukan pada aplikasi yang digunakan oleh pengguna.

Permenkes Nomor 24 Tahun 2022 mewajibkan setiap Fasilitas Pelayanan Kesehatan menyelenggarakan Rekam Medis Elektronik. Regulasi tersebut juga menempatkan Rekam Medis Elektronik sebagai salah satu subsistem dari sistem informasi Fasilitas

Pelayanan Kesehatan yang terhubung dengan subsistem informasi lainnya (Kementerian Kesehatan Republik Indonesia, 2022).

Keterhubungan antarsistem tersebut memiliki konsekuensi penting dari perspektif cybersecurity. Data dapat berpindah dari satu komponen ke komponen lainnya melalui proses integrasi dan pertukaran data. Sebuah kelemahan pada akun pengguna, komputer, aplikasi, konfigurasi akses, atau sistem yang terhubung dapat menciptakan risiko terhadap informasi yang diproses di dalamnya.

Permenkes Nomor 24 Tahun 2022 secara tegas menyebutkan bahwa salah satu tujuan pengaturan Rekam Medis adalah menjamin **keamanan, kerahasiaan, keutuhan, dan ketersediaan data Rekam Medis** (Kementerian Kesehatan Republik Indonesia, 2022).

Dari perspektif keamanan informasi, **kerahasiaan** berarti informasi perlu dilindungi agar tidak diakses atau diungkapkan kepada pihak yang tidak berwenang. **Keutuhan** berkaitan dengan perlindungan terhadap perubahan atau kerusakan data yang tidak semestinya. Sementara itu, **ketersediaan** berkaitan dengan kemampuan pihak yang berwenang untuk memperoleh informasi ketika diperlukan.

Ketiga aspek tersebut saling berkaitan. Sistem yang mampu menjaga kerahasiaan tetapi tidak mampu menyediakan data ketika diperlukan tetap menghadapi persoalan keamanan informasi. Demikian pula, data yang tersedia tetapi telah berubah secara tidak sah dapat menimbulkan persoalan terhadap keutuhan informasi.

Pelindungan Rekam Medis Elektronik juga perlu memperhatikan proses yang terjadi sepanjang penyelenggaraannya. Permenkes Nomor 24 Tahun 2022 menyebutkan bahwa kegiatan penyelenggaraan Rekam Medis Elektronik paling sedikit meliputi registrasi pasien, pendistribusian data Rekam Medis Elektronik, pengisian informasi klinis, pengolahan informasi, penginputan data untuk klaim pembiayaan, penyimpanan, penjaminan mutu, dan transfer isi Rekam Medis Elektronik (Kementerian Kesehatan Republik Indonesia, 2022).

Artinya, data tidak hanya berada dalam kondisi diam di dalam *database*. Data digunakan, ditampilkan, diproses, disimpan, dan dapat dipertukarkan selama penyelenggaraan Rekam Medis Elektronik. Setiap proses tersebut dapat menjadi titik yang perlu mendapatkan pengamanan.

Sebagai contoh, pendistribusian data Rekam Medis Elektronik merupakan kegiatan pengiriman data dari satu unit pelayanan ke unit pelayanan lain di Fasilitas Pelayanan Kesehatan. Dari perspektif keamanan informasi, proses perpindahan tersebut perlu memastikan bahwa data diterima oleh pihak dan sistem yang memang memiliki kewenangan untuk menerimanya (Kementerian Kesehatan Republik Indonesia, 2022).

Risiko juga dapat muncul ketika informasi keluar dari aplikasi utama. Pengguna dapat mengunduh laporan, mengekspor data menjadi *spreadsheet*, mencetak dokumen, atau mengambil *screenshot*. Administrator dapat melihat data ketika melakukan pemeriksaan *database*. Vendor dapat melihat informasi ketika melakukan *remote access* atau *troubleshooting*. Dalam kondisi tersebut, informasi tetap membutuhkan perlindungan meskipun tidak lagi hanya terlihat melalui antarmuka Rekam Medis Elektronik.

Hal ini penting karena Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi memasukkan data dan informasi kesehatan sebagai **Data Pribadi yang bersifat spesifik** (Republik Indonesia, 2022). Dengan demikian, perlindungan tidak bergantung pada media tempat informasi berada. Data yang diekspor, dicetak, difoto, atau disalin tetap dapat mengandung Data Pribadi yang harus dilindungi.

Pengamanan juga perlu diterapkan terhadap salinan dan cadangan data. Sebuah *backup database*, misalnya, dapat mengandung informasi yang sama dengan *database* produksi. Walaupun berkas tersebut tidak digunakan langsung oleh pengguna sehari-hari, kehilangan atau akses tidak sah terhadap berkas *backup* tetap dapat menyebabkan data terekspos.

Prinsip yang sama berlaku pada lingkungan pengembangan dan pengujian. Menyalin *database* produksi ke komputer pengembang atau lingkungan *testing* dapat menciptakan salinan data di lokasi baru. Apabila pekerjaan teknis dapat dilakukan tanpa menggunakan data pasien yang sebenarnya, penggunaan data contoh atau data yang telah disamarkan dapat membantu mengurangi paparan data pribadi.

Pegawai dan pihak ketiga juga harus memahami bahwa kewenangan mengakses Rekam Medis Elektronik tidak dapat dipindahkan hanya dengan memberikan *username* dan *password* kepada orang lain. Hak akses diberikan kepada pengguna sesuai dengan identitas dan kewenangannya. Penggunaan akun orang lain dapat mengurangi akuntabilitas dan menyulitkan penelusuran aktivitas apabila terjadi insiden.

Pelindungan Rekam Medis Elektronik karena itu harus dilakukan secara menyeluruh. Pengamanan tidak berhenti pada server atau *database*, tetapi juga mencakup akun pengguna, perangkat kerja, jaringan, aplikasi, integrasi sistem, proses pertukaran data, salinan data, media penyimpanan, serta pihak-pihak yang memperoleh akses.

Bagi pengguna, prinsipnya sederhana: ketika informasi berasal dari Rekam Medis atau Rekam Medis Elektronik, informasi tersebut tetap harus diperlakukan secara aman meskipun telah berubah menjadi laporan, berkas, hasil cetak, *screenshot*, atau bentuk lainnya.

INGAT: Rekam Medis Elektronik bukan hanya sebuah aplikasi. Data dapat bergerak melalui sistem, jaringan, perangkat, berkas, dan berbagai proses kerja. Di mana pun data tersebut berada, keamanan, kerahasiaan, keutuhan, dan ketersediaannya harus tetap dijaga.

2.5 Data Pasien dalam SIMRS dan Sistem Elektronik Lainnya

Data pasien dalam lingkungan rumah sakit tidak hanya berada di dalam Rekam Medis Elektronik. Pemanfaatan teknologi informasi menyebabkan data dapat diproses melalui berbagai aplikasi, basis data (*database*), server, perangkat pengguna, serta sistem elektronik yang saling terhubung. Kondisi ini membuat perlindungan data pasien perlu diterapkan terhadap seluruh sistem yang menyimpan, menampilkan, mengirimkan, atau memproses data tersebut.

Peraturan Menteri Kesehatan Republik Indonesia Nomor 24 Tahun 2022 tentang Rekam Medis mendefinisikan Sistem Elektronik sebagai serangkaian perangkat dan prosedur elektronik yang berfungsi mempersiapkan, mengumpulkan, mengolah, menganalisis, menyimpan, menampilkan, mengumumkan, mengirimkan, dan/atau menyebarkan informasi elektronik (Kementerian Kesehatan Republik Indonesia, 2022).

Definisi tersebut menunjukkan bahwa sebuah sistem elektronik tidak hanya berfungsi sebagai tempat penyimpanan data. Data dapat mengalami berbagai proses sejak dikumpulkan hingga ditampilkan atau dikirimkan kepada sistem lainnya. Dari perspektif keamanan informasi, setiap proses tersebut dapat menjadi titik yang perlu mendapatkan perlindungan.

Dalam lingkungan rumah sakit, salah satu sistem yang digunakan untuk mendukung pengelolaan informasi adalah Sistem Informasi Manajemen Rumah Sakit (SIMRS). SIMRS dapat berinteraksi dengan berbagai subsistem dan aplikasi lain sesuai dengan arsitektur teknologi informasi yang diterapkan oleh rumah sakit. Karena itu, pengguna tidak seharusnya beranggapan bahwa data pasien hanya perlu dilindungi ketika sedang membuka Rekam Medis Elektronik.

Permenkes Nomor 24 Tahun 2022 menyatakan bahwa Rekam Medis Elektronik merupakan salah satu subsistem dari sistem informasi Fasilitas Pelayanan Kesehatan yang terhubung dengan subsistem informasi lainnya. Regulasi tersebut juga mensyaratkan

Sistem Elektronik yang digunakan dalam penyelenggaraan Rekam Medis Elektronik memiliki kemampuan kompatibilitas dan/atau interoperabilitas (Kementerian Kesehatan Republik Indonesia, 2022).

Interoperabilitas memungkinkan Sistem Elektronik yang berbeda bekerja secara terpadu untuk melakukan komunikasi atau pertukaran data dengan Sistem Elektronik lainnya menggunakan standar pertukaran data. Kemampuan tersebut mendukung integrasi sistem, tetapi dari perspektif cybersecurity juga berarti bahwa data dapat berpindah melewati batas satu aplikasi atau satu *database*.

Sebagai contoh, data yang awalnya dimasukkan melalui sebuah aplikasi dapat diteruskan ke subsistem lain untuk mendukung proses yang berbeda. Informasi dapat pula ditampilkan kembali melalui laporan, antarmuka aplikasi, atau sistem yang memperoleh data melalui proses integrasi. Oleh karena itu, pengamanan harus mempertimbangkan **aliran data**, bukan hanya lokasi penyimpanan awalnya.

Permenkes Nomor 24 Tahun 2022 juga mengatur bahwa kegiatan penyelenggaraan Rekam Medis Elektronik paling sedikit mencakup registrasi pasien, pendistribusian data Rekam Medis Elektronik, pengisian informasi klinis, pengolahan informasi, penginputan data untuk klaim pembiayaan, penyimpanan, penjaminan mutu, dan transfer isi Rekam Medis Elektronik (Kementerian Kesehatan Republik Indonesia, 2022).

Kegiatan tersebut menunjukkan bahwa informasi dapat digunakan oleh berbagai proses dan fungsi sistem. Karena itu, satu data pasien dapat muncul pada lebih dari satu tampilan atau subsistem sesuai dengan kebutuhan dan kewenangan pengguna.

Risiko keamanan juga tidak hanya berada pada server. Data dapat tampil pada komputer pengguna ketika aplikasi digunakan. Data dapat tersimpan sementara pada perangkat, diunduh sebagai laporan, diekspor menjadi *spreadsheet*, dibuat menjadi dokumen PDF, dicetak, atau disalin ke media lainnya. Setiap perpindahan

tersebut dapat menciptakan lokasi baru tempat informasi perlu dilindungi.

Sebagai contoh, sebuah *database* pada server mungkin telah dilindungi dengan pembatasan jaringan dan kontrol akses yang memadai. Namun, apabila pengguna mengeksport data pasien menjadi berkas *spreadsheet* kemudian menyimpannya pada komputer pribadi, maka salinan data tersebut tidak lagi hanya berada di lingkungan pengamanan server.

Hal serupa dapat terjadi dalam kegiatan *troubleshooting*. Administrator atau vendor mungkin perlu memeriksa suatu kesalahan aplikasi. Untuk menjelaskan permasalahan, pengguna kemudian mengambil *screenshot* yang memperlihatkan pesan kesalahan. Tanpa diperiksa terlebih dahulu, gambar tersebut dapat ikut menampilkan nama pasien, nomor Rekam Medis, NIK, atau informasi lain yang tidak diperlukan untuk menyelesaikan masalah.

Karena itu, data yang ditampilkan melalui SIMRS atau Sistem Elektronik lainnya harus diperlakukan berdasarkan **isi informasinya**, bukan berdasarkan nama aplikasi tempat informasi tersebut terlihat. Data pribadi tetap merupakan data pribadi meskipun telah berpindah dari *database* ke layar komputer, laporan, *spreadsheet*, berkas PDF, atau *screenshot*.

Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi mengatur pelindungan Data Pribadi dalam rangkaian pemrosesan Data Pribadi. Undang-undang tersebut juga mengatur kewajiban Pengendali Data Pribadi dan Prosesor Data Pribadi dalam pemrosesan Data Pribadi (Republik Indonesia, 2022).

Dari perspektif keamanan informasi, kondisi tersebut menegaskan pentingnya mengetahui **di mana data berada dan bagaimana data berpindah**. Pengamanan yang hanya berfokus pada satu aplikasi dapat meninggalkan risiko pada sistem lain yang menerima data, perangkat yang digunakan untuk mengaksesnya, atau berkas yang dihasilkan dari sistem tersebut.

Administrator sistem juga perlu memperhatikan salinan data yang dibuat untuk kepentingan teknis. *Backup database*, hasil

database dump, berkas log yang mengandung informasi tertentu, hasil *query*, maupun data yang digunakan dalam lingkungan pengujian dapat menjadi bagian dari aset informasi yang harus diamankan apabila mengandung data pribadi.

Hal yang sama berlaku ketika sistem dikelola atau dipelihara oleh pihak ketiga. Akses vendor terhadap aplikasi, server, *database*, atau sistem melalui *remote access* dapat memberikan kemampuan teknis untuk melihat informasi yang terdapat di dalamnya. Kemampuan tersebut tidak berarti vendor memperoleh kewenangan untuk menyalin atau menggunakan data di luar kebutuhan pekerjaan yang telah ditentukan.

Permenkes Nomor 24 Tahun 2022 bahkan mensyaratkan dokumentasi registrasi Sistem Elektronik memuat antara lain nama sistem, dokumentasi sistem, fitur atau fungsi yang tersedia, **lokasi penyimpanan data**, variabel dan metadata, serta daftar fasilitas pelayanan kesehatan pengguna apabila sistem digunakan oleh fasilitas lainnya (Kementerian Kesehatan Republik Indonesia, 2022).

Bagi pegawai dan pihak ketiga, prinsip yang perlu diterapkan adalah bahwa perlindungan data harus mengikuti data tersebut. Ketika data berpindah dari SIMRS ke sistem lain, diunduh menjadi berkas, dikirimkan melalui integrasi, atau ditampilkan pada perangkat pengguna, kewajiban untuk menjaganya tidak ikut berakhir.

Dengan demikian, keamanan data pasien harus dipandang sebagai pengamanan terhadap **ekosistem informasi**, bukan hanya pengamanan terhadap satu aplikasi. SIMRS, Rekam Medis Elektronik, *database*, server, jaringan, komputer pengguna, integrasi antarsistem, berkas hasil ekspor, media penyimpanan, serta akses pihak ketiga merupakan bagian dari lingkungan yang perlu diperhatikan dalam perlindungan data.

INGAT: Data pasien tidak hanya berada di SIMRS. Data dapat berpindah melalui aplikasi, *database*, server, integrasi sistem, komputer pengguna, berkas hasil ekspor, dan media lainnya. Di

mana pun data berada, kebutuhan untuk melindunginya tetap mengikuti data tersebut.

2.6 Data Pasien dalam Bentuk Dokumen, File, Foto, dan Percakapan

Data pasien tidak selalu berada di dalam SIMRS, Rekam Medis Elektronik, atau *database*. Dalam aktivitas sehari-hari, informasi dapat berpindah ke berbagai bentuk dan media, seperti dokumen cetak, berkas elektronik, foto, tangkapan layar (*screenshot*), hasil ekspor aplikasi, maupun percakapan melalui media komunikasi. Perubahan bentuk tersebut tidak menghilangkan sifat informasi sebagai data pribadi.

Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi mendefinisikan Data Pribadi sebagai data tentang orang perseorangan yang teridentifikasi atau dapat diidentifikasi secara tersendiri atau dikombinasi dengan informasi lainnya, baik secara langsung maupun tidak langsung melalui sistem elektronik atau nonelektronik (Republik Indonesia, 2022). Dengan demikian, pelindungan data pribadi tidak terbatas pada data yang tersimpan secara elektronik.

Dalam lingkungan rumah sakit, informasi yang sama dapat muncul dalam berbagai bentuk. Data yang awalnya tersimpan pada Sistem Elektronik dapat dicetak menjadi dokumen, diekspor menjadi berkas *spreadsheet* atau PDF, ditampilkan pada layar komputer, difoto menggunakan telepon seluler, atau dikirimkan kepada pihak lain melalui sarana komunikasi elektronik.

Peraturan Menteri Kesehatan Nomor 24 Tahun 2022 mendefinisikan Sistem Elektronik sebagai serangkaian perangkat dan prosedur elektronik yang memiliki fungsi antara lain untuk mengumpulkan, mengolah, menyimpan, menampilkan, mengirimkan, dan/atau menyebarkan informasi elektronik (Kementerian Kesehatan Republik Indonesia, 2022). Hal tersebut

menunjukkan bahwa informasi dapat mengalami berbagai proses dan perpindahan selama digunakan dalam suatu Sistem Elektronik.

Data dalam Dokumen Cetak

Dokumen cetak dapat mengandung data pribadi sebagaimana data yang terdapat di dalam aplikasi. Hasil cetak laporan, formulir, daftar, maupun dokumen lain yang memuat identitas atau informasi pasien tetap harus dilindungi.

Risiko dapat terjadi ketika dokumen dibiarkan di atas meja, tertinggal pada mesin pencetak, dibawa ke lokasi yang tidak semestinya, atau dibuang tanpa memperhatikan informasi yang terdapat di dalamnya. Pihak yang tidak memiliki akses ke SIMRS mungkin tetap dapat memperoleh informasi apabila menemukan dokumen cetak yang tidak diamankan.

Oleh karena itu, keamanan informasi tidak berhenti ketika tombol **Print** ditekan. Pengguna yang mencetak informasi perlu memastikan dokumen diambil dari mesin pencetak, disimpan di tempat yang sesuai, hanya diberikan kepada pihak yang berwenang, dan dikelola sesuai dengan ketentuan yang berlaku.

Data dalam File Elektronik

Data pasien juga dapat berada dalam berbagai jenis berkas elektronik. Pengguna dapat mengekspor informasi dari aplikasi menjadi *spreadsheet*, PDF, dokumen, gambar, atau format berkas lainnya untuk mendukung pekerjaan.

Berkas tersebut dapat mengandung informasi yang sama dengan informasi yang ditampilkan oleh sistem sumber. Sebuah berkas *laporan.xlsx*, misalnya, dapat memuat nama pasien, NIK, nomor Rekam Medis, atau informasi lainnya. Nama berkas yang terlihat umum tidak mengubah karakter informasi yang tersimpan di dalamnya.

Risiko meningkat apabila berkas kemudian disalin ke *flashdisk*, laptop pribadi, layanan penyimpanan *cloud* pribadi, atau perangkat lain yang tidak diperuntukkan untuk menyimpan data tersebut. Setiap salinan dapat menciptakan lokasi baru yang juga harus diamankan.

Karena itu, pengguna perlu memperhatikan bukan hanya dari mana sebuah berkas berasal, tetapi juga **di mana berkas tersebut akan disimpan, siapa yang dapat mengaksesnya, dan kepada siapa berkas akan dikirimkan.**

Data dalam Foto dan Screenshot

Foto dan *screenshot* merupakan bentuk data yang sering dianggap sederhana karena mudah dibuat dan dikirimkan. Padahal, sebuah gambar dapat menangkap informasi jauh lebih banyak daripada yang sebenarnya ingin dibagikan.

Sebagai contoh, pengguna mengalami kesalahan pada aplikasi kemudian mengambil *screenshot* untuk meminta bantuan kepada administrator atau vendor. Pesan kesalahan mungkin hanya berada pada sebagian kecil layar, sedangkan bagian lainnya menampilkan nama pasien, nomor Rekam Medis, NIK, atau informasi lain.

Apabila gambar tersebut langsung dikirimkan tanpa diperiksa, informasi pasien ikut berpindah kepada penerima meskipun sebenarnya tidak diperlukan untuk menyelesaikan permasalahan teknis.

Risiko yang sama terdapat pada foto dokumen atau layar komputer. Kamera telepon seluler dapat dengan mudah membuat salinan informasi yang kemudian tersimpan di galeri perangkat, tersinkronisasi ke layanan *cloud*, atau diteruskan melalui aplikasi komunikasi.

Oleh karena itu, sebelum membuat atau mengirimkan foto dan *screenshot*, pengguna perlu mempertimbangkan apakah informasi pasien memang perlu terlihat. Apabila identitas pasien tidak diperlukan, bagian tersebut sebaiknya tidak disertakan atau disamarkan sebelum informasi dibagikan.

Data dalam Percakapan

Data pribadi juga dapat muncul dalam percakapan. Informasi yang diketik atau dikirim melalui aplikasi pesan instan, surat elektronik, grup percakapan, maupun media komunikasi lainnya tetap dapat mengandung data pribadi.

Percakapan dapat menjadi berisiko ketika pengguna menyebutkan identitas pasien bersama informasi lainnya, mengirimkan dokumen, meneruskan foto, atau membagikan *screenshot*. Informasi yang awalnya hanya berada di dalam Sistem Elektronik rumah sakit kemudian dapat memiliki salinan baru pada perangkat para penerima.

Pengguna juga perlu memperhatikan **siapa saja yang berada dalam suatu grup percakapan**. Keberadaan seseorang di dalam grup tidak dengan sendirinya berarti bahwa orang tersebut memiliki kewenangan untuk menerima seluruh data yang dibagikan melalui grup tersebut.

Karena itu, sebelum mengirimkan informasi melalui media komunikasi, pengguna perlu memastikan penerima, kebutuhan pengiriman, dan data yang benar-benar diperlukan. Prinsip tersebut akan dibahas lebih khusus pada BAB 7 mengenai WhatsApp, email, *cloud*, dan media sosial.

Perubahan Media Tidak Mengubah Kebutuhan Pelindungan

Permenkes Nomor 24 Tahun 2022 menetapkan bahwa salah satu tujuan pengaturan Rekam Medis adalah menjamin keamanan, kerahasiaan, keutuhan, dan ketersediaan data Rekam Medis (Kementerian Kesehatan Republik Indonesia, 2022). Prinsip tersebut penting ketika informasi berpindah dari sistem utama ke bentuk atau media lainnya.

Sebuah data tidak menjadi bebas untuk dibagikan hanya karena telah dicetak. Data tidak kehilangan kebutuhan pengamanan setelah diekspor menjadi *spreadsheet*. Informasi tidak menjadi aman hanya karena dikirimkan dalam bentuk gambar. Demikian pula, data pribadi tetap merupakan data pribadi ketika dituliskan dalam sebuah percakapan.

Dari perspektif keamanan informasi, pengguna perlu memperhatikan **siklus hidup data**. Data dapat dibuat, diakses, digunakan, disalin, dikirimkan, disimpan, dan pada akhirnya tidak lagi diperlukan. Setiap tahapan dapat menghadirkan risiko apabila informasi tidak dikelola dengan benar.

Pegawai dan pihak ketiga karena itu perlu membangun kebiasaan untuk memeriksa informasi sebelum memindahkannya dari satu media ke media lain. Sebelum mencetak, mengunduh, mengambil *screenshot*, memotret, atau mengirimkan data, pengguna dapat mempertimbangkan tiga pertanyaan sederhana:

Apakah data ini memang diperlukan?

Apakah penerima berwenang menerima data ini?

Apakah seluruh informasi yang terdapat di dalam dokumen, file, foto, atau pesan perlu dibagikan?

Apabila hanya sebagian informasi yang diperlukan, pengguna sebaiknya membatasi data yang dibagikan. Pendekatan tersebut membantu mengurangi paparan data pribadi yang tidak diperlukan sekaligus mengurangi dampak apabila terjadi kesalahan pengiriman atau akses yang tidak sah.

INGAT: Data pasien tetap harus dilindungi dalam bentuk apa pun. Dokumen cetak, file, foto, *screenshot*, dan percakapan dapat mengandung data pribadi. Sebelum membagikan informasi, periksa data, tujuan, dan penerimaannya.

2.7 Mengidentifikasi Data Pribadi Sebelum Menggunakan atau Membagikannya

Kemampuan mengenali data pribadi merupakan bagian penting dari kesadaran keamanan informasi. Pengguna tidak dapat melindungi informasi dengan baik apabila tidak menyadari bahwa informasi yang sedang dilihat, disalin, diunduh, dicetak, atau dikirimkan mengandung data pribadi.

Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi mendefinisikan Data Pribadi sebagai data tentang orang perseorangan yang teridentifikasi atau dapat diidentifikasi secara tersendiri atau dikombinasi dengan informasi lainnya, baik secara langsung maupun tidak langsung melalui sistem elektronik atau nonelektronik (Republik Indonesia, 2022).

Definisi tersebut memberikan prinsip penting bagi pengguna: **jangan hanya mencari nama seseorang ketika menentukan apakah suatu informasi merupakan data pribadi.** Informasi lain dapat digunakan untuk mengidentifikasi seseorang secara langsung atau setelah dikombinasikan dengan informasi lainnya.

Dalam lingkungan rumah sakit, data pribadi dapat muncul pada berbagai tempat. Informasi dapat terlihat pada layar SIMRS, Rekam Medis Elektronik, laporan, dokumen cetak, *spreadsheet*, berkas PDF, hasil *query database*, *screenshot*, foto, surat elektronik, maupun percakapan melalui media komunikasi.

Sebelum menggunakan atau membagikan informasi tersebut, pengguna perlu terlebih dahulu memperhatikan **apa saja data yang terdapat di dalamnya.**

Sebagai contoh, seorang pengguna hendak mengirimkan *screenshot* kepada administrator untuk menunjukkan pesan kesalahan pada aplikasi. Sebelum gambar dikirimkan, pengguna perlu memeriksa seluruh bagian gambar, bukan hanya pesan kesalahan yang menjadi fokus utama. Nama pasien, NIK, nomor Rekam Medis, atau informasi lain mungkin masih terlihat pada bagian lain layar.

Hal yang sama berlaku ketika menggunakan berkas hasil ekspor. Sebuah *spreadsheet* mungkin dibuat untuk memenuhi kebutuhan tertentu, tetapi hasil ekspor dapat memiliki banyak kolom. Apabila penerima hanya membutuhkan beberapa informasi, kolom lain yang mengandung data pribadi tidak seharusnya ikut dibagikan tanpa kebutuhan dan kewenangan yang sesuai.

Periksa Sebelum Membagikan

Sebelum mengirimkan dokumen, berkas, foto, atau informasi lainnya, pengguna dapat membiasakan diri melakukan pemeriksaan sederhana:

1. **Apa data yang terdapat di dalamnya?**
Periksa apakah informasi memuat nama, NIK, nomor Rekam Medis, data kesehatan, atau informasi lain yang dapat digunakan untuk mengidentifikasi seseorang.

2. **Apakah seluruh data tersebut diperlukan?**

Jangan membagikan lebih banyak informasi daripada yang diperlukan untuk tujuan pekerjaan.

3. **Siapa yang akan menerima data?**

Pastikan penerima merupakan pihak yang memiliki kewenangan dan memang membutuhkan informasi tersebut.

4. **Apakah media yang digunakan sesuai?**

Pertimbangkan apakah informasi dikirimkan melalui sarana yang diperbolehkan dan sesuai dengan kebijakan organisasi.

5. **Apakah ada informasi yang dapat dihilangkan atau disamarkan?**

Apabila identitas pasien tidak diperlukan, informasi tersebut sebaiknya tidak ikut dibagikan.

Kebiasaan tersebut dapat diterapkan sebelum menekan tombol **Send, Share, Upload, Export**, atau **Print**. Beberapa detik yang digunakan untuk memeriksa kembali informasi dapat mencegah data dikirimkan kepada penerima yang salah atau informasi yang tidak diperlukan ikut tersebar.

Gunakan Data Secukupnya

UU Pelindungan Data Pribadi mengatur bahwa pemrosesan Data Pribadi harus dilakukan secara terbatas dan spesifik, sah secara hukum, dan transparan. Pengendali Data Pribadi juga wajib memastikan pemrosesan Data Pribadi dilakukan sesuai dengan tujuan pemrosesan Data Pribadi (Republik Indonesia, 2022).

Dari perspektif kesadaran keamanan, prinsip tersebut dapat diterapkan melalui kebiasaan **menggunakan data secukupnya sesuai kebutuhan pekerjaan**.

Apabila pekerjaan hanya membutuhkan nomor tiket dan pesan kesalahan aplikasi, misalnya, identitas pasien tidak perlu ikut dimasukkan ke dalam *screenshot*. Apabila sebuah laporan hanya membutuhkan data tertentu, informasi lain yang tidak diperlukan sebaiknya tidak ikut diekspor atau dibagikan.

Pendekatan tersebut juga mengurangi dampak apabila terjadi kesalahan. Semakin sedikit data pribadi yang disalin atau dibagikan, semakin sedikit pula informasi yang berpotensi terekspos ketika berkas salah dikirim, perangkat hilang, akun disalahgunakan, atau terjadi insiden keamanan lainnya.

Waspada! Kombinasi Data

Pengguna juga perlu memperhatikan bahwa informasi yang terlihat tidak sensitif ketika berdiri sendiri dapat memiliki arti berbeda ketika digabungkan dengan informasi lain.

Sebuah nomor, kode, tanggal, atau informasi tertentu mungkin tidak langsung menunjukkan identitas seseorang. Namun, apabila informasi tersebut digabungkan dengan data lain yang tersedia, seseorang mungkin dapat diidentifikasi.

Karena itu, menghapus nama pasien dari sebuah dokumen belum tentu membuat dokumen tersebut tidak lagi mengandung data pribadi. Informasi lain yang tersisa perlu diperiksa untuk menentukan apakah seseorang masih dapat diidentifikasi.

Prinsip ini penting terutama ketika data akan digunakan untuk kebutuhan teknis, seperti *troubleshooting*, pengujian aplikasi, pembuatan dokumentasi, atau komunikasi dengan vendor. Apabila identitas sebenarnya tidak diperlukan, penggunaan data contoh atau penyamaran informasi dapat mengurangi paparan data pribadi.

Periksa Penerima, Bukan Hanya Data

Mengidentifikasi data pribadi saja belum cukup. Pengguna juga perlu memastikan bahwa pihak yang menerima informasi memiliki kewenangan untuk menerimanya.

Salah satu kesalahan sederhana yang dapat menyebabkan pengungkapan informasi adalah salah memilih penerima. Fitur *autocomplete* pada surat elektronik atau aplikasi komunikasi dapat menampilkan beberapa nama yang mirip. Pengguna yang terburu-buru dapat memilih penerima yang salah dan baru menyadarinya setelah informasi terkirim.

Risiko serupa terdapat pada grup percakapan. Sebelum membagikan data, pengguna perlu memperhatikan siapa saja

anggota grup tersebut. Sebuah grup yang digunakan untuk koordinasi pekerjaan tidak secara otomatis menjadi tempat yang tepat untuk membagikan seluruh jenis data pasien.

Karena itu, pemeriksaan sebelum mengirimkan informasi harus mencakup dua hal sekaligus: **data yang akan dikirim dan pihak yang akan menerimanya.**

Jika Ragu, Jangan Langsung Membagikan

Tidak semua situasi dapat diputuskan hanya dengan melihat jenis datanya. Pengguna dapat menghadapi kondisi ketika kebutuhan untuk membagikan informasi tidak jelas, penerima belum dapat dipastikan kewenangannya, atau media yang akan digunakan diragukan keamanannya.

Dalam kondisi seperti itu, tindakan yang lebih aman adalah tidak langsung mengirimkan data. Pengguna dapat terlebih dahulu melakukan verifikasi atau meminta arahan kepada pihak yang berwenang sesuai prosedur organisasi.

Prinsip tersebut juga berlaku ketika seseorang meminta data dengan alasan mendesak. Situasi mendesak tidak seharusnya menjadi alasan untuk mengabaikan verifikasi identitas, kewenangan, dan kebutuhan penerima. Permintaan yang menggunakan tekanan atau menciptakan rasa terburu-buru bahkan dapat menjadi salah satu teknik *social engineering* yang akan dibahas pada BAB 9.

Kemampuan mengidentifikasi data pribadi pada akhirnya perlu menjadi kebiasaan dalam aktivitas sehari-hari. Pengguna tidak harus melakukan analisis yang rumit setiap kali bekerja dengan informasi. Yang diperlukan adalah membangun kebiasaan untuk **melihat, mengenali, memeriksa, dan berpikir sebelum menggunakan atau membagikan data.**

INGAT: Sebelum menekan **Send, Share, Upload, Export, atau Print**, periksa tiga hal: **data apa yang akan dibagikan, apakah seluruh data tersebut diperlukan, dan apakah penerimanya berwenang.** Jika ragu, jangan langsung membagikannya.

BAB 3 AKSES DATA PASIEN: TIDAK SEMUA ORANG BOLEH MELIHAT SEMUA DATA

3.1 Hak Akses Bukan Hak untuk Melihat Semua Data

Hak akses merupakan salah satu mekanisme penting dalam keamanan sistem informasi. Melalui hak akses, organisasi menentukan siapa yang dapat menggunakan suatu sistem, fungsi apa yang dapat dijalankan, dan informasi apa yang dapat diakses oleh pengguna. Namun, memiliki akun dan dapat masuk ke dalam sebuah sistem tidak berarti bahwa pengguna memiliki kewenangan untuk melihat seluruh data yang tersedia.

Dalam lingkungan rumah sakit, sistem elektronik dapat menyimpan dan memproses berbagai informasi pasien. Seorang pengguna mungkin secara teknis dapat melakukan pencarian, membuka menu tertentu, atau melihat informasi yang terdapat di dalam sistem. Kemampuan teknis tersebut harus dibedakan dari **kewenangan untuk mengakses data**.

Dengan kata lain, terdapat perbedaan antara:

“Saya bisa membuka data tersebut”

dan

“Saya berwenang membuka data tersebut.”

Perbedaan ini merupakan dasar penting dalam perlindungan data pasien.

Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi mewajibkan Pengendali Data Pribadi melindungi dan memastikan keamanan Data Pribadi yang diprosesnya. Undang-undang tersebut juga mengatur kewajiban untuk mencegah Data Pribadi diakses secara tidak sah (Republik Indonesia, 2022).

Bagi pengguna, prinsip tersebut dapat diterapkan dengan sederhana: data hanya diakses ketika terdapat kebutuhan pekerjaan dan kewenangan yang sesuai. Pengguna tidak seharusnya membuka data pasien hanya karena informasi tersebut tersedia melalui akun yang dimilikinya.

Sebagai contoh, seorang pegawai mengetahui bahwa kerabat, teman, pejabat, tokoh masyarakat, atau orang yang dikenalnya sedang memperoleh pelayanan di rumah sakit. Apabila pegawai tersebut tidak memiliki kebutuhan pekerjaan terhadap informasi pasien tersebut, rasa ingin tahu bukan merupakan alasan untuk melakukan pencarian atau membuka datanya melalui sistem.

Hal yang sama berlaku ketika seorang rekan kerja meminta bantuan untuk melihat data yang tidak dapat diakses menggunakan akunnya. Kondisi tersebut tidak seharusnya diselesaikan dengan menggunakan akun pengguna lain yang memiliki hak akses lebih tinggi. Apabila akses memang diperlukan untuk pekerjaan, pemberian akses seharusnya dilakukan melalui mekanisme yang ditetapkan oleh organisasi.

Prinsip Least Privilege

Dalam cybersecurity dikenal prinsip **least privilege**. NIST menjelaskan *least privilege* sebagai prinsip keamanan yang membatasi hak akses pengguna atau proses pada tingkat minimum yang diperlukan untuk menyelesaikan tugas yang diberikan (Joint Task Force, 2020).

Prinsip tersebut berarti pengguna tidak perlu diberikan akses terhadap seluruh fungsi dan data apabila pekerjaannya hanya membutuhkan sebagian dari sistem.

Sebagai contoh, apabila seorang pengguna hanya membutuhkan fungsi tertentu pada sebuah aplikasi, pengguna tersebut tidak perlu memperoleh hak administrator. Apabila vendor hanya membutuhkan akses ke satu server untuk melakukan *troubleshooting*, akses ke seluruh infrastruktur tidak perlu diberikan.

Penerapan *least privilege* juga memberikan manfaat apabila sebuah akun berhasil diambil alih oleh penyerang. Hak akses yang terbatas dapat membantu membatasi sistem dan informasi yang dapat dijangkau melalui akun tersebut. NIST Cybersecurity Framework 2.0 juga menempatkan *least privilege* sebagai prinsip dalam pengelolaan izin, hak, dan otorisasi akses (Pascoe et al., 2024).

Hak Akses Harus Mengikuti Kebutuhan Pekerjaan

Hak akses seharusnya diberikan berdasarkan kebutuhan pekerjaan, bukan berdasarkan keinginan pengguna untuk memperoleh akses yang lebih luas.

Dalam penerapannya, seorang pengguna dapat membutuhkan akses yang berbeda dengan pengguna lainnya. Administrator sistem dapat membutuhkan fungsi administratif yang tidak diperlukan pengguna biasa. Vendor dapat membutuhkan akses sementara untuk melakukan pemeliharaan. Pengelola aplikasi dapat membutuhkan fungsi tertentu untuk menjalankan tugasnya.

Perbedaan tersebut merupakan hal yang wajar dalam pengelolaan keamanan informasi.

Yang perlu dihindari adalah pemberian akses secara berlebihan dengan alasan untuk mempermudah pekerjaan. Semakin luas hak akses sebuah akun, semakin banyak sumber daya dan informasi yang dapat dijangkau apabila akun tersebut disalahgunakan.

Hak akses juga perlu disesuaikan ketika terjadi perubahan tugas. Apabila seseorang berpindah unit, memperoleh tanggung jawab baru, tidak lagi menjalankan fungsi tertentu, atau hubungan kerja dengan pihak ketiga telah berakhir, kebutuhan aksesnya dapat berubah. NIST Cybersecurity Framework 2.0 merekomendasikan peninjauan hak akses secara berkala dan ketika seseorang berubah peran atau meninggalkan organisasi, serta pencabutan hak yang tidak lagi diperlukan (Pascoe et al., 2024).

Akses Administrator Bukan Izin untuk Membuka Semua Data

Prinsip akses sesuai kewenangan juga berlaku bagi personel teknologi informasi. Administrator sistem atau *database administrator* dapat memiliki kemampuan teknis yang jauh lebih besar dibandingkan pengguna biasa. Hak administratif tersebut diberikan untuk menjalankan fungsi pengelolaan sistem, bukan sebagai izin untuk melihat seluruh data tanpa kebutuhan pekerjaan.

Sebagai contoh, administrator *database* mungkin secara teknis dapat menjalankan *query* terhadap berbagai tabel. Namun, kemampuan tersebut tidak berarti administrator seharusnya

melakukan pencarian data pasien tertentu tanpa alasan pekerjaan yang sah.

Hal yang sama berlaku ketika administrator melakukan *troubleshooting*. Apabila permasalahan dapat diselesaikan tanpa menampilkan data pasien yang sebenarnya, penggunaan data contoh atau pembatasan informasi yang ditampilkan dapat mengurangi paparan data pribadi.

Akses administratif dengan demikian harus dipandang sebagai **tanggung jawab yang lebih besar**, bukan kebebasan yang lebih besar.

Vendor dan Pihak Ketiga Tetap Memiliki Batas Akses

Vendor, teknisi, konsultan, dan pihak ketiga dapat memperoleh akses terhadap sistem untuk tujuan tertentu. Misalnya, vendor aplikasi memperoleh akses untuk melakukan pemeliharaan atau *troubleshooting*.

Akses tersebut harus digunakan sesuai ruang lingkup pekerjaan yang diberikan. Kemampuan vendor untuk melihat *database*, membuka aplikasi, atau melakukan *remote access* tidak berarti vendor diperbolehkan menjelajahi data yang tidak berkaitan dengan pekerjaannya.

Apabila pekerjaan telah selesai, akses sementara yang tidak lagi diperlukan seharusnya dihentikan. Pendekatan tersebut sesuai dengan prinsip *least privilege*, yaitu memberikan sumber daya dan otorisasi minimum yang diperlukan untuk menjalankan suatu fungsi (Joint Task Force, 2020).

Jangan Meminjam Hak Akses Orang Lain

Ketika seorang pengguna tidak dapat mengakses suatu fungsi, kondisi tersebut dapat menunjukkan bahwa fungsi tersebut memang tidak termasuk dalam hak akses yang diberikan kepadanya.

Solusinya bukan meminta *username* dan *password* milik rekan kerja.

Pengguna juga tidak seharusnya meminta orang yang memiliki akses lebih tinggi untuk membuka data hanya untuk menghindari mekanisme permohonan akses yang berlaku.

Apabila akses memang diperlukan untuk melaksanakan pekerjaan, pengguna perlu meminta pemberian atau perubahan hak akses melalui mekanisme yang ditentukan organisasi. Dengan demikian, akses dapat diberikan secara resmi, tercatat, dan dapat dipertanggungjawabkan.

Prinsip ini juga penting bagi administrator. Permintaan seperti *“pinjam akun sebentar”*, *“tolong bukakan karena akun saya tidak bisa”*, atau *“pakai akun admin saja supaya cepat”* tidak seharusnya menjadi cara untuk melewati pembatasan akses.

Pembatasan akses bukan hambatan yang harus dicari jalan pintasnya. Pembatasan tersebut merupakan bagian dari kontrol keamanan yang dirancang untuk melindungi sistem dan informasi.

Biasakan Bertanya Sebelum Membuka Data

Sebelum membuka data pasien, pengguna dapat membiasakan diri mengajukan tiga pertanyaan:

Apakah data ini diperlukan untuk pekerjaan saya?

Apakah saya memiliki kewenangan untuk mengaksesnya?

Apakah tindakan yang akan saya lakukan terhadap data tersebut sesuai dengan tujuan akses yang diberikan?

Apabila jawabannya tidak jelas, pengguna sebaiknya tidak melanjutkan akses sampai memperoleh kepastian dari pihak yang berwenang.

Dengan demikian, hak akses tidak boleh dipahami sebagai izin untuk melihat seluruh informasi yang secara teknis dapat dibuka melalui sebuah akun. Hak akses merupakan mekanisme untuk memastikan pengguna memperoleh akses **sesuai kebutuhan dan kewenangannya**.

INGAT: Bisa membuka bukan berarti boleh membuka. Hak akses diberikan untuk menjalankan pekerjaan, bukan untuk melihat seluruh data yang tersedia. Akseslah data pasien hanya ketika diperlukan dan sesuai dengan kewenangan yang diberikan.

3.2 Prinsip Need-to-Know

Hak akses terhadap suatu sistem tidak berarti bahwa pengguna perlu mengetahui seluruh informasi yang dapat dijangkau melalui hak akses tersebut. Dalam keamanan informasi dikenal prinsip ***need-to-know***, yaitu suatu prinsip yang membatasi akses terhadap informasi berdasarkan kebutuhan seseorang untuk mengetahui informasi tersebut dalam rangka menjalankan tugas dan tanggung jawabnya.

Prinsip *need-to-know* memiliki hubungan yang erat dengan prinsip ***least privilege***. Jika *least privilege* berfokus pada pemberian hak akses minimum yang diperlukan untuk menjalankan suatu fungsi, maka *need-to-know* berfokus pada **informasi apa yang memang perlu diketahui oleh pengguna untuk melaksanakan pekerjaannya** (Joint Task Force, 2020).

Dalam lingkungan rumah sakit, prinsip tersebut penting karena sebuah sistem dapat menyimpan berbagai informasi pasien dalam jumlah besar. Pengguna mungkin secara teknis memiliki kemampuan untuk melakukan pencarian, membuka suatu menu, atau melihat informasi tertentu. Namun, kemampuan tersebut tidak berarti bahwa seluruh informasi yang dapat dibuka memang diperlukan untuk pekerjaannya.

Sebagai contoh, seorang pegawai mengetahui bahwa teman, kerabat, pejabat, tokoh masyarakat, atau seseorang yang dikenalnya sedang mendapatkan pelayanan di rumah sakit. Apabila pegawai tersebut tidak memiliki tugas yang berkaitan dengan data pasien tersebut, maka **rasa ingin tahu bukan merupakan kebutuhan untuk mengetahui informasi**.

Dengan demikian, meskipun akun yang digunakan secara teknis dapat mencari dan membuka data tersebut, pengguna tidak seharusnya melakukan akses apabila informasi tersebut tidak diperlukan dalam pelaksanaan pekerjaannya.

Prinsip yang sama berlaku terhadap data pasien lain yang kebetulan terlihat ketika pengguna sedang bekerja. Informasi yang

muncul pada layar tidak secara otomatis menjadi informasi yang perlu diketahui hanya karena pengguna dapat melihatnya.

Need-to-Know dan Least Privilege

Prinsip *need-to-know* dan *least privilege* dapat digunakan secara bersamaan untuk membatasi akses terhadap sistem dan informasi.

Sebagai contoh, seorang pengguna mungkin diberikan akses ke sebuah aplikasi karena aplikasi tersebut diperlukan dalam pekerjaannya. Penerapan *least privilege* membatasi menu dan fungsi yang dapat digunakan oleh akun tersebut. Sementara itu, penerapan *need-to-know* mengharuskan pengguna hanya mengakses informasi yang memang diperlukan untuk menyelesaikan pekerjaannya.

Secara sederhana, kedua prinsip tersebut dapat dibedakan sebagai berikut:

Least privilege:

“Fungsi dan hak akses apa yang benar-benar diperlukan oleh pengguna?”

Need-to-know:

“Informasi apa yang benar-benar perlu diketahui oleh pengguna?”

Keduanya bertujuan mengurangi akses yang tidak diperlukan dan membatasi paparan informasi apabila terjadi penyalahgunaan akun atau insiden keamanan.

Hak Akses yang Luas Tidak Menghilangkan *Need-to-Know*

Prinsip *need-to-know* juga berlaku bagi pengguna yang memiliki hak akses luas.

Administrator sistem, administrator *database*, pengelola aplikasi, atau personel teknologi informasi dapat memiliki kemampuan teknis untuk mengakses berbagai sistem dan informasi. Hak administratif tersebut diberikan agar mereka dapat menjalankan fungsi pengelolaan dan pemeliharaan sistem, bukan agar seluruh informasi yang terdapat di dalam sistem dapat dilihat tanpa kebutuhan pekerjaan.

Sebagai contoh, seorang administrator *database* mungkin secara teknis dapat menjalankan *query* terhadap tabel yang menyimpan data pasien. Namun, kemampuan tersebut tidak berarti

administrator perlu melakukan pencarian terhadap data pasien tertentu apabila tidak berkaitan dengan pekerjaan yang sedang dilakukan.

Ketika melakukan *troubleshooting*, akses terhadap data sebaiknya dibatasi pada informasi yang memang diperlukan untuk mengidentifikasi dan menyelesaikan masalah.

Apabila permasalahan dapat dianalisis melalui *log*, konfigurasi, pesan kesalahan, atau data contoh tanpa melihat data pasien yang sebenarnya, maka data pasien tidak perlu diakses.

Dengan demikian, **semakin besar kemampuan akses seseorang, semakin besar pula tanggung jawab untuk menggunakan akses tersebut secara terkendali.**

***Need-to-Know* bagi Vendor dan Pihak Ketiga**

Vendor, teknisi, konsultan, pengembang aplikasi, dan pihak ketiga juga harus menerapkan prinsip *need-to-know*.

Vendor mungkin memperoleh akses ke aplikasi, server, *database*, atau infrastruktur tertentu untuk melakukan pemeliharaan dan *troubleshooting*. Namun, akses tersebut tidak berarti bahwa vendor perlu mengetahui seluruh informasi yang tersedia di dalam sistem.

Sebagai contoh, apabila vendor hanya membutuhkan pesan kesalahan aplikasi untuk melakukan analisis, identitas pasien tidak perlu ikut diberikan. Jika *screenshot* diperlukan untuk menunjukkan permasalahan, informasi pasien yang tidak berkaitan dengan permasalahan tersebut sebaiknya tidak ikut ditampilkan atau dapat disamarkan terlebih dahulu.

Hal yang sama berlaku ketika vendor meminta salinan *database* untuk melakukan pengujian. Kebutuhan teknis harus dievaluasi terlebih dahulu. Apabila pekerjaan dapat dilakukan menggunakan data contoh atau data yang telah disamarkan, maka penggunaan data pasien sebenarnya dapat dihindari.

Prinsipnya sederhana: **berikan informasi yang memang diperlukan untuk menyelesaikan pekerjaan, bukan seluruh informasi yang tersedia.**

Bekerja di Rumah Sakit yang Sama Tidak Berarti Perlu Mengetahui Semua Data

Prinsip *need-to-know* juga perlu diterapkan ketika informasi dibagikan kepada sesama pegawai.

Fakta bahwa seseorang bekerja di organisasi yang sama tidak secara otomatis berarti bahwa orang tersebut perlu mengetahui seluruh informasi pasien.

Sebelum membagikan data kepada rekan kerja, pengguna perlu mempertimbangkan apakah penerima memang membutuhkan informasi tersebut untuk menjalankan tugasnya.

Prinsip ini menjadi semakin penting ketika menggunakan grup percakapan atau media komunikasi yang memiliki banyak anggota. Sebuah grup mungkin digunakan untuk koordinasi pekerjaan, tetapi tidak semua anggota grup selalu membutuhkan seluruh informasi yang dibagikan.

Apabila informasi hanya diperlukan oleh satu atau beberapa orang, membagikannya kepada seluruh anggota grup dapat memperluas paparan data secara tidak diperlukan.

Jabatan Tidak Menghilangkan Prinsip *Need-to-Know*

Permintaan informasi juga dapat berasal dari seseorang yang memiliki jabatan atau posisi lebih tinggi. Dalam kondisi tersebut, pengguna tetap perlu mempertimbangkan **kewenangan, kebutuhan, dan tujuan penggunaan informasi**.

Jabatan seseorang tidak secara otomatis berarti bahwa seluruh data pasien harus diberikan kepadanya.

Demikian pula, permintaan yang disampaikan dengan alasan mendesak tidak seharusnya membuat pengguna mengabaikan proses verifikasi. Dalam serangan *social engineering*, penyerang bahkan dapat memanfaatkan otoritas, tekanan waktu, atau keadaan mendesak untuk mendorong seseorang memberikan informasi tanpa melakukan pemeriksaan yang semestinya.

Karena itu, permintaan informasi yang tidak biasa tetap perlu diverifikasi, terutama apabila permintaan tersebut melibatkan data pasien, *credential*, akses sistem, atau informasi sensitif lainnya.

Berikan Informasi Secukupnya

Penerapan *need-to-know* tidak hanya menentukan **siapa yang boleh menerima informasi**, tetapi juga membantu menentukan **berapa banyak informasi yang perlu diberikan**.

Apabila seseorang hanya membutuhkan satu bagian informasi untuk menyelesaikan pekerjaan, tidak perlu memberikan seluruh data yang tersedia.

Sebagai contoh, ketika administrator membutuhkan informasi mengenai waktu terjadinya kesalahan dan pesan *error*, pengguna tidak perlu mengirimkan seluruh data pasien apabila informasi tersebut tidak berkaitan dengan masalah.

Pendekatan tersebut sejalan dengan prinsip pemrosesan Data Pribadi dalam Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi, yang mengatur bahwa pemrosesan Data Pribadi dilakukan secara terbatas dan spesifik serta sesuai dengan tujuan pemrosesan Data Pribadi (Republik Indonesia, 2022).

Sebelum mengakses atau membagikan data pasien, pengguna dapat membiasakan diri mengajukan beberapa pertanyaan:

Apakah saya membutuhkan informasi ini untuk pekerjaan saya?

Apakah penerima membutuhkan informasi ini untuk pekerjaannya?

Apakah seluruh informasi perlu diberikan?

Dapatkah informasi yang tidak diperlukan dihilangkan atau disamarkan?

Jika kebutuhan terhadap informasi tidak jelas, pengguna sebaiknya tidak langsung mengakses atau membagikannya sampai memperoleh kepastian mengenai kewenangan dan tujuan penggunaannya.

Prinsip *need-to-know* bukan dimaksudkan untuk menghambat pekerjaan. Prinsip ini memastikan bahwa informasi tersedia kepada pihak yang memang membutuhkannya, sekaligus mengurangi kemungkinan data diakses atau tersebar secara berlebihan.

INGAT: Memiliki hak akses tidak berarti perlu mengetahui semua informasi yang dapat dibuka. **Akses dan bagikan data pasien hanya kepada pihak yang memang membutuhkannya untuk menjalankan pekerjaan yang sah.**

3.3 Prinsip Least Privilege

Dalam pengelolaan keamanan sistem informasi, setiap pengguna membutuhkan hak akses agar dapat menjalankan pekerjaannya. Namun, hak akses yang diberikan tidak seharusnya lebih luas daripada yang benar-benar diperlukan. Salah satu prinsip yang digunakan untuk mengendalikan kondisi tersebut adalah ***least privilege***.

NIST mendefinisikan *least privilege* sebagai prinsip keamanan yang membatasi hak akses pengguna atau proses pada tingkat minimum yang diperlukan untuk menyelesaikan tugas yang diberikan. Dengan kata lain, pengguna hanya memperoleh sumber daya dan kewenangan sistem yang memang dibutuhkan untuk menjalankan fungsinya (Joint Task Force, 2020).

Prinsip ini penting karena setiap hak akses merupakan kemampuan yang dapat digunakan oleh pemilik akun maupun disalahgunakan apabila akun tersebut jatuh ke tangan pihak lain. Semakin luas hak akses sebuah akun, semakin luas pula sistem, fungsi, dan informasi yang berpotensi dapat dijangkau melalui akun tersebut.

Dalam lingkungan rumah sakit, penerapan *least privilege* berarti **hak akses diberikan berdasarkan kebutuhan pekerjaan, bukan berdasarkan kemudahan atau keinginan untuk dapat mengakses semua fungsi.**

Pengguna Tidak Harus Memiliki Semua Hak Akses

Setiap pengguna memiliki tugas dan tanggung jawab yang berbeda. Karena itu, kebutuhan aksesnya juga dapat berbeda.

Pengguna yang hanya membutuhkan fungsi untuk melihat informasi tertentu tidak perlu memperoleh hak untuk mengubah

atau menghapus data. Pengguna yang hanya bekerja pada satu fungsi aplikasi tidak harus memperoleh akses terhadap seluruh menu yang tersedia.

Demikian pula, akun pengguna biasa tidak seharusnya diberikan hak administrator apabila pekerjaan sehari-harinya tidak membutuhkan kewenangan administratif.

Secara sederhana, penerapan *least privilege* dapat digambarkan sebagai berikut:

Jika hanya perlu melihat, tidak perlu diberikan hak mengubah.

Jika hanya perlu menggunakan aplikasi, tidak perlu diberikan hak administrator.

Jika hanya perlu mengakses satu sistem, tidak perlu diberikan akses ke seluruh sistem.

Jika akses hanya diperlukan sementara, akses tidak perlu diberikan secara permanen.

Pembatasan tersebut bukan dimaksudkan untuk mempersulit pekerjaan. Tujuannya adalah memastikan bahwa setiap akun hanya mempunyai kemampuan yang memang diperlukan.

Mengapa Hak Akses Berlebihan Berbahaya?

Hak akses yang terlalu luas meningkatkan risiko ketika terjadi kesalahan maupun penyalahgunaan akun.

Sebagai contoh, seorang pengguna hanya membutuhkan akses untuk melihat data, tetapi akunnya juga diberikan kemampuan untuk menghapus data. Apabila pengguna melakukan kesalahan atau akun tersebut diambil alih oleh penyerang, kemampuan menghapus data tersebut dapat digunakan meskipun sebenarnya tidak pernah diperlukan untuk pekerjaan pengguna.

Risiko menjadi lebih besar pada akun yang memiliki hak administratif. Akun administrator dapat memiliki kemampuan untuk mengubah konfigurasi, membuat akun, memberikan hak akses, memasang perangkat lunak, mengakses sistem, atau melakukan tindakan administratif lainnya.

Karena itu, **hak administrator seharusnya diberikan hanya kepada pihak yang benar-benar membutuhkannya.**

NIST Cybersecurity Framework 2.0 juga menempatkan *least privilege* dalam pengelolaan izin, *entitlement*, dan otorisasi akses. Salah satu contoh implementasinya adalah membatasi akses dan hak istimewa pada tingkat minimum yang diperlukan (Pascoe et al., 2024).

Hak Administrator Bukan untuk Aktivitas Sehari-hari

Prinsip *least privilege* juga relevan bagi administrator sistem.

Seseorang yang bertugas sebagai administrator mungkin membutuhkan akun dengan hak administratif untuk melakukan konfigurasi atau pemeliharaan sistem. Namun, hak tersebut tidak selalu diperlukan untuk seluruh aktivitas sehari-hari.

Apabila memungkinkan, penggunaan akun dengan hak administratif dapat dipisahkan dari akun yang digunakan untuk aktivitas biasa. Dengan pendekatan tersebut, aktivitas yang tidak membutuhkan kewenangan tinggi tidak harus dilakukan menggunakan akun yang memiliki hak akses luas.

Prinsip ini membantu mengurangi risiko apabila akun yang digunakan untuk aktivitas sehari-hari mengalami kompromi.

Hal yang perlu dipahami adalah bahwa **akun administrator bukan akun yang “lebih nyaman” digunakan, tetapi akun dengan tingkat risiko dan tanggung jawab yang lebih tinggi.**

***Least Privilege* bagi Vendor dan Pihak Ketiga**

Prinsip *least privilege* juga harus diterapkan terhadap vendor, teknisi, konsultan, dan pihak ketiga.

Vendor yang membutuhkan akses untuk melakukan *troubleshooting* pada sebuah aplikasi tidak secara otomatis membutuhkan akses ke seluruh server, *database*, jaringan, atau sistem lainnya.

Apabila pekerjaan hanya membutuhkan akses terhadap satu server, maka akses dapat dibatasi pada server tersebut. Apabila vendor hanya membutuhkan fungsi tertentu, hak akses dapat dibatasi pada fungsi yang diperlukan.

Demikian pula, apabila akses hanya diperlukan selama kegiatan pemeliharaan, akses tersebut dapat diberikan untuk periode yang diperlukan dan ditinjau kembali setelah pekerjaan selesai.

Pemberian hak administrator secara permanen kepada vendor hanya karena sewaktu-waktu mungkin dibutuhkan dapat memperluas risiko keamanan yang sebenarnya dapat dibatasi.

Prinsipnya adalah:

berikan akses minimum, untuk tujuan yang jelas, kepada pihak yang tepat, dan selama akses tersebut masih diperlukan.

Jangan Mengatasi Keterbatasan Akses dengan Meminjam Akun

Dalam penerapan *least privilege*, pengguna dapat menemukan kondisi ketika akun yang dimilikinya tidak dapat menjalankan suatu fungsi.

Kondisi tersebut tidak seharusnya langsung dianggap sebagai masalah yang harus dilewati dengan meminjam akun pengguna lain.

Sebagai contoh, seorang pegawai tidak dapat membuka suatu menu kemudian meminta *username* dan *password* milik rekan kerja yang memiliki akses lebih tinggi. Tindakan tersebut melewati mekanisme pengendalian akses yang telah diterapkan.

Hal yang sama berlaku ketika seseorang meminta administrator:

“Pakai akun admin saja supaya cepat.”

Kemudahan tidak seharusnya menjadi alasan untuk menggunakan hak akses yang lebih tinggi daripada yang diperlukan.

Apabila suatu fungsi memang dibutuhkan untuk pekerjaan, pengguna dapat mengajukan pemberian atau perubahan hak akses melalui mekanisme yang berlaku. Dengan demikian, kebutuhan tersebut dapat dievaluasi dan akses diberikan kepada identitas pengguna yang sebenarnya.

Hak Akses Harus Mengikuti Perubahan Tugas

Kebutuhan akses seseorang dapat berubah dari waktu ke waktu.

Pegawai dapat berpindah unit, memperoleh tugas baru, atau tidak lagi menjalankan fungsi tertentu. Vendor dapat menyelesaikan

kontrak atau kegiatan pemeliharaan. Administrator dapat berpindah tanggung jawab ke sistem yang berbeda.

Perubahan tersebut seharusnya diikuti dengan evaluasi terhadap hak akses yang dimiliki.

Hak akses yang dahulu diperlukan belum tentu masih diperlukan pada saat ini. Membiarkan akses lama tetap aktif dapat menyebabkan terjadinya akumulasi hak akses yang semakin luas dari waktu ke waktu.

Karena itu, pengelolaan *least privilege* tidak berhenti ketika sebuah akun pertama kali dibuat. Hak akses perlu dikelola sepanjang siklus hidup akun.

***Least Privilege* Membatasi Dampak Insiden**

Salah satu manfaat penting *least privilege* adalah **membatasi dampak apabila sebuah akun berhasil disalahgunakan**.

Misalnya, terdapat dua akun pengguna. Akun pertama hanya memiliki akses terhadap fungsi yang diperlukan pekerjaannya, sedangkan akun kedua memiliki hak administrator terhadap berbagai sistem.

Apabila *credential* akun pertama dicuri, penyerang hanya dapat melakukan tindakan sesuai dengan hak yang tersedia pada akun tersebut. Sebaliknya, apabila akun kedua yang memiliki hak administratif berhasil diambil alih, potensi dampaknya dapat jauh lebih besar.

Karena itu, *least privilege* bukan hanya mekanisme untuk mengatur pengguna yang sah. Prinsip ini juga merupakan salah satu cara untuk **mengurangi ruang gerak penyerang apabila sebuah akun berhasil dikompromikan**.

NIST SP 800-53 Rev. 5 menempatkan *Least Privilege* sebagai kontrol **AC-6** dalam keluarga *Access Control*. NIST juga menempatkan kontrol akses, identifikasi dan autentikasi, serta audit dan akuntabilitas sebagai bagian dari katalog kontrol keamanan dan privasi untuk melindungi sistem dan organisasi (Joint Task Force, 2020).

***Least Privilege* dan *Need-to-Know* Harus Berjalan Bersama**

Prinsip *least privilege* yang dibahas pada bagian ini memiliki hubungan erat dengan *need-to-know* pada bagian sebelumnya.

Keduanya dapat dipahami dengan dua pertanyaan sederhana:

Least

privilege:

“Seberapa besar hak akses yang benar-benar saya perlukan?”

Need-to-know:

“Informasi apa yang benar-benar perlu saya ketahui?”

Least privilege membatasi kemampuan akun, sedangkan *need-to-know* membatasi penggunaan informasi berdasarkan kebutuhan pekerjaan.

Jika diterapkan bersama, kedua prinsip tersebut membantu memastikan bahwa pengguna tidak hanya memiliki hak akses yang sesuai, tetapi juga menggunakan hak tersebut hanya untuk informasi yang memang diperlukan.

INGAT: Jangan meminta atau menggunakan hak akses lebih tinggi hanya karena lebih mudah. **Gunakan hak akses minimum yang diperlukan untuk menyelesaikan pekerjaan. Semakin tinggi hak akses, semakin besar pula tanggung jawab dan risikonya.**

3.4 Gunakan Akses Hanya untuk Kepentingan Pekerjaan

Hak akses terhadap sistem informasi diberikan agar pengguna dapat melaksanakan tugas dan tanggung jawabnya. Oleh karena itu, setiap akses terhadap SIMRS, Rekam Medis Elektronik, *database*, server, maupun Sistem Elektronik lainnya harus digunakan **untuk kepentingan pekerjaan yang sah dan sesuai dengan kewenangan yang diberikan.**

Pengguna tidak seharusnya menggunakan hak akses untuk kepentingan pribadi, memenuhi rasa ingin tahu, membantu pihak lain yang tidak memiliki kewenangan, atau melakukan aktivitas lain yang tidak berkaitan dengan tugasnya.

Prinsip ini merupakan kelanjutan dari *need-to-know* dan *least privilege*. *Need-to-know* membatasi informasi berdasarkan kebutuhan untuk mengetahui, sedangkan *least privilege* membatasi

hak akses pada tingkat minimum yang diperlukan. Keduanya akan kehilangan efektivitas apabila pengguna menggunakan akses yang sah untuk tujuan yang tidak berkaitan dengan pekerjaannya.

NIST menjelaskan *access control* sebagai proses atau mekanisme yang berkaitan dengan pemberian atau penolakan akses terhadap objek sistem seperti jaringan, data, aplikasi, dan layanan. Dalam NIST SP 800-53 Rev. 5, pengendalian akses menjadi salah satu keluarga kontrol keamanan dan privasi yang digunakan untuk melindungi sistem dan organisasi (Joint Task Force, 2020).

Akses yang Sah Dapat Digunakan secara Tidak Semestinya

Tidak semua penyalahgunaan data dimulai dengan pencurian akun.

Seseorang dapat menggunakan *username* dan *password* miliknya sendiri, berhasil melewati proses autentikasi secara sah, dan memiliki hak akses yang diberikan organisasi. Namun, aktivitas yang dilakukan setelah masuk ke dalam sistem tetap dapat menjadi tidak semestinya apabila akses tersebut digunakan untuk tujuan di luar pekerjaan.

Sebagai contoh, seorang pegawai mengetahui bahwa teman, kerabat, tetangga, pejabat, tokoh masyarakat, atau orang yang dikenalnya sedang mendapatkan pelayanan di rumah sakit. Pegawai tersebut kemudian menggunakan akun miliknya untuk mencari nama orang tersebut di dalam sistem karena ingin mengetahui informasi lebih lanjut.

Dalam situasi tersebut, tidak terjadi pembobolan akun. Pengguna juga tidak mencuri *password* milik orang lain. Namun, akses dilakukan **bukan karena kebutuhan pekerjaan**.

Contoh tersebut menunjukkan bahwa keamanan informasi tidak cukup hanya memastikan bahwa orang yang masuk ke dalam sistem adalah pengguna yang sah. Organisasi juga perlu memastikan bahwa hak akses **digunakan sesuai dengan tujuan pemberiannya**.

Jangan Mengakses Data karena Rasa Ingin Tahu

Rasa ingin tahu bukan merupakan dasar untuk mengakses data pasien.

Informasi mengenai seseorang mungkin menarik perhatian karena pasien merupakan orang yang dikenal, rekan kerja, pejabat, tokoh masyarakat, atau seseorang yang sedang menjadi perhatian publik. Namun, keadaan tersebut tidak memberikan alasan bagi pengguna untuk mencari atau membuka data apabila informasi tersebut tidak diperlukan dalam pekerjaannya.

Prinsipnya sederhana:

Kenal dengan pasien bukan berarti boleh melihat datanya.

Bekerja di rumah sakit bukan berarti boleh mencari semua pasien.

Memiliki akun bukan berarti boleh menggunakan akses untuk memenuhi rasa ingin tahu.

Ketika data tidak diperlukan untuk melaksanakan pekerjaan, pengguna tidak seharusnya mengaksesnya.

Jangan Menggunakan Akses untuk Membantu Orang Lain Melewati Pembatasan

Penyalahgunaan akses juga dapat terjadi ketika pengguna bermaksud membantu rekan kerja.

Sebagai contoh, seorang rekan tidak dapat membuka suatu data kemudian meminta pengguna lain:

“Tolong bukakan, akun saya tidak bisa.”

Permintaan tersebut perlu diperhatikan dengan hati-hati. Ketidakmampuan sebuah akun untuk mengakses suatu informasi dapat disebabkan oleh pembatasan hak akses yang memang diterapkan pada akun tersebut.

Menggunakan akun yang memiliki kewenangan lebih tinggi untuk melewati pembatasan tersebut dapat merusak tujuan dari kontrol akses.

Apabila rekan kerja memang membutuhkan akses tambahan untuk menjalankan pekerjaannya, solusi yang tepat adalah menggunakan mekanisme permohonan atau perubahan hak akses yang berlaku, bukan memanfaatkan akun pengguna lain.

Hal yang sama berlaku bagi administrator. Hak administratif tidak seharusnya digunakan untuk membuka akses bagi seseorang hanya

karena cara tersebut lebih cepat daripada mengikuti prosedur pemberian akses.

Hak Administrator Tetap Digunakan untuk Kepentingan Pekerjaan

Administrator sistem, administrator *database*, pengelola jaringan, pengelola aplikasi, dan personel teknologi informasi dapat memiliki akses yang lebih luas dibandingkan pengguna biasa.

NIST menggunakan istilah *privileged user* untuk pengguna yang memiliki kewenangan melakukan fungsi yang berkaitan dengan keamanan yang tidak diberikan kepada pengguna biasa. Dengan kewenangan yang lebih tinggi tersebut muncul tanggung jawab yang lebih besar dalam penggunaan akses (Joint Task Force, 2020).

Administrator mungkin secara teknis dapat melihat *database*, mengakses server, mengubah konfigurasi, membuat akun, mengatur hak akses, atau melihat berbagai komponen sistem. Namun, kemampuan teknis tersebut harus digunakan untuk menjalankan fungsi administratif yang menjadi tanggung jawabnya.

Sebagai contoh, akses terhadap *database* untuk melakukan *troubleshooting* merupakan penggunaan yang berkaitan dengan pekerjaan apabila memang diperlukan untuk menyelesaikan gangguan. Sebaliknya, menjalankan *query* terhadap data pasien tertentu hanya karena rasa ingin tahu tidak berkaitan dengan tujuan pemberian hak administratif.

Dengan demikian, **hak administrator adalah alat untuk menjalankan pekerjaan, bukan fasilitas untuk memperoleh akses tanpa batas terhadap informasi.**

Pihak Ketiga Juga Harus Menggunakan Akses Sesuai Tujuan

Prinsip yang sama berlaku bagi vendor, teknisi, konsultan, pengembang aplikasi, dan pihak ketiga lainnya.

Akses pihak ketiga biasanya diberikan untuk tujuan tertentu, misalnya instalasi, pemeliharaan, pengembangan, *troubleshooting*, atau dukungan teknis.

Jika vendor diberikan akses untuk memperbaiki suatu aplikasi, akses tersebut harus digunakan untuk pekerjaan tersebut. Vendor

tidak seharusnya menggunakan kesempatan tersebut untuk melihat data lain, menyalin *database*, mengambil *screenshot*, atau menyimpan informasi yang tidak diperlukan untuk menyelesaikan pekerjaan.

Akses yang diberikan untuk satu pekerjaan juga tidak otomatis dapat digunakan untuk pekerjaan lain tanpa kewenangan yang sesuai.

Prinsip *least privilege* mendukung pembatasan tersebut dengan memberikan sumber daya dan otorisasi sistem minimum yang diperlukan untuk menjalankan fungsi yang ditugaskan (Joint Task Force, 2020).

Jangan Menggunakan Data untuk Pengujian tanpa Mempertimbangkan Kebutuhannya

Penggunaan data untuk kepentingan teknis juga perlu memperhatikan tujuan akses.

Dalam pengembangan atau *troubleshooting* aplikasi, terkadang terdapat keinginan untuk menyalin *database* produksi ke lingkungan pengembangan atau komputer pengembang karena dianggap sebagai cara paling mudah untuk mereproduksi permasalahan.

Namun, kemudahan teknis bukan satu-satunya pertimbangan.

Jika pengujian dapat dilakukan menggunakan **data contoh, data sintesis, atau data yang telah disamarkan**, penggunaan data pasien sebenarnya dapat dikurangi atau dihindari.

Hal yang sama berlaku ketika membuat dokumentasi teknis, materi presentasi, laporan kesalahan, atau bukti *troubleshooting*. Data pasien yang tidak diperlukan sebaiknya tidak ikut dimasukkan hanya karena kebetulan tersedia pada sistem.

Setiap Aktivitas Menggunakan Akun Harus Dapat Dipertanggungjawabkan

Penggunaan akses untuk kepentingan pekerjaan juga berkaitan dengan akuntabilitas.

NIST SP 800-53 Rev. 5 menempatkan **Audit and Accountability** sebagai salah satu keluarga kontrol keamanan dan privasi,

berdampingan dengan *Access Control* serta *Identification and Authentication* (Joint Task Force, 2020).

Dalam penerapannya, sistem dapat mencatat aktivitas seperti *login*, perubahan data, penggunaan fungsi tertentu, atau aktivitas administratif melalui mekanisme *logging* dan *audit trail*.

Karena itu, pengguna sebaiknya menggunakan sistem dengan prinsip:

Setiap aktivitas yang dilakukan menggunakan akun saya harus dapat saya jelaskan sebagai bagian dari pekerjaan saya.

Prinsip tersebut juga menjadi salah satu alasan mengapa akun tidak boleh digunakan secara bersama-sama. Apabila beberapa orang menggunakan akun yang sama, aktivitas yang tercatat atas nama akun tersebut menjadi lebih sulit dikaitkan dengan pengguna yang sebenarnya.

Gunakan Pertanyaan Sederhana Sebelum Mengakses Data

Sebelum mencari, membuka, mengunduh, mengubah, menyalin, atau menggunakan data pasien, pengguna dapat membiasakan diri mengajukan tiga pertanyaan:

Apakah tindakan ini berkaitan dengan pekerjaan saya?

Apakah saya berwenang melakukan tindakan ini?

Apakah saya dapat menjelaskan alasan akses ini apabila aktivitasnya diperiksa melalui audit trail?

Jika ketiga pertanyaan tersebut dapat dijawab dengan jelas, akses memiliki dasar yang lebih mudah dipertanggungjawabkan.

Sebaliknya, apabila alasan utamanya adalah rasa ingin tahu, permintaan informal, kemudahan, atau keinginan untuk melewati pembatasan sistem, pengguna sebaiknya tidak melanjutkan aktivitas tersebut.

Hak akses pada akhirnya merupakan **kepercayaan yang diberikan organisasi kepada pengguna untuk menjalankan tugas tertentu**. Kepercayaan tersebut harus dijaga dengan menggunakan sistem dan data hanya sesuai dengan tujuan pemberian akses.

INGAT: Akun yang sah tidak membuat semua aktivitas menjadi sah.

Gunakan akses hanya untuk kepentingan pekerjaan, sesuai

kewenangan, dan untuk tujuan yang dapat dipertanggungjawabkan.

3.5 Dilarang Mengakses Data karena Rasa Ingin Tahu

Salah satu bentuk penyalahgunaan hak akses yang perlu mendapatkan perhatian adalah mengakses data pasien karena **rasa ingin tahu**. Pengguna dapat memiliki akun yang sah dan secara teknis mampu membuka suatu data, tetapi kemampuan tersebut tidak berarti bahwa data boleh diakses tanpa kebutuhan pekerjaan.

Prinsip ini sangat penting karena penyalahgunaan akses tidak selalu dilakukan dengan tujuan mencuri, mengubah, atau menyebarkan data. Seseorang dapat membuka informasi hanya karena penasaran terhadap pasien tertentu. Walaupun tidak ada niat untuk menyebarkan informasi, tindakan tersebut tetap merupakan penggunaan akses yang tidak sesuai dengan tujuan pemberiannya.

Dalam konteks keamanan informasi, kondisi ini sering disebut sebagai **snooping**, yaitu melihat informasi yang sebenarnya tidak diperlukan oleh seseorang dalam menjalankan pekerjaannya. Panduan NHS England mengenai akses terhadap data pasien secara khusus menyebut bahwa rasa ingin tahu pribadi maupun profesional bukan alasan yang sah untuk mengakses data pasien.

Rasa Ingin Tahu Bukan Kebutuhan Pekerjaan

Situasi yang dapat memunculkan rasa ingin tahu sangat beragam.

Seorang pegawai mungkin mengetahui bahwa teman, tetangga, kerabat, rekan kerja, pejabat, tokoh masyarakat, atau seseorang yang dikenal sedang mendapatkan pelayanan di rumah sakit. Informasi tersebut kemudian menimbulkan keinginan untuk mencari nama pasien melalui SIMRS atau sistem lainnya.

Pengguna mungkin berpikir:

“Saya cuma ingin tahu.”

“Saya hanya melihat sebentar.”

“Saya tidak akan memberitahukan kepada siapa pun.”

“Saya kenal orangnya.”

“Saya hanya memastikan apakah benar dia ada di rumah sakit.”

Alasan-alasan tersebut tidak mengubah prinsip dasarnya. Apabila informasi tidak diperlukan untuk menjalankan pekerjaan, **data tersebut tidak seharusnya diakses.**

Panduan Information Commissioner's Office (ICO) pada 2026 menekankan perbedaan yang sangat penting: memiliki kemampuan untuk melihat suatu rekam bukan berarti memiliki kebutuhan yang sah untuk melihatnya. ICO juga memperingatkan bahwa perhatian publik terhadap suatu kejadian dapat meningkatkan godaan bagi pegawai untuk membuka rekam seseorang yang sebenarnya tidak perlu mereka lihat.

Pasien yang Dikenal Tetap Harus Dilindungi

Hubungan pribadi dengan pasien tidak memberikan kewenangan tambahan terhadap data.

Apabila teman atau anggota keluarga sedang memperoleh pelayanan di rumah sakit, pegawai tidak seharusnya menggunakan akses internal untuk mencari informasi mengenai orang tersebut apabila hal itu bukan bagian dari pekerjaannya.

Prinsip yang sama berlaku terhadap data rekan kerja. Fakta bahwa pasien merupakan sesama pegawai tidak berarti data tersebut boleh dilihat oleh rekan kerjanya.

NHS England bahkan memasukkan akses terhadap data teman, keluarga, kolega, serta individu yang menjadi perhatian media sebagai contoh situasi yang dapat melibatkan akses karena rasa ingin tahu.

Dengan demikian:

Hubungan keluarga bukan hak akses.

Pertemanan bukan hak akses.

Hubungan kerja bukan hak akses.

Rasa penasaran bukan hak akses.

Hak akses tetap ditentukan berdasarkan **kewenangan dan kebutuhan pekerjaan.**

Tokoh Publik dan Peristiwa yang Menjadi Perhatian Masyarakat

Risiko akses karena rasa ingin tahu dapat meningkat ketika pasien merupakan seseorang yang dikenal masyarakat atau berkaitan dengan suatu peristiwa yang sedang menjadi perhatian.

Berita mengenai kecelakaan, peristiwa tertentu, tokoh masyarakat, pejabat, atau kejadian yang ramai diperbincangkan dapat membuat seseorang tergoda mencari informasi melalui sistem internal.

Justru dalam situasi seperti ini pengguna perlu lebih berhati-hati.

Informasi yang menjadi perhatian masyarakat tidak otomatis menjadi informasi yang boleh dilihat melalui sistem internal rumah sakit. Informasi yang tersedia di media sosial atau pemberitaan juga tidak memberikan kewenangan kepada pegawai untuk mencari informasi tambahan melalui SIMRS.

Panduan NHS England mengenai pemantauan akses bahkan mengidentifikasi individu yang menjadi perhatian media lokal atau nasional sebagai kelompok yang dapat memiliki risiko lebih tinggi terhadap akses tidak sah akibat rasa ingin tahu.

“Hanya Melihat” Tetap Merupakan Akses

Kesalahpahaman lain yang perlu dihindari adalah anggapan bahwa tidak terjadi masalah selama pengguna hanya melihat data tanpa mengubah, mengunduh, mencetak, atau membagikannya.

Dalam keamanan informasi, **membaca atau melihat informasi merupakan bentuk akses terhadap informasi.**

Karena itu, tindakan berikut tetap perlu memiliki dasar kewenangan dan kebutuhan pekerjaan:

- mencari nama pasien;
- membuka profil pasien;
- melihat informasi pada Rekam Medis Elektronik;
- membuka dokumen atau berkas pasien;
- menjalankan *query* terhadap data pasien;
- membuka informasi melalui akun administratif;
- atau melihat data melalui sistem lain yang terhubung.

Fakta bahwa pengguna tidak mengubah atau menyebarkan data tidak dengan sendirinya membuat akses tersebut dapat dibenarkan.

Administrator Juga Tidak Boleh “Sekadar Mengecek”

Prinsip ini berlaku pula bagi administrator sistem, administrator *database*, pengelola aplikasi, dan personel teknologi informasi.

Administrator dapat memiliki kemampuan teknis yang memungkinkan akses lebih luas dibandingkan pengguna biasa. Namun, seperti telah dibahas pada prinsip *least privilege* dan *need-to-know*, kemampuan teknis bukan merupakan kewenangan tanpa batas.

Administrator tidak seharusnya menjalankan *query* terhadap data seseorang hanya karena penasaran. Demikian pula, kemampuan untuk membuka *database*, membaca tabel, atau menggunakan akun administratif tidak boleh digunakan untuk mencari informasi yang tidak berkaitan dengan pekerjaan.

Hak administratif merupakan tanggung jawab, bukan fasilitas untuk melihat lebih banyak data.

Vendor dan Pihak Ketiga Juga Terikat Prinsip yang Sama

Vendor dapat memperoleh akses ke aplikasi, server, atau *database* ketika melakukan *troubleshooting* dan pemeliharaan.

Selama proses tersebut, vendor mungkin secara teknis dapat melihat berbagai informasi yang terdapat di dalam sistem. Namun, pihak ketiga tetap harus membatasi penggunaan akses pada pekerjaan yang sedang dilakukan.

Jika vendor sedang memperbaiki modul tertentu, tidak ada kebutuhan untuk menjelajahi data pasien yang tidak berkaitan dengan permasalahan tersebut.

Prinsip *need-to-know* tetap berlaku: **lihat hanya informasi yang memang diperlukan untuk menyelesaikan pekerjaan.**

Aktivitas pada Sistem Dapat Dicatat

Pengguna juga perlu memahami bahwa aktivitas pada Sistem Elektronik dapat dicatat melalui mekanisme *logging* dan *audit trail*.

NIST SP 800-53 Rev. 5 menempatkan **Audit and Accountability** sebagai salah satu keluarga kontrol keamanan. Kontrol audit

digunakan antara lain untuk menghasilkan, melindungi, meninjau, dan menganalisis catatan aktivitas sistem sehingga dapat mendukung akuntabilitas dan investigasi terhadap aktivitas tertentu (Joint Task Force, 2020).

Dalam praktiknya, bergantung pada kemampuan sistem, catatan dapat digunakan untuk membantu mengetahui akun yang melakukan akses, waktu akses, dan aktivitas tertentu yang dilakukan melalui sistem.

Oleh karena itu, pengguna sebaiknya tidak memiliki anggapan:

“Tidak ada yang tahu kalau saya hanya melihat.”

Pendekatan yang lebih tepat adalah menganggap bahwa setiap penggunaan akun harus dapat dipertanggungjawabkan.

Sebuah pertanyaan sederhana dapat digunakan:

“Jika aktivitas ini muncul dalam audit trail dan saya diminta menjelaskan alasan mengakses data tersebut, apakah saya mempunyai alasan pekerjaan yang sah?”

Jika jawabannya tidak, data tersebut seharusnya tidak diakses.

Tidak Ada Niat Jahat Bukan Berarti Akses Dibenarkan

Seseorang yang mengakses data karena rasa ingin tahu mungkin tidak memiliki niat untuk mencuri atau menyebarkan informasi.

Namun, dari perspektif keamanan informasi, persoalannya tetap ada: **informasi telah diakses tanpa kebutuhan pekerjaan.**

Hal inilah yang membuat *security awareness* penting. Pengguna tidak hanya perlu menghindari tindakan yang secara jelas terlihat berbahaya, tetapi juga perlu memahami batas penggunaan akses yang telah diberikan kepadanya.

Panduan keamanan data pasien dari berbagai yurisdiksi juga menunjukkan bahwa *curiosity access* merupakan risiko nyata dalam pengelolaan sistem kesehatan. NHS England pada Juli 2026, misalnya, menerbitkan panduan khusus untuk mencegah akses data pasien karena alasan pribadi atau rasa ingin tahu dan mendorong organisasi melakukan pemantauan terhadap akses yang tidak semestinya.

Gunakan Tes Sederhana Sebelum Membuka Data

Sebelum melakukan pencarian atau membuka data pasien, pengguna dapat membiasakan diri bertanya:

Apakah pasien ini berkaitan dengan pekerjaan yang sedang saya lakukan?

Apakah saya membutuhkan informasi ini untuk menyelesaikan pekerjaan?

Apakah saya memiliki kewenangan untuk mengaksesnya?

Apakah saya dapat menjelaskan alasan akses ini apabila aktivitasnya diperiksa?

Jika alasannya hanya:

“Saya penasaran.”

maka tindakan yang tepat adalah **tidak membuka data tersebut**.

Kebiasaan sederhana ini membantu membangun budaya keamanan informasi. Sistem dapat menyediakan berbagai kontrol teknis untuk membatasi akses, tetapi pengguna tetap memiliki tanggung jawab untuk menggunakan akses yang telah diberikan secara benar.

INGAT: Rasa ingin tahu bukan alasan untuk mengakses data pasien. Walaupun Anda memiliki akun dan secara teknis dapat membuka data tersebut, jangan mengaksesnya apabila tidak diperlukan untuk pekerjaan. **“Hanya melihat” tetap merupakan akses.**

3.6 Risiko Penggunaan Akun Bersama

Setiap akun pada Sistem Elektronik seharusnya merepresentasikan identitas pengguna yang memperoleh kewenangan untuk menggunakan sistem tersebut. Ketika satu akun digunakan oleh beberapa orang, hubungan antara **identitas pengguna dan aktivitas yang dilakukan melalui sistem** menjadi sulit dipastikan. Kondisi ini dapat mengurangi akuntabilitas dan meningkatkan risiko keamanan informasi.

Penggunaan akun bersama sering muncul karena alasan praktis. Sebuah unit mungkin menggunakan satu akun agar seluruh pegawai

dapat mengakses aplikasi tanpa harus memiliki akun masing-masing. Dalam kondisi lain, *username* dan *password* milik seorang pegawai diberikan kepada rekan kerja karena dianggap lebih cepat daripada mengajukan hak akses baru.

Praktik seperti ini mungkin terlihat mempermudah pekerjaan, tetapi dari perspektif keamanan informasi dapat menimbulkan persoalan yang lebih besar.

NIST SP 800-53 Rev. 5 menempatkan pengelolaan akun dalam kontrol **AC-2 Account Management** serta identifikasi dan autentikasi pengguna dalam keluarga kontrol **Identification and Authentication**. Identitas pengguna diperlukan agar sistem dapat mengaitkan aktivitas dengan pengguna atau proses yang memperoleh akses (Joint Task Force, 2020).

Satu Akun Seharusnya Merepresentasikan Satu Pengguna

Dalam penggunaan akun individual, aktivitas yang dilakukan melalui sistem dapat dikaitkan dengan identitas pengguna yang memperoleh akun tersebut.

Sebagai contoh:

Akun A → Pegawai A

Akun B → Pegawai B

Akun C → Pegawai C

Ketika setiap pengguna menggunakan akunnya sendiri, mekanisme *logging* dan *audit trail* dapat memberikan informasi yang lebih berguna untuk membantu mengetahui siapa yang melakukan aktivitas tertentu.

Masalah muncul ketika pola tersebut berubah menjadi:

Akun A → Pegawai A, Pegawai B, Pegawai C, dan Pegawai D

Sistem mungkin mencatat bahwa aktivitas dilakukan oleh **Akun A**, tetapi organisasi menjadi lebih sulit menentukan siapa yang sebenarnya menggunakan akun tersebut pada saat kejadian.

Karena itu, **identitas akun dan identitas pengguna perlu dijaga keterkaitannya**.

Akun Bersama Mengurangi Akuntabilitas

Salah satu risiko utama penggunaan akun bersama adalah berkurangnya **akuntabilitas**.

NIST SP 800-53 Rev. 5 menempatkan *Audit and Accountability* sebagai keluarga kontrol tersendiri. Catatan audit digunakan untuk mendukung kemampuan organisasi menelusuri dan menganalisis aktivitas pada sistem (Joint Task Force, 2020).

Sebagai contoh, *audit trail* menunjukkan bahwa sebuah akun mengakses data tertentu pada pukul 10.15.

Jika akun tersebut hanya digunakan oleh satu pengguna, organisasi memiliki dasar yang lebih kuat untuk melakukan penelusuran terhadap aktivitas tersebut.

Namun, jika *password* akun diketahui oleh sepuluh orang, pertanyaan berikutnya menjadi lebih sulit dijawab:

Siapa yang sebenarnya menggunakan akun tersebut pada pukul 10.15?

Kondisi ini dapat mempersulit pemeriksaan ketika terjadi akses yang tidak semestinya, perubahan data, penghapusan informasi, maupun insiden keamanan lainnya.

Jangan Memberikan *Credential* kepada Rekan Kerja

Akun bersama tidak selalu dibuat secara resmi. Dalam banyak kasus, sebuah akun berubah menjadi akun bersama karena pemiliknya memberikan *credential* kepada orang lain.

Misalnya:

“Pakai akun saya saja.”

“Password-nya ini, nanti login sendiri.”

“Kalau saya tidak ada, gunakan akun saya.”

“Akun vendor belum dibuat, sementara pakai akun saya dulu.”

Praktik tersebut harus dihindari.

Peraturan Pemerintah Nomor 71 Tahun 2019 tentang Penyelenggaraan Sistem dan Transaksi Elektronik memberikan contoh edukasi kepada pengguna mengenai pentingnya menjaga keamanan PIN dan *password*. Penjelasan regulasi tersebut menyebut pentingnya merahasiakan dan tidak memberitahukan PIN

dan *password* kepada siapa pun, termasuk kepada petugas Penyelenggara Sistem Elektronik (Republik Indonesia, 2019).

Dengan demikian, *password* bukan sesuatu yang boleh diberikan kepada orang lain hanya karena orang tersebut merupakan rekan kerja, administrator, atasan, teknisi, atau vendor.

Jika seseorang memang membutuhkan akses, berikan akses kepada identitas orang tersebut melalui mekanisme yang berlaku, bukan dengan memberikan *credential* milik pengguna lain.

Akun Bersama Memperluas Dampak Kebocoran *Password*

Penggunaan akun bersama juga meningkatkan jumlah orang yang mengetahui *password*.

Semakin banyak orang mengetahui sebuah *password*, semakin sulit memastikan bagaimana *password* tersebut disimpan dan digunakan.

Seseorang dapat menuliskannya pada kertas. Orang lain dapat menyimpannya pada aplikasi pesan. Pengguna lainnya mungkin menyimpan *password* tersebut pada komputer atau mengirimkannya kepada pegawai baru.

Pada akhirnya, organisasi dapat kehilangan kendali terhadap pertanyaan sederhana:

Siapa saja yang mengetahui *password* akun ini?

Risiko tersebut semakin besar apabila akun memiliki hak akses yang luas.

Jika akun bersama merupakan akun administrator, kebocoran satu *password* dapat memberikan akses administratif kepada banyak pihak yang seharusnya tidak memiliki kewenangan tersebut.

Pergantian Pegawai Menjadi Lebih Sulit Dikelola

Akun individual memungkinkan organisasi melakukan pengelolaan akses berdasarkan siklus hidup pengguna.

Ketika seorang pegawai pindah unit, hak aksesnya dapat disesuaikan. Ketika hubungan kerja berakhir, akun dapat dinonaktifkan. Ketika vendor selesai melakukan pekerjaan, aksesnya dapat dicabut.

Pada akun bersama, pengelolaan tersebut menjadi lebih sulit.

Sebagai contoh, lima orang mengetahui *password* sebuah akun. Salah seorang kemudian tidak lagi bekerja pada unit tersebut. Apabila *password* tidak segera diganti, orang tersebut mungkin masih mengetahui *credential* yang digunakan oleh pengguna lainnya.

Sebaliknya, dengan akun individual, organisasi dapat menonaktifkan akun pengguna tersebut tanpa harus mengubah *credential* pengguna lainnya.

Jangan Gunakan Akun Administrator secara Bersama-sama

Risiko penggunaan akun bersama menjadi lebih tinggi pada akun yang memiliki hak istimewa atau ***privileged account***.

Akun administrator dapat memiliki kemampuan untuk mengubah konfigurasi, membuat akun, mengatur hak akses, mengakses server, melakukan instalasi, atau menjalankan fungsi penting lainnya.

Karena itu, akun administratif sebaiknya dapat dikaitkan dengan identitas administrator yang menggunakannya.

Contohnya, dibandingkan beberapa administrator menggunakan satu akun bersama seperti:

administrator

lebih baik setiap administrator menggunakan identitas yang dapat dibedakan sesuai mekanisme pengelolaan akses yang diterapkan organisasi.

Dengan demikian, aktivitas administratif dapat lebih mudah dikaitkan dengan pengguna yang menjalankannya.

Prinsip ini juga mendukung *least privilege*. Tidak semua personel teknologi informasi harus memperoleh hak administrator hanya karena bekerja pada unit teknologi informasi. Hak istimewa diberikan berdasarkan fungsi yang memang memerlukannya.

Vendor Harus Memiliki Identitas Akses yang Jelas

Prinsip yang sama berlaku terhadap vendor dan pihak ketiga.

Ketika vendor membutuhkan akses untuk melakukan *troubleshooting*, solusi yang sebaiknya dihindari adalah memberikan *username* dan *password* milik pegawai atau administrator internal.

Akses pihak ketiga sebaiknya dapat dibedakan dari akses pengguna internal dan diberikan sesuai kebutuhan pekerjaan.

Hal tersebut memberikan beberapa manfaat. Organisasi dapat mengetahui bahwa aktivitas berasal dari akses pihak ketiga, membatasi kewenangan yang diberikan, serta mencabut akses ketika pekerjaan selesai.

Sebaliknya, apabila vendor menggunakan akun milik administrator internal, *audit trail* dapat mencatat aktivitas sebagai aktivitas administrator tersebut meskipun tindakan sebenarnya dilakukan oleh vendor.

Jangan Berbagi Akun karena Keadaan Mendesak

Keadaan mendesak sering menjadi alasan untuk berbagi akun.

“Pekerjaan harus segera selesai.”

“Pegawainya sedang tidak masuk.”

“Akun belum dibuat.”

“Vendor harus segera memperbaiki sistem.”

Kebutuhan operasional memang dapat membutuhkan penyelesaian yang cepat, tetapi penggunaan akun milik orang lain menciptakan risiko baru.

Apabila organisasi membutuhkan mekanisme akses dalam kondisi tertentu, mekanisme tersebut sebaiknya dirancang dan ditetapkan sebelumnya sehingga kebutuhan operasional tidak harus diselesaikan dengan membagikan *credential*.

Pembatasan akses merupakan bagian dari kontrol keamanan. **Keadaan mendesak tidak seharusnya secara otomatis menjadi alasan untuk menghilangkan identitas dan akuntabilitas pengguna.**

Akun Individual Mendukung *Audit Trail*

Penggunaan akun individual menjadi semakin penting ketika organisasi menerapkan *logging* dan *audit trail*.

Misalnya, catatan sistem menunjukkan:

User: pegawai.i.a

Action: melihat data

Time: 09.15

Informasi tersebut memiliki nilai akuntabilitas apabila pegawai . a memang hanya digunakan oleh Pegawai A.

Namun, apabila *password* pegawai . a diketahui oleh beberapa orang, catatan tersebut tidak lagi memberikan kepastian yang sama mengenai siapa yang sebenarnya melakukan aktivitas.

Oleh karena itu, efektivitas *audit trail* tidak hanya bergantung pada kemampuan sistem mencatat aktivitas. Efektivitasnya juga bergantung pada **kualitas identitas pengguna yang berada di balik aktivitas tersebut.**

Setiap Pengguna Bertanggung Jawab atas *Credential*-nya

Akun merupakan identitas pengguna dalam Sistem Elektronik. Karena itu, pengguna bertanggung jawab menjaga informasi autentikasi yang digunakan untuk membuktikan identitas tersebut.

Prinsip yang harus dibangun adalah:

Satu pengguna, satu identitas akses.

Gunakan akun sendiri.

Jangan meminjam akun orang lain.

Jangan meminjamkan akun kepada orang lain.

Jangan memberikan password kepada rekan kerja, administrator, teknisi, atau vendor.

Apabila seseorang membutuhkan akses yang belum dimilikinya, kebutuhan tersebut harus diselesaikan melalui mekanisme pemberian hak akses, bukan dengan berbagi akun.

INGAT: Akun adalah identitas Anda di dalam sistem. Jangan meminjamkan akun dan jangan memberikan *password* kepada siapa pun. Akun bersama mengurangi akuntabilitas, memperluas risiko kebocoran *credential*, dan menyulitkan penelusuran ketika terjadi insiden.

3.7 Logging dan Audit Trail

Pembatasan hak akses merupakan bagian penting dalam keamanan informasi, tetapi organisasi juga perlu memiliki kemampuan untuk mengetahui **aktivitas yang terjadi di dalam**

Sistem Elektronik. Salah satu mekanisme yang digunakan untuk mendukung kebutuhan tersebut adalah **logging dan audit trail**.

Logging merupakan proses pencatatan kejadian atau aktivitas yang terjadi pada sistem. Catatan tersebut dapat digunakan untuk membantu mengetahui kapan suatu aktivitas terjadi, akun yang terlibat, sumber aktivitas, serta hasil dari aktivitas tersebut.

Sementara itu, NIST menjelaskan *audit trail* sebagai catatan kronologis aktivitas sistem yang memungkinkan rekonstruksi dan pemeriksaan urutan kejadian yang berkaitan dengan suatu operasi atau peristiwa keamanan (National Institute of Standards and Technology, n.d.).

Dalam lingkungan rumah sakit, *logging* dan *audit trail* memiliki peran penting karena Sistem Elektronik dapat digunakan oleh banyak pengguna dengan kewenangan yang berbeda. Ketika terjadi aktivitas yang tidak semestinya, catatan aktivitas dapat membantu proses penelusuran dan analisis.

Audit Trail Membantu Menjawab “Siapa Melakukan Apa?”

Sebuah *audit trail* yang baik dapat membantu memberikan konteks terhadap aktivitas yang terjadi di dalam sistem.

NIST SP 800-53 Rev. 5 melalui kontrol **AU-3 Content of Audit Records** menjelaskan bahwa catatan audit perlu memuat informasi yang memungkinkan organisasi mengetahui jenis kejadian, waktu kejadian, lokasi kejadian, sumber kejadian, hasil kejadian, serta identitas individu atau entitas yang berkaitan dengan kejadian tersebut (Joint Task Force, 2020).

Secara sederhana, *audit trail* dapat membantu menjawab pertanyaan:

Siapa yang melakukan aktivitas?

Apa yang dilakukan?

Kapan aktivitas terjadi?

Dari mana aktivitas berasal?

Apa hasil dari aktivitas tersebut?

Informasi tersebut dapat menjadi penting ketika organisasi perlu memeriksa suatu kejadian.

Sebagai contoh, apabila terdapat dugaan bahwa data pasien tertentu telah diakses secara tidak semestinya, *audit trail* dapat membantu proses pemeriksaan untuk mengetahui akun yang tercatat melakukan aktivitas dan waktu terjadinya aktivitas tersebut.

Namun, kemampuan tersebut bergantung pada fitur dan konfigurasi sistem. Tidak semua aplikasi mencatat jenis aktivitas dan tingkat detail yang sama.

Logging Mendukung Akuntabilitas

Logging memiliki hubungan yang erat dengan **akuntabilitas pengguna**.

Ketika setiap pengguna memiliki akun individual, aktivitas yang dicatat oleh sistem dapat dikaitkan dengan identitas akun yang digunakan. Hal tersebut membantu organisasi melakukan penelusuran ketika terjadi insiden atau aktivitas yang tidak biasa.

Sebaliknya, seperti dibahas pada bagian sebelumnya, penggunaan akun bersama dapat mengurangi nilai *audit trail*.

Misalnya, sistem mencatat:

User: pegawai.a

Action: membuka data pasien

Time: 10.35

Apabila akun pegawai.a hanya digunakan oleh pemiliknya, catatan tersebut memiliki konteks identitas yang lebih jelas.

Namun, apabila *password* akun tersebut diketahui dan digunakan oleh beberapa orang, sistem mungkin tetap mencatat pegawai.a, tetapi menjadi lebih sulit menentukan siapa yang sebenarnya berada di balik aktivitas tersebut.

Karena itu, **logging yang baik harus didukung dengan pengelolaan identitas dan akun yang baik**.

Aktivitas yang Dicatat Bergantung pada Sistem

Tidak semua aktivitas harus dicatat dengan cara dan tingkat detail yang sama. Organisasi perlu menentukan kejadian yang relevan untuk dicatat berdasarkan kebutuhan keamanan, risiko, kemampuan sistem, dan ketentuan yang berlaku.

NIST SP 800-53 Rev. 5 pada kontrol **AU-2 Event Logging** mengarahkan organisasi untuk menentukan jenis kejadian yang mampu dicatat oleh sistem, memilih kejadian yang perlu dicatat, serta meninjau dan memperbarui jenis kejadian tersebut. Pemilihan *event* juga perlu memadai untuk mendukung investigasi setelah suatu insiden terjadi.

Bergantung pada kemampuan aplikasi dan kebutuhan organisasi, contoh aktivitas yang dapat menjadi relevan untuk dicatat antara lain:

- keberhasilan atau kegagalan *login*;
- perubahan hak akses;
- pembuatan atau penonaktifan akun;
- penggunaan fungsi administratif;
- perubahan konfigurasi tertentu;
- akses atau perubahan terhadap informasi tertentu;
- kegiatan ekspor atau pengunduhan data tertentu;
- serta kejadian keamanan lainnya.

Daftar tersebut merupakan **contoh teknis**, bukan ketentuan bahwa setiap sistem harus mencatat seluruh aktivitas dengan cara yang sama.

Administrator Juga Harus Tercatat

Logging tidak hanya penting bagi aktivitas pengguna biasa.

Administrator sistem, administrator *database*, pengelola aplikasi, dan pengguna dengan hak istimewa memiliki kemampuan yang lebih luas sehingga aktivitas administratif juga perlu mendapatkan perhatian.

NIST SP 800-53 Rev. 5 memasukkan penggunaan fungsi istimewa (*privileged functions*) dalam rangkaian kontrol keamanan terkait *least privilege* dan audit. Tujuannya adalah agar penggunaan kewenangan tinggi tetap dapat dikendalikan dan dipertanggungjawabkan (Joint Task Force, 2020).

Karena itu, hak administrator seharusnya tidak dianggap sebagai akses yang berada di luar mekanisme pencatatan.

Justru karena memiliki kewenangan lebih tinggi, aktivitas administratif dapat memiliki dampak yang lebih besar terhadap sistem dan informasi.

Audit Trail Bukan Sekadar Mengumpulkan Log

Memiliki ribuan atau bahkan jutaan catatan *log* tidak otomatis membuat sebuah sistem menjadi aman.

Catatan tersebut perlu dapat digunakan ketika dibutuhkan.

NIST SP 800-53 Rev. 5 melalui **AU-6 Audit Record Review, Analysis, and Reporting** mengarahkan organisasi untuk melakukan peninjauan dan analisis catatan audit guna menemukan indikasi aktivitas yang tidak semestinya atau tidak biasa serta melaporkan temuan kepada pihak yang telah ditentukan (Joint Task Force, 2020).

Artinya, terdapat perbedaan antara:

“Sistem menyimpan log.”

dan

“Log digunakan untuk membantu mendeteksi dan menyelidiki aktivitas.”

Catatan yang tidak pernah diperiksa dapat memiliki nilai yang terbatas untuk mendukung keamanan.

Dalam lingkungan dengan banyak server dan aplikasi, organisasi juga dapat menggunakan mekanisme terpusat untuk mengumpulkan dan menganalisis *log*. NIST memasukkan korelasi catatan dari berbagai repositori serta kemampuan peninjauan secara terpusat sebagai pengembangan dari kontrol AU-6.

Pendekatan tersebut menjadi dasar bagi penggunaan teknologi seperti ***centralized logging*** dan ***Security Information and Event Management (SIEM)***.

Untuk buku *security awareness* ini, pembahasan tidak perlu masuk terlalu jauh ke konfigurasi teknis SIEM. Hal terpenting bagi pegawai dan pihak ketiga adalah memahami bahwa **aktivitas pada sistem dapat dicatat dan dapat digunakan dalam proses pemeriksaan keamanan.**

Log Juga Harus Dilindungi

Catatan *log* sendiri merupakan aset informasi yang perlu dilindungi.

Jika pihak yang aktivitasnya sedang dicatat dapat dengan bebas mengubah atau menghapus catatan tersebut, nilai *audit trail* dapat berkurang.

NIST SP 800-53 Rev. 5 memasukkan **AU-9 Protection of Audit Information** sebagai kontrol untuk melindungi informasi audit dan perangkat pencatatan audit dari akses, perubahan, dan penghapusan yang tidak sah. NIST juga mengatur retensi catatan melalui **AU-11 Audit Record Retention** untuk mendukung investigasi setelah kejadian dan kebutuhan retensi organisasi.

Karena itu, pengelolaan *logging* tidak hanya berbicara mengenai **apa yang dicatat**, tetapi juga bagaimana catatan tersebut disimpan dan dilindungi.

Waktu pada Sistem Harus Konsisten

Waktu merupakan bagian penting dari *audit trail*.

Bayangkan sebuah insiden melibatkan beberapa sistem. Server aplikasi menunjukkan suatu kejadian pada pukul 10.05, sedangkan *database server* mencatat aktivitas terkait pada pukul 10.12. Jika waktu pada kedua server tidak tersinkronisasi, penyusunan urutan kejadian dapat menjadi lebih sulit.

NIST SP 800-53 Rev. 5 memiliki kontrol **AU-8 Time Stamps** sebagai bagian dari keluarga *Audit and Accountability*.

Dari perspektif teknis, hal ini menunjukkan pentingnya sinkronisasi waktu pada server, perangkat jaringan, aplikasi, dan komponen lain yang menghasilkan *log*.

Dengan waktu yang konsisten, catatan dari berbagai sistem dapat lebih mudah dikorelasikan ketika dilakukan analisis insiden.

Jangan Beranggapan Aktivitas Tidak Diketahui

Bagi pengguna, pemahaman mengenai *logging* dan *audit trail* membentuk satu kebiasaan penting: **setiap aktivitas yang dilakukan menggunakan akun harus dapat dipertanggungjawabkan.**

Pengguna tidak seharusnya beranggapan:

“Saya hanya melihat sebentar.”

“Tidak ada yang akan tahu.”

“Saya tidak mengubah data.”

“Saya hanya menjalankan satu query.”

Bergantung pada kemampuan dan konfigurasi sistem, aktivitas tertentu dapat meninggalkan catatan.

Namun, alasan utama untuk tidak melakukan akses yang tidak sah bukan semata-mata karena takut aktivitas akan tercatat. Pengguna memang harus menggunakan akses hanya sesuai dengan kewenangan dan kebutuhan pekerjaan.

Audit trail berfungsi sebagai salah satu kontrol yang membantu organisasi membangun **akuntabilitas, deteksi, dan kemampuan investigasi**.

***Audit Trail* Membantu Investigasi Insiden**

Ketika terjadi insiden keamanan, salah satu kebutuhan penting adalah membangun urutan kejadian.

Tim keamanan mungkin perlu mengetahui kapan sebuah akun pertama kali digunakan, sistem apa yang diakses, aktivitas apa yang dilakukan, dan kejadian lain yang berkaitan dengan insiden.

NIST secara eksplisit memasukkan dukungan terhadap investigasi setelah kejadian sebagai salah satu pertimbangan dalam pemilihan *event* yang dicatat. Catatan audit juga perlu disimpan untuk mendukung investigasi dan kebutuhan retensi organisasi.

Karena itu, *log* dapat menjadi salah satu sumber bukti teknis ketika dilakukan analisis insiden.

Sebagai contoh, apabila sebuah akun diduga telah dikompromikan, catatan dari aplikasi, server, sistem autentikasi, *firewall*, atau komponen lain dapat membantu membangun gambaran mengenai aktivitas yang terjadi.

Semakin baik kualitas *logging*, identitas pengguna, sinkronisasi waktu, dan perlindungan catatan audit, semakin besar kemungkinan organisasi dapat merekonstruksi kejadian dengan lebih baik.

***Logging* Tidak Menggantikan Kontrol Keamanan Lain**

Walaupun penting, *logging* bukan pengganti kontrol keamanan lainnya.

Organisasi tetap membutuhkan autentikasi, pengelolaan hak akses, *least privilege*, *need-to-know*, perlindungan *credential*, pengamanan perangkat, pemantauan keamanan, serta mekanisme respons insiden.

Logging bekerja bersama kontrol tersebut.

Hak akses membantu menentukan **apa yang boleh dilakukan pengguna**.

Autentikasi membantu memastikan **identitas pengguna**.

Logging membantu mencatat **apa yang terjadi**.

Audit trail membantu **menelusuri rangkaian aktivitas**.

Ketika mekanisme tersebut diterapkan secara bersama, organisasi memiliki kemampuan yang lebih baik untuk mencegah, mendeteksi, dan menyelidiki aktivitas yang tidak semestinya.

INGAT: *Audit trail* membantu menjawab siapa melakukan apa, kapan, dan melalui sistem mana. Gunakan selalu akun Anda sendiri dan gunakan akses hanya untuk kepentingan pekerjaan. Aktivitas yang dilakukan menggunakan akun harus dapat dipertanggungjawabkan.

3.8 Akses Pegawai, Administrator, Vendor, dan Pihak Ketiga

Setiap pihak yang menggunakan Sistem Elektronik dapat memiliki kebutuhan akses yang berbeda. Pegawai menggunakan sistem untuk menjalankan tugas sehari-hari, administrator membutuhkan kewenangan tertentu untuk mengelola infrastruktur dan aplikasi, sedangkan vendor atau pihak ketiga dapat memperoleh akses untuk kegiatan seperti pemeliharaan, pengembangan, dan *troubleshooting*.

Perbedaan kebutuhan tersebut berarti bahwa **hak akses tidak seharusnya diberikan dengan tingkat kewenangan yang sama**

kepada semua pihak. Akses harus disesuaikan dengan fungsi, tanggung jawab, kebutuhan pekerjaan, dan risiko yang menyertainya.

NIST Cybersecurity Framework 2.0 pada kategori **Identity Management, Authentication, and Access Control (PR.AA)** menekankan bahwa akses terhadap aset fisik dan logis dibatasi kepada pengguna, layanan, dan perangkat yang berwenang. Pada PR.AA-05, izin dan otorisasi akses perlu didefinisikan, dikelola, diterapkan, dan ditinjau dengan memasukkan prinsip *least privilege* dan *separation of duties* (Pascoe et al., 2024).

Prinsip tersebut dapat diterapkan terhadap seluruh pengguna, tetapi bentuk penerapannya dapat berbeda sesuai dengan peran masing-masing.

Akses Pegawai

Pegawai membutuhkan akses terhadap aplikasi dan informasi untuk menjalankan tugas yang diberikan kepadanya.

Hak akses tersebut seharusnya mengikuti **fungsi pekerjaan**. Pengguna tidak perlu memperoleh akses terhadap seluruh menu, seluruh sistem, atau seluruh data apabila pekerjaannya hanya membutuhkan sebagian fungsi.

Sebagai contoh, apabila seorang pengguna hanya membutuhkan fungsi tertentu dalam SIMRS, maka hak akses dapat dibatasi pada fungsi yang diperlukan tersebut.

Prinsip *least privilege* mengarahkan agar pengguna hanya memperoleh sumber daya dan otorisasi sistem minimum yang diperlukan untuk menjalankan fungsinya.

Akses pegawai juga harus tetap mengikuti prinsip *need-to-know*. Meskipun suatu menu dapat dibuka menggunakan akun yang dimiliki, pengguna hanya seharusnya mengakses data yang memang diperlukan untuk pekerjaannya.

Dengan demikian, pemberian akses kepada pegawai tidak berarti:

boleh melihat seluruh data;

boleh menggunakan seluruh fungsi;

boleh memberikan akses tersebut kepada rekan kerja;

atau

boleh menggunakan akses untuk kepentingan di luar pekerjaan.

Akun diberikan kepada pengguna untuk menjalankan tugas tertentu dan harus digunakan sesuai dengan tujuan tersebut.

Akses Administrator

Administrator sistem, administrator *database*, administrator jaringan, pengelola aplikasi, dan personel teknologi informasi dapat membutuhkan kewenangan yang lebih tinggi dibandingkan pengguna biasa.

Kewenangan tersebut dapat mencakup kemampuan untuk mengubah konfigurasi, membuat atau mengelola akun, mengatur hak akses, memasang perangkat lunak, mengakses server, menjalankan fungsi administratif, atau melakukan aktivitas teknis lainnya.

NIST SP 800-171 Rev. 3 menjelaskan bahwa *privileged account* merupakan akun yang memperoleh hak lebih tinggi untuk mengakses sumber daya, termasuk fungsi keamanan atau informasi terkait keamanan, yang dibatasi bagi akun biasa. NIST juga merekomendasikan pembatasan akun dengan hak istimewa kepada personel atau peran tertentu yang memang membutuhkannya.

Karena memiliki kemampuan yang lebih besar, **akun administrator memiliki risiko yang lebih tinggi apabila disalahgunakan atau berhasil dikompromikan.**

Hak administrator karena itu tidak seharusnya diberikan hanya berdasarkan alasan:

“Orang ini bagian IT.”

Tidak semua personel teknologi informasi membutuhkan hak administrator pada seluruh sistem.

Administrator jaringan belum tentu membutuhkan akses administratif terhadap *database*. Pengelola aplikasi belum tentu membutuhkan hak administrator terhadap seluruh server. Administrator sebuah sistem juga belum tentu membutuhkan akses administratif terhadap sistem lainnya.

Prinsip *least privilege* tetap berlaku bagi administrator.

Pisahkan Akun Biasa dan Akun Administrator

Administrator tidak selalu membutuhkan kewenangan administratif untuk setiap aktivitas.

NIST SP 800-171 Rev. 3 secara khusus mengarahkan pengguna yang memiliki *privileged account* untuk menggunakan akun non-*privileged* ketika mengakses fungsi atau informasi yang tidak membutuhkan kewenangan istimewa. Pendekatan ini dapat membatasi risiko terhadap fungsi dan informasi yang memiliki tingkat kewenangan lebih tinggi.

Sebagai contoh, seorang administrator dapat memiliki:

akun pengguna biasa untuk aktivitas yang tidak membutuhkan kewenangan administratif;

dan

akun administrator untuk pekerjaan yang memang membutuhkan hak administratif.

Dengan pendekatan tersebut, akun dengan kewenangan tinggi tidak perlu digunakan untuk seluruh aktivitas sehari-hari.

Prinsip yang perlu dibangun adalah:

gunakan hak administrator hanya ketika pekerjaan memang membutuhkan hak administrator.

Hak administratif bukan fasilitas untuk membuat pekerjaan lebih mudah, tetapi kewenangan khusus yang membawa risiko dan tanggung jawab lebih besar.

Akses Administrator terhadap Data Pasien Tetap Memiliki Batas

Kemampuan teknis administrator untuk membuka server atau *database* tidak berarti bahwa administrator memiliki kebutuhan untuk melihat seluruh data pasien.

Sebagai contoh, administrator *database* mungkin dapat menjalankan berbagai *query*. Namun, penggunaan kemampuan tersebut tetap harus berkaitan dengan pekerjaan yang sedang dilakukan.

Apabila *troubleshooting* dapat dilakukan melalui *log*, konfigurasi, struktur *database*, atau data contoh tanpa melihat data pasien sebenarnya, maka akses terhadap data pasien dapat diminimalkan.

Dengan demikian:

akses administratif terhadap sistem tidak sama dengan kewenangan tanpa batas terhadap data.

Administrator tetap harus mengikuti prinsip *need-to-know*, *least privilege*, serta penggunaan akses hanya untuk kepentingan pekerjaan.

Akses Vendor dan Pihak Ketiga

Vendor dan pihak ketiga dapat membutuhkan akses terhadap Sistem Elektronik untuk menjalankan pekerjaan tertentu.

Contohnya adalah vendor aplikasi yang melakukan *troubleshooting*, teknisi yang melakukan pemeliharaan, konsultan yang membantu implementasi sistem, atau pengembang yang melakukan perubahan terhadap aplikasi.

Namun, keberadaan hubungan kerja atau kontrak dengan rumah sakit **tidak otomatis memberikan hak akses terhadap seluruh sistem dan data.**

Akses pihak ketiga harus mengikuti ruang lingkup pekerjaan yang diberikan.

Jika vendor hanya membutuhkan akses terhadap satu aplikasi, tidak perlu diberikan akses ke seluruh sistem.

Jika pekerjaan hanya membutuhkan satu server, tidak perlu diberikan akses ke server lainnya.

Jika pekerjaan tidak membutuhkan data pasien, data pasien tidak perlu diberikan.

Jika akses hanya diperlukan sementara, akses tidak perlu dipertahankan setelah kebutuhan tersebut berakhir.

NIST CSF 2.0 menekankan bahwa hak akses perlu ditinjau secara berkala maupun ketika seseorang berubah peran atau meninggalkan organisasi, dan hak yang tidak lagi diperlukan perlu dicabut.

Prinsip tersebut juga relevan terhadap akses pihak ketiga setelah pekerjaan atau kontrak selesai.

Jangan Memberikan Akun Pegawai kepada Vendor

Ketika vendor membutuhkan akses untuk melakukan pekerjaan, salah satu praktik yang harus dihindari adalah memberikan akun milik pegawai atau administrator kepada vendor.

Misalnya:

“Pakai akun saya saja untuk sementara.”

“Login menggunakan akun admin ini.”

“Password server-nya saya kirim lewat chat.”

Cara tersebut mungkin terlihat cepat, tetapi menghilangkan pemisahan identitas antara pengguna internal dan pihak ketiga.

Apabila vendor melakukan aktivitas menggunakan akun milik administrator internal, *log* dapat mencatat aktivitas tersebut sebagai aktivitas administrator yang akunnya digunakan.

Akibatnya, proses penelusuran menjadi lebih sulit.

Apabila vendor memang membutuhkan akses, akses sebaiknya diberikan menggunakan **identitas yang dapat dibedakan dan hak akses yang sesuai dengan pekerjaannya**.

Akses Vendor Tidak Harus Permanen

Kebutuhan vendor terhadap sistem sering kali bersifat sementara.

Sebagai contoh, vendor membutuhkan akses selama dua hari untuk melakukan *troubleshooting*. Setelah masalah selesai, kebutuhan tersebut mungkin tidak lagi ada.

Dalam kondisi tersebut, membiarkan akun vendor tetap aktif selama berbulan-bulan dapat menciptakan akses yang tidak lagi memiliki kebutuhan pekerjaan.

NIST CSF 2.0 PR.AA-05 memasukkan peninjauan hak akses dan pencabutan hak yang tidak lagi diperlukan sebagai contoh implementasi pengelolaan otorisasi akses.

Karena itu, akses pihak ketiga perlu memiliki **siklus hidup**:

diberikan ketika diperlukan;

digunakan sesuai tujuan;

ditinjau selama masih diperlukan;

dan

91

dicabut ketika kebutuhan berakhir.

Remote Access Pihak Ketiga Juga Merupakan Akses

Vendor dapat melakukan pekerjaan tanpa berada secara fisik di lingkungan rumah sakit. Pemeliharaan dapat dilakukan melalui VPN, *remote desktop*, SSH, aplikasi *remote support*, atau mekanisme akses jarak jauh lainnya.

Dari perspektif keamanan informasi, **remote access tetap merupakan akses terhadap sistem organisasi.**

Karena itu, akses jarak jauh tidak seharusnya diperlakukan sebagai jalur khusus yang berada di luar mekanisme pengendalian akses.

Identitas pengguna tetap perlu diketahui, hak akses tetap perlu dibatasi, dan akses hanya digunakan selama diperlukan.

NIST CSF 2.0 menghubungkan pengelolaan izin dan otorisasi akses dengan berbagai kontrol NIST SP 800-53 Rev. 5, termasuk **AC-17 Remote Access**.

Jangan Membuka Akses “Untuk Jaga-jaga”

Salah satu praktik yang perlu dihindari adalah mempertahankan hak akses yang sebenarnya tidak lagi diperlukan dengan alasan:

“Siapa tahu nanti dibutuhkan.”

Hal tersebut dapat terjadi pada akun pegawai maupun vendor.

Seorang pegawai yang telah berpindah tugas masih memiliki akses ke sistem sebelumnya. Vendor yang telah menyelesaikan pekerjaan masih memiliki akun aktif. Administrator yang tidak lagi mengelola sebuah server masih memiliki hak administratif terhadap server tersebut.

Seiring waktu, kondisi tersebut dapat menyebabkan **akumulasi hak akses**.

NIST CSF 2.0 merekomendasikan peninjauan hak akses ketika seseorang berubah peran atau meninggalkan organisasi dan pencabutan hak yang tidak lagi diperlukan.

Karena itu, hak akses bukan sesuatu yang diberikan sekali kemudian berlaku tanpa batas. Hak akses perlu mengikuti perubahan kebutuhan pekerjaan.

Setiap Jenis Akses Harus Dapat Dipertanggungjawabkan

Walaupun pegawai, administrator, dan vendor memiliki kebutuhan akses yang berbeda, terdapat prinsip yang berlaku untuk semuanya:

- akses harus diberikan kepada identitas yang jelas;**
- akses harus sesuai dengan kebutuhan pekerjaan;**
- hak yang diberikan harus dibatasi;**
- akses harus digunakan hanya untuk tujuan yang diberikan;**
- aktivitas penting perlu dapat ditelusuri;**
- dan

- akses yang tidak lagi diperlukan harus dicabut.**

Dengan prinsip tersebut, organisasi dapat mempertahankan hubungan yang jelas antara **siapa yang memperoleh akses, mengapa akses diberikan, apa yang dapat dilakukan, dan kapan akses tersebut tidak lagi diperlukan.**

Hal ini juga memperkuat penerapan *logging* dan *audit trail* yang telah dibahas sebelumnya.

Jika setiap pegawai, administrator, vendor, dan pihak ketiga menggunakan identitas aksesnya masing-masing, catatan aktivitas sistem memiliki nilai akuntabilitas yang lebih baik dibandingkan apabila beberapa pihak menggunakan akun yang sama.

Pada akhirnya, perbedaan peran tidak mengubah prinsip dasar keamanan akses. Baik pegawai, administrator, vendor, maupun pihak ketiga hanya boleh memperoleh dan menggunakan akses **sesuai kewenangan serta kebutuhan pekerjaan yang sah.**

INGAT: Bekerja di rumah sakit tidak berarti boleh mengakses semua data. Menjadi administrator tidak berarti memiliki akses tanpa batas. Menjadi vendor tidak berarti boleh menggunakan seluruh sistem. Setiap akses harus diberikan kepada pihak yang tepat, dengan hak yang diperlukan, untuk tujuan yang jelas, dan dicabut ketika tidak lagi dibutuhkan.

BAB 4 PASSWORD DAN CREDENTIAL ADALAH MILIK PRIBADI

4.1 Apa yang Dimaksud dengan Credential?

Dalam Sistem Elektronik, pengguna perlu membuktikan identitasnya sebelum memperoleh akses. Informasi atau sarana yang digunakan dalam proses tersebut dikenal sebagai **credential**.

Secara sederhana, **credential** adalah informasi atau bukti yang digunakan dalam proses autentikasi untuk membuktikan bahwa seseorang benar-benar merupakan pengguna yang berhak menggunakan suatu akun. NIST menggunakan istilah *credential* dalam konteks identitas digital sebagai objek atau struktur data yang mengikat identitas dengan autentikator tertentu (Temoshok et al., 2025).

Dalam penggunaan sehari-hari, pengguna sering menganggap *credential* hanya sebagai *username* dan *password*. Padahal, proses autentikasi dapat melibatkan beberapa jenis informasi atau autentikator, seperti:

- *username* atau identitas akun;
- *password* atau *passphrase*;
- PIN;
- kode OTP (*One-Time Password*);
- *security key* atau token autentikasi;
- sertifikat digital;
- serta faktor autentikasi lain yang digunakan untuk membuktikan identitas pengguna.

Tidak semua unsur tersebut memiliki fungsi teknis yang sama. Namun, dari sudut pandang *security awareness*, pengguna perlu memahami satu prinsip utama: **informasi autentikasi yang bersifat rahasia harus dijaga dan tidak diberikan kepada orang lain.**

Credential Mewakili Identitas Pengguna

Ketika seseorang berhasil masuk ke dalam sistem menggunakan *credential* yang benar, sistem akan menganggap aktivitas berikutnya dilakukan menggunakan identitas akun tersebut.

Sebagai contoh, apabila akun pegawai.a berhasil digunakan untuk masuk ke SIMRS, aktivitas yang tercatat pada *audit trail* dapat dikaitkan dengan akun pegawai.a.

Masalah muncul ketika pemilik akun memberikan *password*-nya kepada orang lain. Sistem mungkin tetap mengenali pengguna sebagai pegawai.a, meskipun orang yang sebenarnya berada di depan komputer adalah orang lain.

Karena itu, memberikan *credential* bukan sekadar memberikan sebuah *password*. Tindakan tersebut dapat berarti **memberikan kesempatan kepada orang lain untuk menggunakan identitas dan kewenangan yang melekat pada akun Anda.**

Credential Tidak Boleh Dipinjamkan

Dalam lingkungan kerja terkadang muncul permintaan seperti:

“Pinjam akun sebentar.”

“Kasih password-nya, saya bantu cek.”

“Saya dari IT, password-nya berapa?”

“Kirim OTP yang baru masuk.”

Permintaan seperti itu tidak seharusnya langsung dipenuhi.

PP Nomor 71 Tahun 2019 dalam penjelasannya memberikan contoh edukasi mengenai pentingnya menjaga keamanan PIN dan *password*, termasuk **merahasiakan dan tidak memberitahukannya kepada siapa pun** (Republik Indonesia, 2019).

Jika administrator, teknisi, atau vendor memang membutuhkan akses, akses tersebut seharusnya diberikan melalui mekanisme yang sesuai dengan identitas dan kewenangannya, **bukan dengan menggunakan *credential* milik pegawai lain.**

Waspada Permintaan Credential

Permintaan *credential* juga dapat menjadi bagian dari ***social engineering*** atau *phishing*. Penyerang dapat mengaku sebagai administrator, petugas teknologi informasi, vendor, atau pihak lain

untuk meyakinkan pengguna agar memberikan informasi autentikasi.

Karena itu, pengguna tidak boleh menganggap permintaan menjadi aman hanya karena orang yang meminta mengetahui nama, jabatan, unit kerja, atau informasi internal tertentu.

Jika menerima permintaan *password*, PIN, OTP, atau informasi autentikasi lain yang tidak semestinya diminta, **jangan memberikannya dan lakukan verifikasi melalui mekanisme resmi organisasi.**

Pembahasan mengenai *phishing* dan *social engineering* akan diberikan secara khusus pada bab berikutnya.

Credential dan Passphrase Tanda Tangan Elektronik

Dalam buku ini, perhatian khusus juga diberikan pada **passphrase Tanda Tangan Elektronik.**

Passphrase yang digunakan untuk mengendalikan penggunaan Tanda Tangan Elektronik tidak boleh diperlakukan seperti informasi yang dapat diberikan kepada staf, rekan kerja, administrator, atau pihak lain agar mereka melakukan penandatanganan atas nama pemiliknya.

Masalah ini lebih serius daripada sekadar berbagi *password* aplikasi karena berkaitan dengan penggunaan Tanda Tangan Elektronik dan penguasaan atas mekanisme penandatanganan.

Dasar regulasi dan larangan praktis mengenai penyerahan *passphrase* tersebut akan dibahas secara khusus pada subbab Tanda Tangan Elektronik agar tidak terjadi pengulangan.

INGAT: Credential digunakan untuk membuktikan identitas dan memperoleh akses. Jangan memberikan password, PIN, OTP, passphrase, atau rahasia autentikasi lainnya kepada orang lain. Jika orang lain membutuhkan akses, gunakan mekanisme pemberian akses yang resmi.

4.2 Username dan Password Tidak Boleh Dipinjamkan

Username dan *password* merupakan bagian dari mekanisme autentikasi yang digunakan untuk memperoleh akses ke Sistem Elektronik. Ketika sebuah akun digunakan untuk masuk ke SIMRS, email, VPN, server, atau aplikasi lainnya, sistem menganggap aktivitas tersebut dilakukan menggunakan identitas dan kewenangan yang melekat pada akun tersebut.

Karena itu, ***username* dan terutama *password* tidak boleh dipinjamkan atau diberikan kepada orang lain**, termasuk kepada rekan kerja, atasan, administrator, teknisi, vendor, maupun pihak ketiga.

PP Nomor 71 Tahun 2019 memberikan contoh edukasi kepada pengguna mengenai pentingnya menjaga keamanan PIN dan *password*, termasuk dengan **merahasiakan dan tidak memberitahukannya kepada siapa pun** (Republik Indonesia, 2019).

“Hanya Pinjam Sebentar” Tetap Berisiko

Berbagi akun sering dilakukan dengan alasan praktis:

“Pinjam akun sebentar.”

“Login pakai akun saya saja.”

“Saya sedang tidak di kantor, password-nya saya kirim.”

“Vendor butuh akses sebentar untuk mengecek aplikasi.”

Walaupun dilakukan untuk membantu pekerjaan, praktik tersebut menghilangkan kepastian mengenai **siapa yang sebenarnya menggunakan akun**.

Jika orang lain melakukan perubahan, mengunduh data, atau mengakses informasi pasien menggunakan akun tersebut, *logging* dan *audit trail* dapat mencatat aktivitas atas nama akun pemiliknya.

Dengan demikian, berbagi *password* tidak hanya meningkatkan risiko akses tidak sah, tetapi juga **mengurangi akuntabilitas pengguna**.

Administrator dan Vendor Tidak Perlu Mengetahui *Password* Pengguna

Administrator sistem atau vendor mungkin membutuhkan akses untuk melakukan *troubleshooting*. Namun, kebutuhan tersebut **bukan alasan untuk meminta *password* milik pengguna.**

Administrator seharusnya memiliki mekanisme dan kewenangan tersendiri untuk melakukan tugas administratif. Demikian pula, apabila vendor membutuhkan akses, akses dapat diberikan sesuai kebutuhan pekerjaan dan identitas pihak yang melakukan pekerjaan.

Prinsipnya:

Orang yang membutuhkan akses harus menggunakan identitas aksesnya sendiri, bukan menggunakan identitas pengguna lain.

Jika seseorang mengaku sebagai administrator, teknisi, atau vendor kemudian meminta *password* pengguna, permintaan tersebut perlu ditolak dan diverifikasi melalui mekanisme resmi.

Jangan Mengirim *Password* Melalui Percakapan

Password juga tidak boleh dibagikan melalui WhatsApp, email, SMS, grup percakapan, atau media komunikasi lainnya.

Masalahnya bukan sekadar media yang digunakan. **Informasi yang seharusnya hanya diketahui pemilik akun telah diberikan kepada pihak lain.**

Setelah *password* dikirimkan, pengguna juga kehilangan kendali terhadap salinannya. Informasi tersebut dapat tetap berada dalam riwayat percakapan, diteruskan, disalin, atau tersimpan pada perangkat lain.

Karena itu, jangan mengirimkan *password* hanya karena cara tersebut dianggap cepat atau praktis.

Jangan Menuliskan *Password* di Tempat yang Mudah Diakses

Kerahasiaan *password* juga perlu diperhatikan di lingkungan kerja.

Hindari menuliskan *password* pada *sticky note* yang ditempel di monitor, meja kerja, papan informasi, atau lokasi lain yang mudah dilihat. Jangan pula menyimpan daftar *password* dalam dokumen tanpa perlindungan yang dapat diakses oleh pengguna lain.

NIST SP 800-63B-4 memperlakukan *password* sebagai rahasia yang digunakan dalam proses autentikasi dan memberikan ketentuan mengenai perlindungan serta pengelolaan autentikator berbasis *password* (Temoshok et al., 2025).

Jika Orang Lain Membutuhkan Akses

Apabila rekan kerja, administrator, atau pihak ketiga memang membutuhkan akses terhadap suatu sistem, solusinya **bukan memberikan *username* dan *password***.

Gunakan mekanisme pemberian akses yang berlaku sehingga pengguna memperoleh identitas dan hak akses sesuai kebutuhannya.

Pendekatan tersebut mendukung prinsip ***least privilege*** sekaligus menjaga *audit trail*. Aktivitas dapat dikaitkan dengan akun yang benar dan hak akses dapat dicabut ketika tidak lagi diperlukan.

Jika *password* terlanjur diketahui atau diberikan kepada orang lain, pengguna sebaiknya **segera mengganti *password*** dan melaporkan kejadian tersebut sesuai mekanisme keamanan informasi yang berlaku.

INGAT: Jangan pernah meminjamkan akun atau memberikan *password* kepada orang lain. Rekan kerja, atasan, administrator, teknisi, dan vendor harus menggunakan akses sesuai identitas dan kewenangannya masing-masing. Jika *password* Anda diketahui orang lain, segera ganti dan laporkan sesuai prosedur.

4.3 Jangan Memberikan Password kepada Rekan Kerja

Dalam lingkungan kerja, hubungan yang sudah saling mengenal sering membuat seseorang merasa aman untuk memberikan *password* kepada rekan kerja. Alasannya dapat bermacam-macam, mulai dari membantu menyelesaikan pekerjaan, menggantikan pegawai yang sedang tidak berada di tempat, hingga mengejar penyelesaian pekerjaan dengan cepat.

Namun, **kepercayaan kepada rekan kerja tidak mengubah fungsi *password* sebagai rahasia autentikasi.** *Password* tetap tidak boleh diberikan kepada orang lain.

PP Nomor 71 Tahun 2019 memberikan contoh edukasi mengenai pentingnya menjaga keamanan PIN dan *password*, termasuk dengan merahasiakan dan tidak memberitahukannya kepada siapa pun (Republik Indonesia, 2019).

Rekan Kerja Harus Menggunakan Akunnya Sendiri

Setiap pengguna seharusnya menggunakan akun yang diberikan kepadanya. Jika seorang rekan kerja tidak memiliki akses terhadap suatu fungsi, solusinya bukan dengan menggunakan akun milik orang lain.

Hindari kebiasaan seperti:

“Pakai akun saya saja.”

“Ini password saya, nanti login sendiri.”

“Saya sedang keluar, tolong kerjakan pakai akun saya.”

“Akun kamu tidak bisa? Pakai akun saya dulu.”

Praktik tersebut membuat orang lain dapat bertindak menggunakan **identitas dan hak akses pemilik akun.**

Jika rekan kerja memang membutuhkan akses tambahan, kebutuhan tersebut seharusnya diselesaikan melalui mekanisme pemberian atau perubahan hak akses yang berlaku.

Berbagi *Password* Merusak Akuntabilitas

Penggunaan akun individual mendukung *logging* dan *audit trail*. Sistem dapat mencatat aktivitas berdasarkan akun yang digunakan.

Jika *password* diberikan kepada rekan kerja, sistem tetap dapat mencatat aktivitas sebagai milik pemegang akun meskipun aktivitas sebenarnya dilakukan oleh orang lain.

Misalnya:

User: pegawai.a

Action: mengakses data pasien

Time: 13.15

Apabila *password* pegawai.a hanya diketahui oleh pemiliknya, aktivitas tersebut lebih mudah dikaitkan dengan pengguna yang

bersangkutan. Namun, apabila *password* telah diberikan kepada beberapa rekan kerja, proses penelusuran menjadi lebih sulit.

Karena itu, **menjaga kerahasiaan *password* juga berarti menjaga akuntabilitas atas aktivitas akun.**

Atasan atau Rekan Senior Tetap Tidak Memerlukan *Password* Anda

Permintaan *password* dapat datang dari seseorang yang dikenal atau memiliki posisi lebih tinggi. Pengguna mungkin merasa tidak nyaman menolak permintaan tersebut.

Namun, kebutuhan pekerjaan seseorang seharusnya dipenuhi melalui **hak akses miliknya sendiri**, bukan melalui *password* pengguna lain.

Prinsip yang sama berlaku kepada siapa pun:

Rekan kerja membutuhkan akses → gunakan akunnya sendiri.

Atasan membutuhkan akses → gunakan akunnya sendiri.

Administrator membutuhkan akses → gunakan kewenangan administratifnya sendiri.

Vendor membutuhkan akses → gunakan akses pihak ketiga yang diberikan kepadanya.

Dengan demikian, setiap aktivitas tetap dapat dikaitkan dengan identitas yang benar.

Jika *Password* Sudah Terlanjur Diberikan

Apabila *password* pernah diberikan kepada rekan kerja atau diketahui oleh orang lain, jangan menganggapnya tetap rahasia hanya karena orang tersebut dipercaya.

Segera ganti *password* sehingga informasi lama tidak lagi dapat digunakan untuk masuk ke akun. Apabila terdapat kemungkinan akun telah digunakan oleh pihak lain atau terjadi aktivitas yang mencurigakan, kejadian tersebut perlu dilaporkan melalui mekanisme keamanan informasi yang berlaku.

NIST SP 800-63B-4 juga mengatur penggantian *password* ketika terdapat bukti bahwa autentikator telah dikompromikan (Temoshok et al., 2025).

Pada akhirnya, keamanan akun tidak ditentukan oleh seberapa dekat hubungan dengan orang yang meminta *password*. Prinsipnya tetap sama: ***password* hanya digunakan oleh pemilik akun untuk melakukan autentikasi atas dirinya sendiri.**

INGAT: Rekan kerja tetap tidak boleh mengetahui atau menggunakan *password* Anda. Jika seseorang membutuhkan akses untuk menjalankan pekerjaannya, gunakan mekanisme pemberian hak akses yang benar. **Jangan selesaikan masalah akses dengan meminjamkan akun.**

4.4 Bagaimana Jika Atasan Meminta Password?

Permintaan *password* dapat menjadi lebih sulit ditolak ketika datang dari atasan. Pengguna mungkin merasa bahwa memberikan *password* merupakan bagian dari kepatuhan terhadap perintah atau diperlukan agar pekerjaan dapat segera diselesaikan.

Namun, **jabatan seseorang tidak mengubah fungsi *password* sebagai rahasia autentikasi.** Atasan yang memiliki kewenangan terhadap suatu pekerjaan tidak berarti harus menggunakan akun milik bawahannya.

PP Nomor 71 Tahun 2019 memberikan contoh edukasi mengenai pentingnya menjaga keamanan PIN dan *password*, termasuk dengan **merahasiakan dan tidak memberitahukannya kepada siapa pun** (Republik Indonesia, 2019).

Sampaikan Penolakan dengan Tepat

Jika atasan meminta *password*, pegawai tidak perlu menanggapi secara konfrontatif. Sampaikan bahwa *password* merupakan bagian dari mekanisme autentikasi pribadi dan tidak boleh dibagikan.

Sebagai contoh:

“Mohon izin, password akun tidak boleh saya berikan karena akun tersebut menggunakan identitas saya. Jika Bapak/Ibu membutuhkan akses, saya akan membantu mengajukan atau

menghubungi administrator agar diberikan akses sesuai kewenangan.”

Dengan demikian, pengguna **tidak menolak kebutuhan pekerjaan**, tetapi mengarahkan kebutuhan tersebut melalui mekanisme akses yang benar.

Kewenangan Atasan Tidak Sama dengan Menggunakan Identitas Bawahan

Apabila seorang atasan memang berwenang mengakses suatu sistem atau informasi, akses tersebut seharusnya diberikan melalui **akun dan identitas miliknya sendiri**.

Hal ini penting untuk menjaga akuntabilitas.

Jika atasan menggunakan akun bawahan, *audit trail* dapat mencatat aktivitas sebagai aktivitas pemilik akun. Ketika kemudian terjadi perubahan atau akses terhadap data tertentu, proses penelusuran dapat menghasilkan identitas yang tidak sesuai dengan pengguna sebenarnya.

Prinsipnya sederhana:

Atasan membutuhkan akses → berikan akses sesuai kewenangannya.

Bukan → berikan *password* bawahan.

Jangan Takut Melakukan Verifikasi

Permintaan yang mengatasnamakan atasan juga perlu diverifikasi, terutama jika disampaikan melalui WhatsApp, telepon, email, atau media komunikasi lainnya.

Dalam serangan ***social engineering***, penyerang dapat menggunakan unsur otoritas dan urgensi agar korban segera mengikuti instruksi tanpa melakukan pemeriksaan.

Pesan seperti:

“Saya pimpinan, segera kirim password-nya.”

atau

“Ini mendesak, kirim OTP sekarang.”

tidak boleh langsung dipenuhi hanya karena menggunakan nama atau identitas seseorang yang dikenal.

Jika permintaan tidak biasa, **verifikasi melalui saluran komunikasi yang dapat dipercaya sebelum melakukan tindakan lebih lanjut.**

Bagaimana Jika Tetap Diperintahkan?

Jika pengguna telah menjelaskan bahwa *password* tidak boleh dibagikan tetapi tetap diminta menyerahkannya, jangan mencari jalan tengah dengan mengirimkan *password* melalui pesan pribadi atau menuliskannya pada kertas.

Gunakan **jalur eskalasi yang berlaku di organisasi**, misalnya kepada penanggung jawab sistem, administrator, pengelola keamanan informasi, atau pihak lain yang ditetapkan dalam kebijakan internal.

Tujuannya bukan memperpanjang persoalan, melainkan memastikan bahwa kebutuhan akses dapat dipenuhi **tanpa menghilangkan identitas dan akuntabilitas pengguna.**

Jika *password* telah terlanjur diberikan, **segera lakukan penggantian *password*** dan laporkan sesuai prosedur yang berlaku apabila terdapat risiko akun telah digunakan oleh pihak lain.

INGAT: Jabatan bukan alasan untuk membagikan *password*. Jika atasan membutuhkan akses, bantu memperoleh akses melalui mekanisme yang benar. **Atasan menggunakan akunnya sendiri, Anda menggunakan akun Anda sendiri.**

4.5 Bagaimana Jika Administrator, Teknisi, atau Vendor Meminta Password?

Administrator, teknisi, dan vendor dapat memiliki tugas untuk melakukan pemeliharaan, konfigurasi, atau *troubleshooting* Sistem Elektronik. Namun, kebutuhan tersebut **tidak berarti mereka harus mengetahui *password* milik pengguna.**

Jika administrator atau vendor membutuhkan akses, mereka seharusnya menggunakan **akun dan kewenangan yang diberikan untuk pekerjaannya**, bukan menggunakan identitas pengguna lain.

PP Nomor 71 Tahun 2019 memberikan contoh edukasi mengenai pentingnya menjaga keamanan PIN dan *password*, termasuk dengan merahasiakan dan tidak memberitahukannya kepada siapa pun (Republik Indonesia, 2019).

“Saya dari IT” Bukan Alasan Memberikan *Password*

Pengguna mungkin menerima permintaan seperti:

“Saya dari IT, minta *password*-nya untuk pengecekan.”

“Kami dari vendor, kirim akun SIMRS untuk troubleshooting.”

“Saya perlu login sebagai Anda untuk mencoba masalahnya.”

Permintaan seperti ini **tidak boleh langsung dipenuhi**.

Jika pekerjaan memang membutuhkan pengujian menggunakan akun dengan karakteristik tertentu, administrator perlu menggunakan mekanisme teknis dan prosedur akses yang ditetapkan organisasi. Memberikan *password* pengguna bukan cara yang tepat untuk menyelesaikan kebutuhan akses.

Administrator Memiliki Mekanisme Aksesnya Sendiri

Administrator yang sah seharusnya tidak bergantung pada *password* pengguna untuk menjalankan fungsi administratif.

Jika diperlukan perubahan hak akses, *reset password*, pemeriksaan konfigurasi, atau kegiatan administratif lainnya, tindakan tersebut dilakukan menggunakan mekanisme dan kewenangan administrator.

Prinsip *least privilege* juga tetap berlaku. Administrator hanya menggunakan kewenangan yang diperlukan untuk menyelesaikan pekerjaan dan tidak menggunakan akses tersebut untuk melihat data yang tidak berkaitan dengan tugasnya (Joint Task Force, 2020).

Vendor Harus Menggunakan Akses yang Diberikan kepadanya

Prinsip yang sama berlaku terhadap vendor dan pihak ketiga.

Jika vendor membutuhkan akses ke server atau aplikasi untuk melakukan *troubleshooting*, organisasi dapat menyediakan akses sesuai kebutuhan pekerjaan. Akses tersebut sebaiknya **dapat dibedakan dari akun pegawai**, dibatasi sesuai kebutuhan, dan dicabut ketika pekerjaan selesai.

Jangan memberikan akun pribadi kepada vendor dengan alasan:

“Cuma sebentar.”

“Supaya cepat.”

“Vendor-nya sudah biasa menangani aplikasi ini.”

“Nanti setelah selesai password-nya diganti.”

Kemudahan operasional tidak menghilangkan risiko keamanan dan akuntabilitas.

Waspada *Social Engineering*

Penyerang dapat menyamar sebagai administrator, petugas IT, teknisi, atau vendor untuk memperoleh *credential*. Karena itu, identitas seseorang tidak boleh dipercaya hanya berdasarkan nama yang muncul pada WhatsApp, email, telepon, atau informasi yang disampaikannya.

Jika menerima permintaan *password* yang mencurigakan:

jangan berikan *password*;

verifikasi identitas peminta melalui saluran resmi;

hubungi administrator atau penanggung jawab yang dikenal

jika diperlukan;

dan laporkan permintaan yang mencurigakan sesuai prosedur organisasi.

Prinsip yang sama nantinya berlaku lebih kuat terhadap **OTP dan *passphrase* Tanda Tangan Elektronik**.

Jika *Password* Terlanjur Diberikan

Apabila *password* telah terlanjur diberikan kepada administrator, teknisi, vendor, atau pihak lain, **segera ganti *password***.

Jika terdapat kemungkinan akun telah digunakan atau informasi telah diakses tanpa kewenangan, kejadian tersebut perlu dilaporkan melalui mekanisme penanganan insiden yang berlaku.

Jangan berasumsi bahwa *password* tetap aman hanya karena pihak yang menerimanya merupakan orang yang dikenal atau vendor resmi.

INGAT: Administrator, teknisi, dan vendor tidak membutuhkan *password* Anda untuk menggunakan identitas mereka sendiri.

Jika mereka membutuhkan akses, gunakan mekanisme pemberian

akses yang resmi. **Jangan memberikan *password*, meskipun permintaan tersebut mengatasnamakan kebutuhan teknis.**

4.6 OTP dan Kode Verifikasi Tidak Boleh Diberikan kepada Orang Lain

OTP (*One-Time Password*) dan kode verifikasi digunakan sebagai bagian dari proses autentikasi untuk membantu memastikan bahwa orang yang melakukan akses benar-benar merupakan pengguna yang berhak.

Berbeda dengan *password* yang dapat digunakan berulang kali sampai diganti, OTP umumnya berlaku untuk **satu proses autentikasi atau dalam waktu terbatas**. Meskipun hanya berlaku sementara, OTP tetap merupakan informasi autentikasi yang harus dilindungi.

NIST SP 800-63B-4 memasukkan *single-factor one-time password* sebagai salah satu jenis autentikator dan menetapkan persyaratan keamanan terhadap penggunaannya (Temoshok et al., 2025).

Karena itu, **OTP dan kode verifikasi tidak boleh diberikan kepada orang lain.**

OTP Bukan Sekadar Angka

Pengguna dapat menerima kode melalui SMS, email, aplikasi autentikator, atau mekanisme lain. Karena bentuknya hanya beberapa angka atau karakter dan segera kedaluwarsa, pengguna terkadang menganggap kode tersebut tidak sepenting *password*.

Padahal, kode tersebut dapat menjadi bagian yang diperlukan untuk menyelesaikan proses autentikasi.

Apabila seseorang telah memperoleh *username* dan *password* pengguna, OTP mungkin menjadi penghalang berikutnya yang mencegah orang tersebut masuk ke dalam akun.

Ketika pengguna kemudian memberikan OTP, **pengguna dapat membantu pihak tersebut melewati lapisan autentikasi yang seharusnya melindungi akun.**

Jangan Berikan OTP meskipun Diminta Orang yang Dikenal

Pengguna dapat menerima permintaan seperti:

“OTP-nya berapa? Saya sedang coba login.”

“Kirim kode yang baru masuk.”

“Saya dari IT, butuh kode verifikasinya.”

“Vendor sedang memperbaiki aplikasi, tolong kirim OTP.”

Permintaan tersebut tidak boleh dipenuhi hanya karena pihak yang meminta merupakan rekan kerja, atasan, administrator, teknisi, atau vendor.

Jika proses autentikasi menggunakan identitas Anda, faktor autentikasinya juga harus tetap berada dalam kendali Anda.

Waspada OTP yang Muncul Tanpa Anda Minta

Jika tiba-tiba menerima OTP atau kode verifikasi padahal Anda tidak sedang melakukan *login* atau aktivitas yang memerlukan verifikasi, **jangan memberikan kode tersebut kepada siapa pun.**

Kondisi tersebut dapat menunjukkan bahwa seseorang sedang mencoba menggunakan akun Anda.

Jangan pula menyetujui permintaan autentikasi yang tidak Anda lakukan sendiri, termasuk *push notification* autentikasi apabila sistem menggunakannya.

Jika kejadian tersebut berulang atau terdapat indikasi akun sedang dicoba digunakan oleh pihak lain, lakukan tindakan sesuai prosedur keamanan organisasi, seperti mengganti *password* dan melaporkan kejadian kepada pengelola keamanan informasi atau administrator yang berwenang.

Administrator dan Vendor Tidak Membutuhkan OTP Anda

Administrator atau vendor yang membutuhkan akses seharusnya menggunakan identitas dan mekanisme autentikasinya sendiri.

Jangan memberikan OTP dengan alasan:

“Supaya proses troubleshooting cepat selesai.”

“Vendor sudah mengetahui password saya.”

“Administrator yang meminta, jadi pasti aman.”

Justru apabila seseorang telah mengetahui *password* kemudian meminta OTP yang masuk ke perangkat Anda, kondisi tersebut harus mendapatkan perhatian lebih.

Prinsip sederhananya adalah:

Password tidak diberikan. OTP juga tidak diberikan.

OTP Tidak Boleh Dikirim melalui WhatsApp atau Media Lain

Jangan meneruskan OTP melalui WhatsApp, email, SMS, telepon, atau media komunikasi lainnya.

Masalah utamanya bukan sekadar media yang digunakan. **OTP memang tidak seharusnya diberikan kepada pihak lain.**

Jika seseorang meminta Anda membacakan kode yang baru diterima, jangan melakukannya sebelum memastikan bahwa kode tersebut memang digunakan untuk aktivitas yang Anda lakukan sendiri.

INGAT: OTP dan kode verifikasi adalah bagian dari proses autentikasi. Jangan pernah memberikan atau membacakan OTP kepada orang lain, termasuk rekan kerja, atasan, administrator, teknisi, dan vendor. Jika menerima OTP tanpa melakukan permintaan, jangan menyetujuinya dan waspadai kemungkinan adanya percobaan akses terhadap akun Anda.

4.7 Bahaya Mengirim Password melalui WhatsApp atau Media Komunikasi Lain

Mengirim *password* melalui WhatsApp, email, SMS, atau media komunikasi lainnya sering dianggap sebagai cara cepat untuk membantu pekerjaan. Misalnya, pengguna mengirim *password* kepada rekan kerja atau vendor agar dapat melakukan *troubleshooting* tanpa harus datang langsung.

Namun, **password merupakan rahasia autentikasi dan tidak seharusnya dibagikan kepada orang lain, apa pun media yang digunakan.**

Masalah utamanya bukan sekadar apakah WhatsApp, email, atau aplikasi komunikasi tersebut aman. Masalahnya adalah **password**

yang seharusnya hanya diketahui pemilik akun telah diberikan kepada pihak lain.

Pesan Dapat Meninggalkan Salinan

Ketika *password* dikirim melalui percakapan, informasi tersebut dapat meninggalkan salinan pada perangkat atau riwayat komunikasi.

Contohnya:

“Password SIMRS saya:”

“Ini password server untuk sementara.”

“Saya kirim akun dan password vendor lewat WhatsApp.”

Pesan tersebut dapat tetap tersimpan setelah pekerjaan selesai. Pesan juga dapat disalin, diteruskan, terlihat melalui notifikasi, atau tersedia pada perangkat lain yang terhubung dengan akun komunikasi tersebut.

Akibatnya, pengguna menjadi lebih sulit memastikan **siapa saja yang pernah mengetahui *password*.**

Pesan Salah Kirim Dapat Menjadi Insiden

Risiko lain adalah salah memilih penerima.

Sebuah pesan yang berisi *password* dapat dikirim ke orang yang salah atau bahkan ke grup percakapan. Jika hal tersebut terjadi, rahasia autentikasi telah diketahui oleh pihak yang tidak seharusnya menerimanya.

Karena itu, jangan menjadikan media percakapan sebagai sarana untuk membagikan *password*.

Prinsipnya sederhana:

Password tidak dikirim melalui WhatsApp.

Password tidak dikirim melalui email.

Password tidak dikirim melalui SMS.

Password tidak dikirim melalui grup percakapan.

Bukan karena satu media tertentu selalu tidak aman, tetapi karena ***password* memang tidak boleh diberikan kepada orang lain.**

Vendor Membutuhkan Akses, Bukan *Password* Anda

Permintaan yang sering muncul adalah kebutuhan akses untuk *troubleshooting*:

“Kirim username dan password-nya lewat WhatsApp, nanti kami cek.”

Jika vendor atau teknisi memang membutuhkan akses, solusi yang lebih tepat adalah memberikan **akses tersendiri sesuai kebutuhan dan kewenangannya**, bukan mengirimkan *credential* milik pegawai.

Pendekatan tersebut menjaga identitas pengguna dan mendukung *logging* serta *audit trail* sebagaimana telah dibahas pada BAB 3.

Bagaimana Jika Terlanjur Mengirim *Password*?

Apabila *password* telah terlanjur dikirim kepada orang lain, **jangan hanya menghapus pesan lalu menganggap masalah selesai**. Salinan informasi mungkin sudah dilihat atau tersimpan pada perangkat penerima.

Lakukan penggantian *password* sesegera mungkin. Jika terdapat indikasi bahwa akun telah digunakan oleh pihak yang tidak berwenang, laporkan sesuai mekanisme penanganan insiden yang berlaku.

NIST SP 800-63B-4 mengatur bahwa *password* perlu diganti apabila terdapat bukti autentikator telah dikompromikan (Temoshok et al., 2025).

INGAT: Jangan mengirim password melalui WhatsApp, email, SMS, atau media komunikasi lainnya. Masalahnya bukan hanya media yang digunakan—*password* memang tidak boleh diberikan kepada orang lain. Jika sudah terlanjur dibagikan, **segera ganti password**.

4.8 Jangan Menuliskan Password di Tempat Terbuka

Password yang kuat tetap dapat kehilangan manfaatnya apabila dituliskan di tempat yang mudah dilihat atau ditemukan oleh orang lain. Karena itu, perlindungan *password* tidak hanya berkaitan

dengan cara membuatnya, tetapi juga **bagaimana pengguna menyimpan dan menjaganya.**

Menuliskan *password* pada *sticky note*, kertas, buku catatan terbuka, papan kerja, atau bagian lain yang mudah diakses dapat memberikan kesempatan kepada orang lain untuk menggunakan akun tanpa izin.

Hindari *Password* di Sekitar Komputer

Praktik yang perlu dihindari antara lain menuliskan *password*:

pada kertas yang ditempel di monitor;

di bawah keyboard atau mousepad;

pada meja kerja atau laci yang dapat diakses banyak orang;

pada papan informasi di ruang kerja;

atau

pada buku catatan yang dibiarkan terbuka.

Contoh sederhana:

Username: pegawai.a

Password: RumahSakit123!

kemudian ditempel pada monitor.

Dalam kondisi tersebut, seseorang tidak perlu melakukan serangan teknis untuk memperoleh *credential*. Cukup dengan melihat atau memotret catatan tersebut, orang lain dapat memperoleh informasi yang diperlukan untuk mencoba menggunakan akun.

Waspadai Foto dan Dokumentasi Ruangan

Catatan *password* yang terlihat di lingkungan kerja juga dapat secara tidak sengaja masuk ke dalam foto.

Misalnya, seseorang mengambil foto meja kerja untuk dokumentasi kemudian mengirimkannya ke grup WhatsApp atau mengunggahnya ke media sosial. Tanpa disadari, *sticky note* yang berisi *password* ikut terlihat dalam foto.

Karena itu, **informasi autentikasi tidak boleh ditempatkan pada lokasi yang dapat terlihat oleh orang lain atau terekam dalam dokumentasi.**

Jangan Menyimpan Daftar *Password* Tanpa Perlindungan

Memiliki banyak akun dapat membuat pengguna kesulitan mengingat seluruh *password*. Namun, solusi yang dipilih tidak seharusnya menciptakan risiko baru.

Hindari menyimpan daftar *password* pada dokumen Word, Excel, *text file*, atau catatan digital yang dapat dibuka dengan mudah oleh pengguna lain tanpa perlindungan yang memadai.

Jika organisasi menyediakan atau menetapkan penggunaan ***password manager***, gunakan mekanisme tersebut sesuai kebijakan organisasi. NIST SP 800-63B-4 memperbolehkan penggunaan *password manager* dan menyebut bahwa mekanisme tersebut dapat membantu pengguna memilih *password* yang lebih kuat dan berbeda untuk setiap layanan (Temoshok et al., 2025).

Jangan Mengandalkan Tempat yang Dianggap Tersembunyi

Meletakkan catatan *password* di bawah keyboard atau di dalam laci bukan berarti *password* telah terlindungi.

Prinsip yang perlu digunakan bukan:

“Apakah *password* ini cukup tersembunyi?”

melainkan:

“Apakah orang lain dapat memperoleh *password* ini?”

Jika jawabannya ya, cara penyimpanannya perlu diperbaiki.

Apabila *password* yang dituliskan di tempat terbuka telah diketahui atau diduga dilihat oleh orang lain, **segera ganti *password*** dan lakukan pelaporan apabila terdapat indikasi penyalahgunaan akun.

INGAT: Jangan menuliskan *password* pada monitor, meja, bawah keyboard, papan informasi, atau tempat lain yang mudah dilihat. Jangan pula menyimpan daftar *password* dalam file tanpa perlindungan. ***Password* yang terlihat oleh orang lain harus dianggap tidak lagi rahasia.**

4.9 Gunakan Password yang Kuat dan Berbeda

Menjaga kerahasiaan *password* saja belum cukup. Pengguna juga perlu memilih *password* yang **sulit ditebak dan tidak menggunakan *password* yang sama untuk banyak akun.**

Jika satu *password* digunakan pada SIMRS, email, VPN, aplikasi lain, bahkan layanan pribadi, kebocoran pada salah satu layanan dapat meningkatkan risiko terhadap akun lainnya.

Gunakan *Password* yang Panjang

Dalam praktik keamanan modern, **panjang *password* merupakan faktor penting.** NIST SP 800-63B-4 memberikan perhatian pada panjang *password* dan mengarahkan agar sistem mendukung *password* yang panjang. NIST juga tidak lagi menjadikan aturan komposisi yang memaksa kombinasi karakter tertentu sebagai pendekatan utama dalam pembentukan *password* (Temoshok et al., 2025).

Karena itu, jangan hanya berpikir:

“Password harus rumit.”

Lebih tepat membiasakan diri menggunakan ***password* atau *passphrase* yang panjang, sulit ditebak, tetapi tetap dapat dikelola dengan baik.**

Hindari *password* yang mudah dikaitkan dengan pengguna, misalnya:

nama sendiri;

tanggal lahir;

nama unit kerja;

nama rumah sakit;

nomor telepon;

atau pola sederhana seperti Password123.

Informasi seperti itu dapat lebih mudah ditebak, terutama apabila sebagian informasi mengenai pengguna tersedia secara terbuka.

Gunakan *Password* yang Berbeda untuk Setiap Akun

Kebiasaan yang sangat penting adalah **tidak menggunakan password yang sama pada berbagai layanan**.

Misalnya, jangan menggunakan satu *password* yang sama untuk:

SIMRS → Password A

Email → Password A

VPN → Password A

Akun pribadi → Password A

Jika *Password A* diketahui pihak lain melalui salah satu layanan, *credential* tersebut dapat dicoba pada layanan lainnya. Serangan yang mencoba pasangan *username* dan *password* yang diperoleh dari suatu layanan terhadap layanan lain dikenal sebagai ***credential stuffing***.

CISA juga merekomendasikan penggunaan *password* yang panjang, acak, dan unik untuk setiap akun.

Prinsip yang perlu dibangun adalah:

Satu akun → satu password yang berbeda.

Terutama, **jangan menggunakan *password* akun pribadi sebagai *password* akun pekerjaan**, dan sebaliknya.

Pertimbangkan Penggunaan *Password Manager*

Semakin banyak *password* yang berbeda, semakin sulit pengguna mengingat semuanya. Salah satu mekanisme yang dapat membantu adalah ***password manager***.

NIST SP 800-63B-4 mendukung penggunaan *password manager* dan menjelaskan bahwa penggunaannya dapat meningkatkan kemungkinan pengguna memilih *password* yang lebih kuat dan berbeda untuk setiap layanan (Temoshok et al., 2025).

Apabila organisasi menyediakan atau menetapkan *password manager*, gunakan sesuai kebijakan keamanan informasi yang berlaku.

Pengguna tidak perlu mengganti solusi tersebut dengan menyimpan daftar *password* pada *sticky note*, file teks, atau dokumen yang tidak terlindungi.

Tidak Perlu Mengganti *Password* Hanya karena Jadwal

Kebijakan lama sering mengharuskan pengguna mengganti *password* secara berkala, misalnya setiap 30, 60, atau 90 hari, tanpa melihat apakah terdapat indikasi kebocoran.

Panduan NIST saat ini menyatakan bahwa *password* **tidak seharusnya diwajibkan diganti secara berkala tanpa alasan**, kecuali terdapat bukti bahwa autentikator telah dikompromikan (Temoshok et al., 2025).

Namun, apabila kebijakan internal organisasi masih mewajibkan pergantian berkala, pengguna tetap harus mengikuti kebijakan yang berlaku.

Yang paling penting, *password* **harus segera diganti apabila diketahui, diberikan, bocor, atau diduga telah diperoleh pihak lain**.

INGAT: Gunakan *password* yang panjang, sulit ditebak, dan berbeda untuk setiap akun. Jangan menggunakan *password* akun pekerjaan untuk layanan pribadi. Jika *password* diketahui atau diduga diketahui orang lain, **segera ganti**.

4.10 Multi-Factor Authentication

Multi-Factor Authentication (MFA) adalah mekanisme autentikasi yang menggunakan **lebih dari satu faktor autentikasi** untuk membuktikan identitas pengguna. Dengan MFA, mengetahui *password* saja belum tentu cukup untuk memperoleh akses ke sebuah akun.

NIST SP 800-63B-4 menjelaskan autentikasi multi-faktor sebagai autentikasi yang menggunakan lebih dari satu faktor autentikasi yang berbeda. Faktor tersebut secara umum dapat berupa **sesuatu yang diketahui, sesuatu yang dimiliki, atau sesuatu yang melekat pada pengguna** (Temoshok et al., 2025).

Mengapa MFA Penting?

Jika sebuah akun hanya dilindungi dengan *password*, pihak yang berhasil memperoleh *password* tersebut dapat mencoba menggunakannya untuk masuk.

Dengan MFA, terdapat faktor tambahan yang harus dipenuhi.

Sebagai contoh:

Password + aplikasi autentikator

atau

Password + security key

Dengan demikian, MFA memberikan **lapisan perlindungan tambahan apabila *password* berhasil diketahui atau dicuri oleh pihak lain.**

MFA sangat penting terutama pada akun yang memiliki akses terhadap informasi sensitif atau kewenangan tinggi, seperti akun administrator, VPN, email, dan sistem penting lainnya.

MFA Tidak Berarti OTP Boleh Diberikan

Pengguna perlu memahami bahwa MFA hanya memberikan perlindungan apabila **faktor autentikasi tetap berada dalam kendali pengguna yang sah.**

Misalnya, seorang penyerang telah memperoleh *password*, kemudian mencoba masuk dan menyebabkan kode OTP dikirimkan kepada pemilik akun. Penyerang kemudian menghubungi pengguna dan meminta kode tersebut.

Jika pengguna memberikan OTP, lapisan perlindungan tambahan dapat dilewati.

Karena itu:

Jangan memberikan OTP kepada orang lain.

Jangan menyetujui permintaan autentikasi yang tidak Anda lakukan.

Jangan memberikan kode dari aplikasi autentikator kepada administrator, teknisi, atau vendor.

Jangan Asal Menyetujui Notifikasi MFA

Beberapa sistem menggunakan notifikasi pada perangkat pengguna untuk meminta persetujuan *login*.

Jika muncul permintaan persetujuan padahal Anda tidak sedang melakukan *login*, **jangan menyetujuinya.**

Permintaan tersebut dapat menunjukkan adanya pihak lain yang sedang mencoba menggunakan akun Anda.

Jika permintaan muncul berulang kali, pengguna sebaiknya melaporkannya melalui mekanisme keamanan informasi yang berlaku dan melakukan pemeriksaan terhadap keamanan akun.

MFA Bukan Pengganti *Password* yang Aman

Menggunakan MFA tidak berarti pengguna boleh mengabaikan keamanan *password*.

Prinsip-prinsip sebelumnya tetap berlaku:

gunakan *password* yang kuat dan berbeda;

jangan memberikan *password* kepada orang lain;

jangan memberikan OTP atau kode verifikasi;

dan

jangan menyetujui permintaan autentikasi yang tidak Anda lakukan sendiri.

MFA bekerja sebagai **lapisan tambahan**, bukan sebagai pengganti kebiasaan keamanan yang baik.

INGAT: Aktifkan MFA pada sistem yang menyediakannya dan gunakan sesuai kebijakan organisasi. Jangan pernah memberikan faktor autentikasi kedua kepada orang lain. Jika muncul permintaan autentikasi yang tidak Anda lakukan, jangan setuju dan segera waspadai kemungkinan percobaan akses terhadap akun Anda.

4.11 Apa yang Harus Dilakukan Jika Credential Diketahui Orang Lain?

Jika *password*, PIN, OTP, atau rahasia autentikasi lainnya diketahui oleh orang lain, pengguna harus menganggap bahwa **kerahasiaan *credential* tersebut telah hilang**. Jangan menunggu sampai terdapat bukti bahwa akun telah disalahgunakan.

NIST SP 800-63B-4 mengatur bahwa *password* perlu diganti apabila terdapat bukti autentikator telah dikompromikan (Temoshok et al., 2025).

Segera Ganti *Password*

Jika *password* diketahui, terlihat, terkirim, atau pernah diberikan kepada orang lain, tindakan pertama adalah **segera menggantinya**.

Hal ini berlaku meskipun *password* diketahui oleh orang yang dipercaya, seperti rekan kerja, atasan, administrator, teknisi, atau vendor.

Contohnya:

password tidak sengaja terkirim melalui WhatsApp;

password terlihat pada catatan di meja;

password pernah diberikan kepada rekan kerja;

atau

pengguna memasukkan password pada halaman yang kemudian diketahui sebagai phishing.

Dalam kondisi tersebut, jangan hanya menghapus pesan atau catatan. **Ganti *password*** agar *credential* lama tidak lagi dapat digunakan.

Jangan Gunakan *Password* Lama pada Akun Lain

Jika *password* yang sama digunakan pada beberapa akun, risiko tidak hanya terdapat pada satu sistem.

Misalnya, *password* yang diketahui orang lain ternyata juga digunakan untuk email dan VPN. Pengguna perlu mengganti *password* pada akun lain yang menggunakan *password* sama dan membuat **password yang berbeda untuk setiap akun**.

Hal tersebut menjadi alasan penting mengapa penggunaan ulang *password* sebaiknya dihindari.

Laporkan Jika Ada Kemungkinan Penyalahgunaan

Jika terdapat kemungkinan akun telah digunakan oleh pihak lain, pengguna perlu **segera melaporkan kejadian tersebut melalui mekanisme penanganan insiden yang berlaku**.

Contoh indikasinya antara lain terdapat *login* yang tidak dikenali, perubahan *password* yang tidak dilakukan sendiri, notifikasi MFA yang tidak diminta, atau aktivitas lain yang tidak dilakukan oleh pemilik akun.

Pelaporan yang cepat memberikan kesempatan kepada pengelola sistem atau tim keamanan untuk melakukan tindakan

seperti memeriksa *log*, menonaktifkan sesi aktif, membatasi akses, atau melakukan tindakan respons lain sesuai kebutuhan.

Jika OTP Terlanjur Diberikan

OTP biasanya memiliki masa berlaku terbatas, tetapi apabila OTP telah diberikan kepada orang lain, **jangan menganggap masalah selesai hanya karena kode tersebut kemudian kedaluwarsa.**

Jika OTP diberikan bersamaan dengan kemungkinan *password* telah diketahui pihak lain, akun perlu diperiksa karena pihak tersebut mungkin telah berhasil menyelesaikan proses autentikasi.

Segera laporkan apabila terdapat indikasi akses yang tidak dikenal dan lakukan pengamanan akun sesuai prosedur organisasi.

Jangan Menutupi Kesalahan

Pengguna mungkin merasa malu karena telah memberikan *password*, salah mengirim *credential*, atau menjadi korban *phishing*. Namun, **menunda pelaporan dapat memberikan waktu lebih lama kepada pihak lain untuk menggunakan akun yang telah diperoleh.**

Dalam keamanan informasi, pelaporan yang cepat jauh lebih berguna daripada mencoba menyelesaikan atau menyembunyikan kejadian sendiri.

Prinsip yang perlu diingat adalah:

Credential diketahui orang lain → ganti.

Diduga akun digunakan orang lain → laporkan.

Password digunakan pada akun lain → ganti juga dengan password yang berbeda.

INGAT: Jika *credential* diketahui atau diduga diketahui orang lain, segera lakukan tindakan pengamanan. Ganti *password*, periksa akun lain yang menggunakan *password* sama, dan laporkan segera apabila terdapat kemungkinan penyalahgunaan akun. Jangan menunggu sampai terjadi kebocoran data.

BAB 5 LINDUNGI PASSPHRASE TANDA TANGAN ELEKTRONIK

5.1 Mengenal Tanda Tangan Elektronik

Dalam PP Nomor 71 Tahun 2019, **Penanda Tangan** adalah subjek hukum yang terasosiasikan atau terkait dengan Tanda Tangan Elektronik.

Hal tersebut menjadi penting dari perspektif keamanan.

Jika sebuah dokumen ditandatangani secara elektronik menggunakan identitas seseorang, proses penandatanganan tersebut seharusnya tetap berada dalam kendali pihak yang berhak melakukan penandatanganan.

Karena itu, pengguna perlu membedakan antara:

mempersiapkan dokumen untuk ditandatangani, dan melakukan penandatanganan menggunakan identitas orang lain.

Staf dapat membantu mempersiapkan dokumen sesuai tugas dan kewenangannya. Namun, proses autentikasi dan persetujuan untuk melakukan Tanda Tangan Elektronik **tidak seharusnya dilakukan dengan menggunakan rahasia autentikasi milik Penanda Tangan.**

Tanda Tangan Elektronik Bukan Sekadar Gambar Tanda Tangan

Gambar hasil *scan* tanda tangan yang ditempelkan pada dokumen tidak boleh disamakan begitu saja dengan seluruh konsep Tanda Tangan Elektronik yang memiliki mekanisme autentikasi, verifikasi, dan persyaratan tertentu.

PP Nomor 71 Tahun 2019 mensyaratkan, antara lain, adanya cara untuk **mengidentifikasi Penanda Tangan** serta menunjukkan bahwa Penanda Tangan telah memberikan persetujuan terhadap Informasi Elektronik yang terkait (Republik Indonesia, 2019).

Dengan demikian, aspek penting dalam Tanda Tangan Elektronik bukan hanya bentuk tanda tangan yang terlihat pada dokumen,

tetapi juga **siapa yang melakukan penandatanganan dan bagaimana persetujuan tersebut diberikan.**

Data Pembuatan Tanda Tangan Elektronik Harus Dilindungi

PP Nomor 71 Tahun 2019 mengenal istilah **Data Pembuatan Tanda Tangan Elektronik**, yang antara lain dapat berupa kode pribadi, kode biometrik, atau kode kriptografi.

Lebih penting lagi, Pasal 59 mensyaratkan bahwa Data Pembuatan Tanda Tangan Elektronik pada saat proses penandatanganan elektronik **hanya berada dalam kuasa Penanda Tangan.**

Prinsip inilah yang menjadi dasar penting bagi pembahasan berikutnya mengenai **passphrase**.

Jika **passphrase** digunakan sebagai rahasia autentikasi untuk mengendalikan proses Tanda Tangan Elektronik, pengguna tidak boleh memperlakukannya seperti informasi yang dapat diberikan kepada staf, rekan kerja, administrator, atau pihak lain agar mereka melakukan penandatanganan menggunakan identitas pemiliknya.

Pembahasan tersebut akan kita pertegas pada subbab berikutnya.

INGAT: Tanda Tangan Elektronik berkaitan dengan identitas, autentikasi, dan persetujuan Penanda Tangan. Jangan memperlakukannya seperti gambar tanda tangan atau stempel yang dapat digunakan oleh orang lain. Rahasia autentikasi yang mengendalikan proses penandatanganan harus dijaga oleh pemiliknya.

5.2 Sertifikat Elektronik dan Identitas Pemilik

Sertifikat Elektronik memiliki peran penting dalam Tanda Tangan Elektronik karena digunakan untuk menghubungkan **identitas pemilik dengan informasi elektronik tertentu.**

PP Nomor 71 Tahun 2019 mengatur bahwa sebelum Tanda Tangan Elektronik digunakan, Penyelenggara Sertifikasi Elektronik harus melakukan **identifikasi awal terhadap Penanda Tangan**, termasuk

melalui penyampaian identitas dan proses registrasi (Republik Indonesia, 2019).

Dengan demikian, Sertifikat Elektronik tidak seharusnya dipandang hanya sebagai sebuah file atau fasilitas untuk menandatangani dokumen. Sertifikat tersebut berkaitan dengan **identitas pihak yang menjadi pemilik atau Penanda Tangan.**

Sertifikat Elektronik Berkaitan dengan Identitas

Dalam Tanda Tangan Elektronik tersertifikasi, PP Nomor 71 Tahun 2019 mensyaratkan penggunaan Sertifikat Elektronik yang dibuat oleh Penyelenggara Sertifikasi Elektronik Indonesia. Regulasi yang sama juga mensyaratkan adanya cara untuk mengidentifikasi siapa Penanda Tangannya (Republik Indonesia, 2019).

Artinya, ketika seseorang melakukan Tanda Tangan Elektronik, proses tersebut tidak hanya menghasilkan tanda pada sebuah dokumen. Terdapat hubungan antara **identitas Penanda Tangan, Sertifikat Elektronik, dan proses penandatanganan.**

Karena itu, pengguna tidak boleh memperlakukan identitas Tanda Tangan Elektronik seperti akun bersama.

Pemilik Harus Menjaga Kendali atas Proses Penandatanganan

PP Nomor 71 Tahun 2019 memberikan prinsip keamanan yang sangat jelas. **Data Pembuatan Tanda Tangan Elektronik pada saat proses penandatanganan hanya boleh berada dalam kuasa Penanda Tangan.** Regulasi tersebut juga mewajibkan Penanda Tangan menjaga kerahasiaan dan bertanggung jawab atas Data Pembuatan Tanda Tangan Elektronik (Republik Indonesia, 2019).

Karena itu, praktik seperti berikut harus dihindari:

“Saya sedang tidak di kantor, tolong tanda tangani menggunakan akun saya.”

“Passphrase-nya saya kirim, nanti dokumennya ditandatangani.”

“Staf saya biasa melakukan tanda tangan elektronik untuk saya.”

Walaupun dilakukan untuk mempercepat pekerjaan, praktik tersebut dapat menyebabkan **proses penandatanganan tidak lagi**

berada dalam kendali pemilik identitas yang seharusnya melakukan penandatanganan.

Staf Boleh Membantu Dokumen, Bukan Menggunakan Identitas Penanda Tangan

Perlu dibedakan antara **membantu mempersiapkan dokumen** dengan **melakukan Tanda Tangan Elektronik menggunakan identitas orang lain.**

Staf dapat mempersiapkan dokumen, melakukan pemeriksaan administratif, atau meneruskan dokumen kepada pejabat yang berwenang sesuai proses bisnis organisasi.

Namun, ketika sampai pada proses persetujuan dan Tanda Tangan Elektronik, tindakan tersebut harus dilakukan oleh **Penanda Tangan yang berwenang menggunakan identitas dan mekanisme autentikasinya sendiri.**

PP Nomor 71 Tahun 2019 juga mensyaratkan bahwa sebelum penandatanganan, informasi yang akan ditandatangani harus diketahui dan dipahami oleh Penanda Tangan serta terdapat mekanisme yang menunjukkan persetujuan Penanda Tangan terhadap informasi tersebut.

Sertifikat Elektronik Bukan untuk Dipinjamkan

Prinsip yang perlu dipahami pegawai dan pihak ketiga adalah:

Identitas elektronik tidak dipinjamkan.

Rahasia autentikasi tidak dibagikan.

Penandatanganan dilakukan oleh pihak yang berwenang.

Jika seseorang berhalangan melakukan penandatanganan, penyelesaiannya harus mengikuti mekanisme kewenangan dan proses bisnis yang berlaku, **bukan dengan menyerahkan identitas elektronik atau rahasia autentikasinya kepada orang lain.**

INGAT: Sertifikat Elektronik berkaitan dengan identitas pemiliknya. Jangan menyerahkan kendali Tanda Tangan Elektronik kepada orang lain. Staf dapat membantu menyiapkan dokumen, tetapi proses persetujuan dan penandatanganan harus dilakukan oleh pihak yang berwenang menggunakan identitasnya sendiri.

5.3 Apa yang Dimaksud dengan Passphrase?

Dalam penggunaan Tanda Tangan Elektronik, pengguna dapat diminta memasukkan ***passphrase*** untuk melakukan autentikasi sebelum proses penandatanganan dapat dilakukan.

Secara sederhana, ***passphrase*** adalah rangkaian karakter rahasia yang digunakan oleh pemiliknya untuk membantu mengendalikan akses terhadap fungsi atau mekanisme tertentu. Dalam konteks Tanda Tangan Elektronik, *passphrase* harus diperlakukan sebagai **rahasia autentikasi**, bukan sebagai informasi yang boleh diketahui bersama.

Istilah *passphrase* sendiri tidak perlu disamakan dengan istilah hukum **Data Pembuatan Tanda Tangan Elektronik**. PP Nomor 71 Tahun 2019 mendefinisikan Data Pembuatan Tanda Tangan Elektronik sebagai kode pribadi, kode biometrik, kode kriptografi, dan/atau kode yang dihasilkan dari pengubahan tanda tangan manual menjadi Tanda Tangan Elektronik (Republik Indonesia, 2019).

Yang penting bagi pengguna adalah memahami bahwa **rahasia yang digunakan untuk mengendalikan proses penandatanganan harus dijaga oleh pemilik identitas yang bersangkutan**.

Passphrase Bukan Password Bersama

Dalam pekerjaan sehari-hari dapat muncul kebiasaan menyerahkan proses penandatanganan kepada staf dengan memberikan *passphrase*.

Misalnya:

“Passphrase saya ini, nanti tolong tanda tangani.”

“Kalau ada dokumen masuk, langsung tanda tangani saja menggunakan akun saya.”

“Saya sedang di luar, passphrase-nya saya kirim lewat WhatsApp.”

Praktik seperti ini harus dihindari.

PP Nomor 71 Tahun 2019 mensyaratkan bahwa **Data Pembuatan Tanda Tangan Elektronik pada saat proses penandatanganan hanya berada dalam kuasa Penanda Tangan**. Penanda Tangan juga

berkewajiban menjaga kerahasiaan dan bertanggung jawab atas Data Pembuatan Tanda Tangan Elektronik (Republik Indonesia, 2019).

Dengan demikian, rahasia autentikasi untuk melakukan penandatanganan **tidak seharusnya diserahkan kepada orang lain agar orang tersebut melakukan Tanda Tangan Elektronik atas nama pemiliknya.**

Staf Dapat Membantu, tetapi Tidak Menggantikan Penanda Tangan

Pekerjaan administratif sebelum penandatanganan tetap dapat dilakukan oleh staf sesuai kewenangannya.

Staf dapat membantu menyiapkan dokumen, memeriksa kelengkapan, mengunggah dokumen, atau meneruskannya kepada pihak yang berwenang.

Namun, terdapat perbedaan penting antara:

menyiapkan dokumen untuk ditandatangani

dan

melakukan penandatanganan menggunakan identitas orang lain.

Ketika sistem meminta *passphrase* atau mekanisme autentikasi lain untuk memberikan persetujuan dan melakukan Tanda Tangan Elektronik, proses tersebut **harus tetap berada dalam kendali Penanda Tangan yang berwenang.**

Jangan Mengirim *Passphrase* melalui WhatsApp

Seperti *password* dan OTP, *passphrase* tidak boleh dikirim melalui WhatsApp, email, SMS, atau media komunikasi lainnya kepada staf maupun pihak lain.

Masalah utamanya bukan hanya keamanan media komunikasi.

Rahasia autentikasi tersebut memang tidak seharusnya diberikan kepada orang lain.

Jika *passphrase* telah diketahui pihak lain, pemilik perlu mengambil tindakan pengamanan sesuai mekanisme penyelenggara Tanda Tangan Elektronik dan kebijakan organisasi.

Passphrase Melindungi Identitas dan Kewenangan

Pegawai perlu memahami bahwa penggunaan *passphrase* dalam Tanda Tangan Elektronik bukan sekadar langkah tambahan yang memperlambat pekerjaan.

Mekanisme tersebut membantu menjaga agar proses penandatanganan dilakukan oleh **pihak yang menguasai mekanisme autentikasi yang terkait dengan identitas Penanda Tangan**.

Karena itu, jangan menghilangkan perlindungan tersebut dengan membagikan *passphrase* kepada orang lain.

INGAT: *Passphrase* Tanda Tangan Elektronik adalah rahasia autentikasi. Jangan berikan kepada staf, rekan kerja, atasan, administrator, vendor, atau pihak lain untuk melakukan penandatanganan atas nama Anda. Dokumen dapat dipersiapkan oleh staf, tetapi **proses penandatanganan harus tetap berada dalam kendali Penanda Tangan yang berwenang.**

5.4 *Passphrase* Tanda Tangan Elektronik Bersifat Rahasia

Passphrase yang digunakan dalam proses Tanda Tangan Elektronik harus diperlakukan sebagai **rahasia autentikasi milik Penanda Tangan**. Informasi tersebut tidak boleh diberikan kepada orang lain hanya untuk mempermudah atau mempercepat proses penandatanganan.

Prinsip ini penting karena Tanda Tangan Elektronik berkaitan dengan **identitas dan persetujuan Penanda Tangan**, bukan sekadar proses teknis menambahkan tanda pada sebuah dokumen.

PP Nomor 71 Tahun 2019 mensyaratkan bahwa **Data Pembuatan Tanda Tangan Elektronik pada saat proses penandatanganan hanya berada dalam kuasa Penanda Tangan**. Penanda Tangan juga wajib menjaga kerahasiaan dan bertanggung jawab atas Data Pembuatan Tanda Tangan Elektronik (Republik Indonesia, 2019).

Jangan Memberikan *Passphrase* kepada Staf

Dalam pekerjaan sehari-hari, staf dapat membantu mempersiapkan dokumen yang membutuhkan Tanda Tangan

Elektronik. Namun, bantuan administratif tersebut tidak berarti staf boleh mengetahui *passphrase* Penanda Tangan.

Hindari praktik seperti:

“Ini *passphrase* saya, kalau ada dokumen masuk langsung tanda tangani.”

“Saya sedang rapat, tolong tanda tangani menggunakan akun saya.”

“*Passphrase* saya kirim lewat WhatsApp supaya pekerjaan cepat selesai.”

Walaupun dilakukan atas persetujuan pemilik, praktik tersebut menyebabkan **rahasia autentikasi diketahui dan digunakan oleh orang lain.**

Cara yang lebih tepat adalah staf mempersiapkan dokumen sampai siap ditandatangani, kemudian **Penanda Tangan melakukan sendiri proses autentikasi dan penandatanganannya.**

Jangan Memberikan *Passphrase* kepada Administrator atau Vendor

Administrator, teknisi, maupun vendor juga tidak seharusnya meminta *passphrase* Tanda Tangan Elektronik pengguna untuk melakukan *troubleshooting*.

Apabila terdapat masalah teknis, pemeriksaan harus dilakukan menggunakan mekanisme dukungan yang tersedia tanpa meminta pengguna menyerahkan rahasia autentikasinya.

Prinsipnya sama seperti *password* dan OTP:

Administrator tidak perlu mengetahui *passphrase* Anda.

Vendor tidak perlu mengetahui *passphrase* Anda.

Staf tidak perlu mengetahui *passphrase* Anda.

Persetujuan Harus Tetap Berasal dari Penanda Tangan

PP Nomor 71 Tahun 2019 juga mensyaratkan adanya cara tertentu untuk menunjukkan bahwa **Penanda Tangan telah memberikan persetujuan terhadap Informasi Elektronik yang terkait** dengan Tanda Tangan Elektronik (Republik Indonesia, 2019).

Karena itu, *passphrase* tidak boleh dipandang hanya sebagai kode untuk “membuat tanda tangan muncul”.

Dokumen dapat disiapkan oleh pihak lain, tetapi **keputusan dan tindakan penandatanganan harus tetap berada dalam kendali pihak yang berwenang menandatangani.**

Jika Penanda Tangan sedang tidak berada di tempat, penyelesaiannya harus mengikuti mekanisme kewenangan dan proses bisnis organisasi, bukan dengan memberikan *passphrase* kepada orang lain.

Jika *Passphrase* Diketahui Orang Lain

Apabila *passphrase* telah diberikan, terlihat, atau diduga diketahui orang lain, jangan menganggapnya tetap rahasia hanya karena pihak tersebut dipercaya.

Penanda Tangan perlu segera melakukan tindakan pengamanan sesuai prosedur organisasi dan mekanisme yang disediakan oleh Penyelenggara Sertifikasi Elektronik yang digunakan.

Jika terdapat kemungkinan Tanda Tangan Elektronik telah digunakan tanpa kewenangan, kejadian tersebut perlu **segera dilaporkan dan diperiksa.**

INGAT: *Passphrase* Tanda Tangan Elektronik bersifat rahasia. Jangan berikan kepada staf, rekan kerja, administrator, teknisi, vendor, atau pihak lain. Staf boleh membantu menyiapkan dokumen, tetapi autentikasi, persetujuan, dan proses penandatanganan harus tetap berada dalam kendali Penanda Tangan yang berwenang.

5.5 Dilarang Menyerahkan *Passphrase* kepada Orang Lain

Passphrase Tanda Tangan Elektronik tidak boleh diserahkan kepada orang lain, termasuk kepada staf, rekan kerja, atasan, administrator, teknisi, maupun vendor. Prinsip ini berlaku meskipun penyerahan dilakukan atas persetujuan pemilik atau dengan alasan mempercepat pekerjaan.

PP Nomor 71 Tahun 2019 mensyaratkan bahwa **Data Pembuatan Tanda Tangan Elektronik pada saat proses penandatanganan hanya berada dalam kuasa Penanda Tangan.** Penanda Tangan juga

berkewajiban menjaga kerahasiaan dan bertanggung jawab atas Data Pembuatan Tanda Tangan Elektronik (Republik Indonesia, 2019).

Karena itu, proses Tanda Tangan Elektronik tidak seharusnya dilakukan oleh orang lain dengan menggunakan rahasia autentikasi milik Penanda Tangan.

Pemberian Izin Tidak Berarti *Passphrase* Boleh Diserahkan

Dalam praktik sehari-hari dapat muncul situasi seperti:

“Saya izinkan staf menggunakan *passphrase* saya.”

“Saya sedang di luar kantor, tolong tanda tangani untuk saya.”

“Saya sudah setuju dengan dokumennya, staf tinggal memasukkan *passphrase*.”

Cara tersebut perlu dihindari.

Masalahnya bukan hanya apakah Penanda Tangan telah memberikan izin kepada staf. **Rahasia autentikasi telah berpindah kepada orang lain dan proses penandatanganan tidak lagi sepenuhnya berada dalam kendali Penanda Tangan.**

PP Nomor 71 Tahun 2019 juga mensyaratkan adanya cara tertentu yang digunakan untuk menunjukkan bahwa Penanda Tangan telah memberikan persetujuan terhadap Informasi Elektronik yang terkait (Republik Indonesia, 2019).

Staf Menyiapkan Dokumen, Pejabat Berwenang Menandatangani

Pemisahan tugas dapat dilakukan secara sederhana:

Staf → menyiapkan dan memproses dokumen sesuai kewenangan.

Penanda Tangan → memeriksa, memberikan persetujuan, melakukan autentikasi, dan menandatangani.

Dengan mekanisme tersebut, pekerjaan administratif tetap dapat berjalan tanpa menyerahkan *passphrase* kepada staf.

Jika Penanda Tangan berhalangan, gunakan mekanisme pengalihan atau pelimpahan kewenangan yang berlaku dalam organisasi. **Jangan menyelesaikannya dengan menyerahkan *passphrase* kepada orang lain.**

Jangan Menyimpan *Passphrase* agar Dapat Digunakan Bersama

Passphrase juga tidak boleh disimpan agar dapat digunakan bergantian, misalnya ditulis pada kertas, disimpan dalam grup WhatsApp, diberikan kepada sekretariat, atau disimpan dalam dokumen yang dapat dibuka oleh beberapa pegawai.

Praktik tersebut membuat rahasia autentikasi tidak lagi berada dalam kendali pemiliknya.

Hal yang sama berlaku ketika seseorang berkata:

“*Passphrase*-nya sudah diketahui staf kepercayaan saya.”

Kepercayaan kepada seseorang tidak mengubah prinsip keamanan Tanda Tangan Elektronik. **Orang yang dipercaya tetap bukan pemilik identitas elektronik tersebut.**

Administrator dan Vendor Juga Tidak Boleh Meminta *Passphrase*

Administrator atau vendor dapat membantu apabila terjadi gangguan pada aplikasi atau proses Tanda Tangan Elektronik. Namun, bantuan teknis tersebut tidak membutuhkan penyerahan *passphrase* pengguna.

Jika seseorang mengaku sebagai administrator, teknisi, atau vendor kemudian meminta *passphrase*, **jangan memberikannya**. Lakukan verifikasi dan gunakan mekanisme dukungan resmi.

Jika *passphrase* sudah terlanjur diketahui pihak lain, segera lakukan tindakan pengamanan sesuai prosedur organisasi dan mekanisme Penyelenggara Sertifikasi Elektronik yang digunakan.

INGAT: Jangan pernah menyerahkan *passphrase* Tanda Tangan Elektronik kepada orang lain, meskipun kepada staf kepercayaan dan meskipun Anda memberikan izin. Dokumen dapat dipersiapkan oleh staf, tetapi rahasia autentikasi dan proses penandatanganan harus tetap berada dalam kendali Penanda Tangan yang berwenang.

5.6 Jangan Menitipkan Proses Penandatanganan Elektronik

Tanda Tangan Elektronik berkaitan dengan **identitas dan persetujuan Penanda Tangan**. Karena itu, proses penandatanganan tidak boleh dititipkan kepada orang lain dengan memberikan akun, *passphrase*, OTP, atau rahasia autentikasi yang digunakan untuk melakukan penandatanganan.

PP Nomor 71 Tahun 2019 mensyaratkan bahwa **Data Pembuatan Tanda Tangan Elektronik pada saat proses penandatanganan hanya berada dalam kuasa Penanda Tangan**. Regulasi tersebut juga mensyaratkan adanya cara tertentu untuk menunjukkan bahwa Penanda Tangan telah memberikan persetujuan terhadap Informasi Elektronik yang terkait (Republik Indonesia, 2019).

“Tolong Tanda Tangani untuk Saya” Harus Dihindari

Dalam pekerjaan sehari-hari, proses penandatanganan terkadang dianggap sebagai pekerjaan administratif yang dapat dititipkan kepada staf.

Misalnya:

“Dokumennya sudah benar, nanti tolong tanda tangani untuk saya.”

“Saya sedang di luar kantor, gunakan passphrase saya.”

“Kalau ada dokumen masuk, langsung tanda tangani saja.”

Praktik tersebut harus dihindari. Meskipun Penanda Tangan telah membaca dokumen atau memberikan persetujuan secara lisan, **orang lain tidak seharusnya menggunakan identitas dan rahasia autentikasi milik Penanda Tangan untuk melakukan proses penandatanganan**.

Staf Dapat Membantu Sebelum Proses Penandatanganan

Larangan menitipkan Tanda Tangan Elektronik tidak berarti seluruh proses dokumen harus dilakukan sendiri oleh pejabat yang menandatangani.

Staf tetap dapat membantu sesuai kewenangannya, misalnya:
menyiapkan dokumen;

**memeriksa kelengkapan administratif;
mengunggah atau meneruskan dokumen;
dan**

menempatkan dokumen dalam alur persetujuan.

Setelah dokumen siap, **Penanda Tangan yang berwenang melakukan pemeriksaan, autentikasi, persetujuan, dan proses penandatanganan menggunakan identitasnya sendiri.**

Dengan demikian, efisiensi pekerjaan tetap dapat dijaga tanpa menyerahkan kendali Tanda Tangan Elektronik kepada orang lain.

Berhalangan Bukan Alasan Menyerahkan *Passphrase*

Jika Penanda Tangan sedang rapat, berada di luar kantor, cuti, atau berhalangan melakukan penandatanganan, solusinya bukan memberikan *passphrase* kepada staf.

Apabila dokumen harus segera ditandatangani, gunakan **mekanisme kewenangan atau penggantian Penanda Tangan yang berlaku dalam organisasi.**

Pihak yang memperoleh kewenangan tersebut menggunakan **identitas dan Tanda Tangan Elektroniknya sendiri**, bukan menggunakan identitas pejabat yang berhalangan.

Menitipkan Penandatanganan Mengurangi Akuntabilitas

Jika seseorang menggunakan identitas elektronik milik orang lain untuk menandatangani dokumen, terdapat ketidaksesuaian antara **orang yang secara teknis melakukan proses autentikasi dengan identitas Penanda Tangan yang digunakan pada sistem.**

Hal tersebut dapat mengurangi akuntabilitas dan menyulitkan penelusuran apabila kemudian muncul pertanyaan mengenai siapa yang sebenarnya melakukan proses penandatanganan.

Prinsipnya sederhana:

Dokumen boleh dipersiapkan oleh staf.

Proses administrasi boleh dibantu oleh staf.

Namun, Tanda Tangan Elektronik dilakukan oleh Penanda Tangan yang berwenang menggunakan identitasnya sendiri.

INGAT: Jangan menitipkan proses Tanda Tangan Elektronik kepada orang lain. Jangan memberikan akun, *passphrase*, OTP, atau

rahasia autentikasi agar orang lain menandatangani atas nama Anda. **Staf dapat membantu menyiapkan dokumen, tetapi proses penandatanganan tetap dilakukan oleh Penanda Tangan yang berwenang.**

5.7 Staf atau Operator Tidak Boleh Menggunakan TTE Milik Orang Lain

Staf atau operator dapat membantu proses administrasi dokumen elektronik, tetapi **tidak boleh menggunakan Tanda Tangan Elektronik (TTE) milik orang lain** untuk melakukan penandatanganan.

Prinsip ini tetap berlaku meskipun staf memperoleh izin dari pemilik TTE. PP Nomor 71 Tahun 2019 mensyaratkan bahwa **Data Pembuatan Tanda Tangan Elektronik pada saat proses penandatanganan hanya berada dalam kuasa Penanda Tangan**. Penanda Tangan juga berkewajiban menjaga kerahasiaan Data Pembuatan Tanda Tangan Elektronik (Republik Indonesia, 2019).

Membantu Administrasi Berbeda dengan Menandatangani

Dalam alur dokumen elektronik, staf atau operator dapat memiliki tugas seperti:

menyiapkan dokumen;

memeriksa kelengkapan;

mengunggah dokumen ke sistem;

meneruskan dokumen kepada pejabat yang berwenang;

atau memantau proses administrasi dokumen.

Namun, ketika dokumen telah sampai pada tahap penandatanganan, **TTE harus digunakan oleh Penanda Tangan yang berwenang menggunakan identitasnya sendiri.**

Dengan demikian, terdapat batas yang jelas:

Staf/operator → membantu proses administrasi.

Penanda Tangan → memberikan persetujuan dan melakukan TTE.

Izin Pemilik Bukan Alasan Menggunakan TTE Orang Lain

Praktik seperti berikut harus dihindari:

“Saya sudah mendapat izin dari pejabatnya.”

“Beliau yang memberikan passphrase kepada saya.”

“Saya memang biasa membantu tanda tangan dokumen beliau.”

“Dokumennya sudah disetujui, saya hanya memasukkan passphrase.”

Walaupun terdapat izin atau kebiasaan kerja, **staf tetap tidak seharusnya melakukan proses penandatanganan menggunakan identitas dan rahasia autentikasi milik orang lain.**

PP Nomor 71 Tahun 2019 juga mensyaratkan adanya cara tertentu untuk menunjukkan bahwa Penanda Tangan telah memberikan persetujuan terhadap Informasi Elektronik yang terkait dengan TTE (Republik Indonesia, 2019).

Jangan Menyimpan *Passphrase* Pejabat

Staf atau operator juga tidak boleh menyimpan daftar *passphrase* milik pejabat agar proses penandatanganan dapat dilakukan dengan cepat.

Hindari penyimpanan *passphrase* pada:

catatan di meja kerja;

WhatsApp atau grup percakapan;

dokumen Word atau Excel;

browser;

atau media lain yang digunakan agar *passphrase* dapat digunakan kembali oleh staf.

Jika *passphrase* telah diberikan kepada staf atau operator, rahasia tersebut **tidak lagi hanya diketahui oleh pemiliknya** dan perlu ditangani sesuai prosedur keamanan yang berlaku.

Gunakan Mekanisme Kewenangan yang Benar

Apabila Penanda Tangan sedang tidak tersedia sedangkan dokumen harus segera diproses, jangan menggunakan TTE milik pejabat tersebut.

Gunakan mekanisme pengalihan, pelimpahan, atau kewenangan lain **sesuai ketentuan organisasi yang berlaku**. Pihak yang memang

memperoleh kewenangan kemudian menggunakan **identitas dan TTE miliknya sendiri**.

Cara tersebut menjaga hubungan yang jelas antara **orang yang melakukan penandatanganan dan identitas elektronik yang digunakan**.

INGAT: Staf atau operator boleh membantu menyiapkan dan memproses dokumen, tetapi tidak boleh menggunakan TTE milik orang lain. Jangan menyimpan atau menggunakan *passphrase* pejabat, meskipun telah mendapat izin. Setiap Penanda Tangan menggunakan identitas dan TTE miliknya sendiri.

5.8 Risiko Penyalahgunaan Tanda Tangan Elektronik

Tanda Tangan Elektronik (TTE) berkaitan dengan **identitas dan persetujuan Penanda Tangan**. Karena itu, penyalahgunaan TTE dapat menimbulkan risiko yang lebih serius daripada sekadar penggunaan akun oleh orang lain.

Risiko dapat muncul ketika *passphrase*, akun, OTP, atau rahasia autentikasi yang digunakan dalam proses penandatanganan diketahui dan digunakan oleh pihak lain.

PP Nomor 71 Tahun 2019 mensyaratkan bahwa **Data Pembuatan Tanda Tangan Elektronik pada saat proses penandatanganan hanya berada dalam kuasa Penanda Tangan**. Penanda Tangan juga wajib menjaga kerahasiaannya dan bertanggung jawab atas penggunaannya (Republik Indonesia, 2019).

Dokumen Dapat Ditandatangani Menggunakan Identitas Orang Lain

Salah satu risiko utama adalah orang lain dapat mencoba melakukan proses penandatanganan menggunakan identitas Penanda Tangan.

Misalnya, seorang staf mengetahui akun dan *passphrase* pejabat kemudian menggunakannya untuk memproses TTE.

Walaupun staf merasa telah memperoleh izin, terdapat persoalan akuntabilitas: **orang yang melakukan proses penandatanganan**

berbeda dengan identitas Penanda Tangan yang digunakan dalam sistem.

Karena itu, *passphrase* tidak boleh diberikan sebagai cara untuk mewakili proses penandatanganan.

Persetujuan terhadap Dokumen Menjadi Bermasalah

PP Nomor 71 Tahun 2019 mensyaratkan adanya cara tertentu untuk menunjukkan bahwa **Penanda Tangan telah memberikan persetujuan terhadap Informasi Elektronik yang terkait** dengan TTE (Republik Indonesia, 2019).

Jika proses penandatanganan dilakukan oleh orang lain menggunakan identitas pemilik TTE, dapat timbul persoalan mengenai siapa yang sebenarnya melakukan tindakan penandatanganan dan memberikan persetujuan melalui sistem.

Hal ini menunjukkan mengapa:

“Pejabatnya sudah setuju secara lisan.”

tidak seharusnya diterjemahkan menjadi:

“Berarti staf boleh menggunakan TTE pejabat tersebut.”

Persetujuan terhadap pekerjaan dan penyerahan rahasia autentikasi merupakan dua hal yang berbeda.

Akuntabilitas Menjadi Lemah

TTE seharusnya membantu membangun hubungan antara dokumen, proses penandatanganan, dan identitas Penanda Tangan.

Jika identitas elektronik digunakan bersama, nilai akuntabilitas tersebut menjadi berkurang.

Sebagai contoh, sistem mencatat bahwa sebuah dokumen ditandatangani menggunakan identitas **Pejabat A**. Namun, *passphrase* Pejabat A ternyata diketahui oleh beberapa staf.

Ketika kemudian dilakukan pemeriksaan, muncul pertanyaan:

Siapa yang sebenarnya melakukan proses penandatanganan?

Kondisi seperti inilah yang harus dicegah dengan menjaga rahasia autentikasi tetap berada dalam kendali pemiliknya.

Penyalahgunaan Dapat Tidak Segera Diketahui

Risiko menjadi lebih besar apabila *passphrase* telah lama diketahui orang lain.

Pemilik TTE mungkin tidak mengetahui kapan rahasia tersebut digunakan, dokumen apa yang diproses, atau apakah *passphrase* pernah diberikan lagi kepada pihak lain.

Karena itu, jangan mempertahankan kebiasaan:

“Passphrase saya memang dipegang staf.”

Jika rahasia autentikasi sudah diketahui pihak lain, lakukan tindakan pengamanan sesuai prosedur organisasi dan mekanisme Penyelenggara Sertifikasi Elektronik yang digunakan.

Lindungi TTE seperti Melindungi Identitas Anda

Pencegahan penyalahgunaan sebenarnya dapat dimulai dari beberapa prinsip sederhana:

jangan memberikan *passphrase* atau OTP kepada orang lain;

jangan menitipkan proses penandatanganan;

jangan menggunakan TTE milik orang lain;

pastikan dokumen yang akan ditandatangani telah diperiksa;

dan

segera laporkan apabila terdapat dugaan penyalahgunaan TTE.

TTE memberikan kemudahan dalam proses administrasi elektronik, tetapi kemudahan tersebut harus tetap disertai dengan perlindungan terhadap identitas dan rahasia autentikasi Penanda Tangan.

INGAT: Penyalahgunaan TTE dapat membuat suatu proses penandatanganan dilakukan menggunakan identitas Anda oleh orang lain. Jangan membagikan *passphrase*, OTP, atau rahasia autentikasi. Setiap Penanda Tangan harus menjaga kendali atas identitas dan proses penandatangerannya sendiri.

5.9 Apa yang Harus Dilakukan Jika Passphrase Diduga Telah Diketahui Orang Lain?

Jika *passphrase* Tanda Tangan Elektronik diduga telah diketahui oleh orang lain, kondisi tersebut **tidak boleh diabaikan**, meskipun belum diketahui adanya penyalahgunaan.

PP Nomor 71 Tahun 2019 mewajibkan Penanda Tangan menjaga kerahasiaan dan bertanggung jawab atas Data Pembuatan Tanda Tangan Elektronik. Regulasi tersebut juga mensyaratkan bahwa pada proses penandatanganan perlu dipastikan Data Pembuatan Tanda Tangan Elektronik tidak dilaporkan hilang, tidak dilaporkan berpindah tangan kepada orang yang tidak berhak, dan tetap berada dalam kuasa Penanda Tangan (Republik Indonesia, 2019).

Jangan Menunggu Terjadi Penyalahgunaan

Kecurigaan dapat muncul dalam berbagai kondisi, misalnya:

passphrase pernah diberikan kepada staf;

passphrase tidak sengaja terkirim melalui WhatsApp;

passphrase terlihat atau diketahui orang lain;

atau **terdapat aktivitas TTE yang tidak dikenali.**

Dalam kondisi tersebut, jangan menunggu sampai ditemukan dokumen yang ditandatangani tanpa kewenangan.

Segera Lakukan Pengamanan

Apabila *passphrase* diduga telah diketahui pihak lain, lakukan tindakan berikut sesuai mekanisme organisasi dan Penyelenggara Sertifikasi Elektronik (PSrE) yang digunakan:

segera hentikan penggunaan passphrase yang diduga tidak lagi rahasia;

ubah atau lakukan pengamanan kembali credential apabila fasilitas tersebut tersedia;

laporkan kepada pengelola TTE atau pihak yang bertanggung jawab di organisasi;

hubungi PSrE apabila diperlukan tindakan terhadap Sertifikat Elektronik;

dan periksa aktivitas atau dokumen yang ditandatangani apabila terdapat dugaan penyalahgunaan.

Langkah teknis dapat berbeda bergantung pada layanan PSrE yang digunakan. Karena itu, pengguna sebaiknya **tidak mencoba menyelesaikan sendiri dengan mengabaikan prosedur penyelenggara.**

Jika TTE Diduga Telah Digunakan Orang Lain

Jika ditemukan dokumen atau aktivitas penandatanganan yang tidak dilakukan oleh pemilik TTE, **segera laporkan sebagai dugaan insiden keamanan.**

Informasi seperti waktu kejadian, dokumen terkait, notifikasi, email, *screenshot*, dan informasi aktivitas lain sebaiknya tidak dihapus karena dapat membantu proses pemeriksaan.

Jangan mencoba menutupi kejadian karena merasa pernah memberikan *passphrase* kepada orang lain. Semakin cepat kejadian diketahui, semakin cepat tindakan pengamanan dan pemeriksaan dapat dilakukan.

Jangan Mengulangi *Passphrase* yang Sama

Setelah mekanisme pengamanan atau perubahan *passphrase* dilakukan, jangan memberikan *passphrase* baru kepada staf atau pihak lain.

Jika sebelumnya terdapat kebiasaan staf melakukan penandatanganan atas nama pejabat, **perbaiki proses kerjanya**, bukan sekadar mengganti *passphrase*.

Staf tetap dapat mempersiapkan dokumen, sedangkan Penanda Tangan melakukan sendiri autentikasi, persetujuan, dan proses penandatanganan.

Prinsipnya sederhana:

Diduga diketahui orang lain → amankan.

Diduga disalahgunakan → laporkan dan periksa.

Setelah diamankan → jangan dibagikan kembali.

INGAT: Jika *passphrase* Tanda Tangan Elektronik diduga telah diketahui orang lain, segera lakukan pengamanan dan laporkan sesuai prosedur. Jangan menunggu sampai terjadi penyalahgunaan. Jika terdapat aktivitas penandatanganan yang tidak Anda lakukan, **perlakukan sebagai dugaan insiden keamanan dan segera laporkan.**

5.10 Tanggung Jawab Pemilik Tanda Tangan Elektronik

Pemilik Tanda Tangan Elektronik (TTE) memiliki tanggung jawab untuk **menjaga agar identitas dan mekanisme penandatanganannya tetap berada dalam kendalinya**. Tanggung jawab tersebut tidak berhenti pada saat Sertifikat Elektronik diterbitkan, tetapi berlaku selama TTE digunakan.

PP Nomor 71 Tahun 2019 mengatur bahwa Penanda Tangan wajib menjaga kerahasiaan dan bertanggung jawab atas Data Pembuatan Tanda Tangan Elektronik. Pada saat proses penandatanganan, data tersebut juga harus berada dalam kuasa Penanda Tangan (Republik Indonesia, 2019).

Menjaga Kerahasiaan *Passphrase*

Dalam praktik penggunaan TTE, salah satu tanggung jawab paling penting adalah menjaga *passphrase* dan rahasia autentikasi lainnya.

Penanda Tangan tidak boleh memberikan *passphrase* kepada:

staf atau operator;

rekan kerja atau atasan;

administrator atau teknisi;

maupun **vendor dan pihak ketiga**.

Kepercayaan kepada seseorang tidak menghilangkan kewajiban untuk menjaga kerahasiaan mekanisme autentikasi.

Memeriksa Dokumen Sebelum Menandatangani

Penanda Tangan juga harus memastikan bahwa dokumen yang akan ditandatangani merupakan dokumen yang memang dimaksudkan untuk mendapatkan persetujuannya.

PP Nomor 71 Tahun 2019 mensyaratkan bahwa sebelum penandatanganan, **Informasi Elektronik yang akan ditandatangani harus diketahui dan dipahami oleh Penanda Tangan**. Selain itu, harus terdapat cara untuk menunjukkan bahwa Penanda Tangan memberikan persetujuan terhadap Informasi Elektronik tersebut (Republik Indonesia, 2019).

Karena itu, jangan memasukkan *passphrase* atau menyetujui permintaan TTE tanpa terlebih dahulu mengetahui dokumen yang sedang diproses.

Melakukan Sendiri Proses Penandatanganan

Staf dapat membantu menyiapkan dokumen, tetapi **Penanda Tangan harus tetap mengendalikan proses autentikasi dan penandatangerannya sendiri.**

Hindari kebiasaan:

“Passphrase saya dipegang staf.”

atau

“Kalau saya tidak ada, staf yang tanda tangan.”

Jika Penanda Tangan berhalangan, gunakan mekanisme kewenangan yang berlaku dalam organisasi. Jangan menyerahkan identitas dan rahasia autentikasi kepada orang lain.

Seegera Bertindak Jika Terjadi Masalah

Jika *passphrase* diketahui orang lain, Sertifikat Elektronik diduga disalahgunakan, atau terdapat dokumen yang tidak dikenali tetapi menggunakan TTE miliknya, Penanda Tangan harus **segera melakukan tindakan pengamanan dan pelaporan.**

PP Nomor 71 Tahun 2019 juga mengatur kewajiban Penanda Tangan untuk memberitahukan pihak terkait apabila Data Pembuatan Tanda Tangan Elektronik diketahui oleh pihak lain yang tidak berhak atau terdapat keadaan yang menimbulkan risiko akibat kemungkinan penyalahgunaan (Republik Indonesia, 2019).

Karena itu, insiden terkait TTE tidak boleh dibiarkan hanya karena belum diketahui adanya dampak.

TTE adalah Kemudahan Sekaligus Tanggung Jawab

TTE membuat proses administrasi dapat dilakukan secara elektronik dengan lebih efisien. Namun, kemudahan tersebut harus disertai kedisiplinan dalam menjaga identitas elektronik.

Prinsip tanggung jawab pemilik TTE dapat diringkas menjadi:

jaga kerahasiaan *passphrase*;

periksa dokumen sebelum menandatangani;

lakukan sendiri proses autentikasi dan penandatanganan;

dan

segera laporkan apabila terdapat dugaan penyalahgunaan.

INGAT: Pemilik TTE bertanggung jawab menjaga kendali atas identitas dan rahasia autentikasinya. Jangan memberikan *passphrase*, periksa dokumen sebelum menandatangani, lakukan sendiri proses penandatanganan, dan **segera laporkan jika terdapat dugaan penyalahgunaan TTE.**

BAB 6 HATI-HATI MEMFOTO, SCREENSHOT, DAN MENGIRIM DATA PASIEN

6.1 Screenshot SIMRS Dapat Mengandung Data Pribadi

Screenshot atau tangkapan layar sering digunakan untuk menunjukkan kesalahan aplikasi, meminta bantuan teknis, atau mendokumentasikan suatu pekerjaan. Namun, tangkapan layar dari Sistem Informasi Manajemen Rumah Sakit (SIMRS) dapat memuat **data pribadi pasien yang seharusnya tidak disebarluaskan**.

Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi mengatur data kesehatan sebagai **Data Pribadi yang bersifat spesifik** (Republik Indonesia, 2022). Karena itu, pengguna perlu memperhatikan informasi yang terlihat sebelum mengambil dan membagikan *screenshot* dari SIMRS.

Periksa Isi Layar Sebelum Mengambil Screenshot

Satu tampilan SIMRS dapat memuat berbagai informasi, misalnya:

nama pasien;

NIK atau nomor identitas;

alamat dan nomor telepon;

nomor rekam medis;

tanggal lahir;

serta informasi lain yang berkaitan dengan pasien.

Bahkan ketika tujuan *screenshot* hanya untuk menunjukkan pesan *error*, bagian lain pada layar dapat ikut tertangkap.

Karena itu, sebelum mengambil *screenshot*, tanyakan:

“Apakah ada data pasien yang ikut terlihat?”

Jangan Langsung Mengirim Screenshot ke Grup

Risiko meningkat ketika *screenshot* langsung dikirim ke grup WhatsApp atau media komunikasi lain.

Sebagai contoh, pengguna menemukan masalah pada SIMRS kemudian mengambil seluruh layar dan mengirimkannya ke grup:

“Mohon dicek, SIMRS error seperti ini.”

Pesan *error* mungkin memang perlu diperiksa, tetapi *screenshot* tersebut juga dapat memperlihatkan identitas atau informasi pasien yang **tidak diperlukan untuk menyelesaikan masalah teknis**.

Prinsip yang perlu digunakan adalah:

Bagikan informasi yang diperlukan untuk menyelesaikan masalah, bukan seluruh informasi yang kebetulan tampil di layar.

Samarkan Data yang Tidak Diperlukan

Jika *screenshot* memang diperlukan untuk pelaporan atau *troubleshooting*, periksa terlebih dahulu informasi yang terdapat di dalamnya.

Bagian yang tidak diperlukan dapat **dipotong (*crop*)** atau **disamarkan secara memadai** sebelum gambar dikirim.

Misalnya, jika teknisi hanya membutuhkan pesan:

“Database connection failed”

maka identitas pasien yang kebetulan berada pada layar yang sama tidak perlu ikut dikirim.

Pendekatan tersebut sejalan dengan prinsip **pemrosesan Data Pribadi secara terbatas dan spesifik, sah secara hukum, serta sesuai tujuan** sebagaimana diatur dalam UU Pelindungan Data Pribadi (Republik Indonesia, 2022).

Vendor Tidak Otomatis Membutuhkan Seluruh Data pada Layar

Vendor SIMRS atau teknisi mungkin membutuhkan *screenshot* untuk memahami suatu masalah. Namun, status sebagai vendor **tidak berarti seluruh data yang terdapat pada layar harus ikut diberikan**.

Jika masalah dapat ditunjukkan tanpa identitas pasien, gunakan tampilan yang tidak memperlihatkan identitas atau samarkan bagian yang tidak diperlukan.

Jika data pasien memang diperlukan untuk penanganan masalah tertentu, penggunaan dan penyampaiannya harus mengikuti

kewenangan, tujuan, serta mekanisme yang ditetapkan organisasi.

Perhatikan Tempat Penyimpanan Screenshot

Risiko tidak berhenti setelah *screenshot* dikirim.

Tangkapan layar dapat tetap tersimpan di folder *Pictures*, *Downloads*, galeri telepon, aplikasi percakapan, atau layanan penyimpanan lainnya.

Karena itu, *screenshot* yang mengandung data pribadi tidak boleh diperlakukan sebagai gambar biasa. **Salinan yang sudah tidak diperlukan perlu dikelola sesuai kebijakan organisasi**, terutama apabila gambar tersebut mengandung data pasien.

INGAT: Sebelum mengambil atau mengirim *screenshot* SIMRS, periksa apakah terdapat data pasien di dalamnya. Jika informasi tersebut tidak diperlukan, jangan ikut membagikannya. Potong atau samarkan data yang tidak relevan sebelum *screenshot* dikirim.

6.2 Risiko Memfoto Layar Komputer

Memfoto layar komputer menggunakan telepon seluler sering menjadi cara cepat untuk mendokumentasikan masalah atau meminta bantuan. Namun, jika layar menampilkan SIMRS, Rekam Medis Elektronik, atau Sistem Elektronik lainnya, foto tersebut dapat ikut merekam **data pribadi pasien yang tidak berkaitan dengan tujuan pengambilan foto**.

UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi menggolongkan data dan informasi kesehatan sebagai **Data Pribadi yang bersifat spesifik** (Republik Indonesia, 2022). Karena itu, pengguna perlu berhati-hati sebelum memfoto layar yang menampilkan informasi pasien.

Foto Dapat Merekam Lebih Banyak dari yang Disadari

Ketika memfoto layar, perhatian pengguna mungkin hanya tertuju pada satu bagian, misalnya pesan *error*. Namun, kamera dapat sekaligus menangkap:

nama atau identitas pasien;

nomor rekam medis;
NIK atau informasi identitas lainnya;
informasi yang tampil pada aplikasi;
serta bagian lain di sekitar layar.

Akibatnya, sebuah foto yang awalnya dibuat untuk melaporkan masalah teknis dapat berubah menjadi **salinan data pasien pada perangkat pribadi.**

Perangkat Pribadi Menambah Risiko

Risiko menjadi lebih besar apabila foto diambil menggunakan telepon seluler pribadi.

Foto dapat tersimpan di galeri, tercadangkan secara otomatis ke layanan *cloud*, muncul dalam pratinjau aplikasi, atau tanpa sengaja ikut dipilih ketika pengguna membagikan foto lainnya.

Karena itu, **jangan memfoto layar yang mengandung data pasien menggunakan perangkat pribadi apabila tidak diperlukan dan tidak sesuai dengan kebijakan organisasi.**

Jangan Memfoto Seluruh Layar Hanya untuk Menunjukkan Error

Jika tujuan pelaporan hanya untuk menunjukkan pesan kesalahan, data pasien yang berada di layar tidak perlu ikut didokumentasikan.

Sebagai contoh, teknisi hanya membutuhkan informasi:

“Internal Server Error”

maka nama pasien, nomor rekam medis, atau informasi lainnya tidak perlu ikut terlihat.

Jika dokumentasi memang diperlukan, gunakan mekanisme yang ditetapkan organisasi dan **batasi informasi hanya pada bagian yang diperlukan.** Prinsip ini sejalan dengan UU PDP yang mensyaratkan pemrosesan Data Pribadi dilakukan secara terbatas, spesifik, sah secara hukum, dan sesuai dengan tujuan (Republik Indonesia, 2022).

Jangan Langsung Mengirim Foto kepada Vendor atau Grup

Setelah mengambil foto, pengguna sering langsung mengirimkannya melalui WhatsApp kepada administrator, vendor, atau grup kerja.

Sebelum mengirim, periksa kembali:

Apakah terdapat identitas pasien?

Apakah seluruh informasi pada foto memang diperlukan?

Siapa yang akan menerima foto tersebut?

Jika data pasien tidak diperlukan, jangan ikut mengirimkannya. Gunakan foto yang tidak menampilkan data pasien atau samarkan bagian yang tidak relevan.

Jika Terlanjur Memfoto Data Pasien

Jika foto yang mengandung data pasien terlanjur dibuat atau dikirim kepada pihak yang tidak seharusnya menerima, **jangan mengabaikannya**.

Hentikan penyebaran lebih lanjut dan lakukan tindakan sesuai prosedur organisasi. Jika terdapat kemungkinan data telah diterima oleh pihak yang tidak berwenang, kejadian tersebut perlu dilaporkan agar dapat dinilai dan ditangani dengan tepat.

Prinsip sederhananya adalah:

Lihat layar sebelum memfoto.

Periksa foto sebelum mengirim.

Jangan dokumentasikan data yang tidak diperlukan.

INGAT: Memfoto layar komputer dapat membuat salinan data pasien berpindah ke telepon seluler. Jangan memfoto layar SIMRS atau Sistem Elektronik yang mengandung data pasien jika tidak diperlukan. Jika dokumentasi memang dibutuhkan, **batasi hanya pada informasi yang diperlukan dan ikuti mekanisme organisasi.**

6.3 Foto Dokumen dan Data Pasien

Data pasien tidak hanya terdapat di dalam SIMRS atau Rekam Medis Elektronik. Informasi tersebut juga dapat terdapat pada **dokumen cetak, formulir, surat, hasil pemeriksaan, daftar pasien, atau dokumen administratif lainnya.**

Ketika dokumen tersebut difoto menggunakan telepon seluler, informasi yang sebelumnya berada pada dokumen fisik berubah menjadi **salinan digital** yang dapat tersimpan, disalin, dan dibagikan dengan mudah.

UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi menggolongkan data dan informasi kesehatan sebagai **Data Pribadi yang bersifat spesifik** (Republik Indonesia, 2022). Oleh karena itu, foto dokumen yang memuat informasi pasien juga perlu dilindungi.

Jangan Memfoto Dokumen Tanpa Kebutuhan

Kemudahan kamera pada telepon seluler dapat mendorong kebiasaan memfoto dokumen sebagai cara cepat untuk menyimpan atau menyampaikan informasi.

Sebelum melakukannya, pengguna perlu mempertimbangkan:

Apakah foto tersebut memang diperlukan untuk pekerjaan?

Apakah seluruh informasi pada dokumen perlu ikut difoto?

Apakah perangkat dan media yang digunakan sesuai dengan kebijakan organisasi?

Jika tujuan dapat dicapai tanpa membuat salinan foto data pasien, **hindari membuat salinan yang tidak diperlukan.**

Perhatikan Informasi yang Ikut Terfoto

Satu lembar dokumen dapat mengandung lebih banyak informasi daripada yang sebenarnya dibutuhkan.

Misalnya, pengguna hanya membutuhkan satu bagian tertentu, tetapi foto juga menangkap nama pasien, NIK, nomor rekam medis, alamat, nomor telepon, atau informasi lainnya.

Prinsip pemrosesan Data Pribadi dalam UU PDP antara lain mengharuskan pemrosesan dilakukan secara **terbatas dan spesifik, sah secara hukum, serta sesuai dengan tujuannya** (Republik Indonesia, 2022).

Karena itu, dokumentasikan **hanya informasi yang memang diperlukan dan sesuai kewenangan.**

Jangan Menyimpan Foto Data Pasien di Galeri Pribadi

Foto dokumen pasien yang dibuat menggunakan telepon seluler dapat tetap tersimpan di galeri setelah kebutuhan pekerjaan selesai.

Selain itu, perangkat dapat memiliki fitur pencadangan otomatis ke layanan *cloud*. Akibatnya, pengguna mungkin tidak menyadari bahwa salinan data pasien juga tersimpan di lokasi lain.

Karena itu, **hindari menyimpan foto dokumen pasien pada perangkat pribadi**, terutama jika tidak terdapat kebutuhan dan mekanisme organisasi yang membenarkannya.

Jangan Membagikan Foto kepada Pihak yang Tidak Berkepentingan

Foto dokumen pasien tidak boleh diteruskan kepada rekan kerja, grup WhatsApp, vendor, atau pihak lain hanya karena cara tersebut dianggap praktis.

Jika informasi memang harus disampaikan untuk kepentingan pekerjaan, gunakan **mekanisme komunikasi yang ditetapkan organisasi dan batasi data sesuai kebutuhan penerima**.

Foto yang telah diterima juga tidak boleh diteruskan kembali untuk tujuan lain tanpa kewenangan yang sesuai.

Jika Foto Terlanjur Tersebar

Jika foto dokumen yang mengandung data pasien terlanjur dikirim kepada pihak yang tidak berwenang atau ke grup yang salah, **jangan meneruskannya lagi dan segera laporkan sesuai prosedur organisasi**.

Penghapusan foto dari perangkat sendiri belum tentu berarti seluruh salinan telah hilang karena gambar mungkin sudah diterima, disimpan, atau diteruskan oleh pihak lain.

INGAT: Foto dokumen pasien tetap merupakan salinan informasi pasien. Jangan memfoto, menyimpan, atau membagikannya tanpa kebutuhan dan kewenangan yang sesuai. **Kemudahan kamera telepon seluler bukan alasan untuk membuat salinan data pasien secara bebas.**

6.4 Dokumen Identitas dan Dokumen Pendukung Pasien

Dalam proses pelayanan dan administrasi, rumah sakit dapat menerima berbagai dokumen yang berkaitan dengan pasien.

Dokumen tersebut dapat mengandung **Data Pribadi** sehingga tidak boleh diperlakukan seperti dokumen biasa yang dapat difoto, disalin, disimpan, atau dibagikan tanpa memperhatikan tujuan dan kewenangan.

UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi membedakan Data Pribadi menjadi **Data Pribadi yang bersifat spesifik** dan **Data Pribadi yang bersifat umum**. Data kesehatan termasuk Data Pribadi yang bersifat spesifik, sedangkan nama lengkap, jenis kelamin, kewarganegaraan, agama, dan status perkawinan termasuk Data Pribadi yang bersifat umum (Republik Indonesia, 2022).

Dokumen Dapat Memuat Banyak Data Pribadi

Dokumen identitas atau dokumen pendukung dapat memuat berbagai informasi, misalnya:

nama lengkap;

NIK atau nomor identitas;

alamat;

tanggal lahir;

foto;

informasi keluarga;

serta informasi lain yang berkaitan dengan pasien.

Karena itu, satu lembar dokumen dapat mengandung beberapa Data Pribadi sekaligus.

Pengguna perlu memperhatikan bukan hanya dokumen aslinya, tetapi juga **fotokopi, hasil scan, foto, dan file digital** yang dibuat dari dokumen tersebut.

Gunakan Dokumen Sesuai Tujuan

Jika dokumen diberikan untuk keperluan tertentu, penggunaannya harus mengikuti tujuan dan kewenangan yang berlaku.

UU PDP menetapkan prinsip bahwa pemrosesan Data Pribadi dilakukan secara **terbatas dan spesifik, sah secara hukum, serta transparan**, dan sesuai dengan tujuan pemrosesan Data Pribadi (Republik Indonesia, 2022).

Artinya, keberadaan dokumen di lingkungan kerja bukan berarti seluruh pegawai bebas melihat, menyalin, atau menggunakannya.

Akses tetap mengikuti kebutuhan pekerjaan.

Jangan Membuat Salinan yang Tidak Diperlukan

Hindari membuat salinan tambahan hanya untuk kemudahan pribadi, misalnya memfoto dokumen menggunakan telepon seluler agar dapat dilihat kembali kemudian.

Setiap fotokopi, *scan*, foto, atau file yang dibuat akan menambah **salinan data yang harus dilindungi**.

Jika salinan memang diperlukan untuk proses kerja, gunakan mekanisme yang telah ditetapkan organisasi dan simpan hanya pada lokasi yang sesuai.

Jangan Membagikan Dokumen melalui Media Pribadi

Dokumen identitas dan dokumen pendukung pasien tidak seharusnya dikirim melalui WhatsApp pribadi, email pribadi, penyimpanan *cloud* pribadi, atau media lain hanya karena dianggap lebih praktis.

Sebelum mengirim dokumen, pastikan:

penerima memang berwenang;

dokumen memang diperlukan;

dan **media yang digunakan sesuai dengan mekanisme organisasi.**

Jika hanya sebagian informasi yang dibutuhkan, jangan membagikan seluruh dokumen apabila hal tersebut tidak diperlukan.

Perhatikan Dokumen Setelah Digunakan

Pelindungan data tidak berhenti setelah proses administrasi selesai.

Dokumen cetak tidak boleh dibiarkan terbuka di meja atau tempat yang dapat dilihat pihak yang tidak berkepentingan. File hasil *scan* atau foto juga tidak seharusnya dibiarkan tersimpan pada perangkat atau lokasi yang tidak sesuai.

Prinsip sederhananya adalah:

akses seperlunya;

salin seperlunya;

bagikan hanya kepada pihak yang berwenang;

dan simpan melalui mekanisme yang ditetapkan organisasi.

INGAT: Dokumen identitas dan dokumen pendukung pasien dapat mengandung Data Pribadi. Jangan memfoto, menyalin, menyimpan, atau membagikannya hanya karena dokumen tersebut berada dalam jangkauan Anda. **Gunakan data sesuai kewenangan dan kebutuhan pekerjaan.**

6.5 Jangan Menyimpan Data Pasien pada Galeri Ponsel Pribadi

Ponsel pribadi sering digunakan untuk membantu komunikasi dan pekerjaan sehari-hari. Namun, **galeri ponsel pribadi bukan tempat yang tepat untuk menyimpan data pasien.**

Foto dokumen, foto layar komputer, atau *screenshot* SIMRS dapat mengandung nama, nomor rekam medis, NIK, maupun informasi lain yang berkaitan dengan pasien. Jika gambar tersebut tersimpan di galeri pribadi, data pasien telah berpindah dari sistem atau dokumen organisasi ke **perangkat yang pengelolaannya berada pada pengguna.**

UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi mengatur bahwa pemrosesan Data Pribadi harus dilakukan secara terbatas dan spesifik, sah secara hukum, transparan, serta sesuai dengan tujuan pemrosesan (Republik Indonesia, 2022).

Galeri Ponsel Dapat Membuat Salinan Data Bertambah

Foto yang tersimpan pada ponsel tidak selalu hanya berada pada satu lokasi. Bergantung pada konfigurasi perangkat, foto dapat tersinkronisasi atau dicadangkan ke layanan penyimpanan *cloud*.

Akibatnya, satu foto data pasien dapat memiliki beberapa salinan tanpa disadari pengguna.

Risiko juga muncul ketika ponsel:

dipinjamkan kepada orang lain;

hilang atau dicuri;

diperbaiki oleh pihak lain;
atau **digunakan untuk membagikan foto dan pengguna salah memilih gambar.**

Karena itu, membuat foto data pasien menggunakan ponsel pribadi dapat menciptakan risiko yang sebenarnya tidak diperlukan.

Jangan Menggunakan Galeri sebagai Arsip Pekerjaan

Hindari kebiasaan menyimpan foto data pasien dengan alasan:

“Nanti saya hapus.”

“Hanya untuk mengingat datanya.”

“Supaya kalau dibutuhkan tidak perlu membuka SIMRS lagi.”

“Cuma untuk pekerjaan.”

Tujuan pekerjaan tidak otomatis menjadikan seluruh cara penyimpanan dapat dibenarkan. Jika informasi tersedia melalui SIMRS atau media resmi organisasi, **gunakan sumber tersebut daripada membuat salinan pribadi pada ponsel.**

Jika Dokumentasi Memang Diperlukan

Dalam kondisi tertentu, dokumentasi mungkin memang diperlukan untuk pekerjaan. Gunakan **mekanisme dan media yang ditetapkan organisasi** serta batasi data yang didokumentasikan hanya pada informasi yang diperlukan.

Jika kebutuhan hanya untuk menunjukkan *error* aplikasi, hindari memasukkan identitas pasien. Gunakan *crop*, penyamaran yang memadai, atau data uji apabila memungkinkan.

Prinsipnya adalah **meminimalkan data pasien yang berpindah ke perangkat dan media lain.**

Jika Data Pasien Terlanjur Tersimpan

Jika foto atau *screenshot* data pasien terlanjur tersimpan pada galeri ponsel pribadi, jangan membagikannya lebih lanjut.

Kelola atau hapus salinan tersebut sesuai kebijakan organisasi. Jika data telah tersinkronisasi ke layanan lain, terkirim kepada pihak yang tidak berwenang, atau terdapat kemungkinan penyalahgunaan, **laporkan sesuai prosedur keamanan informasi yang berlaku.**

INGAT: Jangan menjadikan galeri ponsel pribadi sebagai tempat penyimpanan data pasien. Hindari memfoto dokumen atau layar

yang mengandung data pasien apabila tidak diperlukan. **Gunakan sistem dan media resmi organisasi untuk menyimpan serta memproses informasi pekerjaan.**

6.6 Minimalkan Data Sebelum Membagikannya

Dalam pekerjaan, data pasien terkadang perlu dibagikan kepada pihak lain yang memang berwenang, misalnya untuk koordinasi pekerjaan atau penyelesaian masalah teknis. Namun, **kebutuhan untuk membagikan informasi tidak berarti seluruh data pasien harus ikut dibagikan.**

Prinsip yang perlu diterapkan adalah **gunakan dan bagikan data seminimal mungkin sesuai tujuan yang hendak dicapai.**

UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi menetapkan bahwa pemrosesan Data Pribadi dilakukan secara **terbatas dan spesifik, sah secara hukum, transparan, serta sesuai dengan tujuannya.** Pemrosesan juga dilakukan dengan menjamin hak Subjek Data Pribadi (Republik Indonesia, 2022).

Bagikan Hanya Data yang Dibutuhkan

Sebelum mengirim data, tanyakan:

Data apa yang sebenarnya dibutuhkan penerima?

Misalnya, administrator membutuhkan *screenshot* untuk memeriksa pesan *error* pada SIMRS. Jika masalah dapat dianalisis tanpa mengetahui identitas pasien, nama, NIK, nomor rekam medis, dan informasi pasien lainnya **tidak perlu ikut dikirim.**

Demikian pula ketika sebuah dokumen hanya membutuhkan satu bagian tertentu untuk diperiksa, jangan otomatis mengirim seluruh dokumen jika bagian lainnya tidak relevan.

Gunakan Crop atau Penyamaran Jika Diperlukan

Jika *screenshot*, foto, atau dokumen memang harus dibagikan, periksa terlebih dahulu apakah terdapat data yang tidak diperlukan.

Informasi yang tidak relevan dapat:

dipotong (*crop*);

disamarkan secara memadai;

atau **tidak disertakan sejak awal**.

Sebagai contoh, jika vendor hanya perlu melihat pesan:

“Connection timeout”

maka identitas pasien yang berada pada bagian lain layar tidak perlu ikut terlihat.

Tujuannya bukan sekadar membuat gambar lebih rapi, tetapi **mengurangi jumlah Data Pribadi yang ikut diproses dan diterima pihak lain**.

Periksa Penerima Sebelum Mengirim

Meminimalkan data juga perlu disertai pemeriksaan terhadap penerima.

Sebelum menekan tombol **Send**, periksa kembali:

Apakah penerimanya benar?

Apakah penerima memang membutuhkan data tersebut?

Apakah seluruh data yang terlampir diperlukan?

Apakah media yang digunakan sesuai dengan mekanisme organisasi?

Kebiasaan sederhana ini dapat mengurangi risiko salah kirim maupun penyampaian data secara berlebihan.

Data Minimal Tetap Harus Dilindungi

Mengurangi jumlah data bukan berarti data yang tersisa menjadi bebas untuk dibagikan.

Walaupun hanya satu nama, satu nomor rekam medis, atau sebagian informasi pasien, pengguna tetap harus memastikan bahwa **penerima, tujuan, dan media penyampaian sesuai dengan kewenangan dan kebutuhan pekerjaan**.

Prinsip sederhananya:

Jika tidak diperlukan, jangan ikut dikirim.

Jika cukup sebagian, jangan kirim seluruhnya.

Jika dapat disamarkan, samarkan data yang tidak diperlukan.

INGAT: Sebelum membagikan data pasien, minimalkan data sesuai kebutuhan. Jangan mengirim seluruh *screenshot*, foto, atau dokumen jika penerima hanya membutuhkan sebagian informasi.

Bagikan hanya data yang diperlukan, kepada pihak yang berwenang, untuk tujuan yang jelas.

6.7 Periksa Data dan Penerima Sebelum Mengirim

Kesalahan pengiriman data tidak selalu disebabkan oleh serangan siber. Dalam pekerjaan sehari-hari, data pasien dapat terkirim kepada pihak yang salah karena **pengguna terburu-buru, salah memilih kontak, salah memilih grup, atau tidak memeriksa kembali file yang dilampirkan.**

Karena itu, sebelum mengirim *screenshot*, foto, dokumen, atau informasi pasien, biasakan melakukan pemeriksaan sederhana terhadap **data yang akan dikirim dan siapa penerimanya.**

UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi menetapkan bahwa pemrosesan Data Pribadi harus dilakukan secara terbatas dan spesifik, sah secara hukum, transparan, serta sesuai dengan tujuan pemrosesan (Republik Indonesia, 2022).

Periksa Penerima Sebelum Menekan Send

Nama kontak yang mirip atau banyaknya grup percakapan dapat menyebabkan pengguna salah memilih penerima.

Sebelum mengirim informasi pasien, pastikan:

Apakah penerimanya sudah benar?

Apakah penerima memang berwenang menerima informasi tersebut?

Apakah informasi tersebut diperlukan untuk pekerjaannya?

Jangan hanya melihat foto profil atau nama kontak secara sekilas.

Pastikan tujuan pengiriman benar sebelum menekan tombol Send.

Periksa Kembali Data yang Akan Dikirim

Penerima yang benar belum tentu membutuhkan seluruh informasi yang terdapat dalam dokumen.

Misalnya, pengguna hendak mengirim *screenshot* pesan *error* kepada administrator. Sebelum mengirim, periksa apakah gambar

tersebut juga memperlihatkan nama pasien, nomor rekam medis, NIK, hasil pemeriksaan, atau informasi lain yang tidak diperlukan.

Jika ada data yang tidak relevan, **potong (crop) atau samarkan secara memadai sebelum dikirim.**

Prinsip pada subbab sebelumnya tetap berlaku:

Jika tidak diperlukan, jangan ikut dikirim.

Periksa Lampiran yang Dipilih

Kesalahan juga dapat terjadi karena pengguna memilih file atau foto yang salah.

Nama file yang hampir sama, beberapa *screenshot* dalam satu folder, atau banyak dokumen yang terbuka sekaligus dapat menyebabkan dokumen pasien yang berbeda ikut terkirim.

Sebelum mengirim lampiran:

buka kembali file yang dipilih;

pastikan dokumennya benar;

periksa data yang terdapat di dalamnya;

dan **pastikan tidak ada lampiran tambahan yang tidak diperlukan.**

Pemeriksaan beberapa detik sebelum mengirim dapat mencegah data diterima oleh pihak yang tidak seharusnya.

Berhati-hati dengan Grup Percakapan

Grup WhatsApp atau media komunikasi lain dapat beranggotakan banyak orang dengan tugas dan kewenangan yang berbeda.

Informasi yang memang boleh diketahui oleh satu anggota grup **belum tentu perlu diketahui oleh seluruh anggota grup.**

Karena itu, jangan menggunakan grup sebagai tempat membagikan data pasien hanya karena dianggap sebagai cara tercepat untuk memperoleh respons.

Jika informasi harus disampaikan, gunakan **mekanisme komunikasi yang ditetapkan organisasi dan penerima yang memang membutuhkan informasi tersebut.**

Jika Salah Mengirim Data

Jika data pasien terlanjur dikirim kepada penerima yang salah, jangan hanya menghapus pesan kemudian menganggap masalah selesai.

Penerima mungkin telah melihat, menyimpan, atau meneruskan informasi tersebut.

Hentikan penyebaran lebih lanjut dan segera laporkan kejadian sesuai prosedur organisasi agar risiko dapat dinilai dan tindakan yang diperlukan dapat dilakukan.

Jangan menunda pelaporan hanya karena kesalahan terjadi secara tidak sengaja.

INGAT: Sebelum menekan *Send*, periksa tiga hal: data, penerima, dan lampiran. Pastikan data memang diperlukan, penerimanya benar dan berwenang, serta tidak ada informasi pasien yang ikut terkirim tanpa kebutuhan. **Beberapa detik untuk memeriksa dapat mencegah terjadinya insiden pelanggaran data.**

6.8 Salah Kirim Data Merupakan Insiden Keamanan

Salah mengirim data pasien kepada orang atau grup yang tidak seharusnya menerima bukan sekadar kesalahan komunikasi. **Kejadian tersebut dapat menjadi insiden keamanan dan pelanggaran Data Pribadi yang harus segera ditangani.**

Kesalahan dapat terjadi melalui WhatsApp, email, aplikasi percakapan, maupun media lainnya. Penyebabnya sering sederhana, seperti salah memilih kontak, salah memilih grup, atau salah melampirkan dokumen.

UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi mewajibkan Pengendali Data Pribadi melindungi Data Pribadi dari pemrosesan yang tidak sah dan mencegah Data Pribadi diakses secara tidak sah (Republik Indonesia, 2022).

Salah Kirim Tetap Menimbulkan Risiko

Bayangkan seorang pegawai hendak mengirim foto dokumen pasien kepada petugas yang memang berwenang. Karena nama

kontak hampir sama, dokumen tersebut justru terkirim kepada orang lain.

Walaupun terjadi tanpa disengaja, data telah diterima oleh **pihak yang tidak seharusnya memperoleh akses.**

Hal yang sama dapat terjadi ketika:

screenshot SIMRS terkirim ke grup yang salah;

dokumen pasien dilampirkan pada email yang salah;

foto identitas pasien terkirim kepada kontak yang salah;

atau

file pasien A dikirim ketika seharusnya mengirim file pasien B.

Niat pengguna mungkin tidak untuk membocorkan data, tetapi risiko terhadap kerahasiaan data tetap ada.

Jangan Hanya Menghapus Pesan

Ketika menyadari salah kirim, tindakan pertama pengguna sering kali adalah menggunakan fitur **Delete** atau **Unsend**.

Tindakan tersebut dapat membantu membatasi penyebaran, tetapi **jangan menganggap masalah otomatis selesai setelah pesan dihapus.**

Penerima mungkin telah:

membaca pesan;

melihat dokumen;

mengunduh file;

mengambil screenshot;

atau **meneruskan informasi kepada pihak lain.**

Karena itu, salah kirim yang melibatkan data pasien perlu segera ditangani sesuai prosedur organisasi.

Segera Laporkan

Jika data pasien salah terkirim, pengguna sebaiknya **segera melaporkan kejadian tersebut kepada pihak yang ditetapkan oleh organisasi.**

Sampaikan informasi secara jelas, misalnya:

data apa yang terkirim;

kepada siapa data terkirim;

kapan kejadian terjadi;

dan **tindakan apa yang sudah dilakukan.**

Jangan menunda laporan karena merasa takut disalahkan atau berharap penerima tidak melihat pesan.

Pelaporan yang cepat memungkinkan organisasi menilai risiko dan menentukan tindakan yang diperlukan.

Jangan Menutupi Kesalahan

Salah kirim dapat terjadi karena kesalahan manusia. Hal yang justru dapat memperbesar risiko adalah **mengetahui adanya salah kirim tetapi tidak melaporkannya.**

Dalam kondisi tertentu, apabila terjadi kegagalan Pelindungan Data Pribadi, UU PDP mengatur kewajiban Pengendali Data Pribadi untuk menyampaikan pemberitahuan tertulis paling lambat **3 × 24 jam** kepada Subjek Data Pribadi dan lembaga. Pemberitahuan tersebut sekurang-kurangnya memuat Data Pribadi yang terungkap, kapan dan bagaimana data terungkap, serta upaya penanganan dan pemulihan (Republik Indonesia, 2022).

Penentuan apakah suatu kejadian memenuhi kondisi tersebut merupakan bagian dari penanganan insiden oleh pihak yang bertanggung jawab di organisasi. Karena itu, **pegawai harus segera melaporkan kejadian agar dapat dinilai dengan benar.**

Pencegahan Dimulai Sebelum Menekan *Send*

Cara paling sederhana mengurangi risiko salah kirim adalah membiasakan pemeriksaan sebelum mengirim:

periksa penerima;

periksa data;

periksa lampiran;

dan **pastikan media yang digunakan sesuai dengan ketentuan organisasi.**

Beberapa detik untuk melakukan pemeriksaan jauh lebih baik daripada harus menangani data pasien yang sudah terkirim kepada pihak yang salah.

INGAT: Salah kirim data pasien dapat menjadi insiden keamanan. Jangan hanya menghapus pesan dan diam. Hentikan penyebaran, segera laporkan kejadian, dan ikuti prosedur penanganan insiden

yang berlaku. Semakin cepat dilaporkan, semakin cepat risiko dapat ditangani.

6.9 Apa yang Harus Dilakukan Jika Terlanjur Salah Mengirim?

Kesalahan dapat terjadi meskipun pengguna telah berhati-hati. Dokumen pasien dapat terkirim ke kontak yang salah, *screenshot* SIMRS dapat masuk ke grup yang tidak tepat, atau file yang salah dapat terlampir dalam email.

Jika hal tersebut terjadi, **jangan panik, tetapi jangan pula mengabaikannya**. Tindakan yang cepat dapat membantu membatasi penyebaran dan dampak terhadap data pasien.

Hentikan Penyebaran Secepat Mungkin

Setelah menyadari adanya salah kirim, segera lakukan tindakan yang memungkinkan untuk membatasi penyebaran.

Jika aplikasi menyediakan fitur **Delete for Everyone**, *Unsend*, atau penarikan pesan, gunakan fitur tersebut sesegera mungkin.

Namun, perlu dipahami bahwa **menghapus pesan tidak menjamin data belum dilihat atau disimpan oleh penerima**.

Penerima mungkin telah membuka dokumen, mengunduh file, mengambil *screenshot*, atau meneruskan informasi sebelum pesan berhasil dihapus.

Karena itu, penghapusan pesan merupakan **tindakan awal**, bukan akhir dari penanganan kejadian.

Jangan Mengirim Pesan Tambahan yang Memperluas Masalah

Dalam kepanikan, pengguna dapat melakukan tindakan yang justru menambah penyebaran.

Misalnya, setelah salah mengirim dokumen ke grup, pengguna mengirim kembali dokumen yang sama sambil menulis:

“Maaf, dokumen pasien yang tadi jangan dibuka.”

Tindakan tersebut justru membuat salinan tambahan.

Jika perlu memberikan pemberitahuan kepada penerima, **jangan mengirim ulang data yang sama**. Sampaikan bahwa informasi

sebelumnya salah terkirim dan minta penerima tidak menggunakan, menyimpan, atau meneruskannya serta menghapusnya sesuai arahan organisasi.

Segera Laporkan Kejadian

Setelah melakukan tindakan awal, **segera laporkan salah kirim melalui mekanisme penanganan insiden yang berlaku di organisasi.**

Jangan menunggu sampai mengetahui apakah penerima telah membuka data.

Informasi yang sebaiknya disampaikan ketika melapor antara lain:

waktu kejadian;

jenis data yang salah terkirim;

penerima atau grup yang menerima;

media yang digunakan;

dan tindakan yang telah dilakukan setelah menyadari kesalahan.

Informasi tersebut membantu pihak yang menangani insiden menilai tingkat risiko dan menentukan langkah berikutnya.

Jangan Menghapus Bukti yang Dibutuhkan untuk Pemeriksaan

Selain berusaha membatasi penyebaran, pengguna perlu berhati-hati agar tidak menghilangkan informasi yang mungkin dibutuhkan untuk penanganan insiden.

Catat waktu kejadian, penerima, jenis data, dan kronologi singkat. Jika diperlukan, simpan bukti sesuai arahan pihak yang menangani insiden.

Tujuannya bukan untuk menyimpan lebih banyak salinan data pasien, tetapi agar organisasi memiliki informasi yang cukup untuk mengetahui **apa yang terjadi dan tindakan apa yang perlu dilakukan.**

Jangan Menutupi Kejadian

Kesalahan manusia dapat terjadi. Yang berbahaya adalah ketika pengguna mengetahui adanya salah kirim tetapi memilih tidak melaporkannya.

UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi mengatur bahwa dalam hal terjadi kegagalan Pelindungan Data Pribadi, Pengendali Data Pribadi wajib menyampaikan pemberitahuan tertulis paling lambat **3 x 24 jam** kepada Subjek Data Pribadi dan lembaga. Pemberitahuan sekurang-kurangnya memuat Data Pribadi yang terungkap, kapan dan bagaimana data terungkap, serta upaya penanganan dan pemulihan (Republik Indonesia, 2022).

Pegawai tidak perlu menentukan sendiri apakah suatu kejadian telah memenuhi kriteria tersebut. **Tugas pengguna adalah segera melaporkannya sehingga pihak yang bertanggung jawab dapat melakukan penilaian dan penanganan.**

Ingat Urutan Tindakannya

Jika terlanjur salah mengirim data pasien, ingat urutan sederhana berikut:

HENTIKAN → LAPORKAN → IKUTI PROSEDUR

Hentikan penyebaran sejauh yang masih memungkinkan.

Laporkan kejadian sesegera mungkin.

Ikuti prosedur dan arahan pihak yang menangani insiden.

Jangan mencoba menyelesaikan seluruh kejadian sendiri atau menganggap masalah selesai hanya karena pesan sudah dihapus.

INGAT: Jika data pasien terlanjur salah dikirim, segera batasi penyebarannya dan laporkan. Jangan hanya menghapus pesan lalu diam. Berikan informasi yang jelas mengenai apa yang terkirim, kepada siapa, kapan terjadi, dan tindakan yang sudah dilakukan. Pelaporan yang cepat membantu organisasi menangani risiko dengan lebih cepat.

BAB 7 WHATSAPP, EMAIL, CLOUD, DAN MEDIA SOSIAL

7.1 Risiko Pertukaran Data melalui Aplikasi Pesan Instan

Aplikasi pesan instan seperti WhatsApp dan aplikasi sejenis memudahkan komunikasi dalam pekerjaan. Informasi dapat dikirim dengan cepat kepada rekan kerja, unit lain, maupun pihak yang membantu penyelesaian suatu masalah.

Namun, kemudahan tersebut dapat menimbulkan risiko ketika aplikasi pesan instan digunakan untuk **bertukar data pasien tanpa memperhatikan kebutuhan, kewenangan penerima, dan mekanisme yang ditetapkan organisasi.**

UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi menetapkan bahwa pemrosesan Data Pribadi harus dilakukan secara terbatas dan spesifik, sah secara hukum, transparan, serta sesuai dengan tujuan pemrosesan (Republik Indonesia, 2022).

Pesan Instan Dapat Membuat Data Mudah Berpindah

Data yang dikirim melalui aplikasi pesan instan dapat dengan mudah:

diteruskan (*forward*);

disimpan atau diunduh;

diambil *screenshot*;

tersimpan pada perangkat penerima;

atau **diterima oleh pihak yang salah akibat kesalahan pengiriman.**

Karena itu, pengguna tidak boleh beranggapan bahwa data menjadi aman hanya karena dikirim melalui percakapan pribadi atau grup internal.

Setelah informasi dikirim, pengguna juga memiliki **kendali yang lebih terbatas terhadap salinan yang telah diterima pihak lain.**

Grup Kerja Bukan Berarti Semua Anggota Membutuhkan Data

Grup WhatsApp sering digunakan untuk koordinasi pekerjaan. Namun, keberadaan seseorang dalam grup tidak otomatis berarti

orang tersebut membutuhkan seluruh data yang dibagikan di dalamnya.

Misalnya, sebuah grup terdiri atas petugas pelayanan, administrator aplikasi, manajemen, dan vendor. Ketika *screenshot* SIMRS yang berisi data pasien dikirim ke grup, informasi tersebut dapat terlihat oleh **seluruh anggota**, padahal mungkin hanya satu orang yang membutuhkan informasi teknisnya.

Prinsip ***need-to-know*** yang telah dibahas pada BAB 3 tetap berlaku.

Data hanya diberikan kepada pihak yang memang membutuhkan dan berwenang menggunakannya.

Jangan Mengirim Data Pasien Hanya karena Lebih Praktis

Kemudahan bukan satu-satunya pertimbangan dalam memilih media komunikasi.

Hindari kebiasaan seperti:

“Kirim saja data pasiennya lewat WhatsApp.”

“Foto KTP-nya kirim ke grup.”

“Screenshot SIMRS-nya kirim semua supaya vendor bisa cek.”

Sebelum mengirim, pertimbangkan apakah data tersebut memang diperlukan dan apakah media yang digunakan sesuai dengan kebijakan organisasi.

Jika hanya sebagian informasi yang dibutuhkan, **minimalkan atau samarkan data yang tidak relevan.**

Risiko Tidak Berhenti Setelah Pesan Dihapus

Menghapus pesan dari percakapan tidak selalu berarti seluruh salinan data telah hilang.

Sebelum pesan dihapus, penerima mungkin telah membaca, menyimpan, mengunduh, mengambil *screenshot*, atau meneruskannya.

Karena itu, prinsip yang lebih aman adalah **mencegah data yang tidak diperlukan terkirim sejak awal**, bukan mengandalkan kemampuan untuk menghapusnya kemudian.

Gunakan Media Resmi yang Ditetapkan Organisasi

Apabila organisasi menyediakan sistem atau saluran resmi untuk pertukaran data pasien, gunakan mekanisme tersebut sesuai ketentuan yang berlaku.

Jika aplikasi pesan instan memang digunakan untuk komunikasi pekerjaan, pengguna tetap harus memperhatikan:

data apa yang dikirim;

siapa penerimanya;

apakah penerima membutuhkan data tersebut;

dan **apakah pengiriman tersebut sesuai dengan kebijakan organisasi.**

INGAT: Aplikasi pesan instan memudahkan komunikasi, tetapi bukan berarti semua data pasien boleh dikirim melaluinya. Sebelum mengirim, periksa data, penerima, tujuan, dan media yang digunakan. **Jika data tidak diperlukan, jangan dikirim.**

7.2 Data Pasien dalam Grup WhatsApp

Grup WhatsApp sering digunakan untuk mempercepat koordinasi pekerjaan. Namun, **grup kerja bukan tempat yang secara otomatis aman untuk membagikan data pasien.**

Sebelum mengirim informasi pasien ke dalam grup, pengguna perlu mempertimbangkan apakah seluruh anggota grup memang **berwenang dan membutuhkan informasi tersebut untuk menjalankan pekerjaannya.**

UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi mengatur bahwa data dan informasi kesehatan merupakan **Data Pribadi yang bersifat spesifik.** Pemrosesan Data Pribadi juga harus dilakukan secara terbatas dan spesifik serta sesuai dengan tujuan pemrosesan (Republik Indonesia, 2022).

Anggota Grup Memiliki Kebutuhan yang Berbeda

Sebuah grup WhatsApp dapat terdiri atas banyak pihak, misalnya pegawai dari beberapa unit, administrator aplikasi, pimpinan, teknisi, atau vendor.

Walaupun seluruh anggota tergabung dalam grup pekerjaan yang sama, **tidak berarti seluruh anggota memiliki kebutuhan dan kewenangan yang sama terhadap data pasien.**

Misalnya, administrator hanya membutuhkan informasi mengenai pesan *error* pada SIMRS. Jika pengguna mengirim *screenshot* lengkap yang memperlihatkan identitas dan informasi pasien, data tersebut ikut terlihat oleh seluruh anggota grup.

Prinsip ***need-to-know*** tetap berlaku:

Orang berada di dalam grup ≠ orang tersebut membutuhkan seluruh data yang dikirim ke grup.

Hindari Mengirim Data Pasien Secara Berlebihan

Pengguna perlu berhati-hati ketika hendak mengirim:

foto identitas pasien;

foto dokumen pasien;

***screenshot* SIMRS atau Rekam Medis Elektronik;**

hasil pemeriksaan;

atau informasi lain yang dapat mengidentifikasi pasien.

Jika tujuan komunikasi dapat dicapai tanpa mengirim data tersebut, **jangan ikut mengirimkannya.**

Jika sebagian informasi memang diperlukan, minimalkan data terlebih dahulu dengan memotong (*crop*) atau menyamarkan bagian yang tidak relevan.

Jangan Menganggap Grup Internal Pasti Aman

Kalimat seperti:

“Tidak apa-apa, ini grup internal.”

perlu dihindari sebagai alasan untuk membagikan data pasien.

Risiko tetap dapat terjadi. Anggota grup dapat berubah, seseorang dapat salah meneruskan pesan, perangkat anggota dapat digunakan orang lain, atau informasi dapat tersimpan lebih lama daripada kebutuhan awalnya.

Karena itu, keputusan untuk membagikan data harus didasarkan pada **tujuan, kebutuhan, kewenangan, dan prosedur organisasi**, bukan hanya karena grup dianggap internal.

Perhatikan Vendor dan Pihak Ketiga dalam Grup

Perhatian tambahan diperlukan apabila grup juga berisi vendor atau pihak ketiga.

Vendor mungkin membutuhkan informasi tertentu untuk melakukan *troubleshooting*, tetapi hal tersebut **tidak berarti vendor membutuhkan seluruh data pasien yang terlihat pada layar.**

Jika vendor hanya membutuhkan pesan *error*, kirim informasi teknis yang diperlukan tanpa menyertakan identitas pasien apabila identitas tersebut tidak relevan.

Prinsipnya:

Bagikan masalah teknisnya, bukan seluruh data pasiennya.

Jika Data Pasien Terlanjur Dikirim ke Grup yang Tidak Tepat

Jika data pasien terlanjur dikirim ke grup yang tidak seharusnya menerima informasi tersebut, lakukan tindakan untuk membatasi penyebaran dan **segera laporkan sesuai prosedur organisasi.**

Jangan hanya menghapus pesan kemudian menganggap kejadian selesai. Informasi mungkin telah dilihat, disimpan, atau diteruskan oleh anggota grup.

Sebagaimana dibahas pada BAB 6, salah kirim data dapat menjadi insiden keamanan yang perlu dinilai dan ditangani.

INGAT: Grup WhatsApp bukan berarti semua anggota boleh menerima seluruh data pasien. Sebelum mengirim, tanyakan: *Apakah data ini perlu dikirim? Apakah semua anggota grup perlu melihatnya?* Jika tidak, **jangan kirim atau minimalkan data terlebih dahulu.**

7.3 Penggunaan Email untuk Pertukaran Data

Email merupakan salah satu media komunikasi yang umum digunakan untuk mengirim dokumen dan informasi pekerjaan. Dibandingkan percakapan informal, email dapat memberikan pencatatan komunikasi yang lebih terstruktur. Namun, **penggunaan email tidak otomatis membuat pertukaran data pasien menjadi aman.**

UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi menetapkan bahwa pemrosesan Data Pribadi harus dilakukan secara terbatas dan spesifik, sah secara hukum, transparan, serta sesuai dengan tujuan pemrosesan (Republik Indonesia, 2022).

Karena itu, sebelum mengirim data pasien melalui email, pengguna harus memastikan bahwa **pengiriman memang diperlukan, penerimanya berwenang, dan data yang dikirim sesuai kebutuhan.**

Gunakan Email Resmi untuk Kepentingan Pekerjaan

Untuk komunikasi yang berkaitan dengan pekerjaan, gunakan **akun email resmi yang disediakan atau ditetapkan organisasi.**

Hindari memindahkan data pasien ke email pribadi hanya karena dianggap lebih mudah diakses.

Praktik seperti:

“Saya kirim dulu ke email pribadi supaya bisa dikerjakan di rumah.”

atau

“File-nya saya teruskan ke email pribadi supaya tidak lupa.”

dapat menyebabkan salinan data pasien berada di luar sistem dan pengelolaan yang ditetapkan organisasi.

Periksa Alamat Penerima

Salah satu risiko email adalah kesalahan memilih penerima, terutama ketika aplikasi secara otomatis menyarankan alamat berdasarkan nama yang diketik.

Sebelum menekan **Send**, periksa kembali alamat pada kolom:

To;

Cc;

dan **Bcc.**

Pastikan seluruh penerima memang membutuhkan dan berwenang menerima informasi tersebut.

Berhati-hatilah ketika menggunakan **Reply All**, karena balasan dapat terkirim kepada lebih banyak orang daripada yang sebenarnya diperlukan.

Periksa Lampiran Sebelum Mengirim

Kesalahan juga dapat terjadi ketika pengguna melampirkan file yang salah.

Sebelum mengirim email yang mengandung informasi pasien, buka kembali lampiran dan pastikan:

dokumennya benar;
data pasien yang terdapat di dalamnya memang diperlukan;
dan tidak terdapat file lain yang ikut terlampir tanpa kebutuhan.

Jika penerima hanya membutuhkan sebagian informasi, jangan mengirim seluruh dokumen apabila hal tersebut tidak diperlukan.

Jangan Menganggap Email sebagai Tempat Penyimpanan Data Pasien

Kotak masuk maupun folder **Sent Items** dapat menyimpan email dan lampiran dalam waktu lama.

Karena itu, jangan menggunakan email sebagai tempat penyimpanan atau arsip data pasien hanya karena informasi tersebut mudah dicari kembali.

Data pasien seharusnya disimpan dan dikelola melalui **sistem serta mekanisme penyimpanan yang ditetapkan organisasi.**

Waspada Email yang Meminta Data Pasien

Pengguna juga perlu berhati-hati terhadap email yang meminta pengiriman data dengan alasan mendesak.

Misalnya:

“Mohon segera kirim data pasien berikut.”

“Kami dari vendor, mohon kirim database untuk pengecekan.”

“Balas email ini dengan username dan password aplikasi.”

Jangan langsung memenuhi permintaan hanya berdasarkan nama pengirim atau isi email. **Verifikasi identitas, kewenangan, dan kebutuhan permintaan melalui mekanisme yang dapat dipercaya**, terutama jika permintaan tidak biasa.

Pembahasan mengenai *phishing* dan manipulasi melalui email akan dibahas lebih khusus pada bab mengenai *social engineering*.

Jika Salah Mengirim Email

Jika email yang mengandung data pasien terlanjur dikirim kepada penerima yang salah, **jangan hanya mengandalkan fitur *recall***.

Penerima mungkin telah membaca atau mengunduh lampiran sebelum email ditarik.

Segera lakukan tindakan untuk membatasi penyebaran dan **laporkan kejadian melalui prosedur penanganan insiden organisasi**, sebagaimana telah dibahas pada BAB 6.

INGAT: Email resmi bukan berarti semua data boleh dikirim melalui email. Sebelum menekan *Send*, periksa **penerima, data, dan lampiran**. Gunakan akun email resmi organisasi dan jangan memindahkan data pasien ke email pribadi hanya untuk kemudahan.

7.4 Risiko Menggunakan Email Pribadi

Email pribadi sering dianggap lebih praktis karena dapat diakses dari berbagai perangkat dan sudah biasa digunakan sehari-hari. Namun, **email pribadi tidak seharusnya digunakan untuk menyimpan atau mempertukarkan data pasien untuk kepentingan pekerjaan**, kecuali memang terdapat mekanisme resmi organisasi yang secara khusus mengaturnya.

Ketika data pasien dikirim ke akun email pribadi, salinan data dapat berpindah dari lingkungan yang dikelola organisasi ke akun dan layanan yang pengelolaannya berada di luar mekanisme internal rumah sakit.

UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi mewajibkan Pengendali Data Pribadi menjaga kerahasiaan Data Pribadi serta melakukan pengawasan terhadap setiap pihak yang terlibat dalam pemrosesan Data Pribadi (Republik Indonesia, 2022).

Data Dapat Tersimpan di Luar Lingkungan Organisasi

Praktik seperti berikut perlu dihindari:

“Saya kirim ke email pribadi supaya bisa dibuka dari rumah.”

“File pasien saya simpan dulu di email pribadi.”

“Email kantor sulit dibuka, kirim ke email pribadi saya saja.”

Cara tersebut mungkin terasa praktis, tetapi dapat menyebabkan dokumen pasien tersimpan pada kotak masuk, folder *Sent*, *Draft*, atau penyimpanan lain yang terkait dengan akun pribadi.

Akibatnya, organisasi menjadi lebih sulit mengendalikan **lokasi penyimpanan, akses, retensi, dan penghapusan data tersebut**.

Akun Pribadi Digunakan untuk Banyak Kepentingan

Email pribadi biasanya digunakan untuk berbagai aktivitas di luar pekerjaan, seperti pendaftaran layanan daring, media sosial, belanja, atau komunikasi pribadi.

Penggunaan satu akun untuk berbagai kepentingan dapat menambah risiko terhadap data pekerjaan yang ikut tersimpan di dalamnya.

Jika akun pribadi mengalami kompromi, data pasien yang pernah dikirim atau disimpan melalui akun tersebut juga dapat ikut terpapar.

Karena itu, **pisahkan komunikasi pekerjaan dari akun pribadi**.

Jangan Mengirim dari Email Kantor ke Email Pribadi untuk Kemudahan

Risiko tidak hanya muncul ketika data dikirim kepada orang lain.

Mengirim data dari:

email kantor → email pribadi milik sendiri

tetap membuat salinan data berpindah ke lingkungan lain.

Demikian pula dengan mengunduh dokumen dari email kantor kemudian mengunggahnya ke email pribadi agar dapat dikerjakan menggunakan perangkat lain.

Jika pekerjaan perlu dilakukan dari luar lokasi kerja, gunakan **mekanisme akses jarak jauh atau fasilitas resmi yang disediakan organisasi**, apabila tersedia.

Hindari Menggunakan Email Pribadi untuk Berkomunikasi dengan Vendor

Vendor atau pihak ketiga juga tidak seharusnya meminta pegawai mengirim data pasien ke alamat email pribadi hanya untuk mempermudah *troubleshooting*.

Apabila pertukaran data memang diperlukan, gunakan **saluran resmi dan mekanisme yang telah ditetapkan organisasi**, dengan tetap menerapkan prinsip *need-to-know* dan minimalisasi data.

Vendor membutuhkan **data yang relevan untuk pekerjaannya**, bukan seluruh data yang tersedia.

Jika Data Pasien Terlanjur Dikirim ke Email Pribadi

Jika data pasien telah terlanjur dikirim ke email pribadi, jangan meneruskannya kepada pihak lain.

Ikuti prosedur organisasi untuk menangani dan menghapus salinan yang tidak semestinya. Jika data telah terkirim kepada pihak yang tidak berwenang, akun diduga telah diakses pihak lain, atau terdapat risiko kebocoran, **segera laporkan sebagai kejadian keamanan untuk dilakukan penilaian lebih lanjut**.

Jangan menganggap masalah selesai hanya karena email telah dihapus dari *Inbox*. Salinan dapat masih terdapat pada *Sent*, *Trash*, perangkat yang melakukan sinkronisasi, atau lokasi penyimpanan lainnya.

INGAT: Jangan menggunakan email pribadi untuk menyimpan atau mempertukarkan data pasien hanya karena lebih praktis. Gunakan akun, sistem, dan saluran komunikasi resmi yang ditetapkan organisasi. **Data pekerjaan harus tetap berada dalam mekanisme pengelolaan yang dapat dikendalikan oleh organisasi.**

7.5 Penyimpanan Cloud Pribadi

Layanan penyimpanan *cloud* memberikan kemudahan untuk menyimpan dan mengakses file dari berbagai perangkat. Namun, **penyimpanan cloud pribadi tidak seharusnya digunakan untuk menyimpan data pasien atau dokumen pekerjaan**, kecuali penggunaannya memang disediakan atau secara resmi ditetapkan oleh organisasi.

Ketika data pasien diunggah ke akun *cloud* pribadi, salinan data berpindah dari lingkungan yang dikelola organisasi ke akun yang

berada dalam kendali pribadi pengguna. Hal ini dapat mengurangi kemampuan organisasi dalam mengendalikan akses, penyimpanan, dan penghapusan data.

UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi mengatur bahwa Pengendali Data Pribadi wajib menjaga kerahasiaan Data Pribadi serta melakukan pengawasan terhadap pihak yang terlibat dalam pemrosesan Data Pribadi (Republik Indonesia, 2022).

Hindari Menyimpan Data Pasien pada Akun *Cloud* Pribadi

Pengguna perlu menghindari kebiasaan seperti:

“Saya simpan dulu di cloud pribadi supaya bisa dibuka dari rumah.”

“File pasien saya upload supaya bisa dibuka dari HP.”

“Saya backup dokumen pekerjaan ke akun pribadi supaya tidak hilang.”

Walaupun tujuannya untuk mempermudah pekerjaan, tindakan tersebut dapat menciptakan **salinan data pasien di luar media penyimpanan yang ditetapkan organisasi**.

Data pasien sebaiknya disimpan pada SIMRS, sistem dokumen, *file server*, atau media penyimpanan resmi lainnya sesuai kebijakan organisasi.

Sinkronisasi Otomatis Dapat Membuat Salinan Tanpa Disadari

Pengguna juga perlu memperhatikan fitur ***automatic backup dan synchronization***.

Komputer atau ponsel dapat dikonfigurasi untuk secara otomatis mencadangkan folder tertentu ke layanan *cloud*. Akibatnya, file pekerjaan yang mengandung data pasien dapat ikut terunggah tanpa pengguna sengaja memilih file tersebut.

Hal yang sama dapat terjadi pada foto dan *screenshot*. Foto layar SIMRS yang tersimpan di galeri ponsel dapat ikut dicadangkan apabila fitur sinkronisasi foto aktif.

Karena itu, **perhatikan lokasi penyimpanan dan fitur sinkronisasi pada perangkat yang digunakan untuk pekerjaan**.

Jangan Membagikan Data Menggunakan Tautan Pribadi

Layanan *cloud* biasanya memungkinkan pengguna membagikan file melalui sebuah tautan.

Kemudahan ini perlu digunakan dengan hati-hati. Konfigurasi seperti:

“Anyone with the link”

dapat menyebabkan file dapat diakses oleh pihak lain yang memperoleh tautan tersebut.

Jangan mengunggah data pasien ke *cloud* pribadi kemudian membagikan tautannya kepada rekan kerja atau vendor sebagai pengganti mekanisme pertukaran data resmi.

Jika organisasi menyediakan layanan berbagi file, gunakan layanan tersebut dengan **hak akses yang sesuai dan hanya kepada pihak yang membutuhkan.**

Menghapus File dari Komputer Belum Tentu Menghapus Salinan *Cloud*

Jika sebuah file telah tersinkronisasi, menghapus salinan pada satu perangkat belum tentu berarti seluruh salinan telah hilang.

File mungkin masih terdapat pada:

penyimpanan cloud;

folder sinkronisasi perangkat lain;

folder sampah atau *recycle bin*;

atau **salinan yang sebelumnya telah dibagikan.**

Karena itu, pencegahan jauh lebih baik daripada mencoba mencari dan menghapus berbagai salinan setelah data terlanjur tersebar.

Gunakan Penyimpanan Resmi Organisasi

Jika organisasi menyediakan *file server*, penyimpanan *cloud* organisasi, SIMRS, atau sistem pengelolaan dokumen, gunakan fasilitas tersebut sesuai peruntukannya.

Penggunaan layanan *cloud* tidak selalu dilarang. Yang menjadi masalah adalah **penggunaan akun dan penyimpanan pribadi tanpa mekanisme pengendalian organisasi untuk menyimpan Data Pribadi pasien.**

Prinsip sederhananya:

Data pekerjaan → penyimpanan resmi organisasi.

Data pasien → jangan dipindahkan ke cloud pribadi untuk kemudahan.

INGAT: Jangan menyimpan data pasien pada penyimpanan *cloud* pribadi hanya agar mudah diakses dari perangkat lain. Waspadai pula fitur sinkronisasi dan *backup* otomatis. Gunakan sistem dan media penyimpanan resmi yang ditetapkan organisasi.

7.6 Berbagi Tautan Dokumen dan Risiko Kesalahan Hak Akses

Berbagi dokumen melalui tautan dapat mempermudah kolaborasi karena pengguna tidak perlu mengirim file berulang kali. Namun, **kesalahan pengaturan hak akses pada tautan dapat menyebabkan dokumen dapat dibuka oleh pihak yang tidak seharusnya memperoleh akses.**

Risiko menjadi lebih serius apabila dokumen mengandung data pasien, data kesehatan, dokumen identitas, atau informasi internal rumah sakit.

UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi mengatur bahwa Pengendali Data Pribadi wajib melindungi Data Pribadi dari pemrosesan yang tidak sah serta mencegah Data Pribadi diakses secara tidak sah (Republik Indonesia, 2022).

Perhatikan Siapa yang Dapat Membuka Tautan

Layanan berbagi dokumen biasanya menyediakan beberapa pilihan hak akses. Istilahnya dapat berbeda pada setiap sistem, tetapi secara umum dapat berupa akses hanya untuk pengguna tertentu atau akses bagi siapa saja yang memperoleh tautan.

Pengaturan seperti:

“Anyone with the link”

perlu mendapatkan perhatian khusus.

Jika tautan diteruskan kepada orang lain, pihak tersebut mungkin dapat membuka dokumen tanpa harus memperoleh izin kembali dari pemilik dokumen.

Karena itu, untuk dokumen yang mengandung data pasien, **hindari membuat tautan terbuka apabila tidak diperlukan dan tidak sesuai dengan kebijakan organisasi.**

Berikan Akses Hanya kepada Pihak yang Membutuhkan

Jika dokumen hanya diperlukan oleh beberapa orang, berikan akses kepada **pengguna atau kelompok yang memang membutuhkan dokumen tersebut.**

Prinsip ***need-to-know* dan *least privilege*** yang telah dibahas pada BAB 3 tetap berlaku.

Sebagai contoh, apabila vendor hanya membutuhkan sebuah file untuk melakukan *troubleshooting*, tidak berarti vendor harus memperoleh akses ke seluruh folder yang berisi dokumen pasien lainnya.

Prinsipnya:

Butuh satu file → jangan otomatis memberikan akses ke seluruh folder.

Butuh membaca → jangan otomatis memberikan hak mengubah.

Tidak lagi membutuhkan → akses perlu dicabut sesuai mekanisme yang berlaku.

Hak View dan Edit Tidak Sama

Kesalahan lain adalah memberikan hak akses yang lebih besar daripada kebutuhan.

Jika seseorang hanya perlu membaca dokumen, hak ***view*** mungkin sudah mencukupi. Memberikan hak ***edit*** dapat memungkinkan penerima mengubah isi dokumen atau melakukan tindakan lain yang sebenarnya tidak diperlukan.

Sebelum membagikan tautan, periksa:

siapa yang memperoleh akses;

dokumen atau folder apa yang dapat diakses;

dan hak apa yang diberikan.

Jangan menggunakan pengaturan akses yang lebih luas hanya karena lebih mudah.

Tautan Dapat Diteruskan

Tautan yang dikirim melalui email atau aplikasi pesan dapat diteruskan kepada pihak lain.

Karena itu, jangan mengandalkan anggapan:

“Saya hanya mengirim link kepada satu orang.”

Keamanan dokumen tetap bergantung pada **konfigurasi hak akses yang diterapkan pada dokumen tersebut**, bukan hanya kepada siapa tautan pertama kali dikirim.

Jika sistem memungkinkan pembatasan berdasarkan akun atau identitas pengguna, gunakan mekanisme tersebut sesuai kebutuhan dan kebijakan organisasi.

Periksa Kembali Akses Setelah Pekerjaan Selesai

Hak akses yang sebelumnya diperlukan dapat menjadi tidak diperlukan setelah pekerjaan selesai.

Misalnya, vendor diberikan akses sementara untuk menangani gangguan aplikasi. Setelah pekerjaan selesai, akses tersebut perlu ditinjau dan dicabut apabila sudah tidak diperlukan.

Hal yang sama berlaku ketika pegawai berpindah tugas atau suatu tim tidak lagi terlibat dalam pekerjaan tertentu.

Akses yang pernah diberikan tidak seharusnya dianggap berlaku selamanya.

Jika Tautan Terlanjur Dibagikan Secara Terbuka

Jika diketahui bahwa dokumen yang mengandung data pasien dapat diakses lebih luas daripada yang seharusnya, **segera batasi atau cabut akses tersebut.**

Jika terdapat kemungkinan dokumen telah diakses oleh pihak yang tidak berwenang, laporkan melalui mekanisme penanganan insiden organisasi agar dapat dilakukan penilaian lebih lanjut.

Jangan hanya mengganti atau menghapus tautan kemudian menganggap kejadian selesai, karena dokumen mungkin telah diakses atau disalin sebelumnya.

INGAT: Sebelum membagikan tautan dokumen, periksa siapa yang dapat mengakses dan hak apa yang diberikan. Hindari akses terbuka seperti *“Anyone with the link”* untuk data pasien jika tidak

diperlukan. Terapkan prinsip: **orang yang tepat, data yang tepat, dan hak akses yang tepat.**

7.7 Data Pasien dan Media Sosial

Media sosial memungkinkan informasi menyebar dengan sangat cepat dan menjangkau banyak orang. Karena itu, **data pasien tidak boleh dipublikasikan melalui media sosial tanpa dasar, kewenangan, dan mekanisme yang sesuai.**

Data pasien dapat muncul dalam bentuk yang tidak selalu disadari, misalnya foto, video, *screenshot*, dokumen, atau tulisan yang mengandung informasi mengenai pasien.

UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi menggolongkan data dan informasi kesehatan sebagai **Data Pribadi yang bersifat spesifik** (Republik Indonesia, 2022).

Jangan Mengunggah Data Pasien ke Akun Pribadi

Pegawai perlu berhati-hati ketika menggunakan akun media sosial pribadi.

Hindari mengunggah:

foto pasien atau dokumen pasien;

***screenshot* SIMRS atau Rekam Medis Elektronik;**

hasil pemeriksaan atau informasi kesehatan;

foto gelang identitas pasien;

atau informasi lain yang dapat mengidentifikasi pasien.

Walaupun unggahan dibuat dengan tujuan berbagi pengalaman kerja, edukasi, atau sekadar dokumentasi aktivitas, **data pasien tetap harus dilindungi.**

Foto di Lingkungan Kerja Dapat Mengandung Data Pasien

Risiko tidak selalu berasal dari foto pasien secara langsung.

Misalnya, pegawai mengambil foto di ruang kerja untuk diunggah ke media sosial. Di belakangnya terdapat monitor yang menampilkan SIMRS, dokumen pasien di atas meja, papan informasi, label, atau informasi lain yang dapat terbaca.

Karena itu, sebelum mengambil dan mengunggah foto dari lingkungan kerja, **periksa seluruh bagian gambar**, bukan hanya objek utama yang ingin difoto.

Menyamarkan Nama Belum Tentu Cukup

Menghapus nama pasien tidak selalu membuat informasi aman untuk dipublikasikan.

Informasi lain dapat memungkinkan seseorang mengenali pasien, misalnya nomor rekam medis, foto, tanggal lahir, alamat, waktu pelayanan, atau kombinasi beberapa informasi lainnya.

Karena itu, jangan beranggapan:

“Namanya sudah saya tutup, berarti aman untuk diunggah.”

UU PDP mendefinisikan Data Pribadi sebagai data tentang orang perseorangan yang teridentifikasi atau **dapat diidentifikasi secara tersendiri maupun dikombinasikan dengan informasi lainnya** (Republik Indonesia, 2022).

Akun Privat Bukan Berarti Bebas Membagikan Data

Pengaturan akun menjadi *private* tidak menjadikan data pasien bebas untuk dipublikasikan.

Pengikut tetap dapat melihat informasi tersebut dan konten dapat disalin, diambil *screenshot*, atau diteruskan kepada pihak lain.

Hal yang sama berlaku untuk fitur seperti *Story*, *Status*, atau konten yang otomatis hilang setelah jangka waktu tertentu.

Konten sementara tetap dapat disalin sebelum menghilang.

Publikasi Resmi Harus Mengikuti Mekanisme Organisasi

Rumah sakit dapat memiliki kebutuhan untuk mempublikasikan kegiatan, edukasi kesehatan, dokumentasi pelayanan, atau informasi lainnya melalui media sosial resmi.

Namun, publikasi tersebut harus mengikuti **kebijakan, kewenangan, dan prosedur organisasi**, termasuk ketentuan yang berlaku apabila melibatkan Data Pribadi.

Pegawai tidak seharusnya mengambil keputusan sendiri untuk mempublikasikan data pasien hanya karena merasa konten tersebut bermanfaat.

Prinsip pemrosesan Data Pribadi dalam UU PDP tetap harus diperhatikan, termasuk bahwa pemrosesan dilakukan secara terbatas dan spesifik, sah secara hukum, transparan, serta sesuai dengan tujuan pemrosesan (Republik Indonesia, 2022).

Jika Data Pasien Terlanjur Terunggah

Jika diketahui bahwa data pasien terlanjur dipublikasikan melalui media sosial secara tidak semestinya, **segera lakukan tindakan untuk membatasi penyebarannya dan laporkan sesuai prosedur organisasi.**

Menghapus unggahan merupakan tindakan awal, tetapi tidak menjamin seluruh salinan telah hilang. Konten mungkin telah dilihat, disimpan, atau diambil *screenshot* oleh pihak lain.

Kejadian tersebut perlu dinilai sebagai kemungkinan **insiden keamanan dan perlindungan Data Pribadi.**

INGAT: Jangan mengunggah data pasien ke media sosial pribadi.

Periksa juga latar belakang foto dan video sebelum dipublikasikan karena monitor, dokumen, atau informasi pasien dapat ikut terlihat.

Akun privat, Story, atau Status tidak menghilangkan kewajiban untuk melindungi data pasien.

7.8 Foto Pasien dan Risiko Pengungkapan Data

Foto pasien perlu diperlakukan dengan hati-hati karena sebuah foto dapat mengandung **informasi yang memungkinkan seseorang dikenali**, baik secara langsung maupun ketika dikombinasikan dengan informasi lainnya.

UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi mendefinisikan Data Pribadi sebagai data tentang orang perseorangan yang teridentifikasi atau dapat diidentifikasi secara tersendiri maupun dikombinasikan dengan informasi lainnya (Republik Indonesia, 2022).

Karena itu, mengambil, menyimpan, mengirim, atau mempublikasikan foto pasien **tidak boleh dilakukan hanya karena secara teknis mudah dilakukan.**

Foto Dapat Mengungkap Lebih Banyak Informasi

Foto pasien tidak hanya dapat memperlihatkan wajah.

Sebuah foto di lingkungan pelayanan kesehatan dapat ikut memperlihatkan:

gelang identitas pasien;

label atau dokumen di sekitar pasien;

monitor yang menampilkan informasi pasien;

nomor kamar atau lokasi pelayanan;

atau informasi lain yang dapat dikaitkan dengan pasien.

Jika foto tersebut disertai tulisan mengenai diagnosis, tindakan medis, atau kondisi kesehatan seseorang, risiko pengungkapan informasi menjadi semakin besar.

Data dan informasi kesehatan sendiri dikategorikan sebagai **Data Pribadi yang bersifat spesifik** dalam UU PDP (Republik Indonesia, 2022).

Jangan Memfoto Pasien untuk Dokumentasi Pribadi

Hindari mengambil foto pasien menggunakan ponsel pribadi hanya untuk dokumentasi pribadi atau karena dianggap menarik.

Misalnya:

“Saya foto untuk dokumentasi saja.”

“Tidak akan saya sebar.”

“Cuma disimpan di HP.”

Membuat foto berarti menciptakan **salinan digital baru**. Foto tersebut dapat tersimpan di galeri, tersinkronisasi ke *cloud*, terlihat oleh orang lain yang menggunakan perangkat, atau tanpa sengaja ikut dibagikan.

Dokumentasi yang memang diperlukan untuk pelayanan atau kepentingan resmi harus dilakukan melalui **mekanisme yang ditetapkan organisasi**.

Jangan Mengunggah Foto Pasien ke Media Sosial

Foto pasien tidak seharusnya diunggah ke akun media sosial pribadi, termasuk melalui *Story*, *Status*, atau grup komunitas, hanya karena tujuan unggahan dianggap baik.

Contohnya:

183

“Semoga pasien ini cepat sembuh.”

“Hari ini menangani kasus seperti ini.”

“Kegiatan pelayanan hari ini.”

Tujuan yang baik tidak otomatis memberikan kewenangan untuk mengungkapkan informasi pasien.

Jika rumah sakit membutuhkan foto untuk publikasi, edukasi, dokumentasi, atau kepentingan lainnya, proses tersebut harus mengikuti **dasar pemrosesan, kewenangan, dan prosedur organisasi yang berlaku.**

Menutup Wajah Belum Tentu Menghilangkan Risiko

Menyamarkan wajah tidak selalu membuat sebuah foto kehilangan keterkaitannya dengan pasien.

Identitas masih mungkin diketahui melalui informasi lain yang terlihat, misalnya nama pada gelang pasien, dokumen, lokasi, tulisan pada gambar, atau informasi yang disertakan pada unggahan.

Karena itu, jangan hanya bertanya:

“Apakah wajah pasien terlihat?”

Pertanyaan yang lebih tepat adalah:

“Apakah pasien masih dapat dikenali dari foto dan informasi yang menyertainya?”

Persetujuan Bukan Berarti Foto Bebas Digunakan untuk Semua Tujuan

Dalam kondisi tertentu, pemrosesan Data Pribadi dapat didasarkan pada persetujuan yang sah. UU PDP juga mengatur bahwa apabila pemrosesan dilakukan berdasarkan persetujuan, Pengendali Data Pribadi wajib menyampaikan informasi mengenai tujuan pemrosesan dan informasi terkait lainnya (Republik Indonesia, 2022).

Karena itu, apabila foto pasien diperoleh untuk **tujuan tertentu**, jangan menganggap foto tersebut otomatis dapat digunakan kembali untuk tujuan lain.

Penggunaan foto pasien harus mengikuti dasar pemrosesan dan prosedur yang berlaku di organisasi.

Jika Foto Pasien Terlanjur Tersebar

Jika foto pasien terlanjur dikirim atau dipublikasikan kepada pihak yang tidak seharusnya menerima, segera lakukan tindakan untuk **membatasi penyebaran dan melaporkan kejadian sesuai prosedur organisasi.**

Menghapus foto atau unggahan merupakan tindakan awal, tetapi tidak menjamin seluruh salinan telah hilang karena foto mungkin sudah disimpan, diteruskan, atau diambil *screenshot* oleh pihak lain.

INGAT: Foto pasien dapat menjadi Data Pribadi dan dapat mengungkapkan informasi kesehatan maupun identitas seseorang. Jangan mengambil, menyimpan, mengirim, atau mempublikasikan foto pasien untuk kepentingan pribadi. **Dokumentasi pasien harus mengikuti kebutuhan pekerjaan, kewenangan, dasar pemrosesan, dan prosedur organisasi.**

7.9 Periksa Penerima Sebelum Menekan Tombol Kirim

Salah satu penyebab data pasien diterima oleh pihak yang tidak seharusnya adalah **kesalahan memilih penerima.** Kesalahan sederhana seperti memilih kontak dengan nama yang mirip, salah memilih grup WhatsApp, menggunakan *Reply All*, atau salah mengetik alamat email dapat menyebabkan informasi pasien terkirim kepada pihak yang tidak berkepentingan.

Karena itu, biasakan melakukan **pemeriksaan terakhir sebelum menekan tombol Kirim (Send).**

Jangan Mengandalkan Nama Kontak Saja

Dalam daftar kontak dapat terdapat beberapa orang dengan nama yang sama atau hampir sama. Aplikasi email dan pesan instan juga dapat memberikan saran penerima secara otomatis.

Sebelum mengirim data pekerjaan, pastikan penerima yang dipilih memang benar.

Jangan hanya berpikir:

“Namanya sudah benar.”

Periksa kembali apakah **orang, alamat email, atau grup yang dipilih benar-benar merupakan tujuan yang dimaksud.**

Periksa Siapa Saja yang Akan Menerima

Kesalahan tidak selalu terjadi pada penerima utama. Pada email, informasi dapat ikut terkirim kepada orang lain melalui kolom **Cc** atau akibat penggunaan **Reply All**.

Pada grup percakapan, satu pesan dapat langsung diterima oleh banyak anggota.

Sebelum mengirim, tanyakan:

Apakah semua penerima membutuhkan informasi ini?

Jika hanya satu atau beberapa orang yang membutuhkan data tersebut, jangan membagikannya kepada kelompok yang lebih luas tanpa kebutuhan.

Hal ini sejalan dengan prinsip pemrosesan Data Pribadi secara terbatas, spesifik, dan sesuai tujuan sebagaimana diatur dalam UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi (Republik Indonesia, 2022).

Periksa Data dan Lampiran Sekaligus

Penerima yang benar saja belum cukup. Pengguna juga perlu memastikan bahwa **data yang dikirim merupakan data yang benar dan memang diperlukan.**

Sebelum menekan tombol Kirim, lakukan pemeriksaan sederhana:

PENERIMA → DATA → LAMPIRAN → KIRIM

Pastikan penerimanya benar, informasi yang diberikan sesuai kebutuhan, dan file atau foto yang dilampirkan merupakan file yang dimaksud.

Jika terdapat data pasien yang tidak diperlukan, **hapus, potong, atau samarkan secara memadai sebelum dikirim.**

Berhati-hati Saat Terburu-buru

Risiko salah kirim meningkat ketika pengguna bekerja terburu-buru.

Pesan seperti:

“URGENT, segera kirim datanya.”

tidak boleh membuat pengguna melewatkan pemeriksaan keamanan.

Kebutuhan pekerjaan yang mendesak tetap harus disertai kehati-hatian dalam menangani data pasien. **Beberapa detik untuk memeriksa penerima dapat mencegah data terkirim kepada pihak yang salah.**

Jika Menemukan Kesalahan Setelah Mengirim

Jika setelah menekan tombol Kirim pengguna menyadari bahwa data pasien telah terkirim kepada penerima yang salah, segera lakukan tindakan untuk membatasi penyebaran dan **laporkan sesuai prosedur organisasi.**

Sebagaimana telah dibahas pada BAB 6, jangan hanya menghapus pesan dan menganggap kejadian selesai. Penerima mungkin telah melihat, mengunduh, atau menyimpan informasi tersebut.

INGAT: Sebelum menekan tombol Kirim, periksa PENERIMA → DATA → LAMPIRAN. Pastikan penerimanya benar dan memang membutuhkan informasi tersebut. **Jangan biarkan beberapa detik yang dihemat karena terburu-buru berubah menjadi insiden keamanan data pasien.**

BAB 8 AMANKAN KOMPUTER DAN PERANGKAT KERJA

8.1 Kunci Komputer Ketika Meninggalkan Tempat Kerja

Komputer yang sudah berhasil *login* memberikan akses ke berbagai aplikasi dan informasi sesuai hak akses penggunanya. Di lingkungan rumah sakit, komputer tersebut dapat digunakan untuk mengakses **SIMRS, Rekam Medis Elektronik, email, dokumen kerja, maupun sistem lainnya yang mengandung data pasien.**

Karena itu, ketika meninggalkan tempat kerja, meskipun hanya sebentar, **kunci (*lock*) komputer terlebih dahulu.**

Komputer yang Terbuka Dapat Digunakan Orang Lain

Pengguna terkadang meninggalkan komputer dalam keadaan terbuka karena merasa hanya pergi sebentar.

Misalnya:

“Saya hanya mengambil dokumen.”

“Saya cuma ke ruangan sebelah.”

“Hanya beberapa menit.”

Namun, selama komputer tidak terkunci, orang lain yang berada di sekitar perangkat dapat melihat informasi pada layar atau menggunakan aplikasi yang masih aktif.

Jika SIMRS masih terbuka, pihak lain bahkan dapat memperoleh akses menggunakan **sesi pengguna yang sedang aktif** tanpa perlu mengetahui *password*.

Aktivitas Orang Lain Dapat Tercatat Menggunakan Akun Anda

Risiko komputer yang tidak dikunci bukan hanya data terlihat oleh orang lain.

Jika seseorang menggunakan komputer ketika akun Anda masih aktif, tindakan tersebut dapat dilakukan menggunakan **identitas akun Anda.**

Sebagai contoh, orang lain dapat membuka data pasien, mengubah informasi, mengunduh dokumen, atau melakukan aktivitas lainnya melalui sesi yang sedang aktif.

Pada sistem yang memiliki *logging* atau *audit trail*, aktivitas tersebut dapat tercatat sebagai aktivitas akun Anda.

Karena itu:

Akun Anda → akses Anda → tanggung jawab Anda.

Biasakan Menekan Windows + L

Pada komputer Windows, cara cepat untuk mengunci layar adalah:

Windows + L

Biasakan menekan kombinasi tersebut setiap kali meninggalkan komputer.

Tidak perlu menunggu sampai pergi dalam waktu lama. Bahkan ketika hanya meninggalkan meja selama beberapa menit, **mengunci komputer seharusnya menjadi kebiasaan otomatis.**

Prinsip sederhananya:

Berdiri dari kursi → Windows + L → tinggalkan meja.

Screen Lock Berbeda dengan Logout

Mengunci komputer tidak berarti keluar dari seluruh aplikasi.

Ketika komputer dikunci, sesi pengguna tetap dapat dipertahankan, tetapi untuk kembali menggunakannya diperlukan autentikasi sesuai konfigurasi perangkat.

Karena itu, *screen lock* merupakan cara praktis untuk melindungi sesi kerja ketika pengguna hanya meninggalkan komputer sementara.

Jika pekerjaan telah selesai atau komputer digunakan secara bergantian sesuai mekanisme organisasi, lakukan **logout** dari aplikasi atau sistem sesuai kebutuhan.

Jangan Mengandalkan Orang Lain untuk Menjaga Komputer

Hindari kebiasaan:

“Tolong jagain komputer saya sebentar.”

Keberadaan rekan kerja di ruangan bukan pengganti mekanisme pengamanan perangkat.

Demikian pula, jangan menganggap komputer aman hanya karena berada di ruang staf atau ruangan yang tidak dapat dimasuki masyarakat umum.

Orang yang berada di ruangan belum tentu memiliki kewenangan yang sama terhadap seluruh data yang dapat Anda akses.

Gunakan Penguncian Otomatis sebagai Perlindungan Tambahan

Organisasi juga dapat menerapkan penguncian layar otomatis setelah komputer tidak digunakan selama periode tertentu.

Fitur tersebut membantu apabila pengguna lupa mengunci perangkat secara manual. Namun, penguncian otomatis sebaiknya menjadi **perlindungan tambahan**, bukan alasan untuk meninggalkan komputer dalam keadaan terbuka.

Kebiasaan pengguna tetap penting:

Tinggalkan komputer → kunci layar.

INGAT: Setiap kali meninggalkan komputer, tekan Windows + L. Jangan meninggalkan SIMRS, Rekam Medis Elektronik, email, atau aplikasi lainnya dalam keadaan terbuka. **Beberapa detik untuk mengunci layar dapat mencegah orang lain melihat atau menggunakan data melalui akun Anda.**

8.2 Jangan Membiarkan SIMRS dalam Keadaan Login Tanpa Pengawasan

SIMRS memberikan akses kepada pengguna berdasarkan **akun dan kewenangan yang dimilikinya**. Setelah pengguna berhasil *login*, sistem dapat memberikan akses ke data pasien, transaksi pelayanan, dokumen, maupun fungsi lainnya tanpa meminta *password* pada setiap tindakan.

Karena itu, **SIMRS yang masih dalam keadaan *login* tidak boleh ditinggalkan tanpa pengawasan.**

Sesi yang Masih Aktif Dapat Digunakan Orang Lain

Risiko tidak hanya muncul ketika seseorang mengetahui *username* dan *password* Anda. Orang lain dapat menggunakan akun Anda apabila menemukan komputer dengan SIMRS yang masih terbuka.

Misalnya, pengguna meninggalkan meja untuk beberapa menit sementara halaman pasien masih tampil.

Orang lain yang berada di dekat komputer dapat melihat informasi pasien atau menggunakan fungsi SIMRS melalui **sesi pengguna yang masih aktif**.

Dengan kata lain:

Tidak mengetahui password bukan berarti tidak dapat menggunakan akun yang sudah login.

Aktivitas Dapat Tercatat Menggunakan Identitas Anda

SIMRS dapat memiliki mekanisme *logging* atau *audit trail* untuk mencatat aktivitas pengguna.

Jika orang lain menggunakan SIMRS melalui sesi Anda, aktivitas tersebut dapat tercatat menggunakan **akun yang sedang login**.

Hal ini dapat menimbulkan persoalan ketika kemudian ditemukan akses atau perubahan data yang tidak semestinya.

Pengguna mungkin mengatakan:

“Bukan saya yang melakukannya.”

Namun, pemeriksaan sistem dapat menunjukkan bahwa aktivitas dilakukan melalui akun pengguna tersebut.

Karena itu, menjaga sesi SIMRS merupakan bagian dari menjaga **akuntabilitas penggunaan akun**.

Jangan Membiarkan Data Pasien Terlihat di Layar

SIMRS yang dibiarkan terbuka juga dapat menyebabkan data pasien terlihat oleh orang yang tidak memiliki kepentingan untuk mengaksesnya.

UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi menggolongkan data dan informasi kesehatan sebagai **Data Pribadi yang bersifat spesifik** (Republik Indonesia, 2022).

Karena itu, ketika meninggalkan komputer, jangan membiarkan halaman yang menampilkan identitas, riwayat pelayanan, hasil pemeriksaan, atau informasi pasien lainnya tetap terbuka.

Kunci Komputer atau Keluar dari SIMRS

Jika hanya meninggalkan komputer sementara, **kunci layar komputer** sehingga sesi tidak dapat digunakan oleh orang lain.

Pada Windows:

Windows + L

Jika pekerjaan telah selesai atau komputer akan digunakan oleh pengguna lain, lakukan **logout dari SIMRS** sesuai prosedur yang berlaku.

Perbedaannya sederhana:

Pergi sebentar → kunci komputer.

Selesai menggunakan SIMRS → *logout*.

Komputer akan digunakan orang lain → *logout*, jangan serahkan sesi yang masih aktif.

Jangan Meminjamkan Sesi SIMRS

Hindari kebiasaan meminta rekan kerja menggunakan SIMRS melalui akun yang sedang aktif.

Misalnya:

“Pakai komputer saya saja, SIMRS-nya sudah login.”

atau:

“Tidak perlu login lagi, gunakan akun saya dulu.”

Praktik tersebut memiliki risiko yang sama dengan penggunaan akun bersama. Aktivitas orang lain dapat tercatat menggunakan identitas pemilik sesi.

Setiap pengguna seharusnya menggunakan **akun dan kewenangannya sendiri**.

***Automatic Logout* Bukan Pengganti Kebiasaan Pengguna**

SIMRS dapat memiliki fitur *session timeout* atau *automatic logout* setelah periode tertentu tidak digunakan. Fitur tersebut merupakan perlindungan tambahan apabila pengguna lupa keluar dari sistem.

Namun, pengguna tidak seharusnya mengandalkan fitur tersebut.

Jika komputer ditinggalkan selama lima menit sedangkan *session timeout* baru bekerja setelah periode yang lebih lama, selama jeda tersebut **sesi masih dapat digunakan oleh orang lain**.

Karena itu, tindakan pengguna tetap menjadi pertahanan pertama.

INGAT: Jangan pernah meninggalkan SIMRS dalam keadaan *login* tanpa pengawasan. Jika meninggalkan komputer sementara, kunci layar. Jika penggunaan SIMRS telah selesai, lakukan *logout*. Jangan membiarkan orang lain menggunakan sesi SIMRS melalui akun Anda.

8.3 Jangan Memasang Aplikasi Sembarangan

Komputer yang digunakan untuk mengakses SIMRS, Rekam Medis Elektronik, atau sistem rumah sakit merupakan bagian dari lingkungan kerja yang harus dijaga keamanannya. Karena itu, **pengguna tidak boleh memasang aplikasi sembarangan pada komputer kerja.**

Aplikasi yang terlihat sederhana atau bermanfaat belum tentu aman. Perangkat lunak dari sumber yang tidak terpercaya dapat membawa *malware*, mengubah konfigurasi komputer, mengakses file, atau menimbulkan celah keamanan.

Komputer Kerja Bukan Komputer Pribadi

Pengguna mungkin merasa perlu memasang aplikasi tertentu untuk mempermudah pekerjaan, misalnya aplikasi konversi dokumen, *download manager*, aplikasi PDF, ekstensi browser, atau utilitas lainnya.

Namun, pada komputer organisasi, pemasangan aplikasi harus mengikuti **kebijakan dan mekanisme yang ditetapkan pengelola TI.**

Hindari kebiasaan:

“Install saja, aplikasinya gratis.”

“Saya biasa menggunakan aplikasi ini di rumah.”

“Download dari internet saja, cuma aplikasi kecil.”

Aplikasi yang aman digunakan pada perangkat pribadi belum tentu diperbolehkan pada perangkat yang digunakan untuk mengakses data pasien.

Aplikasi Tidak Resmi Dapat Membawa *Malware*

Perangkat lunak yang diunduh dari situs tidak resmi, aplikasi bajakan, *crack*, *keygen*, atau installer yang dimodifikasi memiliki risiko keamanan.

Aplikasi tersebut dapat membawa program berbahaya seperti *malware*, *spyware*, atau perangkat lunak lain yang bekerja tanpa diketahui pengguna.

Jika komputer tersebut digunakan untuk mengakses SIMRS, dampaknya tidak hanya mengenai satu komputer. **Credential, dokumen kerja, dan data yang dapat diakses melalui komputer tersebut juga berpotensi terkena risiko.**

Jangan Menonaktifkan Keamanan agar Aplikasi Dapat Dipasang

Pengguna juga tidak boleh menonaktifkan antivirus, *endpoint protection*, firewall, atau mekanisme keamanan lainnya hanya karena sebuah aplikasi tidak dapat dijalankan.

Hindari tindakan seperti:

“Antivirus-nya dimatikan dulu supaya bisa install.”

“Browser bilang file berbahaya, tetapi lanjutkan saja.”

“Windows memblokir aplikasinya, saya bypass saja.”

Peringatan keamanan perlu diperiksa, bukan langsung diabaikan.

Jika aplikasi memang diperlukan untuk pekerjaan tetapi diblokir oleh sistem, **hubungi administrator atau pengelola TI.**

Waspada Ekstensi Browser

Risiko aplikasi tidak hanya berasal dari program yang di-*install* pada Windows.

Ekstensi atau *browser extension* juga merupakan perangkat lunak yang dapat memiliki kemampuan membaca atau mengubah informasi yang ditampilkan pada halaman web, tergantung izin yang diberikan.

Karena itu, jangan memasang ekstensi browser sembarangan pada komputer yang digunakan untuk mengakses sistem rumah sakit.

Gunakan Aplikasi yang Disetujui Organisasi

Jika membutuhkan aplikasi baru untuk pekerjaan, gunakan mekanisme yang berlaku.

Pengelola TI dapat melakukan pemeriksaan terhadap kebutuhan aplikasi, sumber perangkat lunak, lisensi, kompatibilitas, serta risiko keamanannya sebelum aplikasi digunakan.

Prinsipnya sederhana:

Butuh aplikasi → ajukan atau koordinasikan.

Jangan mengunduh → memasang → baru melapor ketika bermasalah.

Jika Terlanjur Memasang Aplikasi yang Mencurigakan

Jika pengguna telah memasang aplikasi kemudian menemukan perilaku yang tidak biasa, seperti munculnya program asing, iklan berlebihan, browser berubah sendiri, antivirus memberikan peringatan, atau komputer melakukan aktivitas yang mencurigakan, **segera laporkan kepada pengelola TI.**

Jangan mencoba menyembunyikan kejadian atau menghapus berbagai file secara sembarangan karena tindakan tersebut dapat menyulitkan pemeriksaan.

INGAT: Jangan memasang aplikasi, ekstensi browser, aplikasi bajakan, crack, atau perangkat lunak lain secara sembarangan pada komputer kerja. Jika membutuhkan aplikasi untuk pekerjaan, gunakan aplikasi yang disetujui organisasi atau koordinasikan dengan pengelola TI.

8.4 Penggunaan Flashdisk dan Media Penyimpanan Eksternal

Flashdisk, hard disk eksternal, kartu memori, dan media penyimpanan portabel lainnya memudahkan pemindahan file antarperangkat. Namun, penggunaannya pada komputer rumah sakit dapat menimbulkan **risiko terhadap keamanan perangkat dan kerahasiaan data pasien.**

Media penyimpanan eksternal dapat menjadi sarana masuknya *malware* ke komputer sekaligus menjadi sarana keluarnya data dari

lingkungan organisasi. Karena itu, penggunaannya harus mengikuti **kebijakan dan mekanisme yang ditetapkan organisasi.**

Media Eksternal Dapat Membawa *Malware*

Sebuah *flashdisk* dapat digunakan pada banyak komputer. Jika salah satu komputer terinfeksi *malware*, file atau media tersebut dapat ikut terkontaminasi dan kemudian membawa ancaman ke komputer lainnya.

Karena itu, hindari memasang *flashdisk* yang:

tidak diketahui asalnya;

ditemukan tanpa diketahui pemiliknya;

sering digunakan pada komputer umum;

atau **tidak diperlukan untuk pekerjaan.**

Jangan membuka file hanya karena terlihat seperti dokumen biasa. Nama dan ikon file dapat dibuat menyerupai dokumen, padahal sebenarnya merupakan program berbahaya.

Jangan Menyalin Data Pasien untuk Kemudahan

Risiko lain adalah penggunaan *flashdisk* untuk membawa data pasien keluar dari sistem atau komputer kerja.

Hindari kebiasaan:

“Saya copy dulu ke flashdisk supaya bisa dikerjakan di rumah.”

“Saya simpan data pasien di flashdisk untuk cadangan.”

“Saya bawa database-nya supaya vendor bisa cek.”

Kemudahan membawa media tersebut justru menjadi risiko. *Flashdisk* dapat hilang, tertinggal, dipinjamkan, atau digunakan pada perangkat lain.

UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi mewajibkan adanya langkah teknis operasional untuk melindungi Data Pribadi dari gangguan pemrosesan yang bertentangan dengan ketentuan peraturan perundang-undangan serta menentukan tingkat keamanan Data Pribadi dengan memperhatikan sifat dan risiko pemrosesan (Republik Indonesia, 2022).

Jangan Menggunakan *Flashdisk* Pribadi Sembarangan

Flashdisk pribadi mungkin sebelumnya digunakan pada komputer rumah, tempat percetakan, komputer umum, atau perangkat lainnya.

Ketika media yang sama kemudian dipasang pada komputer rumah sakit, risiko dari perangkat lain ikut dibawa ke lingkungan kerja.

Jika pemindahan file menggunakan media eksternal memang diperlukan, gunakan **media dan prosedur yang telah ditetapkan organisasi**.

Waspada Kehilangan Media

Berbeda dengan *file server* atau sistem penyimpanan organisasi, media eksternal berukuran kecil dan mudah dibawa.

Akibatnya, media tersebut juga mudah:

hilang;

tertinggal;

tertukar;

atau **diakses oleh orang lain**.

Jika media yang hilang mengandung data pasien, kejadian tersebut dapat menimbulkan risiko terhadap kerahasiaan Data Pribadi.

Karena itu, jangan menyimpan data pasien pada media eksternal tanpa kebutuhan, kewenangan, dan pengamanan yang sesuai.

Jangan Meminjamkan Media yang Mengandung Data

Media penyimpanan yang digunakan untuk pekerjaan tidak seharusnya dipinjamkan kepada orang lain apabila di dalamnya terdapat informasi organisasi atau data pasien.

Menghapus sebuah file juga belum tentu menjamin data tidak dapat dipulihkan dengan teknik tertentu. Karena itu, media yang pernah digunakan untuk menyimpan data sensitif perlu **dikelola dan dimusnahkan sesuai prosedur organisasi** ketika sudah tidak digunakan.

Jika Menemukan *Flashdisk*, Jangan Langsung Dipasang

Jika menemukan *flashdisk* yang tidak diketahui pemiliknya di lingkungan kerja, **jangan memasangnya ke komputer hanya untuk mengetahui isinya.**

Serahkan kepada pengelola TI atau pihak yang ditetapkan organisasi untuk dilakukan pemeriksaan sesuai prosedur.

Prinsip sederhananya:

Tidak dikenal → jangan dipasang.

Tidak diperlukan → jangan digunakan.

Mengandung data pasien → jangan dibawa atau disalin tanpa kewenangan.

INGAT: *Flashdisk* dapat menjadi jalan masuk malware sekaligus jalan keluar data. Jangan menggunakan media penyimpanan eksternal sembarangan pada komputer rumah sakit dan jangan menyalin data pasien ke *flashdisk* hanya untuk kemudahan. **Gunakan media dan mekanisme resmi yang ditetapkan organisasi.**

8.5 Jangan Menyalin Data Pasien ke Perangkat Pribadi

Data pasien yang digunakan dalam pekerjaan harus tetap berada pada **sistem, perangkat, dan media penyimpanan yang ditetapkan organisasi.** Pengguna tidak seharusnya menyalin data pasien ke laptop, komputer, ponsel, tablet, atau perangkat pribadi hanya untuk mempermudah pekerjaan.

Ketika data disalin ke perangkat pribadi, organisasi dapat kehilangan sebagian kendali terhadap **penyimpanan, akses, pengamanan, pencadangan, dan penghapusan data tersebut.**

Perangkat Pribadi Bukan Penyimpanan Data Pasien

Hindari kebiasaan seperti:

“Saya copy ke laptop pribadi supaya bisa dikerjakan di rumah.”

“Saya kirim ke HP supaya lebih mudah dibaca.”

“Saya simpan sementara, nanti setelah selesai saya hapus.”

Walaupun dilakukan untuk kepentingan pekerjaan, tindakan tersebut tetap menciptakan **salinan baru data pasien di luar media yang dikelola organisasi.**

Jika pekerjaan perlu dilakukan dari lokasi lain, gunakan mekanisme resmi yang disediakan organisasi apabila tersedia.

Data Dapat Tersebar Tanpa Disadari

Perangkat pribadi dapat terhubung dengan berbagai layanan lain. File atau foto dapat secara otomatis tersinkronisasi ke penyimpanan *cloud*, aplikasi pencadangan, atau perangkat lain yang menggunakan akun yang sama.

Akibatnya, satu file yang awalnya hanya disalin ke laptop atau ponsel dapat memiliki beberapa salinan di lokasi lain.

Pengguna juga belum tentu mengetahui secara pasti **di mana seluruh salinan tersebut tersimpan.**

Perangkat Pribadi Memiliki Risiko Kehilangan dan Akses Orang Lain

Ponsel dan laptop pribadi dapat:

hilang atau dicuri;

dipinjam anggota keluarga atau orang lain;

dibawa ke tempat servis;

atau **digunakan tanpa pengamanan yang sesuai.**

Jika perangkat tersebut menyimpan data pasien, kejadian pada perangkat pribadi dapat sekaligus menimbulkan risiko terhadap kerahasiaan informasi pasien.

UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi mewajibkan Pengendali Data Pribadi menjaga kerahasiaan Data Pribadi dan melindunginya dari pemrosesan serta akses yang tidak sah (Republik Indonesia, 2022).

Jangan Memindahkan Data Melalui Akun Pribadi

Menyalin data ke perangkat pribadi tidak selalu dilakukan menggunakan *flashdisk*. Data juga dapat berpindah melalui:

email pribadi;

WhatsApp atau aplikasi pesan;

penyimpanan *cloud* pribadi;

atau **kabel dan media penyimpanan lainnya**.

Cara pemindahannya mungkin berbeda, tetapi risikonya sama: **data pasien berpindah dari lingkungan yang dikendalikan organisasi ke lingkungan pribadi pengguna**.

Kebutuhan Bekerja dari Rumah Harus Menggunakan Mekanisme Resmi

Jika pegawai memang membutuhkan akses dari luar lingkungan rumah sakit, solusinya bukan otomatis menyalin data ke perangkat pribadi.

Organisasi dapat menetapkan mekanisme tertentu, misalnya akses jarak jauh, perangkat kerja resmi, atau sistem lain dengan pengamanan yang sesuai.

Pengguna harus mengikuti mekanisme tersebut dan **tidak membuat cara sendiri hanya karena lebih praktis**.

Jika Data Terlanjur Tersalin

Jika data pasien terlanjur tersimpan pada perangkat pribadi, jangan meneruskan atau membuat salinan tambahan.

Ikuti prosedur organisasi untuk menangani data tersebut. Jika perangkat hilang, digunakan pihak lain, atau terdapat kemungkinan data telah diakses tanpa kewenangan, **segera laporkan sebagai kejadian keamanan** agar dapat dilakukan penilaian dan penanganan.

Jangan hanya menghapus file kemudian menganggap masalah selesai karena salinan mungkin masih terdapat pada *cloud*, *backup*, folder sampah, atau perangkat lain yang tersinkronisasi.

INGAT: Jangan menyalin data pasien ke laptop, komputer, ponsel, atau perangkat pribadi hanya untuk kemudahan. Data pekerjaan harus tetap berada pada sistem dan perangkat yang ditetapkan organisasi. Jika membutuhkan akses dari luar, gunakan mekanisme resmi yang disediakan organisasi.

8.6 Risiko Kehilangan Laptop dan Perangkat Kerja

Laptop dan perangkat kerja dapat menyimpan atau memberikan akses ke **dokumen, email, SIMRS, aplikasi internal, serta informasi lain yang berkaitan dengan pasien**. Karena itu, kehilangan perangkat bukan hanya masalah kehilangan barang, tetapi juga dapat menjadi **insiden keamanan informasi**.

Risiko menjadi lebih besar apabila perangkat masih dalam keadaan *login*, tidak menggunakan pengamanan layar, atau menyimpan data pasien secara lokal.

Perangkat yang Hilang Dapat Membuka Akses ke Data

Laptop yang hilang atau dicuri dapat memberikan kesempatan kepada pihak lain untuk mencoba mengakses informasi di dalamnya.

Risiko dapat mencakup:

file dan dokumen kerja;

email;

data yang tersimpan pada browser;

aplikasi yang masih dalam keadaan *login*;

serta data pasien yang tersimpan pada perangkat.

Karena itu, jangan menilai dampak kehilangan perangkat hanya berdasarkan harga perangkat tersebut. **Data dan akses yang terdapat di dalamnya dapat jauh lebih penting.**

Jangan Menyimpan Data Pasien Jika Tidak Diperlukan

Semakin banyak data yang tersimpan pada laptop, semakin besar potensi dampak ketika perangkat hilang.

Jika data dapat diakses melalui SIMRS, *file server*, atau sistem resmi organisasi, hindari membuat salinan lokal tanpa kebutuhan.

Prinsipnya:

Data yang tidak tersimpan pada perangkat yang hilang tidak dapat ikut hilang bersama perangkat tersebut.

Hal ini sejalan dengan prinsip pemrosesan Data Pribadi yang terbatas, spesifik, dan sesuai dengan tujuan sebagaimana diatur

dalam UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi (Republik Indonesia, 2022).

Lindungi Perangkat Saat Dibawa

Laptop kerja yang dibawa keluar kantor perlu mendapatkan perhatian tambahan.

Jangan meninggalkan perangkat tanpa pengawasan di kendaraan, ruang publik, ruang rapat, hotel, atau tempat lain yang memungkinkan perangkat diambil oleh pihak lain.

Saat tidak digunakan, **kunci layar dan simpan perangkat pada tempat yang aman.**

Perangkat kerja juga tidak seharusnya dipinjamkan kepada anggota keluarga, teman, atau pihak lain hanya karena perangkat sedang berada di luar kantor.

Password Saja Tidak Selalu Cukup

Password atau PIN merupakan pengamanan penting, tetapi organisasi dapat menerapkan perlindungan tambahan seperti **enkripsi penyimpanan perangkat**, pengelolaan perangkat secara terpusat, dan mekanisme keamanan lainnya.

Pengguna tidak perlu mengubah konfigurasi keamanan tersebut sendiri. Yang penting adalah **jangan menonaktifkan atau mencoba melewati pengamanan yang telah diterapkan oleh pengelola TI.**

Jika Laptop atau Perangkat Kerja Hilang

Jika perangkat kerja hilang atau dicuri, **segera laporkan** kepada pihak yang ditetapkan organisasi.

Jangan menunggu beberapa hari dengan harapan perangkat akan ditemukan terlebih dahulu.

Sampaikan informasi yang diketahui, misalnya:

perangkat yang hilang;

waktu dan lokasi terakhir perangkat diketahui;

apakah perangkat dalam keadaan terkunci;

apakah terdapat data pasien yang tersimpan;

dan **sistem atau akun apa yang dapat diakses melalui perangkat tersebut.**

Pelaporan yang cepat memungkinkan pengelola TI melakukan tindakan pengamanan yang tersedia, misalnya menonaktifkan akses atau sesi tertentu dan menilai kemungkinan terjadinya pengungkapan data.

UU PDP mewajibkan Pengendali Data Pribadi melakukan langkah teknis operasional untuk melindungi Data Pribadi serta mencegah Data Pribadi diakses secara tidak sah (Republik Indonesia, 2022).

Jangan Menutupi Kehilangan Perangkat

Kehilangan perangkat dapat terjadi. Namun, **menunda atau tidak melaporkannya dapat memperbesar risiko.**

Perangkat yang ditemukan kembali pun tetap perlu dilaporkan apabila selama periode kehilangan terdapat kemungkinan perangkat telah berada dalam penguasaan pihak lain. Pengelola TI dapat menentukan apakah pemeriksaan keamanan diperlukan sebelum perangkat kembali digunakan.

INGAT: Kehilangan laptop atau perangkat kerja dapat berarti kehilangan kendali atas data dan akses yang terdapat di dalamnya. Jika perangkat hilang atau dicuri, segera laporkan. Jangan menunggu perangkat ditemukan terlebih dahulu sebelum memberi tahu pengelola TI atau pihak yang bertanggung jawab.

8.7 Malware dan Ransomware

Malware adalah perangkat lunak berbahaya yang dirancang untuk melakukan tindakan yang tidak diinginkan pada komputer atau sistem. Salah satu jenis ancaman yang perlu mendapat perhatian adalah **ransomware**, yaitu *malware* yang dapat mengganggu akses terhadap sistem atau data, termasuk dengan mengenkripsi file dan kemudian meminta tebusan.

Di lingkungan rumah sakit, dampaknya dapat lebih serius karena gangguan pada perangkat dan sistem informasi dapat memengaruhi **akses terhadap data pasien dan kelangsungan pelayanan.**

Malware Dapat Masuk dari Aktivitas Sehari-hari

Serangan tidak selalu dimulai dengan teknik yang rumit. *Malware* dapat masuk ketika pengguna:

membuka lampiran email berbahaya;
mengunduh aplikasi dari sumber yang tidak terpercaya;
menggunakan aplikasi bajakan atau *crack*;
memasang *flashdisk* yang terinfeksi;
atau **mengklik tautan berbahaya.**

Karena itu, perilaku pengguna merupakan salah satu bagian penting dalam pertahanan keamanan informasi.

***Ransomware* Dapat Membuat Data Tidak Dapat Digunakan**

Pada serangan *ransomware*, korban dapat menemukan file yang sebelumnya dapat dibuka menjadi tidak dapat digunakan. Dalam kasus tertentu, serangan juga dapat mengganggu layanan dan menyebar ke perangkat atau sumber daya jaringan lainnya.

Dampaknya bagi rumah sakit dapat berupa terganggunya akses terhadap dokumen dan sistem yang diperlukan dalam pekerjaan.

Karena itu, *ransomware* bukan hanya persoalan:

“Komputer terkena virus.”

Serangan tersebut dapat berkembang menjadi **insiden keamanan yang memengaruhi ketersediaan sistem dan data.**

UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi mewajibkan Pengendali Data Pribadi melindungi Data Pribadi dari gangguan pemrosesan yang bertentangan dengan ketentuan peraturan perundang-undangan dan mencegah Data Pribadi diakses secara tidak sah (Republik Indonesia, 2022).

Jangan Mengabaikan Peringatan Keamanan

Jika antivirus atau sistem keamanan memberikan peringatan, jangan menonaktifkannya hanya agar sebuah file dapat dibuka atau aplikasi dapat dijalankan.

Hindari tindakan seperti:

“Matikan antivirus sebentar.”

“File ini diblokir, tetapi saya yakin aman.”

“Klik saja *Allow* supaya bisa dibuka.”

Jika file memang diperlukan tetapi sistem keamanan memblokirnya, **hubungi pengelola TI untuk dilakukan pemeriksaan.**

Kenali Tanda yang Tidak Biasa

Pengguna tidak harus mampu menganalisis *malware*. Namun, pengguna perlu mengenali perubahan yang mencurigakan, misalnya:

- file tiba-tiba tidak dapat dibuka;**
- nama atau ekstensi banyak file berubah;**
- muncul pesan meminta pembayaran atau tebusan;**
- antivirus memberikan peringatan;**
- atau **komputer menunjukkan aktivitas yang tidak biasa setelah membuka file tertentu.**

Jika menemukan kondisi seperti itu, jangan mencoba memperbaikinya sendiri dengan mengunduh berbagai aplikasi dari internet.

Jika Mencurigai *Ransomware*, Segera Laporkan

Jika komputer menunjukkan indikasi terkena *malware* atau *ransomware*, **hentikan aktivitas yang dapat memperluas dampak dan segera hubungi pengelola TI atau tim yang menangani insiden keamanan.**

Jangan:

- membayar tebusan sendiri;**
- menghapus bukti secara sembarangan;**
- memasang aplikasi pembersih tanpa arahan;**
- atau **menyembunyikan kejadian karena takut disalahkan.**

Ikuti prosedur penanganan insiden yang berlaku. Pengelola TI perlu menentukan tindakan teknis yang tepat berdasarkan kondisi perangkat dan jaringan.

Pencegahan Dimulai dari Kebiasaan Sederhana

Risiko dapat dikurangi dengan kebiasaan:

- gunakan aplikasi resmi;**
- jangan membuka file atau tautan mencurigakan;**
- jangan menonaktifkan sistem keamanan;**

gunakan media penyimpanan sesuai ketentuan;
dan segera laporkan aktivitas yang tidak biasa.

Keamanan tidak hanya menjadi tugas administrator. Pengguna yang berhati-hati dapat membantu menghentikan ancaman sebelum berkembang menjadi insiden yang lebih besar.

INGAT: Ransomware dapat membuat data dan sistem tidak dapat digunakan. Jangan membuka file atau tautan mencurigakan dan jangan menonaktifkan perlindungan keamanan. Jika komputer menunjukkan tanda-tanda serangan, **segera laporkan kepada pengelola TI dan ikuti prosedur penanganan insiden.**

8.8 Pembaruan Sistem dan Perangkat Lunak Keamanan

Sistem operasi, browser, aplikasi, antivirus, dan perangkat lunak lainnya perlu diperbarui secara berkala. Pembaruan tidak hanya menambahkan fitur, tetapi juga dapat **memperbaiki kerentanan keamanan yang ditemukan setelah perangkat lunak digunakan.**

Karena itu, komputer yang digunakan untuk mengakses SIMRS dan data pasien perlu mengikuti mekanisme pembaruan yang ditetapkan oleh pengelola TI.

Jangan Mengabaikan Pembaruan Keamanan

Pengguna terkadang menunda pembaruan karena dianggap mengganggu pekerjaan.

Misalnya:

“Nanti saja, sedang banyak pekerjaan.”

“Jangan update, takut aplikasinya berubah.”

“Restart-nya nanti saja.”

Penundaan yang terlalu lama dapat menyebabkan perangkat tetap menggunakan komponen yang memiliki kerentanan yang sebenarnya sudah tersedia perbaikannya.

ISO/IEC 27002:2022 menempatkan pengelolaan kerentanan teknis sebagai salah satu kontrol keamanan informasi. Informasi mengenai kerentanan teknis perlu diperoleh, risiko dievaluasi, dan tindakan yang sesuai perlu dilakukan (ISO/IEC, 2022).

Pembaruan Harus Mengikuti Pengelolaan TI

Pada komputer organisasi, pengguna tidak perlu melakukan pembaruan secara sembarangan.

Beberapa aplikasi rumah sakit dapat memiliki ketergantungan terhadap versi sistem operasi, browser, atau komponen tertentu. Pembaruan yang dilakukan tanpa pengujian dapat menimbulkan masalah kompatibilitas.

Karena itu, prinsip yang tepat bukan:

“Semua komputer harus selalu di-update sendiri oleh pengguna.”

melainkan:

“Pembaruan keamanan harus dikelola dan diterapkan sesuai mekanisme organisasi.”

Jika pembaruan dikelola secara terpusat oleh pengelola TI, pengguna sebaiknya tidak menonaktifkan mekanisme tersebut.

Antivirus Juga Memerlukan Pembaruan

Antivirus atau perangkat lunak keamanan bukan perlindungan yang cukup apabila komponennya tidak diperbarui.

Perangkat lunak keamanan dapat memerlukan pembaruan terhadap:

mesin (*engine*) keamanan;

basis data atau informasi deteksi ancaman;

dan versi aplikasi keamanan itu sendiri.

Karena itu, jangan menonaktifkan pembaruan antivirus hanya karena dianggap menggunakan koneksi internet atau membuat komputer bekerja lebih lambat.

ISO/IEC 27002:2022 juga memberikan panduan mengenai perlindungan terhadap *malware*, termasuk penerapan tindakan pencegahan dan deteksi yang sesuai (ISO/IEC, 2022).

Jangan Menonaktifkan Sistem Keamanan

Pengguna tidak seharusnya mematikan antivirus, *endpoint protection*, firewall, atau fitur pembaruan hanya agar aplikasi tertentu dapat berjalan.

Jika aplikasi pekerjaan mengalami masalah setelah pembaruan atau diblokir oleh sistem keamanan, **laporkan kepada pengelola TI.**

Jangan mencoba mengatasi masalah dengan menurunkan tingkat keamanan perangkat tanpa kewenangan.

Lakukan Restart Jika Memang Diperlukan

Beberapa pembaruan baru diterapkan sepenuhnya setelah komputer di-*restart*.

Jika sistem meminta *restart*, ikuti mekanisme dan waktu yang ditetapkan organisasi. Jangan terus-menerus menundanya hingga pembaruan keamanan tidak pernah selesai diterapkan.

Simpan pekerjaan terlebih dahulu, tutup aplikasi dengan benar, kemudian lakukan *restart* pada waktu yang sesuai.

Pengguna dan Pengelola TI Memiliki Peran yang Berbeda

Pengelola TI bertanggung jawab mengatur dan menerapkan mekanisme teknis sesuai kebijakan organisasi. Pengguna membantu dengan **tidak menghambat mekanisme keamanan yang telah diterapkan.**

Bagi pengguna, kebiasaan yang penting adalah:

jangan menonaktifkan pembaruan;

jangan mematikan antivirus;

ikuti permintaan *restart* yang sah;

dan **laporkan jika pembaruan menimbulkan masalah pada aplikasi pekerjaan.**

INGAT: Pembaruan keamanan membantu menutup kerentanan yang dapat dimanfaatkan oleh penyerang. Jangan menonaktifkan *update*, antivirus, atau perlindungan perangkat tanpa kewenangan. Ikuti mekanisme pembaruan yang ditetapkan pengelola TI.

8.9 Keamanan Fisik Perangkat dan Dokumen

Pelindungan data pasien tidak hanya dilakukan melalui *password*, antivirus, atau pengaturan sistem. **Perangkat dan dokumen secara fisik juga harus dilindungi** dari kehilangan, pencurian, kerusakan, atau akses oleh pihak yang tidak berwenang.

Komputer, laptop, *flashdisk*, dokumen cetak, maupun media lainnya dapat menjadi tempat penyimpanan atau sarana untuk mengakses data pasien. Karena itu, keamanan fisik merupakan bagian dari keamanan informasi.

ISO/IEC 27002:2022 memuat kontrol keamanan fisik yang bertujuan mencegah akses fisik yang tidak sah serta melindungi aset informasi dari ancaman fisik dan lingkungan (ISO/IEC, 2022).

Jangan Membiarkan Dokumen Pasien Terbuka

Dokumen pasien yang diletakkan di meja dapat terlihat oleh orang yang berada di sekitarnya.

Ketika tidak sedang digunakan, hindari meninggalkan:

rekam medis atau dokumen pelayanan;

fotokopi identitas pasien;

hasil pemeriksaan;

daftar pasien;

atau **dokumen lain yang mengandung Data Pribadi**

di tempat yang dapat dilihat atau diambil oleh pihak yang tidak berkepentingan.

Dokumen yang telah selesai digunakan perlu dikembalikan ke **tempat penyimpanan yang ditetapkan organisasi.**

Terapkan Prinsip *Clear Desk*

Meja kerja sebaiknya tidak menjadi tempat penyimpanan permanen dokumen yang mengandung data pasien.

Sebelum meninggalkan tempat kerja atau setelah dokumen selesai digunakan, periksa apakah masih terdapat dokumen sensitif yang terbuka.

Prinsip sederhananya:

Digunakan → jaga.

Selesai digunakan → simpan kembali.

Tidak diperlukan → kelola sesuai prosedur.

ISO/IEC 27002:2022 secara khusus mencakup kontrol ***clear desk and clear screen*** untuk mengurangi risiko akses, kehilangan, dan kerusakan informasi pada meja, layar, serta fasilitas pemrosesan informasi (ISO/IEC, 2022).

Lindungi Perangkat dari Akses Fisik

Komputer dan laptop kerja juga tidak boleh dibiarkan sehingga dapat digunakan secara bebas oleh orang lain.

Ketika meninggalkan meja:

kunci layar komputer;

jangan meninggalkan laptop tanpa pengawasan di tempat umum;

dan simpan perangkat portabel secara aman ketika tidak digunakan.

Pengamanan fisik tetap diperlukan meskipun perangkat telah menggunakan *password*.

Perhatikan Dokumen pada Printer dan Mesin Fotokopi

Dokumen yang dicetak dapat tertinggal pada printer atau mesin fotokopi.

Jika dokumen mengandung data pasien, ambil dokumen segera setelah proses pencetakan selesai. Periksa juga apakah terdapat halaman yang tertinggal pada baki keluaran atau area mesin.

Hindari mencetak dokumen sensitif kemudian membiarkannya selama berjam-jam dengan alasan:

“Nanti saya ambil.”

Selama dokumen berada di tempat tersebut, pihak lain dapat melihat atau mengambilnya.

Dokumen Tidak Boleh Dibuang Seperti Sampah Biasa

Dokumen yang tidak lagi diperlukan tetapi masih mengandung data pasien tidak seharusnya langsung dimasukkan ke tempat sampah biasa dalam keadaan dapat dibaca.

Pemusnahan dokumen harus mengikuti **prosedur organisasi**, misalnya melalui mekanisme penghancuran dokumen yang telah ditetapkan.

Hal yang sama berlaku terhadap media penyimpanan yang pernah mengandung data sensitif.

Perhatikan Area Pelayanan

Keamanan fisik juga berkaitan dengan posisi layar dan dokumen.

Jika monitor menampilkan data pasien, perhatikan apakah layar dapat terlihat oleh pengunjung atau pihak lain yang tidak berkepentingan. Dokumen pasien juga tidak seharusnya diletakkan pada area pelayanan yang memungkinkan informasi terbaca secara bebas.

Prinsip ***need-to-know*** tetap berlaku, termasuk terhadap **akses secara visual**.

INGAT: Data pasien harus dilindungi secara digital maupun fisik. Jangan meninggalkan dokumen pasien terbuka, ambil dokumen segera dari printer, kunci komputer ketika ditinggalkan, dan simpan perangkat serta dokumen pada tempat yang sesuai. **Meja, layar, printer, dan dokumen juga merupakan bagian dari keamanan informasi.**

8.10 Penghapusan Data secara Aman

Menghapus data bukan sekadar menekan tombol **Delete**. Data pasien yang sudah tidak diperlukan tetap harus dikelola dengan hati-hati agar **tidak dapat diakses kembali oleh pihak yang tidak berwenang**.

Prinsip ini berlaku terhadap file pada komputer, media penyimpanan, dokumen cetak, maupun perangkat yang pernah digunakan untuk menyimpan data pasien.

ISO/IEC 27002:2022 memasukkan ***information deletion*** sebagai salah satu kontrol keamanan informasi. Informasi yang tersimpan pada sistem, perangkat, atau media penyimpanan perlu dihapus ketika tidak lagi diperlukan, dengan mempertimbangkan ketentuan organisasi dan persyaratan yang berlaku (ISO/IEC, 2022).

Tombol *Delete* Belum Tentu Menghapus Data Secara Permanen

Ketika sebuah file dihapus dari komputer, file tersebut dapat berpindah ke ***Recycle Bin*** atau lokasi sementara lainnya.

Data juga mungkin masih memiliki salinan pada:
folder lain;

media penyimpanan eksternal;
email;
penyimpanan *cloud*;
atau **sistem pencadangan (*backup*).**

Karena itu, pengguna tidak boleh beranggapan bahwa data sudah benar-benar hilang hanya karena file tidak lagi terlihat pada folder asalnya.

Jangan Menghapus Data Pasien Sembarangan

Penghapusan data yang aman bukan berarti pengguna boleh menghapus semua data yang dianggap sudah tidak diperlukan.

Data pasien dapat memiliki **ketentuan retensi dan kebutuhan pelayanan, administrasi, hukum, maupun organisasi.**

Karena itu, pengguna harus mengikuti kebijakan retensi dan prosedur yang berlaku. Jangan menghapus data dari SIMRS, Rekam Medis Elektronik, atau sistem lainnya hanya untuk mengurangi jumlah file.

Prinsipnya:

Data tidak lagi diperlukan oleh pengguna ≠ data boleh langsung dihapus dari sistem organisasi.

Dokumen Cetak Juga Harus Dimusnahkan dengan Aman

Dokumen yang mengandung data pasien tidak seharusnya dibuang ke tempat sampah biasa dalam keadaan masih dapat dibaca.

Dokumen yang memang telah memenuhi ketentuan untuk dimusnahkan harus diproses melalui **mekanisme pemusnahan dokumen yang ditetapkan organisasi.**

Hal ini berlaku terhadap fotokopi identitas, hasil cetak SIMRS, daftar pasien, formulir, maupun dokumen lain yang mengandung Data Pribadi.

Perhatikan Perangkat dan Media yang Akan Dialihkan

Komputer, laptop, hard disk, *flashdisk*, atau media penyimpanan lainnya dapat menyimpan data meskipun perangkat tersebut sudah tidak digunakan.

Sebelum perangkat:

**dipindahtangankan;
dikembalikan;
diperbaiki oleh pihak lain;
digunakan kembali untuk keperluan berbeda;
atau dimusnahkan,**

data yang terdapat di dalamnya harus ditangani sesuai prosedur pengelola TI.

ISO/IEC 27002:2022 juga mengatur keamanan ketika peralatan digunakan kembali atau dibuang, sehingga informasi sensitif tidak tertinggal pada media penyimpanan (ISO/IEC, 2022).

Jangan Melakukan Penghapusan Teknis Sendiri Jika Tidak Berwenang

Penghapusan aman pada media digital dapat memerlukan metode tertentu sesuai jenis media dan sistem yang digunakan.

Karena itu, pengguna tidak perlu mencoba melakukan *format*, menggunakan aplikasi penghapus data, atau menghancurkan media sendiri.

Jika perangkat atau media yang mengandung data pasien sudah tidak digunakan, **serahkan proses penghapusan atau pemusnahannya kepada pihak yang berwenang sesuai prosedur organisasi.**

Jika Data Tersimpan pada Tempat yang Tidak Semestinya

Jika menemukan data pasien tersimpan pada perangkat pribadi, *flashdisk*, folder lokal, atau lokasi lain yang tidak semestinya, jangan langsung menghapusnya tanpa mempertimbangkan prosedur organisasi.

Hentikan penggunaan atau penyebaran lebih lanjut dan **laporkan kepada pihak yang bertanggung jawab** agar data dapat ditangani dengan benar.

Hal ini penting terutama apabila terdapat kemungkinan data sudah disalin, disinkronkan, atau diakses oleh pihak lain.

INGAT: Menghapus data bukan sekadar menekan tombol Delete.
Data pasien harus disimpan selama masih diperlukan sesuai ketentuan dan dihapus atau dimusnahkan melalui mekanisme yang

aman ketika masa penggunaannya berakhir. **Jangan menghapus data organisasi atau memusnahkan media sendiri tanpa kewenangan.**

BAB 9 WASPADA PHISHING DAN SOCIAL ENGINEERING

9.1 Tidak Semua Serangan Siber Menggunakan Teknik Peretasan

Ketika mendengar istilah serangan siber, banyak orang membayangkan penyerang yang menggunakan program rumit untuk membobol server atau menembus sistem keamanan. Padahal, **tidak semua serangan dilakukan dengan meretas sistem secara teknis.**

Dalam banyak situasi, penyerang justru berusaha memanfaatkan **manusia** agar memberikan informasi, membuka file, mengklik tautan, atau melakukan tindakan yang menguntungkan penyerang.

Teknik manipulasi terhadap manusia tersebut dikenal sebagai ***social engineering***.

Manusia Dapat Menjadi Sasaran Serangan

Sistem dapat memiliki firewall, antivirus, *Multi-Factor Authentication* (MFA), dan berbagai mekanisme keamanan lainnya. Namun, penyerang dapat mencoba melewati perlindungan tersebut dengan menghubungi pengguna secara langsung.

Contohnya, seseorang menghubungi pegawai dan mengatakan:

“Saya dari tim IT. Akun Anda sedang bermasalah. Tolong berikan kode OTP yang baru masuk.”

Jika pengguna percaya dan memberikan kode tersebut, penyerang tidak perlu membobol sistem secara teknis. **Pengguna sendiri telah memberikan informasi yang dibutuhkan penyerang.**

Penyerang Dapat Menyamar sebagai Pihak yang Dipercaya

Dalam *social engineering*, penyerang dapat mengaku sebagai:

administrator atau petugas TI;

vendor aplikasi;

rekan kerja;

pimpinan;

atau **pihak lain yang dianggap memiliki kewenangan.**

Tujuannya adalah membuat korban percaya sehingga melakukan sesuatu tanpa melakukan verifikasi terlebih dahulu.

Karena itu, identitas yang disebutkan seseorang **tidak boleh langsung dianggap benar hanya karena terdengar meyakinkan.**

Serangan Sering Memanfaatkan Rasa Mendesak

Penyerang dapat menggunakan tekanan agar korban tidak sempat berpikir atau melakukan verifikasi.

Misalnya:

“Akun Anda akan diblokir dalam 10 menit.”

“Ini instruksi pimpinan, segera kirim datanya.”

“Server sedang bermasalah. Saya membutuhkan password sekarang.”

Pesan yang mendesak dapat membuat seseorang mengabaikan prosedur keamanan.

Karena itu:

Mendesak bukan berarti boleh melewati prosedur.

Informasi Kecil Juga Dapat Berguna bagi Penyerang

Penyerang tidak selalu langsung meminta *password*. Mereka dapat terlebih dahulu mencari informasi mengenai nama pegawai, jabatan, unit kerja, aplikasi yang digunakan, alamat email, atau nama vendor.

Informasi tersebut kemudian dapat digunakan untuk membuat komunikasi berikutnya terlihat lebih meyakinkan.

Karena itu, pengguna perlu berhati-hati ketika memberikan **informasi internal organisasi**, meskipun informasi tersebut terlihat tidak penting.

Keamanan Tidak Hanya Tanggung Jawab Pengelola TI

Teknologi dapat membantu melindungi sistem, tetapi keputusan pengguna tetap memiliki peran penting.

Pengguna perlu membiasakan diri untuk:

memeriksa identitas pihak yang meminta informasi;

tidak memberikan password, OTP, atau credential;

berhati-hati terhadap tautan dan lampiran;

dan melaporkan komunikasi yang mencurigakan.

ISO/IEC 27002:2022 menempatkan *information security awareness, education and training* sebagai salah satu kontrol keamanan untuk membantu personel memahami tanggung jawab dan mengenali ancaman keamanan informasi (ISO/IEC, 2022).

INGAT: Penyerang tidak selalu mencoba meretas komputer. Terkadang mereka mencoba “meretas” manusia. Jangan memberikan informasi atau melakukan tindakan hanya karena seseorang mengaku sebagai administrator, vendor, pimpinan, atau pihak yang dipercaya. **Verifikasi terlebih dahulu melalui mekanisme yang resmi.**

9.2 Apa yang Dimaksud dengan Social Engineering?

Social engineering adalah teknik manipulasi yang memanfaatkan **kepercayaan, kebiasaan, rasa takut, rasa ingin membantu, atau kondisi psikologis seseorang** agar korban memberikan informasi atau melakukan tindakan yang menguntungkan penyerang.

Dalam serangan ini, sasaran utama tidak selalu komputer atau aplikasi. **Manusia dapat menjadi sasaran utama karena memiliki akses terhadap informasi dan sistem organisasi.**

Penyerang Berusaha Membuat Korban Percaya

Pelaku *social engineering* biasanya membuat situasi yang terlihat masuk akal. Mereka dapat mengaku sebagai administrator TI, vendor, pimpinan, rekan kerja, atau pihak lain yang dianggap dapat dipercaya.

Misalnya, seseorang menghubungi pegawai:

“Saya dari administrator SIMRS. Ada perbaikan akun. Tolong informasikan kode OTP yang baru masuk.”

Permintaan tersebut mungkin terdengar meyakinkan, terutama jika pelaku mengetahui nama aplikasi atau informasi organisasi. Namun, **OTP merupakan credential yang tidak boleh diberikan kepada orang lain**, sebagaimana telah dibahas pada BAB 4.

Social Engineering Memanfaatkan Reaksi Manusia

Penyerang dapat memanfaatkan beberapa kondisi untuk mendorong korban bertindak tanpa melakukan pemeriksaan terlebih dahulu.

Contohnya:

Rasa **takut**

“Akun Anda terdeteksi bermasalah dan akan segera dinonaktifkan.”

Rasa **mendesak**

“Harus dilakukan sekarang karena sistem akan ditutup.”

Otoritas

“Ini permintaan pimpinan. Segera kirim datanya.”

Keinginan **membantu**

“Saya teknisi baru. Tolong bantu berikan akses sementara.”

Tujuannya sama, yaitu membuat korban **bertindak terlebih dahulu sebelum melakukan verifikasi.**

Informasi yang Dicari Tidak Selalu Password

Pelaku tidak selalu langsung meminta *password*. Informasi kecil juga dapat digunakan untuk mempersiapkan serangan berikutnya.

Misalnya:

nama dan jabatan pegawai;

alamat email;

nama administrator atau vendor;

aplikasi yang digunakan;

nomor telepon internal;

atau **informasi mengenai prosedur organisasi.**

Informasi tersebut dapat digunakan untuk membuat penyamaran berikutnya terlihat semakin meyakinkan.

Media yang Digunakan Dapat Beragam

Social engineering dapat dilakukan melalui berbagai media, seperti email, telepon, WhatsApp, media sosial, maupun komunikasi langsung.

Karena itu, pesan yang terlihat berasal dari orang yang dikenal **belum tentu benar-benar dikirim oleh orang tersebut.** Identitas pengirim perlu diverifikasi apabila terdapat permintaan yang tidak biasa, terutama permintaan credential, akses, atau data pasien.

ISO/IEC 27002:2022 menekankan pentingnya *information security awareness, education and training* agar personel memahami tanggung jawab keamanan informasi dan memiliki kesadaran terhadap ancaman yang relevan (ISO/IEC, 2022).

Verifikasi Sebelum Bertindak

Jika menerima permintaan yang mencurigakan, jangan terburu-buru mengikuti instruksi.

Gunakan prinsip sederhana:

BERHENTI → PERIKSA → VERIFIKASI → BERTINDAK

Jika seseorang mengaku sebagai administrator, vendor, atau pimpinan dan meminta sesuatu yang tidak biasa, lakukan verifikasi melalui **saluran resmi atau kontak yang sudah diketahui**, bukan hanya melalui informasi kontak yang diberikan oleh pihak yang meminta.

INGAT: *Social engineering* menyerang kepercayaan dan keputusan manusia. Jangan memberikan password, OTP, data pasien, atau akses hanya karena seseorang terlihat meyakinkan atau mengaku sebagai pihak yang berwenang. **Jika permintaan terasa tidak biasa, verifikasi sebelum bertindak.**

9.3 Apa yang Dimaksud dengan Phishing?

Phishing adalah bentuk *social engineering* yang menggunakan pesan atau komunikasi palsu untuk **menipu korban agar memberikan informasi, membuka tautan, mengunduh file, atau melakukan tindakan tertentu.**

Pelaku biasanya menyamar sebagai pihak yang dipercaya, misalnya administrator TI, bank, vendor, layanan digital, rekan kerja, atau pimpinan. Pesan dibuat agar terlihat meyakinkan sehingga korban bertindak tanpa melakukan verifikasi terlebih dahulu.

Phishing Tidak Selalu Meminta Password Secara Langsung

Pesan *phishing* dapat meminta korban melakukan berbagai tindakan, misalnya:

mengklik tautan untuk melakukan login;

membuka lampiran;
memasukkan username dan password;
memberikan OTP atau kode verifikasi;
atau **mengirimkan informasi tertentu.**

Contohnya:

“Akun SIMRS Anda akan dinonaktifkan. Silakan login melalui tautan berikut untuk melakukan verifikasi.”

Tautan tersebut dapat mengarahkan korban ke halaman palsu yang dibuat menyerupai halaman *login* asli. Ketika korban memasukkan *username* dan *password*, informasi tersebut dapat diterima oleh pelaku.

Kenali Tanda-Tanda yang Mencurigakan

Tidak semua pesan *phishing* memiliki ciri yang sama. Namun, pengguna perlu lebih waspada apabila pesan:

mendesak untuk segera bertindak;
meminta password, OTP, atau informasi sensitif;
menggunakan alamat pengirim yang tidak biasa;
meminta membuka tautan atau lampiran yang tidak diharapkan;
atau **mengancam akun akan diblokir jika instruksi tidak segera dilakukan.**

Pesan yang terlihat rapi dan menggunakan logo resmi **belum tentu merupakan pesan yang sah.**

Jangan Langsung Mengklik Tautan

Jika menerima pesan yang meminta *login*, jangan langsung menggunakan tautan yang terdapat dalam pesan.

Apabila perlu mengakses suatu layanan, lebih aman menggunakan **alamat atau aplikasi resmi yang biasa digunakan**, sesuai mekanisme organisasi.

Jika ragu, konfirmasi kepada administrator atau pihak terkait melalui saluran komunikasi resmi.

Waspada Lampiran

Phishing juga dapat menggunakan lampiran yang dibuat seolah-olah merupakan dokumen pekerjaan, misalnya:

**Surat Undangan;
Invoice;
Daftar Pasien;
Laporan;
atau Dokumen Penting.**

Lampiran tersebut dapat mengandung atau mengarahkan pengguna kepada *malware*. Karena itu, jangan membuka lampiran yang tidak diharapkan hanya karena nama filenya terlihat meyakinkan.

Phishing Dapat Menargetkan Pegawai Rumah Sakit

Pelaku dapat membuat pesan yang disesuaikan dengan lingkungan rumah sakit, misalnya mengaku sebagai administrator SIMRS atau vendor aplikasi.

Contohnya:

“Kami sedang melakukan pembaruan SIMRS. Silakan login melalui link berikut.”

atau:

“Saya dari vendor. Tolong kirim OTP untuk pengecekan akun.”

Pengetahuan pelaku mengenai nama organisasi atau aplikasi **tidak membuktikan bahwa pelaku benar-benar berasal dari pihak tersebut.**

ISO/IEC 27002:2022 menekankan pentingnya *information security awareness, education and training* agar personel memiliki kesadaran terhadap ancaman keamanan informasi yang relevan dengan pekerjaannya (ISO/IEC, 2022).

Jika Menerima Pesan yang Mencurigakan

Gunakan prinsip sederhana:

JANGAN KLIK → JANGAN BERIKAN CREDENTIAL → VERIFIKASI → LAPORKAN

Jangan membalas dengan memberikan informasi sensitif. Verifikasi permintaan melalui saluran resmi dan laporkan pesan mencurigakan sesuai mekanisme organisasi.

Jika sudah terlanjur memasukkan *password*, memberikan OTP, atau membuka file mencurigakan, **segera laporkan kepada pengelola TI** agar tindakan pengamanan dapat dilakukan.

INGAT: *Phishing* berusaha membuat Anda percaya dan bertindak.

Jangan langsung mengklik tautan, membuka lampiran, atau memberikan *password* dan OTP hanya karena pesan terlihat resmi.

Jika ragu, verifikasi melalui saluran resmi sebelum melakukan tindakan.

9.4 Penyerang Dapat Menyamar sebagai Atasan

Dalam serangan *social engineering*, pelaku dapat **menyamar sebagai atasan atau pimpinan** untuk membuat korban merasa harus segera mengikuti perintah. Teknik ini memanfaatkan rasa hormat terhadap jabatan, tekanan waktu, dan kekhawatiran dianggap tidak mematuhi instruksi.

Pesan dapat dikirim melalui WhatsApp, email, telepon, atau akun lain yang dibuat menyerupai identitas pimpinan.

Jabatan Dapat Digunakan untuk Menciptakan Tekanan

Pelaku dapat mengirim pesan seperti:

“Ini saya, segera kirimkan data tersebut. Saya sedang rapat.”

“Tolong kirim file pasien ini sekarang. Jangan menunggu.”

“Saya menggunakan nomor baru. Simpan nomor ini.”

“Ini mendesak, tidak perlu konfirmasi ke orang lain.”

Permintaan seperti ini sengaja dibuat agar penerima **segera bertindak tanpa melakukan verifikasi.**

Prinsip penting yang perlu diingat:

Perintah yang terlihat berasal dari atasan tetap harus mengikuti prosedur keamanan.

Nama dan Foto Profil Bukan Bukti Identitas

Nama, jabatan, dan foto pimpinan dapat diperoleh dari situs web, media sosial, atau sumber terbuka lainnya. Pelaku kemudian dapat menggunakan informasi tersebut untuk membuat akun atau profil yang terlihat meyakinkan.

Karena itu, jangan menganggap sebuah pesan benar hanya karena:

menggunakan nama pimpinan;

menggunakan foto pimpinan;

mengetahui nama unit kerja;

atau **mengetahui beberapa informasi internal.**

Informasi tersebut belum cukup untuk membuktikan identitas pengirim.

Waspada! Permintaan yang Tidak Biasa

Kecurigaan perlu meningkat apabila seseorang yang mengaku sebagai atasan meminta:

password atau OTP;

data pasien yang biasanya tidak pernah diminta melalui media tersebut;

pengiriman dokumen ke nomor atau email baru;

pemberian akses ke suatu sistem;

atau **tindakan yang bertentangan dengan prosedur organisasi.**

Permintaan yang bersifat rahasia dan disertai tekanan seperti **“jangan beri tahu siapa pun”** juga perlu diperiksa lebih lanjut.

Verifikasi Bukan Berarti Menolak Perintah Atasan

Melakukan verifikasi merupakan bagian dari menjaga keamanan informasi.

Jika menerima permintaan yang tidak biasa, lakukan konfirmasi menggunakan **saluran komunikasi yang sudah dikenal dan dapat dipercaya.**

Misalnya, jika pesan datang dari nomor baru yang mengaku sebagai pimpinan, jangan hanya melakukan verifikasi melalui nomor tersebut. Hubungi pimpinan melalui nomor resmi yang sudah diketahui atau gunakan mekanisme verifikasi lain yang ditetapkan organisasi.

Prinsipnya:

Permintaan tidak biasa → verifikasi melalui saluran lain → baru bertindak.

Atasan Juga Tidak Membutuhkan Password Anda

Sebagaimana telah dibahas pada BAB 4, *password*, OTP, dan credential merupakan informasi yang harus dijaga kerahasiaannya.

Jika seseorang yang mengaku sebagai atasan meminta *password* atau OTP, **jangan memberikannya.**

Kewenangan jabatan tidak mengubah prinsip keamanan credential. Jika akses tertentu memang diperlukan, gunakan mekanisme pemberian akses yang resmi tanpa menggunakan credential milik orang lain.

Jika Terlanjur Mengikuti Instruksi Palsu

Jika pengguna terlanjur memberikan data, mengirim dokumen, memberikan OTP, membuka tautan, atau melakukan tindakan lain setelah menerima instruksi yang ternyata mencurigakan, **segera laporkan kepada pengelola TI atau pihak yang menangani insiden keamanan.**

Jangan menunggu sampai mengetahui apakah data benar-benar telah disalahgunakan.

Semakin cepat kejadian dilaporkan, semakin cepat organisasi dapat melakukan tindakan untuk membatasi dampaknya.

INGAT: Penyerang dapat menggunakan nama, foto, dan jabatan pimpinan untuk membuat perintah palsu terlihat meyakinkan.

Jika menerima permintaan yang tidak biasa atau bertentangan dengan prosedur, **verifikasi melalui saluran resmi sebelum bertindak. Jabatan bukan alasan untuk memberikan password, OTP, atau melewati prosedur keamanan.**

9.5 Penyerang Dapat Menyamar sebagai Administrator TI

Administrator TI merupakan pihak yang sering dipercaya ketika terjadi masalah pada komputer, akun, jaringan, atau aplikasi. Kepercayaan tersebut dapat dimanfaatkan oleh pelaku *social engineering* dengan **menyamar sebagai administrator TI** untuk memperoleh credential, data, atau akses ke sistem.

Pelaku dapat menghubungi pengguna melalui telepon, WhatsApp, email, atau media komunikasi lainnya dan menggunakan istilah teknis agar terlihat meyakinkan.

Administrator TI Tidak Memerlukan Password Anda

Salah satu pola yang perlu diwaspadai adalah permintaan seperti:

“Saya dari bagian TI. Tolong kirim password SIMRS untuk pengecekan.”

“Kami sedang memperbaiki akun Anda. Berikan OTP yang baru masuk.”

“Password-nya apa? Saya perlu login untuk melakukan perbaikan.”

Permintaan tersebut tidak boleh langsung dipenuhi.

Sebagaimana telah dibahas pada BAB 4, **password, OTP, dan credential pengguna tidak boleh diberikan kepada orang lain**, termasuk kepada seseorang yang mengaku sebagai administrator TI.

Administrator yang memang memiliki kewenangan seharusnya menggunakan **mekanisme administratif yang tersedia**, bukan meminta password milik pengguna.

Penyerang Dapat Mengetahui Informasi Teknis

Jangan menganggap seseorang pasti administrator hanya karena mengetahui nama SIMRS, nama aplikasi, jenis komputer, atau informasi teknis lainnya.

Informasi tersebut dapat diperoleh melalui percakapan sebelumnya, media sosial, situs web, dokumen yang tersebar, atau informasi dari pihak lain.

Pelaku dapat menggunakan informasi tersebut untuk membuat komunikasi terdengar lebih meyakinkan.

Karena itu:

Mengetahui informasi teknis ≠ membuktikan bahwa seseorang adalah administrator.

Waspadai Permintaan untuk Menjalankan Program

Pelaku yang mengaku sebagai administrator juga dapat meminta pengguna melakukan tindakan pada komputer.

Misalnya:

“Download aplikasi ini supaya saya bisa memperbaiki komputer.”

“Klik link berikut untuk melakukan pembaruan.”

“Matikan antivirus sementara karena mengganggu proses perbaikan.”

“Jalankan file ini sebagai Administrator.”

Jangan mengikuti instruksi semacam itu apabila identitas dan permintaannya belum dapat dipastikan.

Aplikasi atau file yang diberikan dapat digunakan untuk memasang *malware* atau memberikan akses kepada pihak lain.

Berhati-hati dengan Akses Jarak Jauh

Administrator TI dapat menggunakan aplikasi *remote support* untuk membantu menangani masalah komputer. Namun, penggunaan akses jarak jauh harus mengikuti **mekanisme resmi organisasi**.

Jika seseorang yang tidak dikenal meminta Anda memasang aplikasi *remote access*, memberikan kode koneksi, atau mengizinkan kendali terhadap komputer, **verifikasi terlebih dahulu kepada pengelola TI melalui saluran resmi**.

Jangan memberikan akses hanya karena orang tersebut mengatakan:

“Saya dari IT.”

Verifikasi Melalui Saluran yang Sudah Dikenal

Jika menerima telepon atau pesan dari seseorang yang mengaku sebagai administrator dan permintaannya tidak biasa, lakukan verifikasi.

Gunakan nomor, *helpdesk*, atau saluran komunikasi resmi yang memang sudah diketahui.

Jangan hanya melakukan verifikasi melalui nomor yang digunakan oleh pihak tersebut.

Gunakan prinsip:

MENGAKU ADMINISTRATOR → PERIKSA IDENTITAS → VERIFIKASI → BARU BERTINDAK

ISO/IEC 27002:2022 menekankan pentingnya *information security awareness, education and training* agar personel memahami ancaman keamanan informasi dan tanggung jawabnya dalam melindungi informasi organisasi (ISO/IEC, 2022).

Jika Terlanjur Memberikan Credential atau Akses

Jika pengguna terlanjur memberikan *password*, OTP, kode *remote access*, atau menjalankan aplikasi atas permintaan pihak yang kemudian dicurigai bukan administrator resmi, **segera laporkan kepada pengelola TI.**

Jika *password* telah diberikan, lakukan tindakan pengamanan sesuai arahan organisasi. Jangan menunggu sampai akun benar-benar disalahgunakan.

Demikian pula jika pihak tersebut sempat memperoleh akses jarak jauh ke komputer. Informasikan apa yang terjadi dan tindakan apa saja yang dilakukan selama akses berlangsung agar dapat dilakukan pemeriksaan.

INGAT: Administrator TI yang sah tidak seharusnya meminta Anda menyerahkan password atau OTP pribadi. Jangan memasang aplikasi, menjalankan file, menonaktifkan keamanan, atau memberikan akses jarak jauh hanya karena seseorang mengaku sebagai administrator. **Jika ragu, verifikasi melalui saluran resmi TI.**

9.6 Penyerang Dapat Menyamar sebagai Vendor atau Teknisi

Rumah sakit dapat bekerja sama dengan vendor atau teknisi untuk pemeliharaan SIMRS, perangkat komputer, jaringan, maupun sistem lainnya. Kondisi ini dapat dimanfaatkan oleh pelaku *social engineering* dengan **menyamar sebagai vendor atau teknisi resmi.**

Pelaku dapat menghubungi pegawai dan menggunakan nama perusahaan, aplikasi, atau istilah teknis tertentu agar permintaannya terlihat meyakinkan.

Mengenal Nama Sistem Bukan Bukti Identitas

Pelaku dapat mengatakan:

“Saya dari vendor SIMRS, sedang ada perbaikan.”

“Saya teknisi yang biasa menangani server rumah sakit.”

“Kami sedang melakukan maintenance, mohon bantu aksesnya.”

Pengetahuan mengenai nama aplikasi atau vendor **tidak membuktikan bahwa orang tersebut benar-benar pihak yang berwenang.**

Informasi mengenai organisasi dan teknologi yang digunakan dapat diperoleh dari berbagai sumber. Karena itu, identitas tetap perlu diverifikasi.

Vendor Tidak Berhak Meminta Credential Pribadi

Vendor atau teknisi mungkin memerlukan akses tertentu untuk melakukan pekerjaannya. Namun, kebutuhan tersebut harus diberikan melalui **mekanisme akses yang ditetapkan organisasi**, bukan dengan menggunakan credential milik pegawai.

Jangan memberikan:

username dan password;

OTP atau kode verifikasi;

passphrase tanda tangan elektronik;

atau **credential pribadi lainnya.**

Prinsipnya tetap sama:

Vendor membutuhkan akses → berikan melalui mekanisme resmi.

Vendor meminta password Anda → jangan diberikan.

Jangan Memberikan Akses Hanya karena Ada Masalah Mendesak

Pelaku dapat menggunakan alasan gangguan sistem untuk menciptakan tekanan.

Misalnya:

“Server sedang bermasalah. Kalau tidak segera diberikan akses, SIMRS bisa berhenti.”

Situasi yang mendesak tidak menghilangkan kebutuhan untuk melakukan verifikasi.

Sebagaimana dibahas sebelumnya:

Mendesak bukan berarti boleh melewati prosedur keamanan.

Jika memang terjadi gangguan, koordinasikan dengan pengelola TI atau pihak yang bertanggung jawab sebelum memberikan akses.

Berhati-hati dengan Permintaan *Remote Access*

Vendor atau teknisi dapat menggunakan akses jarak jauh untuk melakukan *troubleshooting*. Namun, akses tersebut harus dilakukan melalui **mekanisme resmi dan dengan kewenangan yang jelas**.

Jangan langsung:

memasang aplikasi *remote access*;

memberikan kode koneksi;

menonaktifkan antivirus atau firewall;

atau **memberikan kendali komputer**

hanya karena seseorang mengaku sebagai teknisi.

Jika permintaan tidak biasa, verifikasi terlebih dahulu kepada pengelola TI.

Vendor Tidak Otomatis Berhak Melihat Data Pasien

Vendor yang bertugas memperbaiki aplikasi **tidak otomatis membutuhkan seluruh data pasien**.

Jika vendor hanya membutuhkan pesan *error*, konfigurasi, atau informasi teknis tertentu, berikan informasi yang diperlukan tanpa menyertakan data pasien yang tidak relevan.

Hal ini merupakan penerapan kembali prinsip ***need-to-know* dan *least privilege***.

ISO/IEC 27002:2022 juga memberikan perhatian terhadap keamanan informasi dalam hubungan dengan pemasok (*supplier relationships*), termasuk pengelolaan risiko keamanan informasi terkait penggunaan produk dan layanan pemasok (ISO/IEC, 2022).

Verifikasi Sebelum Memberikan Akses

Jika seseorang mengaku sebagai vendor atau teknisi, gunakan prinsip:

VERIFIKASI IDENTITAS → PERIKSA KEBUTUHAN → BERIKAN AKSES SESUAI KEWENANGAN

Konfirmasi melalui pengelola TI, penanggung jawab kontrak, atau saluran resmi yang telah ditetapkan.

Jangan melakukan verifikasi hanya dengan bertanya kepada orang tersebut:

“Benar dari vendor?”

Verifikasi harus menggunakan **sumber atau saluran lain yang dapat dipercaya.**

Jika Terlanjur Memberikan Akses

Jika pengguna terlanjur memberikan *password*, OTP, akses jarak jauh, atau data kepada seseorang yang kemudian diketahui atau dicurigai bukan vendor resmi, **segera laporkan kepada pengelola TI atau pihak yang menangani insiden keamanan.**

Sampaikan informasi mengenai apa yang diberikan, kapan kejadian berlangsung, dan tindakan apa yang sempat dilakukan oleh pihak tersebut.

Jangan menunggu sampai ditemukan kerusakan atau penyalahgunaan.

INGAT: Seseorang yang mengetahui nama vendor, SIMRS, atau informasi teknis belum tentu merupakan teknisi resmi. Jangan memberikan *password*, OTP, data pasien, atau akses komputer hanya karena seseorang mengaku sebagai vendor. **Verifikasi identitas dan kebutuhan akses melalui mekanisme resmi organisasi.**

9.7 Jangan Memberikan Password, OTP, atau Passphrase melalui Telepon dan Pesan

Password, OTP, dan *passphrase* merupakan **credential yang digunakan untuk membuktikan identitas atau memberikan akses.** Informasi tersebut harus dijaga kerahasiaannya dan tidak boleh diberikan kepada orang lain melalui telepon, WhatsApp, SMS, email, atau media komunikasi lainnya.

Prinsip ini tetap berlaku meskipun pihak yang meminta mengaku sebagai **atasan, administrator TI, vendor, teknisi, atau pihak lain yang dipercaya.**

Password Tidak Boleh Diberikan kepada Orang Lain

Jika seseorang mengetahui *password* Anda, orang tersebut dapat mencoba menggunakan akun seolah-olah sebagai pemilik akun.

Karena itu, hindari permintaan seperti:

“Kirim password-nya lewat WhatsApp.”

“Sebutkan password-nya lewat telepon.”

“Saya perlu login menggunakan akun Anda sebentar.”

Sebagaimana telah dibahas pada BAB 4, **credential bersifat pribadi dan tidak untuk dipinjamkan.**

Jika pihak lain memang membutuhkan akses, akses harus diberikan melalui mekanisme resmi dengan akun dan kewenangannya sendiri.

OTP Bukan Sekadar Kode Angka

OTP (*One-Time Password*) biasanya hanya berlaku dalam waktu singkat. Namun, justru pada waktu tersebut kode dapat digunakan untuk menyelesaikan proses autentikasi tertentu.

Pelaku *social engineering* dapat mengatakan:

“Kode yang masuk ke HP berapa? Saya perlu untuk verifikasi.”

“Sebutkan enam angka yang baru dikirim sistem.”

“Ini hanya kode verifikasi, bukan password.”

Jangan memberikan kode tersebut.

OTP yang diminta orang lain harus diperlakukan sebagai tanda bahaya, terutama jika Anda tidak sedang melakukan proses autentikasi yang menghasilkan kode tersebut.

Password Tanda Tangan Elektronik Harus Tetap Rahasia

Password yang digunakan dalam proses Tanda Tangan Elektronik juga tidak boleh diberikan kepada staf, operator, administrator, maupun pihak lain.

Jangan mengirim *password* melalui pesan dengan alasan:

“Tolong tandatangani dokumennya menggunakan akun saya.”

atau:

“Saya sedang di luar kantor, passphrase-nya saya kirim lewat WhatsApp.”

Sebagaimana telah dibahas pada BAB 5, proses penandatanganan elektronik harus dilakukan oleh **pemilik yang berwenang sesuai mekanisme yang berlaku**, bukan dengan menyerahkan *passphrase* kepada orang lain.

Jangan Terkecoh oleh Permintaan Mendesak

Pelaku dapat menggunakan tekanan waktu agar korban segera memberikan credential.

Misalnya:

“Kalau OTP tidak diberikan sekarang, akun akan terblokir.”

“Server sedang bermasalah, password dibutuhkan sekarang.”

“Ini perintah pimpinan, segera kirim passphrase-nya.”

Jangan membiarkan kata **“segera”, “darurat”, atau “perintah pimpinan”** membuat prosedur keamanan diabaikan.

Credential tetap rahasia meskipun permintaan terlihat mendesak.

Jika Menerima Permintaan Credential

Gunakan prinsip sederhana:

JANGAN BERIKAN → VERIFIKASI → LAPORKAN JIKA MENCURIGAKAN

Jika seseorang meminta *password*, OTP, atau *passphrase*, jangan memberikannya.

Apabila permintaan mengatasnamakan administrator, vendor, atau pimpinan, lakukan verifikasi melalui saluran resmi yang sudah diketahui.

ISO/IEC 27002:2022 menekankan pengelolaan informasi autentikasi agar alokasi dan pengelolaannya dilakukan melalui proses yang sesuai serta pengguna memahami tanggung jawabnya dalam menangani informasi autentikasi (ISO/IEC, 2022).

Jika Credential Terlanjur Diberikan

Jika *password*, OTP, atau *passphrase* terlanjur diberikan kepada pihak lain, **segera laporkan** melalui mekanisme organisasi.

Untuk *password*, lakukan perubahan sesuai prosedur dan arahan pengelola sistem. Untuk OTP atau *passphrase*, informasikan jenis credential yang diberikan, kapan kejadian terjadi, dan kepada siapa informasi tersebut diberikan.

Jangan menunggu sampai ditemukan penyalahgunaan.

INGAT: Password, OTP, dan passphrase tidak boleh diberikan melalui telepon, WhatsApp, SMS, email, atau media komunikasi lainnya. Administrator, vendor, teknisi, rekan kerja, bahkan atasan tidak memerlukan credential pribadi Anda. Jika ada yang memintanya, jangan berikan dan lakukan verifikasi.

9.8 Waspadai Tautan, Lampiran, dan QR Code

Tautan, lampiran, dan *QR Code* sering digunakan untuk mempermudah pekerjaan. Namun, media yang sama juga dapat digunakan dalam serangan *phishing* dan *social engineering* untuk mengarahkan pengguna ke **situs palsu, file berbahaya, atau halaman yang meminta credential.**

Karena itu, jangan langsung membuka sesuatu hanya karena pesan terlihat berasal dari pihak yang dikenal.

Waspadai Tautan yang Meminta Login

Pelaku dapat membuat halaman palsu yang tampilannya menyerupai layanan resmi, kemudian mengirim tautan dengan pesan seperti:

“Akun Anda harus diverifikasi.”

“Silakan login untuk melihat dokumen.”

“Password Anda akan kedaluwarsa, lakukan pembaruan melalui link berikut.”

Ketika pengguna memasukkan *username* dan *password* pada halaman palsu tersebut, credential dapat jatuh ke tangan pelaku.

Jika sebuah pesan meminta Anda melakukan *login*, **jangan terburu-buru menggunakan tautan dalam pesan.** Gunakan alamat atau aplikasi resmi yang biasa digunakan sesuai mekanisme organisasi.

Lampiran Dapat Mengandung Ancaman

Lampiran berbahaya dapat dibuat menyerupai dokumen pekerjaan, misalnya:

Undangan Rapat;

Surat Tugas;

Invoice;

Laporan;

atau **Data Pasien.**

Nama file yang terlihat meyakinkan tidak menjamin bahwa file tersebut aman.

Jangan membuka lampiran yang tidak diharapkan, terutama jika pengirimnya tidak dikenal atau isi pesannya tidak biasa. Jika ragu, **verifikasi kepada pengirim melalui saluran komunikasi yang sudah diketahui.**

QR Code Juga Dapat Mengarahkan ke Situs Berbahaya

QR Code pada dasarnya dapat digunakan untuk membawa pengguna menuju suatu alamat atau informasi tertentu. Masalahnya, **alamat tujuan tidak selalu terlihat sebelum kode dipindai.**

Pelaku dapat menggunakan QR Code untuk mengarahkan korban ke halaman *phishing* yang meminta *login*, informasi pribadi, atau tindakan lainnya.

Misalnya, pengguna menerima pesan:

“Scan QR Code berikut untuk aktivasi ulang akun.”

Setelah dipindai, pengguna diarahkan ke halaman yang menyerupai halaman *login* resmi.

Karena itu, perlakukan QR Code dengan kehati-hatian yang sama seperti sebuah tautan.

Periksa Sebelum Membuka

Sebelum membuka tautan, lampiran, atau QR Code, tanyakan:

Apakah saya memang mengharapkan pesan ini?

Apakah pengirimnya dapat dipercaya?

Apakah permintaannya masuk akal?

Mengapa saya diminta melakukan login atau memberikan informasi?

Jika terdapat keraguan, **jangan membuka terlebih dahulu**. Lakukan verifikasi melalui saluran resmi.

ISO/IEC 27002:2022 menekankan pentingnya *information security awareness, education and training* agar personel memiliki kesadaran terhadap ancaman keamanan informasi yang relevan dengan pekerjaannya (ISO/IEC, 2022).

Jangan Abaikan Peringatan Browser atau Antivirus

Jika browser, antivirus, atau sistem keamanan memberikan peringatan ketika membuka tautan atau file, jangan langsung memilih:

“Proceed anyway”

atau menonaktifkan perlindungan agar file dapat dibuka.

Peringatan tersebut perlu diperiksa. Jika file memang berkaitan dengan pekerjaan, **hubungi pengelola TI untuk membantu melakukan pemeriksaan**.

Jika Terlanjur Membuka

Jika terlanjur membuka tautan atau memindai *QR Code* tetapi belum memasukkan informasi apa pun, hentikan proses apabila halaman terlihat mencurigakan.

Jika sudah memasukkan *password*, memberikan OTP, mengunduh file, atau menjalankan lampiran yang mencurigakan, **segera laporkan kepada pengelola TI**.

Jangan menunggu sampai akun atau komputer menunjukkan tanda-tanda serangan.

INGAT: Tautan, lampiran, dan QR Code dapat digunakan sebagai jalan masuk serangan. Jangan langsung klik, buka, atau pindai hanya karena pesan terlihat resmi. **Periksa pengirim, tujuan, dan permintaannya. Jika ragu, verifikasi sebelum bertindak.**

9.9 Verifikasi Permintaan yang Mencurigakan melalui Kanal Terpercaya

Ketika menerima permintaan yang tidak biasa, tindakan yang tepat bukan langsung menuruti atau langsung menolaknya. **Lakukan verifikasi melalui kanal komunikasi yang sudah diketahui dan dipercaya.**

Verifikasi penting terutama jika permintaan berkaitan dengan **data pasien, credential, akses sistem, perubahan akun, instalasi aplikasi, atau tindakan yang dapat memengaruhi keamanan informasi.**

Jangan Memverifikasi melalui Kanal yang Sama

Jika seseorang menghubungi melalui nomor WhatsApp baru dan mengaku sebagai atasan, jangan melakukan verifikasi hanya dengan bertanya:

“Benar ini Bapak/Ibu?”

Pelaku tentu dapat menjawab bahwa identitas tersebut benar.

Gunakan kanal lain yang sebelumnya sudah diketahui, misalnya nomor telepon resmi, kontak yang tersimpan sebelumnya, *helpdesk* resmi, atau konfirmasi langsung kepada pihak terkait.

Prinsipnya:

Pesan mencurigakan → gunakan kanal lain untuk memverifikasi.

Jangan Menggunakan Kontak yang Diberikan oleh Pengirim

Pelaku dapat mengatakan:

“Kalau tidak percaya, hubungi nomor ini.”

Nomor tersebut mungkin masih dikendalikan oleh pelaku atau pihak yang bekerja sama dengannya.

Jika perlu melakukan verifikasi, cari kontak melalui **sumber resmi yang sudah diketahui**, bukan hanya menggunakan nomor telepon, alamat email, atau tautan yang terdapat dalam pesan mencurigakan.

Verifikasi Identitas dan Permintaannya

Mengetahui identitas pengirim saja belum cukup. Pengguna juga perlu memastikan bahwa **permintaan tersebut benar-benar**

berasal dari pihak yang bersangkutan dan sesuai dengan kewenangannya.

Misalnya, seseorang memang merupakan vendor resmi SIMRS. Namun, jika ia tiba-tiba meminta *password* pengguna, permintaan tersebut tetap tidak boleh dipenuhi.

Karena itu, verifikasi dua hal:

Siapa yang meminta?

dan

Apakah permintaannya memang sah dan sesuai prosedur?

Permintaan Mendesak Tetap Harus Diverifikasi

Pelaku *social engineering* sering menggunakan tekanan waktu:

“Harus sekarang.”

“Pimpinan sedang menunggu.”

“Kalau terlambat, sistem akan bermasalah.”

“Tidak perlu konfirmasi, langsung kerjakan.”

Justru permintaan yang mendesak dan tidak biasa perlu mendapatkan perhatian lebih.

Kadaan mendesak tidak menghilangkan kewajiban untuk menjaga keamanan informasi.

Contoh Verifikasi yang Benar

Misalnya, Anda menerima WhatsApp dari nomor baru:

“Saya dari vendor SIMRS. Tolong kirimkan database pasien untuk pengecekan.”

Jangan langsung mengirim data.

Hubungi administrator TI atau penanggung jawab vendor melalui kontak resmi yang sudah diketahui dan tanyakan apakah permintaan tersebut benar.

Demikian pula jika seseorang mengaku sebagai pimpinan dan meminta dokumen pasien. **Konfirmasikan permintaan melalui kanal resmi sebelum mengirimkan informasi.**

ISO/IEC 27002:2022 menekankan pentingnya kesadaran dan pelatihan keamanan informasi agar personel memahami tanggung jawabnya dan mampu merespons ancaman keamanan yang relevan (ISO/IEC, 2022).

Jika Masih Ragu, Jangan Bertindak Terlebih Dahulu

Jika verifikasi belum dapat dilakukan, jangan memberikan credential, mengirim data pasien, memasang aplikasi, atau memberikan akses hanya karena merasa tidak enak menolak permintaan.

Gunakan prinsip sederhana:

**BERHENTI → VERIFIKASI IDENTITAS → VERIFIKASI PERMINTAAN
→ BERTINDAK**

Jika setelah diverifikasi permintaan ternyata tidak sah, **laporkan kejadian tersebut melalui mekanisme keamanan informasi organisasi** agar pihak lain dapat diperingatkan apabila diperlukan.

INGAT: Jangan mempercayai permintaan hanya berdasarkan nama, foto profil, nomor telepon, alamat email, atau jabatan pengirim. Jika permintaan tidak biasa, verifikasi identitas dan permintaannya melalui kanal lain yang resmi dan sudah dipercaya. Jika belum dapat diverifikasi, jangan berikan data, credential, atau akses.

9.10 Laporkan Percobaan Phishing dan Social Engineering

Percobaan *phishing* atau *social engineering* perlu dilaporkan **meskipun pengguna tidak terlanjur mengklik tautan, membuka lampiran, memberikan credential, atau mengirim data.**

Sebuah pesan mencurigakan yang diterima oleh satu pegawai dapat menjadi bagian dari serangan yang juga menargetkan pegawai lainnya. Pelaporan yang cepat membantu organisasi melakukan pemeriksaan dan mengambil tindakan pencegahan.

Jangan Hanya Menghapus Pesan

Ketika menerima email atau WhatsApp mencurigakan, pengguna mungkin berpikir:

“Saya tahu ini penipuan, hapus saja.”

Menghapus pesan memang dapat mencegah pengguna membukanya kembali, tetapi organisasi kehilangan kesempatan

untuk mengetahui bahwa **sedang ada upaya serangan terhadap pegawai.**

Karena itu, jika tersedia mekanisme pelaporan keamanan informasi, gunakan mekanisme tersebut sebelum menghapus pesan sesuai arahan organisasi.

Laporkan Meskipun Tidak Menjadi Korban

Tidak perlu menunggu sampai serangan berhasil.

Laporkan jika menemukan:

email *phishing*;

pesan yang meminta password atau OTP;

pihak yang mengaku sebagai administrator, vendor, atau pimpinan secara mencurigakan;

tautan atau *QR Code* yang mencurigakan;

atau lampiran yang tidak diharapkan dan diduga berbahaya.

Informasi tersebut dapat membantu pengelola TI mengetahui pola serangan yang sedang berlangsung.

Informasi yang Perlu Disampaikan

Ketika melaporkan, berikan informasi yang cukup agar kejadian dapat diperiksa, misalnya:

waktu pesan diterima;

media yang digunakan;

identitas atau alamat pengirim yang terlihat;

isi atau jenis permintaan;

dan tindakan yang sudah dilakukan.

Jika organisasi meminta bukti berupa email, pesan, atau *screenshot*, ikuti prosedur yang diberikan. Jangan menyebarkan pesan mencurigakan ke banyak rekan kerja hanya untuk memperingatkan mereka karena hal tersebut dapat ikut menyebarkan tautan atau lampiran berbahaya.

Jika Sudah Terlanjur Berinteraksi, Sampaikan dengan Jelas

Jika pengguna sudah terlanjur melakukan sesuatu, **jangan menyembunyikan informasi tersebut ketika melapor.**

Sampaikan apabila sudah:

mengklik tautan;

membuka atau menjalankan lampiran;

memindai QR Code;

memasukkan username dan password;

memberikan OTP;

atau **memberikan akses maupun data kepada pihak tersebut.**

Informasi ini penting karena tindakan penanganannya dapat berbeda.

Pelaporan yang Cepat Membantu Melindungi Pengguna Lain

Jika satu pegawai melaporkan sebuah email *phishing*, pengelola TI dapat melakukan pemeriksaan dan, sesuai kemampuan sistem serta prosedur organisasi, mengambil tindakan untuk mengurangi risiko terhadap pengguna lainnya.

Karena itu, laporan dari pengguna bukan sekadar laporan mengenai:

“Saya menerima pesan aneh.”

Laporan tersebut dapat menjadi **peringatan dini terhadap serangan yang sedang berlangsung.**

ISO/IEC 27002:2022 mengatur pelaporan kejadian keamanan informasi melalui kontrol **6.8 Information security event reporting**, yaitu agar personel melaporkan kejadian keamanan informasi yang diamati atau dicurigai melalui saluran yang sesuai secara tepat waktu (ISO/IEC, 2022).

Jangan Takut Melapor karena Terlanjur Melakukan Kesalahan

Jika pengguna terlanjur mengklik tautan atau memberikan informasi, menunda laporan dapat memberikan waktu lebih lama bagi pelaku untuk menyalahgunakan akses yang diperoleh.

Karena itu, fokus pertama adalah **memungkinkan organisasi melakukan penanganan secepat mungkin.**

Gunakan prinsip:

TEMUKAN → JANGAN SEBARKAN → LAPORKAN

Jika sudah terlanjur berinteraksi:

HENTIKAN → LAPORKAN → IKUTI ARAHAN PENANGANAN

INGAT: Percobaan phishing dan social engineering tetap perlu dilaporkan meskipun serangan belum berhasil. Jangan hanya

menghapus pesan dan melupakannya. **Laporan dari satu pegawai dapat membantu melindungi banyak pegawai lainnya dari serangan yang sama.**

BAB 10 KEAMANAN AKSES VENDOR DAN PIHAK KETIGA

10.1 Pihak Ketiga Juga Wajib Melindungi Data Pasien

Pelindungan data pasien tidak hanya menjadi tanggung jawab pegawai rumah sakit. Dalam penyelenggaraan pelayanan dan sistem informasi, organisasi dapat bekerja sama dengan **vendor, konsultan, teknisi, penyedia aplikasi, penyedia layanan cloud, maupun pihak ketiga lainnya.**

Jika pihak ketiga memperoleh akses terhadap data pasien atau sistem yang memproses data tersebut, **akses itu harus tetap dikelola dan dilindungi sesuai kewenangan serta tujuan pekerjaan.**

Status sebagai Vendor Bukan Berarti Bebas Mengakses Data

Vendor dapat membutuhkan akses untuk melakukan pemeliharaan, *troubleshooting*, pembaruan aplikasi, atau pekerjaan teknis lainnya.

Namun, status sebagai vendor tidak otomatis memberikan hak untuk:

melihat seluruh data pasien;

mengunduh database;

menyalin data ke perangkat pribadi;

meminta credential pegawai;

atau **menggunakan data untuk kepentingan di luar pekerjaan yang diberikan.**

Akses harus dibatasi sesuai kebutuhan pekerjaan.

Prinsip ***need-to-know*** dan ***least privilege*** yang telah dibahas pada BAB 3 tetap berlaku terhadap pihak ketiga.

Data Hanya Digunakan untuk Tujuan yang Disepakati

Jika pihak ketiga memperoleh data untuk suatu pekerjaan tertentu, data tersebut tidak boleh digunakan untuk tujuan lain tanpa dasar dan kewenangan yang sesuai.

UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi mengatur hubungan antara Pengendali Data Pribadi dan Prosesor Data Pribadi. Prosesor melakukan pemrosesan Data Pribadi berdasarkan **perintah Pengendali Data Pribadi**, dan pemrosesan tersebut termasuk dalam tanggung jawab Pengendali Data Pribadi (Republik Indonesia, 2022).

Karena itu, penggunaan pihak ketiga tidak menghilangkan kebutuhan organisasi untuk mengendalikan bagaimana Data Pribadi diproses.

Vendor Harus Menggunakan Mekanisme Akses Resmi

Jika vendor membutuhkan akses ke sistem, gunakan mekanisme yang ditetapkan organisasi.

Hindari praktik seperti:

“Pakai akun saya saja.”

“Password administrator saya kirim lewat WhatsApp.”

“Database saya copy ke flashdisk vendor supaya lebih cepat.”

Pihak ketiga sebaiknya memperoleh akses yang **dapat dikendalikan, dibatasi, dan dipertanggungjawabkan** sesuai kebutuhan pekerjaan.

ISO/IEC 27002:2022 juga memberikan perhatian khusus terhadap keamanan informasi dalam hubungan dengan pemasok (*supplier relationships*), termasuk pengelolaan risiko keamanan yang berkaitan dengan produk dan layanan pihak ketiga (ISO/IEC, 2022).

Data untuk *Troubleshooting* Tetap Harus Diminimalkan

Vendor terkadang membutuhkan contoh data untuk menganalisis masalah aplikasi.

Namun, jangan langsung memberikan seluruh database atau dokumen pasien jika permasalahan dapat diperiksa menggunakan informasi yang lebih terbatas.

Jika memungkinkan, gunakan:

data uji;

data yang telah diminimalkan;

atau **informasi teknis yang tidak mengandung identitas pasien.**

Prinsipnya:

Berikan informasi yang diperlukan untuk menyelesaikan masalah, bukan seluruh data yang tersedia.

Kewajiban Perlindungan Tidak Berakhir Setelah Data Diberikan

Ketika data atau akses diberikan kepada pihak ketiga, organisasi tetap perlu memastikan pengelolaannya sesuai ketentuan dan hubungan kerja yang berlaku.

Hal yang perlu diperhatikan antara lain **ruang lingkup akses, kerahasiaan, penggunaan data, penyimpanan, pengembalian atau penghapusan data, serta pencabutan akses ketika pekerjaan selesai.**

Akses yang diberikan untuk pekerjaan sementara tidak seharusnya tetap aktif tanpa kebutuhan setelah pekerjaan tersebut berakhir.

Pegawai Tetap Harus Berhati-hati

Pegawai tidak perlu menentukan sendiri seluruh aspek hukum atau teknis hubungan dengan vendor. Namun, setiap pegawai perlu memahami satu prinsip penting:

“Dia vendor resmi” bukan alasan untuk memberikan semua data atau akses.

Jika pihak ketiga meminta data atau akses yang tidak biasa, **konfirmasi kepada pengelola TI atau pihak yang berwenang sebelum memenuhi permintaan tersebut.**

INGAT: Pihak ketiga yang bekerja untuk organisasi tetap wajib menjaga keamanan dan kerahasiaan data pasien. Status sebagai vendor atau teknisi tidak memberikan hak untuk mengakses seluruh data. **Berikan akses dan informasi hanya sesuai kebutuhan, kewenangan, dan mekanisme resmi organisasi.**

10.2 Akses Pihak Ketiga Harus Berdasarkan Kebutuhan

Pihak ketiga seperti vendor, teknisi, konsultan, atau penyedia layanan terkadang memerlukan akses ke sistem rumah sakit untuk

melakukan pemeliharaan, *troubleshooting*, pembaruan, atau pekerjaan lainnya.

Namun, **akses tidak boleh diberikan lebih luas daripada yang benar-benar diperlukan untuk menyelesaikan pekerjaan.**

Prinsip ini merupakan penerapan *need-to-know* dan *least privilege* yang telah dibahas pada BAB 3.

Vendor Tidak Membutuhkan Akses ke Semua Sistem

Kebutuhan akses harus disesuaikan dengan pekerjaan yang dilakukan.

Sebagai contoh, vendor yang melakukan perbaikan pada modul tertentu dalam SIMRS **tidak otomatis membutuhkan akses ke seluruh modul, seluruh server, atau seluruh database pasien.**

Demikian pula teknisi yang hanya memperbaiki printer tidak seharusnya memperoleh akses ke SIMRS hanya karena sedang bekerja pada komputer yang digunakan untuk pelayanan.

Prinsip sederhananya:

Akses diberikan sesuai pekerjaan, bukan berdasarkan status sebagai vendor.

Tentukan Apa yang Benar-Benar Dibutuhkan

Sebelum memberikan akses kepada pihak ketiga, perlu dipastikan:

sistem apa yang perlu diakses;

data apa yang diperlukan;

fungsi apa yang diperlukan;

dan berapa lama akses tersebut dibutuhkan.

Jika pekerjaan hanya membutuhkan akses baca, jangan memberikan kewenangan untuk mengubah atau menghapus data.

Jika pekerjaan dapat dilakukan tanpa melihat data pasien, **jangan memberikan akses terhadap data pasien.**

Jangan Meminjamkan Akun Pegawai

Akses pihak ketiga tidak seharusnya dilakukan dengan meminjam akun milik pegawai.

Hindari:

“Login saja menggunakan akun saya.”

“Saya berikan username dan password supaya pekerjaan cepat selesai.”

Penggunaan akun pegawai oleh vendor menyebabkan aktivitas sulit dibedakan antara tindakan pemilik akun dan tindakan pihak ketiga.

Jika pihak ketiga memang membutuhkan akses, gunakan **mekanisme akses resmi yang dapat dipertanggungjawabkan.**

Akses Sementara Harus Benar-Benar Sementara

Beberapa pekerjaan pihak ketiga hanya berlangsung beberapa jam atau beberapa hari.

Jika akses diberikan khusus untuk pekerjaan tersebut, akses perlu **ditinjau dan dicabut ketika pekerjaan selesai.**

Jangan membiarkan akun vendor tetap aktif berbulan-bulan hanya karena:

“Nanti mungkin dibutuhkan lagi.”

Akses yang tidak lagi diperlukan menjadi risiko keamanan tambahan.

Akses Jarak Jauh Juga Harus Dibatasi

Prinsip yang sama berlaku terhadap **remote access**.

Jika vendor melakukan pemeliharaan dari luar organisasi, akses jarak jauh harus menggunakan mekanisme yang disetujui dan dikendalikan organisasi.

Pihak ketiga tidak seharusnya memasang aplikasi *remote access* permanen atau membuat jalur akses sendiri tanpa sepengetahuan pihak yang bertanggung jawab.

ISO/IEC 27002:2022 menekankan pengelolaan risiko keamanan informasi dalam hubungan dengan pemasok, termasuk pengaturan akses pemasok terhadap informasi dan aset organisasi (ISO/IEC, 2022).

Pegawai Tidak Menentukan Akses Vendor Sendiri

Pegawai yang sedang dibantu oleh teknisi tidak seharusnya memberikan akses tambahan hanya karena vendor mengatakan akses tersebut diperlukan.

Jika vendor meminta akses yang lebih tinggi, data tambahan, akun administrator, atau akses ke sistem lain, **koordinasikan terlebih dahulu dengan pengelola TI atau pihak yang memiliki kewenangan.**

Prinsipnya:

BUTUH AKSES → VERIFIKASI KEBUTUHAN → BERIKAN SECUKUPNYA → CABUT SETELAH SELESAI

INGAT: Pihak ketiga hanya boleh memperoleh akses yang benar-benar diperlukan untuk pekerjaannya. Jangan meminjamkan akun pegawai, jangan memberikan akses berlebihan, dan jangan membiarkan akses sementara tetap aktif setelah pekerjaan selesai. Semakin sedikit akses yang diperlukan, semakin kecil risiko yang harus dikelola.

10.3 Hindari Penggunaan Akun Pegawai oleh Vendor

Vendor atau teknisi mungkin membutuhkan akses ke aplikasi atau sistem untuk melakukan pemeliharaan dan *troubleshooting*. Namun, **vendor tidak seharusnya menggunakan akun milik pegawai untuk melakukan pekerjaannya.**

Setiap akun merupakan identitas pengguna di dalam sistem. Jika akun pegawai digunakan oleh vendor, aktivitas vendor dapat tercatat seolah-olah dilakukan oleh pegawai pemilik akun.

Akun Pegawai Bukan Akun Vendor

Hindari praktik seperti:

“Pakai akun saya saja supaya cepat.”

“SIMRS sudah login, silakan dicek menggunakan akun ini.”

“Saya berikan password sementara, nanti setelah selesai diganti.”

Cara tersebut mungkin terlihat praktis, tetapi menghilangkan kejelasan mengenai **siapa yang sebenarnya melakukan suatu aktivitas.**

Vendor yang membutuhkan akses harus menggunakan mekanisme akses yang ditetapkan oleh organisasi.

Penggunaan Akun Bersama Mengurangi Akuntabilitas

Sistem dapat mencatat aktivitas pengguna melalui *logging* dan *audit trail*.

Misalnya, akun seorang pegawai digunakan vendor untuk melakukan perubahan konfigurasi. Ketika kemudian ditemukan perubahan pada sistem, catatan aktivitas dapat menunjukkan **akun pegawai tersebut sebagai pelakunya**.

Akan sulit membedakan apakah tindakan dilakukan oleh pemilik akun atau oleh vendor yang meminjam akun.

Karena itu:

Satu akun → satu identitas → aktivitas dapat dipertanggungjawabkan.

Jangan Memberikan Password kepada Vendor

Vendor tidak membutuhkan *password* pribadi pegawai.

Jika vendor mengatakan:

“Saya membutuhkan username dan password Anda untuk pengecekan.”

jangan langsung memberikannya.

Koordinasikan dengan pengelola TI agar vendor memperoleh **akses yang sesuai dengan kebutuhan pekerjaannya**.

Hal ini juga konsisten dengan pembahasan BAB 4 bahwa *password* merupakan credential yang harus dijaga kerahasiaannya.

Akun Vendor Harus Sesuai Kebutuhan

Jika pekerjaan memang membutuhkan akses sistem, organisasi dapat menyediakan mekanisme akses yang sesuai. Akses tersebut sebaiknya dibatasi berdasarkan:

sistem yang diperlukan;
tingkat kewenangan yang diperlukan;
tujuan pekerjaan;
dan **jangka waktu pekerjaan.**

Tidak semua vendor membutuhkan hak administrator. Jika akses terbatas sudah cukup, tidak perlu memberikan akses yang lebih tinggi.

ISO/IEC 27002:2022 menekankan pengelolaan hak akses dan keamanan informasi dalam hubungan dengan pemasok, termasuk pengendalian akses terhadap informasi dan aset organisasi (ISO/IEC, 2022).

Jangan Membiarkan Vendor Menggunakan Sesi yang Masih Login

Masalah tidak hanya terjadi ketika password diberikan.

Jika pegawai membuka SIMRS kemudian membiarkan vendor menggunakan komputer melalui sesi tersebut, vendor tetap menggunakan **identitas dan kewenangan pegawai**.

Karena itu, jangan mengatakan:

“Saya login-kan saja, nanti vendor yang menggunakan.”

Jika vendor membutuhkan akses, gunakan mekanisme yang memang disediakan untuk pihak tersebut.

Setelah Pekerjaan Selesai

Akses yang diberikan khusus untuk pekerjaan vendor perlu **ditinjau dan dicabut ketika sudah tidak diperlukan**.

Hal ini penting terutama untuk akun sementara dan akses jarak jauh. Jangan membiarkan akses tetap aktif hanya karena kemungkinan akan digunakan kembali di kemudian hari.

Prinsip sederhananya:

BUTUH AKSES → GUNAKAN AKSES RESMI → BATASI KEWENANGAN → CABUT SETELAH SELESAI

INGAT: Jangan meminjamkan akun, password, atau sesi SIMRS yang sedang login kepada vendor. Penggunaan akun pegawai oleh pihak lain menghilangkan akuntabilitas dan dapat membuat aktivitas vendor tercatat atas nama pegawai. **Vendor harus menggunakan mekanisme akses resmi sesuai kebutuhan pekerjaannya.**

10.4 Setiap Pengguna Harus Memiliki Identitas dan Akun yang Dapat Dipertanggungjawabkan

Setiap pengguna yang mengakses SIMRS, Rekam Medis Elektronik, maupun sistem informasi lainnya seharusnya

menggunakan **identitas dan akun yang dapat dikaitkan dengan dirinya sendiri**.

Akun bukan sekadar sarana untuk masuk ke sistem. Akun merupakan **identitas digital** yang digunakan sistem untuk menentukan hak akses dan mencatat aktivitas pengguna.

Satu Pengguna, Satu Identitas

Penggunaan akun individual membantu organisasi mengetahui siapa yang melakukan suatu aktivitas.

Karena itu, hindari penggunaan akun seperti:

“operator”

“adminruangan”

“petugas1”

atau akun bersama lainnya apabila akun tersebut digunakan oleh banyak orang tanpa mekanisme identifikasi individual yang memadai.

Prinsip yang perlu dibangun adalah:

Satu pengguna → satu identitas → satu akun yang dapat dipertanggungjawabkan.

Akun Bersama Menghilangkan Kejelasan

Bayangkan satu akun SIMRS digunakan oleh lima pegawai.

Kemudian ditemukan perubahan terhadap data pasien. *Audit trail* menunjukkan bahwa perubahan dilakukan oleh akun tersebut, tetapi organisasi tidak dapat dengan mudah mengetahui **siapa dari lima pengguna yang sebenarnya melakukan perubahan**.

Kondisi ini mengurangi akuntabilitas dan menyulitkan proses pemeriksaan ketika terjadi kesalahan atau insiden.

Jangan Menggunakan Akun Milik Orang Lain

Setiap pegawai harus menggunakan akun yang diberikan untuk dirinya sendiri.

Hindari:

meminjam akun rekan kerja;

menggunakan akun pegawai yang sedang tidak masuk;

memberikan akun kepada pegawai pengganti;

atau membiarkan vendor menggunakan akun pegawai.

Jika seseorang membutuhkan akses, solusi yang tepat adalah **memberikan akses melalui mekanisme resmi**, bukan meminjamkan identitas pengguna lain.

Hak Akses Mengikuti Tugas Pengguna

Memiliki akun sendiri bukan berarti setiap pengguna mendapatkan akses yang sama.

Hak akses harus disesuaikan dengan **tugas, fungsi, dan kewenangan masing-masing pengguna**.

Sebagai contoh, petugas pendaftaran, tenaga kesehatan, bagian keuangan, administrator TI, dan vendor dapat memiliki kebutuhan akses yang berbeda.

Prinsip ***least privilege*** tetap berlaku:

Berikan akses yang diperlukan untuk bekerja, bukan seluruh akses yang tersedia.

Perubahan Pegawai Harus Diikuti Pengelolaan Akun

Identitas dan akun juga perlu dikelola ketika terjadi perubahan kondisi pengguna.

Jika pegawai berpindah unit, berubah tugas, berhenti bekerja, atau tidak lagi membutuhkan suatu akses, hak aksesnya perlu **ditinjau, disesuaikan, atau dicabut sesuai prosedur organisasi**.

Hal yang sama berlaku terhadap akun vendor dan tenaga pihak ketiga ketika pekerjaan atau kontraknya telah selesai.

ISO/IEC 27002:2022 mengatur ***identity management*** dan ***access rights*** sebagai bagian dari pengendalian keamanan informasi. Identitas serta hak akses perlu dikelola sepanjang siklus hidupnya agar akses tetap sesuai dengan kebutuhan organisasi (ISO/IEC, 2022).

Akun Individual Mendukung *Audit Trail*

Akun individual memungkinkan *logging* dan *audit trail* memberikan informasi yang lebih berguna.

Jika setiap pengguna menggunakan identitasnya sendiri, organisasi dapat lebih mudah menelusuri:

siapa yang mengakses sistem;

kapan akses dilakukan;

dan aktivitas apa yang dilakukan.

Karena itu, akun individual tidak hanya berkaitan dengan keamanan akses, tetapi juga mendukung **akuntabilitas penggunaan sistem.**

INGAT: Setiap pengguna harus menggunakan identitas dan akunnya sendiri. Jangan meminjam, meminjamkan, atau menggunakan akun bersama tanpa mekanisme akuntabilitas yang memadai. **Satu pengguna → satu identitas → aktivitas dapat dipertanggungjawabkan.**

10.5 Larangan Menyalin Database Tanpa Kewenangan

Database rumah sakit dapat berisi **data pasien dalam jumlah besar**, termasuk identitas, riwayat pelayanan, informasi kesehatan, transaksi, serta informasi lainnya yang digunakan dalam penyelenggaraan pelayanan.

Karena itu, **database tidak boleh disalin, diunduh, diekspor, atau dipindahkan tanpa kebutuhan dan kewenangan yang sah.**

Risiko penyalinan database berbeda dengan membuka satu data pasien. Satu salinan database dapat menyebabkan **sejumlah besar data ikut berpindah sekaligus.**

Jangan Menyalin Database untuk Kemudahan

Dalam proses *troubleshooting* atau pengembangan sistem, mungkin muncul kebiasaan seperti:

“Copy database-nya saja supaya bisa dicek di laptop.”

“Backup database-nya kirim ke vendor.”

“Saya download dulu supaya bisa dikerjakan dari rumah.”

Cara tersebut mungkin terlihat praktis, tetapi dapat menciptakan **salinan data pasien di luar lingkungan yang seharusnya.**

Setiap salinan baru juga menambah lokasi yang harus diamankan.

Hak Akses Database Bukan Izin untuk Menyalin

Administrator atau tenaga TI mungkin memiliki akses teknis yang memungkinkan melakukan *backup*, *export*, atau menyalin database.

Namun:

Mampu secara teknis ≠ berwenang secara organisasi.

Hak administrator diberikan untuk menjalankan tugas tertentu. Kemampuan teknis tersebut tidak boleh digunakan untuk menyalin data bagi kepentingan pribadi atau tujuan lain di luar pekerjaan yang diberikan.

Vendor Tidak Otomatis Berhak Mendapat Salinan Database

Vendor dapat membutuhkan informasi untuk melakukan *troubleshooting*. Namun, kebutuhan tersebut tidak otomatis berarti seluruh database harus diberikan.

Jika masalah dapat dianalisis menggunakan:

data uji;

contoh data yang terbatas;

log aplikasi;

pesan *error*;

atau **data yang telah diminimalkan,**

maka gunakan informasi tersebut terlebih dahulu.

Prinsipnya:

Berikan data seminimal mungkin sesuai kebutuhan pekerjaan.

Waspada Database Produksi

Database produksi dapat berisi data nyata dalam jumlah besar. Karena itu, penggunaannya untuk pengembangan, pengujian, demonstrasi, atau pelatihan perlu mendapatkan perhatian khusus.

Jangan sembarangan menyalin database produksi ke:

laptop pribadi;

komputer pengembang;

server pengujian;

media penyimpanan eksternal;

atau **lingkungan milik pihak ketiga.**

Jika data memang diperlukan untuk suatu proses resmi, gunakan mekanisme dan pengamanan yang ditetapkan organisasi.

Salinan Database Juga Harus Dilindungi

Risiko tidak berakhir setelah proses *backup* atau *export* selesai.

File hasil *backup* database tetap dapat mengandung Data Pribadi. Karena itu, file tersebut harus diperlakukan dengan tingkat kehati-hatian yang sesuai.

Jangan meninggalkan file seperti:

backup.sql

database.zip

atau file *dump* lainnya pada folder yang dapat diakses secara bebas, perangkat pribadi, atau media yang tidak dikelola dengan semestinya.

UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi mewajibkan adanya langkah teknis operasional untuk melindungi Data Pribadi serta mencegah akses yang tidak sah (Republik Indonesia, 2022).

Jika Membutuhkan Salinan Database

Jika pekerjaan memang membutuhkan *backup*, *export*, atau salinan database, proses tersebut harus dilakukan berdasarkan **kebutuhan pekerjaan, kewenangan, dan prosedur organisasi**.

Pastikan pula salinan tidak dipertahankan lebih lama daripada yang diperlukan dan dikelola sesuai ketentuan mengenai penyimpanan serta penghapusan data.

ISO/IEC 27002:2022 menekankan pengendalian akses, pelindungan informasi, serta pengelolaan keamanan dalam hubungan dengan pihak ketiga (ISO/IEC, 2022).

INGAT: Jangan menyalin, mengunduh, mengekspor, atau membawa database pasien tanpa kewenangan. Hak administrator atau kemampuan melakukan *backup* bukan berarti bebas membuat salinan database. Jika kebutuhan dapat dipenuhi dengan data yang lebih sedikit, jangan memberikan seluruh database.

10.6 Penggunaan Data untuk Pengujian dan Troubleshooting

Pengujian dan *troubleshooting* merupakan bagian penting dalam pengelolaan SIMRS dan sistem informasi rumah sakit. Dalam proses

tersebut, administrator, pengembang, atau vendor terkadang membutuhkan data untuk **mereproduksi masalah, menguji perbaikan, atau memastikan aplikasi berjalan dengan benar.**

Namun, kebutuhan teknis tersebut tidak berarti data pasien produksi dapat digunakan secara bebas. **Gunakan data seminimal mungkin dan hindari penggunaan data pasien nyata apabila pengujian dapat dilakukan dengan data uji.**

Utamakan Data Uji

Untuk pengembangan dan pengujian, pilihan pertama sebaiknya adalah **data uji (test data)** yang tidak menggunakan identitas pasien sebenarnya.

Misalnya, daripada menggunakan data pasien nyata, buat data seperti:

Nama: Pasien Uji 001

Nomor Rekam Medis: TEST-0001

Alamat: Data Pengujian

Tanggal Lahir: data simulasi

Data tersebut cukup untuk menguji banyak fungsi aplikasi tanpa membuka Data Pribadi pasien.

Prinsipnya:

Bisa menggunakan data uji → jangan menggunakan data pasien nyata.

Jangan Langsung Memberikan Database Produksi

Ketika terjadi masalah pada aplikasi, vendor mungkin meminta:

“Kirim database produksi supaya kami bisa mengecek.”

Permintaan tersebut tidak boleh langsung dipenuhi.

Periksa terlebih dahulu apakah masalah dapat dianalisis menggunakan:

pesan error;

log aplikasi;

screenshot yang telah meminimalkan data pasien;

contoh data terbatas;

atau **database pengujian.**

Memberikan seluruh database produksi seharusnya bukan pilihan pertama.

Gunakan Data Seminimal Mungkin

Dalam beberapa kasus, masalah mungkin hanya muncul pada kondisi data tertentu. Jika data memang diperlukan untuk *troubleshooting*, batasi data hanya pada bagian yang benar-benar diperlukan.

Sebagai contoh, jika masalah hanya terjadi pada satu transaksi, **tidak perlu memberikan data seluruh pasien rumah sakit.**

Prinsip ini sejalan dengan prinsip pembatasan pemrosesan Data Pribadi sesuai tujuan sebagaimana diatur dalam UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi (Republik Indonesia, 2022).

Samarkan Data Jika Memungkinkan

Jika struktur dan karakteristik data nyata diperlukan untuk pengujian, organisasi dapat menerapkan mekanisme seperti **masking, pseudonimisasi, atau teknik lain yang sesuai** untuk mengurangi keterkaitan data dengan individu sebenarnya.

Namun, mengganti nama pasien saja belum tentu cukup.

Nomor rekam medis, NIK, nomor telepon, alamat, tanggal lahir, maupun kombinasi informasi lainnya masih dapat memungkinkan seseorang dikenali.

Karena itu, proses penyamaran data perlu dilakukan melalui **mekanisme teknis yang ditetapkan organisasi**, bukan sekadar mengubah beberapa nama secara manual.

Pisahkan Lingkungan Produksi dan Pengujian

Pengujian sebaiknya dilakukan pada lingkungan yang memang disediakan untuk pengembangan atau pengujian, bukan langsung pada sistem produksi tanpa mekanisme yang sesuai.

Hal ini membantu mengurangi risiko perubahan tidak disengaja terhadap data maupun layanan yang sedang digunakan.

ISO/IEC 27002:2022 memberikan perhatian khusus terhadap **pemisahan lingkungan pengembangan, pengujian, dan produksi**, serta perlindungan informasi yang digunakan dalam proses pengujian (ISO/IEC, 2022).

Data yang Diberikan kepada Vendor Tetap Harus Dilindungi

Jika pihak ketiga memang harus memperoleh data tertentu untuk *troubleshooting*, pemberian tersebut harus mengikuti kewenangan dan prosedur organisasi.

Jangan mengirim data melalui:

email pribadi;

penyimpanan *cloud* pribadi;

WhatsApp pribadi;

atau **media lain yang tidak ditetapkan organisasi**

hanya karena dianggap lebih cepat.

Setelah kebutuhan *troubleshooting* selesai, data yang diberikan juga perlu **dikembalikan atau dihapus sesuai ketentuan dan mekanisme yang berlaku.**

Dokumentasikan Kebutuhan Penggunaan Data

Untuk data yang sensitif atau cakupannya besar, penggunaan data produksi untuk pengujian sebaiknya dapat diketahui dan dipertanggungjawabkan.

Setidaknya harus jelas:

mengapa data diperlukan;

siapa yang memperoleh akses;

data apa yang digunakan;

dan untuk tujuan apa data tersebut digunakan.

Dengan demikian, kebutuhan teknis tidak berubah menjadi alasan untuk menyalin data produksi secara bebas.

INGAT: Untuk pengujian dan troubleshooting, utamakan data uji.

Jika data produksi benar-benar diperlukan, gunakan **data seminimal mungkin, lindungi identitas pasien, gunakan lingkungan dan mekanisme resmi, serta batasi akses hanya kepada pihak yang membutuhkan.** Jangan menjadikan seluruh database produksi sebagai data pengujian hanya karena lebih praktis.

10.7 Remote Access ke Sistem Rumah Sakit

Akses jarak jauh (*remote access*) memungkinkan administrator, vendor, atau teknisi mengakses komputer, server, maupun sistem rumah sakit dari lokasi lain. Fasilitas ini dapat membantu pemeliharaan dan *troubleshooting*, tetapi juga dapat menjadi **jalur masuk ke sistem dan data pasien apabila tidak dikendalikan dengan baik.**

Karena itu, *remote access* harus dilakukan melalui **mekanisme resmi, berdasarkan kebutuhan, dan hanya oleh pihak yang berwenang.**

Jangan Membuat Akses Jarak Jauh Sendiri

Pengguna atau vendor tidak seharusnya memasang aplikasi *remote access* atau membuat jalur akses sendiri tanpa persetujuan pengelola TI.

Hindari tindakan seperti:

“Install aplikasi remote ini supaya nanti saya bisa masuk lagi.”

“Biarkan remote-nya aktif supaya kalau ada masalah tidak perlu datang.”

“Saya buka akses langsung ke server agar vendor lebih mudah melakukan maintenance.”

Kemudahan akses tidak boleh mengorbankan keamanan.

Akses Vendor Harus Melalui Mekanisme Resmi

Jika vendor membutuhkan *remote access*, akses tersebut harus diberikan melalui mekanisme yang ditetapkan organisasi.

Akses sebaiknya dibatasi berdasarkan:

siapa yang melakukan akses;

sistem yang boleh diakses;

tingkat kewenangan yang diperlukan;

dan jangka waktu akses.

Vendor yang hanya menangani satu aplikasi tidak otomatis membutuhkan akses ke seluruh jaringan atau server rumah sakit.

ISO/IEC 27002:2022 menekankan pengendalian akses dan pengelolaan keamanan informasi dalam hubungan dengan pemasok (ISO/IEC, 2022).

Hindari *Remote Access* yang Aktif Permanen

Akses yang dibuat untuk kebutuhan *troubleshooting* sementara sebaiknya tidak dibiarkan aktif tanpa batas waktu.

Misalnya, vendor membutuhkan akses selama dua jam untuk memperbaiki aplikasi. Setelah pekerjaan selesai, akses tersebut perlu **ditutup atau dicabut sesuai mekanisme organisasi**.

Prinsipnya:

Dibutuhkan → aktifkan.

Pekerjaan selesai → tutup akses.

Semakin banyak jalur akses yang selalu terbuka, semakin besar pula risiko yang harus dikelola.

Jangan Memberikan Credential Pegawai

Vendor tidak seharusnya melakukan *remote access* menggunakan *username* dan *password* milik pegawai.

Hindari:

“Gunakan akun saya saja.”

“Saya kirim password administrator lewat WhatsApp.”

“Saya login-kan dulu, setelah itu vendor lanjut bekerja.”

Setiap pihak harus menggunakan **identitas dan mekanisme akses yang dapat dipertanggungjawabkan**, sebagaimana telah dibahas pada 10.3 dan 10.4.

***Remote Access* Harus Dapat Dipantau dan Dipertanggungjawabkan**

Organisasi perlu dapat mengetahui siapa yang memperoleh akses dan kapan akses tersebut digunakan.

Pencatatan aktivitas (*logging*) membantu proses pemeriksaan apabila terjadi perubahan konfigurasi, gangguan, atau insiden keamanan.

Karena itu, hindari mekanisme akses jarak jauh yang membuat aktivitas pihak ketiga **tidak dapat dikaitkan dengan identitas tertentu**.

Waspada! Permintaan *Remote Access* melalui Telepon atau WhatsApp

Pelaku *social engineering* dapat mengaku sebagai teknisi kemudian meminta pengguna memasang aplikasi *remote access*.

Misalnya:

“Komputernya bermasalah. Install aplikasi ini, lalu kirim kode aksesnya.”

Jangan langsung mengikuti instruksi tersebut.

Verifikasi terlebih dahulu melalui pengelola TI atau kanal resmi. Jika pihak yang meminta memang vendor resmi, proses akses tetap harus mengikuti mekanisme organisasi.

Setelah Pekerjaan Selesai

Setelah pekerjaan pihak ketiga selesai, akses sementara perlu diperiksa kembali. Akun sementara, sesi aktif, atau mekanisme akses lain yang sudah tidak diperlukan harus **dicabut atau dinonaktifkan sesuai prosedur**.

Hal ini mencegah akses yang awalnya sah berubah menjadi jalur masuk yang tidak lagi diperlukan.

INGAT: *Remote access* adalah jalur masuk ke sistem rumah sakit.

Jangan memasang aplikasi atau membuka akses jarak jauh tanpa kewenangan. **Akses harus menggunakan mekanisme resmi, identitas yang dapat dipertanggungjawabkan, kewenangan seminimal mungkin, dan ditutup ketika pekerjaan selesai.**

10.8 Pengamanan Credential untuk Akses Pihak Ketiga

Pihak ketiga seperti vendor, teknisi, atau konsultan dapat diberikan *credential* untuk mengakses sistem apabila memang diperlukan dalam pekerjaannya. Namun, *credential* tersebut harus **dikelola secara khusus, dibatasi penggunaannya, dan tidak menggunakan akun milik pegawai**.

Pemberian akses kepada vendor bukan berarti organisasi kehilangan kendali terhadap akun yang digunakan.

Gunakan Akun Khusus untuk Pihak Ketiga

Jika vendor membutuhkan akses, hindari memberikan:

akun milik pegawai;

akun administrator pribadi;

akun bersama yang digunakan banyak pihak;

atau ***password* milik pengguna lain.**

Gunakan akun atau mekanisme akses yang memang disediakan untuk pihak ketiga sehingga aktivitasnya dapat dibedakan dari aktivitas pegawai.

Prinsipnya:

Satu identitas → satu akun → aktivitas dapat dipertanggungjawabkan.

Berikan Hak Akses Sesuai Kebutuhan

Akun vendor tidak otomatis harus memiliki hak administrator.

Jika pekerjaan hanya membutuhkan akses ke satu aplikasi atau fungsi tertentu, berikan hak akses sebatas kebutuhan tersebut.

ISO/IEC 27002:2022 menekankan pengelolaan hak akses agar diberikan, ditinjau, diubah, dan dicabut sesuai kebutuhan organisasi (ISO/IEC, 2022).

Karena itu:

Butuh akses aplikasi → jangan otomatis berikan akses server.

Butuh akses baca → jangan otomatis berikan akses perubahan.

Jangan Mengirim *Credential* melalui Media yang Tidak Semestinya

Hindari mengirim *username* dan *password* vendor melalui grup WhatsApp, email pribadi, atau media komunikasi lain yang tidak ditetapkan organisasi.

Credential harus diberikan menggunakan **mekanisme yang aman dan sesuai kebijakan organisasi.**

Jika *credential* diketahui pihak yang tidak seharusnya, lakukan tindakan pengamanan dan pelaporan sesuai prosedur.

Gunakan MFA Jika Disediakan

Untuk akses penting, terutama *remote access*, organisasi dapat menerapkan **Multi-Factor Authentication (MFA)** sebagai perlindungan tambahan.

Dengan MFA, penguasaan *password* saja tidak selalu cukup untuk menyelesaikan proses autentikasi.

Namun, kode OTP atau faktor autentikasi lainnya tetap harus dijaga. Vendor tidak boleh meminta OTP milik pegawai untuk menggunakan akun pegawai.

Hindari *Credential* Permanen untuk Kebutuhan Sementara

Jika vendor hanya membutuhkan akses selama proses *maintenance* atau *troubleshooting*, jangan membiarkan *credential* tersebut tetap aktif tanpa kebutuhan setelah pekerjaan selesai.

Prinsip sederhananya:

Pekerjaan dimulai → akses diberikan sesuai kebutuhan.

Pekerjaan selesai → akses ditinjau dan dicabut jika tidak diperlukan.

Hal ini mengurangi jumlah akun yang dapat menjadi jalur akses ke sistem.

Jangan Menanam *Password* Sembarangan

Credential untuk akses sistem tidak seharusnya dituliskan sembarangan dalam dokumen, pesan percakapan, file teks, *script*, atau catatan yang dapat dibaca pihak lain.

Jika organisasi menggunakan mekanisme khusus untuk mengelola *credential*, gunakan mekanisme tersebut dan jangan membuat penyimpanan sendiri hanya karena lebih mudah.

Credential Pihak Ketiga Tetap Harus Dapat Dipertanggungjawabkan

Organisasi perlu mengetahui **siapa yang menggunakan akses, untuk keperluan apa, dan kapan akses tersebut masih diperlukan.**

Ketika vendor berganti personel atau kontrak berakhir, akses yang tidak lagi diperlukan harus ditinjau dan dicabut.

ISO/IEC 27002:2022 mengatur pengelolaan informasi autentikasi serta keamanan informasi dalam hubungan dengan pemasok (ISO/IEC, 2022).

INGAT: *Credential* pihak ketiga harus dikelola, bukan sekadar diberikan. Gunakan akun khusus, batasi hak akses, jangan meminjamkan akun pegawai, gunakan MFA jika tersedia, dan **cabut akses ketika sudah tidak diperlukan.**

10.9 Logging dan Pemantauan Aktivitas Pihak Ketiga

Akses yang diberikan kepada vendor atau pihak ketiga perlu **dapat dicatat dan ditelusuri**. Hal ini penting karena pihak ketiga dapat memperoleh akses ke aplikasi, server, database, atau perangkat yang memproses data pasien.

Melalui *logging* dan pemantauan, organisasi dapat mengetahui **siapa yang mengakses sistem, kapan akses dilakukan, dan aktivitas apa yang dilakukan.**

Aktivitas Vendor Harus Dapat Dibedakan

Jika vendor menggunakan akun pegawai atau akun bersama, aktivitas yang dilakukan menjadi sulit dikaitkan dengan orang tertentu.

Misalnya, *log* menunjukkan:

User: administrator

Waktu: 22.15

Aktivitas: perubahan konfigurasi

Jika akun tersebut digunakan oleh banyak orang, akan sulit menentukan siapa yang sebenarnya melakukan perubahan.

Karena itu, sebagaimana dibahas pada subbab sebelumnya, pihak ketiga sebaiknya menggunakan **identitas dan akun yang dapat dipertanggungjawabkan.**

Catat Akses yang Diberikan

Untuk akses pihak ketiga, organisasi perlu dapat mengetahui setidaknya:

siapa yang memperoleh akses;

sistem yang diakses;

tujuan akses;

waktu akses;

dan jangka waktu akses diberikan.

Untuk pekerjaan tertentu, pencatatan dapat dikaitkan dengan tiket *helpdesk*, permintaan *maintenance*, atau mekanisme administrasi lain yang digunakan organisasi.

Dengan demikian, ketika ditemukan aktivitas tertentu, organisasi dapat menghubungkannya dengan **pekerjaan yang memang sedang dilakukan**.

***Logging* Membantu Investigasi**

Log dan *audit trail* sangat berguna ketika terjadi gangguan atau insiden.

Misalnya, setelah vendor melakukan *maintenance*, ditemukan perubahan konfigurasi atau data yang tidak semestinya. Catatan aktivitas dapat membantu menjawab:

Akun apa yang digunakan?

Kapan perubahan terjadi?

Sistem apa yang diakses?

Aktivitas apa yang tercatat?

ISO/IEC 27002:2022 memasukkan ***logging*** sebagai kontrol keamanan informasi untuk membantu pencatatan aktivitas, pengecualian, kesalahan, dan kejadian relevan lainnya (ISO/IEC, 2022).

Pemantauan Bukan Berarti Mengawasi Setiap Gerakan Vendor

Tujuan pemantauan adalah memastikan akses digunakan **sesuai kebutuhan dan kewenangan yang diberikan**, bukan sekadar mengawasi seseorang.

Perhatian dapat diberikan pada aktivitas yang tidak sesuai pola pekerjaan, misalnya akses di luar waktu yang disepakati, percobaan mengakses sistem lain, atau penggunaan hak akses yang tidak diperlukan.

Jika ditemukan aktivitas yang tidak sesuai, organisasi dapat melakukan pemeriksaan lebih lanjut.

Remote Access Juga Perlu Dicatat

Akses jarak jauh merupakan salah satu aktivitas pihak ketiga yang penting untuk dapat ditelusuri.

Jika vendor melakukan *remote maintenance*, organisasi sebaiknya dapat mengetahui:

siapa yang melakukan koneksi;

kapan koneksi dilakukan;

sistem yang diakses;

dan kapan akses berakhir.

Akses sementara juga perlu ditutup ketika pekerjaan selesai agar tidak tetap menjadi jalur masuk yang tidak diperlukan.

Jangan Menghapus atau Mengubah Log Tanpa Kewenangan

Catatan aktivitas merupakan bagian penting dalam pemeriksaan keamanan.

Pengguna, administrator, maupun pihak ketiga tidak seharusnya menghapus atau mengubah *log* untuk menyembunyikan aktivitas tertentu.

Pengelolaan, penyimpanan, perlindungan, dan masa retensi *log* harus mengikuti **kebijakan dan mekanisme organisasi**.

Logging Tidak Menggantikan Pembatasan Akses

Adanya *log* bukan alasan untuk memberikan akses seluas-luasnya kepada vendor.

Keduanya memiliki fungsi berbeda:

Pembatasan akses → mengurangi apa yang dapat dilakukan.

***Logging* → membantu mengetahui apa yang telah dilakukan.**

Karena itu, *least privilege*, identitas individual, *logging*, dan pemantauan perlu digunakan secara bersama-sama.

INGAT: Aktivitas pihak ketiga yang mengakses sistem rumah sakit harus dapat dipertanggungjawabkan dan ditelusuri. Gunakan identitas yang jelas, batasi akses sesuai kebutuhan, catat aktivitas yang relevan, dan tinjau aktivitas apabila ditemukan sesuatu yang tidak semestinya.

10.10 Pengakhiran Akses Setelah Pekerjaan Selesai

Akses yang diberikan kepada vendor, teknisi, konsultan, atau pihak ketiga **tidak boleh dibiarkan aktif setelah kebutuhan pekerjaan berakhir.**

Akses yang sebelumnya sah dapat menjadi risiko apabila tetap tersedia ketika pihak tersebut sudah tidak memiliki kebutuhan untuk mengakses sistem rumah sakit.

Akses Sementara Harus Memiliki Akhir

Vendor dapat memperoleh akses untuk kegiatan seperti:

pemeliharaan aplikasi;

***troubleshooting*;**

pembaruan sistem;

implementasi;

atau **pekerjaan teknis tertentu.**

Ketika pekerjaan tersebut selesai, akses perlu ditinjau dan **dicabut atau dinonaktifkan jika sudah tidak diperlukan.**

Jangan membiarkan akun tetap aktif dengan alasan:

“Nanti mungkin dibutuhkan lagi.”

Jika akses kembali diperlukan, akses dapat diberikan kembali melalui prosedur yang berlaku.

Periksa Semua Jalur Akses

Pengakhiran akses bukan hanya menonaktifkan satu akun.

Perlu diperhatikan apakah pihak ketiga sebelumnya memperoleh:

akun aplikasi;

akun server atau database;

***remote access* atau VPN;**

akses ke penyimpanan atau folder;

API key, token, atau credential lainnya;

atau **akses fisik tertentu.**

Akses yang sudah tidak diperlukan perlu ditangani sesuai kewenangan dan prosedur organisasi.

Perubahan Personel Vendor Juga Perlu Diperhatikan

Kontrak dengan perusahaan vendor mungkin masih berlangsung, tetapi personel yang menangani rumah sakit dapat berubah.

Jika seorang teknisi vendor sudah tidak lagi menangani pekerjaan, **akses milik teknisi tersebut perlu ditinjau**, meskipun perusahaan vendornya masih bekerja sama dengan rumah sakit.

Akun tidak seharusnya dipindahkan begitu saja kepada teknisi pengganti.

Personel baru → identitas baru → akses sesuai kebutuhan baru.

Data yang Diberikan Juga Harus Ditangani

Pengakhiran pekerjaan tidak hanya berkaitan dengan akun.

Jika pihak ketiga sebelumnya menerima data untuk pengujian atau *troubleshooting*, perlu dipastikan bahwa data tersebut **dikembalikan, dihapus, atau ditangani sesuai perjanjian dan prosedur organisasi** ketika sudah tidak diperlukan.

Hal ini penting agar salinan data pasien tidak tetap berada pada lingkungan pihak ketiga tanpa kebutuhan yang jelas.

Dokumentasikan Pengakhiran Akses

Untuk akses yang penting, organisasi sebaiknya dapat mengetahui bahwa akses telah ditutup.

Misalnya, pencatatan dapat menunjukkan:

siapa yang aksesnya dicabut;

akses apa yang dihentikan;

kapan dilakukan;

dan **siapa yang melakukan atau menyetujui tindakan tersebut.**

Dokumentasi membantu memastikan tidak ada akses lama yang terlupakan.

ISO/IEC 27002:2022 menekankan pengelolaan hak akses sepanjang siklus hidupnya, termasuk peninjauan, perubahan, dan pencabutan ketika akses tidak lagi diperlukan (ISO/IEC, 2022).

Jangan Menunggu Kontrak Berakhir

Akses dapat perlu dicabut **sebelum kontrak vendor berakhir.**

Misalnya, pekerjaan tertentu sudah selesai, teknisi berganti, ruang lingkup pekerjaan berubah, atau suatu akses tidak lagi dibutuhkan.

Karena itu, prinsip yang digunakan bukan:

Kontrak selesai → baru cabut semua akses.

Tetapi:

Kebutuhan akses selesai → akses ditinjau dan dicabut.

Tutup Pekerjaan dengan Menutup Akses

Pengakhiran akses sebaiknya menjadi bagian dari proses penyelesaian pekerjaan pihak ketiga.

Gunakan prinsip sederhana:

PEKERJAAN SELESAI → PERIKSA AKSES → CABUT YANG TIDAK DIPERLUKAN → DOKUMENTASIKAN

Dengan demikian, akun, *remote access*, dan credential lama tidak menjadi jalur akses yang terlupakan.

INGAT: Akses pihak ketiga tidak boleh aktif lebih lama daripada kebutuhannya. Setelah pekerjaan selesai, tinjau akun, *remote access*, credential, dan akses lainnya. Pekerjaan belum benar-benar selesai sebelum akses yang tidak lagi diperlukan telah ditutup.

10.11 Kerahasiaan Data oleh Vendor dan Pihak Ketiga

Vendor dan pihak ketiga dapat memperoleh akses terhadap sistem, perangkat, atau informasi rumah sakit dalam rangka menjalankan pekerjaannya. Akses tersebut dapat menyebabkan pihak ketiga melihat atau memproses **data pasien dan informasi internal organisasi**.

Karena itu, pihak ketiga wajib menjaga **kerahasiaan informasi yang diperoleh selama pelaksanaan pekerjaan** dan tidak menggunakannya di luar tujuan yang telah ditetapkan.

Akses untuk Bekerja Bukan Hak untuk Menggunakan Data

Vendor yang memperoleh akses ke SIMRS, server, database, atau sistem lainnya mungkin secara teknis dapat melihat banyak informasi.

Namun:

Dapat melihat ≠ boleh menggunakan.

Dapat mengunduh ≠ boleh menyalin.

Memiliki akses ≠ memiliki data.

Data hanya boleh digunakan sejauh diperlukan untuk melaksanakan pekerjaan yang telah diberikan.

Data Pasien Tidak Boleh Dibawa untuk Kepentingan Lain

Pihak ketiga tidak boleh menggunakan data yang diperoleh dari rumah sakit untuk kepentingan lain tanpa dasar dan kewenangan yang sesuai.

Misalnya, data pasien tidak boleh digunakan secara sembarangan sebagai:

data demonstrasi aplikasi;

bahan presentasi;

data pengembangan produk;

contoh kepada pelanggan lain;

atau **bahan pelatihan internal vendor.**

Jika kegiatan tersebut membutuhkan data, gunakan **data uji atau data lain yang telah dipersiapkan sesuai mekanisme yang berlaku.**

Jangan Menyimpan Salinan Tanpa Kebutuhan

Selama *troubleshooting*, vendor mungkin memperoleh file, *log*, *screenshot*, atau data tertentu.

Informasi tersebut tidak seharusnya disimpan lebih lama daripada kebutuhan pekerjaannya atau disalin ke berbagai perangkat tanpa alasan yang sah.

Setelah pekerjaan selesai, data perlu **dikembalikan, dihapus, atau ditangani sesuai ketentuan organisasi dan perjanjian dengan pihak ketiga.**

Kerahasiaan Berlaku kepada Personel Pihak Ketiga

Kerahasiaan tidak hanya berlaku pada perusahaan vendor sebagai organisasi, tetapi juga perlu diterapkan terhadap **personel yang memperoleh akses.**

Teknisi tidak boleh membagikan data yang dilihat selama bekerja kepada rekan yang tidak berkepentingan, mengunggahnya ke media

sosial, atau menjadikannya bahan percakapan di luar kebutuhan pekerjaan.

Prinsip ***need-to-know*** tetap berlaku di lingkungan pihak ketiga.

Kewajiban Kerahasiaan Perlu Ditetapkan dengan Jelas

Hubungan dengan pihak ketiga sebaiknya memiliki ketentuan yang jelas mengenai keamanan dan kerahasiaan informasi, termasuk sesuai kebutuhan:

jenis informasi yang dapat diakses;

tujuan penggunaan;

pembatasan pengungkapan;

pengamanan yang harus diterapkan;

penanganan insiden;

serta **pengembalian atau penghapusan data setelah pekerjaan selesai.**

ISO/IEC 27002:2022 menekankan pengelolaan keamanan informasi dalam hubungan dengan pemasok serta perlunya persyaratan keamanan yang relevan disepakati dengan pemasok (ISO/IEC, 2022).

Insiden pada Vendor Tetap Harus Dilaporkan

Jika pihak ketiga mengetahui bahwa data rumah sakit salah kirim, hilang, diakses tanpa kewenangan, terkena *malware*, atau mengalami kejadian keamanan lainnya, kejadian tersebut **tidak boleh disembunyikan.**

Vendor perlu segera melaporkannya melalui mekanisme yang telah disepakati agar organisasi dapat melakukan penilaian dan penanganan.

Semakin lama kejadian tidak diketahui, semakin sulit organisasi membatasi dampaknya.

Kerahasiaan Tidak Otomatis Berakhir ketika Pekerjaan Selesai

Berakhirnya pekerjaan atau kontrak tidak berarti informasi yang pernah diperoleh menjadi bebas digunakan atau disebar.

Data pasien dan informasi rahasia yang diketahui selama pelaksanaan pekerjaan **tetap harus dijaga sesuai kewajiban hukum, kontrak, dan ketentuan yang berlaku.**

INGAT: Vendor dan pihak ketiga memperoleh akses untuk menjalankan pekerjaan, bukan untuk memiliki atau menggunakan data secara bebas. Data pasien tidak boleh disalin, disebar, digunakan untuk kepentingan lain, atau disimpan tanpa kebutuhan dan kewenangan. **Kerahasiaan tetap harus dijaga selama maupun setelah pekerjaan selesai.**

BAB 11 JIKA TERJADI INSIDEN ATAU KEBOCORAN DATA

11.1 Apa yang Dimaksud dengan Insiden Keamanan Informasi?

Insiden keamanan informasi adalah **kejadian yang dapat mengganggu kerahasiaan, keutuhan, atau ketersediaan informasi dan sistem yang digunakan organisasi.**

Di lingkungan rumah sakit, insiden keamanan tidak selalu berupa serangan siber besar. Kesalahan sederhana seperti salah mengirim data pasien, kehilangan laptop, atau memberikan *password* kepada orang lain juga dapat menjadi insiden yang perlu ditangani.

Insiden Tidak Selalu Berarti Sistem Diretas

Contoh insiden keamanan informasi antara lain:

data pasien terkirim kepada penerima yang salah;

akun digunakan oleh orang lain;

laptop atau *flashdisk* yang mengandung data hilang;

komputer terkena *malware* atau *ransomware*;

data pasien terlihat atau diberikan kepada pihak yang tidak berwenang;

atau *credential* diketahui pihak lain.

Karena itu, jangan hanya melaporkan kejadian ketika server berhasil diretas atau sistem berhenti beroperasi.

Insiden Dapat Berasal dari Kesalahan Manusia

Tidak semua insiden dilakukan dengan sengaja.

Seorang pegawai dapat salah memilih penerima email, salah mengirim dokumen ke grup WhatsApp, meninggalkan SIMRS dalam keadaan *login*, atau kehilangan perangkat kerja.

Walaupun tidak ada niat untuk membocorkan informasi, kejadian tersebut tetap perlu diperhatikan karena **dapat menimbulkan risiko terhadap data pasien.**

Tiga Aspek yang Perlu Dilindungi

Secara sederhana, keamanan informasi berkaitan dengan tiga aspek utama:

Kerahasiaan **(Confidentiality)**

Informasi hanya dapat diakses oleh pihak yang berwenang.

Keutuhan **(Integrity)**

Informasi tidak diubah atau dirusak secara tidak sah.

Ketersediaan **(Availability)**

Informasi dan sistem tersedia ketika dibutuhkan oleh pihak yang berwenang.

Sebagai contoh, data pasien yang dikirim kepada orang yang salah dapat mengganggu **kerahasiaan**, perubahan data tanpa kewenangan dapat mengganggu **keutuhan**, sedangkan *ransomware* yang menyebabkan sistem tidak dapat digunakan dapat mengganggu **ketersediaan**.

Insiden Data Pribadi Memerlukan Perhatian Khusus

Jika insiden melibatkan Data Pribadi pasien, dampaknya dapat berkaitan langsung dengan perlindungan Data Pribadi.

UU Nomor 27 Tahun 2022 menggunakan istilah **kegagalan perlindungan Data Pribadi** untuk kondisi kegagalan dalam melindungi Data Pribadi seseorang, termasuk pelanggaran terhadap kerahasiaan, integritas, dan ketersediaan Data Pribadi (Republik Indonesia, 2022).

Karena itu, kejadian yang melibatkan data pasien tidak boleh dianggap sebagai masalah teknis biasa tanpa dilakukan penilaian lebih lanjut.

Jangan Menentukan Sendiri bahwa Kejadian “Tidak Penting”

Pegawai tidak harus melakukan investigasi sendiri untuk menentukan tingkat keparahan sebuah kejadian.

Jika menemukan sesuatu yang mencurigakan, **laporkan melalui mekanisme yang ditetapkan organisasi.**

Hindari berpikir:

“Datanya cuma satu pasien.”

“File-nya sudah saya hapus.”

“Komputernya sudah normal lagi.”

“Belum tentu ada yang melihat.”

Informasi tersebut dapat disampaikan dalam laporan dan pihak yang berwenang dapat menentukan tindakan selanjutnya.

ISO/IEC 27002:2022 mengatur pengelolaan kejadian dan insiden keamanan informasi, termasuk pelaporan kejadian keamanan serta penilaian dan respons terhadap insiden (ISO/IEC, 2022).

Tujuan Pelaporan adalah Memungkinkan Penanganan

Semakin cepat insiden diketahui, semakin cepat organisasi dapat mengambil tindakan untuk **membatasi dampak, mengamankan akun atau sistem, melindungi data, dan melakukan pemeriksaan.**

Karena itu, prinsip dasar yang perlu dipahami seluruh pegawai adalah:

TEMUKAN → LAPORKAN → IKUTI PROSEDUR PENANGANAN

INGAT: Insiden keamanan informasi tidak selalu berarti server diretas. Salah kirim data pasien, kehilangan perangkat, credential diketahui orang lain, *malware*, akses tanpa kewenangan, dan berbagai kejadian lainnya dapat menjadi insiden. **Jika menemukan kejadian yang berpotensi mengganggu keamanan data atau sistem, segera laporkan melalui mekanisme organisasi.**

11.2 Contoh Insiden Keamanan Data di Lingkungan Rumah Sakit

Insiden keamanan data di rumah sakit dapat terjadi dalam berbagai bentuk. Sebagian disebabkan oleh serangan siber, tetapi sebagian lainnya berasal dari **kesalahan pengguna, kehilangan perangkat, penyalahgunaan akses, atau pengiriman informasi kepada pihak yang tidak berwenang.**

Pegawai perlu mengenali contoh-contohnya agar dapat segera melakukan pelaporan ketika menemukan kejadian serupa.

Salah Mengirim Data Pasien

Kesalahan memilih penerima merupakan contoh insiden yang dapat terjadi dalam aktivitas sehari-hari.

Misalnya:

hasil pemeriksaan pasien dikirim ke nomor WhatsApp yang salah;

dokumen pasien dikirim ke grup yang tidak sesuai;

email berisi data pasien dikirim kepada penerima yang salah;
atau lampiran yang dikirim ternyata milik pasien lain.

Walaupun pengiriman dilakukan tanpa sengaja, informasi telah berpotensi diterima oleh pihak yang tidak seharusnya.

Kehilangan Perangkat atau Media Penyimpanan

Laptop, ponsel kerja, *flashdisk*, atau media penyimpanan yang hilang dapat menjadi insiden apabila perangkat tersebut menyimpan atau memberikan akses terhadap informasi organisasi.

Risiko menjadi lebih tinggi jika perangkat:

menyimpan data pasien;

tidak menggunakan pengamanan yang memadai;

atau masih memiliki sesi aplikasi yang aktif.

Kehilangan perangkat perlu segera dilaporkan agar organisasi dapat menilai risiko dan melakukan tindakan pengamanan.

Credential Diketahui Orang Lain

Jika *password*, OTP, atau *passphrase* diketahui atau diberikan kepada pihak lain, kejadian tersebut perlu mendapat perhatian.

Contohnya:

password terlanjur diberikan kepada orang yang mengaku administrator;

OTP diberikan kepada pelaku *phishing*;

atau *passphrase* Tanda Tangan Elektronik diketahui orang lain.

Jangan menunggu sampai akun benar-benar digunakan secara tidak sah sebelum melaporkan kejadian tersebut.

Akses Data Tanpa Kewenangan

Insiden juga dapat terjadi ketika seseorang mengakses data yang sebenarnya tidak diperlukan untuk pekerjaannya.

Misalnya, pegawai membuka rekam medis pasien hanya karena mengenal pasien tersebut atau ingin mengetahui kondisi kesehatannya.

Walaupun pengguna memiliki akun yang secara teknis dapat membuka data tersebut:

Dapat mengakses ≠ berwenang mengakses untuk semua tujuan.

Prinsip *need-to-know* tetap berlaku.

SIMRS Ditinggalkan dalam Keadaan *Login*

Komputer dengan SIMRS yang masih terbuka dapat digunakan oleh orang lain melalui sesi pengguna yang aktif.

Jika orang lain kemudian melihat atau mengubah data melalui sesi tersebut, kejadian dapat berkembang menjadi insiden keamanan.

Karena itu, sebagaimana dibahas pada BAB 8, **kunci komputer ketika meninggalkan tempat kerja dan lakukan *logout* ketika penggunaan sistem selesai.**

Malware dan Ransomware

Komputer yang menunjukkan indikasi terkena *malware* juga perlu segera dilaporkan.

Contohnya:

antivirus mendeteksi ancaman;

file tiba-tiba berubah atau tidak dapat dibuka;

muncul pesan tebusan;

atau **komputer menunjukkan aktivitas yang tidak biasa setelah membuka lampiran.**

Jangan mencoba menangani *ransomware* sendiri tanpa koordinasi dengan pengelola TI.

Data Pasien Terpublikasi atau Tersebar

Foto, *screenshot* SIMRS, dokumen, atau informasi pasien yang terunggah ke media sosial atau tersebar kepada pihak yang tidak berkepentingan juga merupakan kejadian yang perlu dilaporkan.

Menghapus unggahan merupakan tindakan awal, tetapi **tidak menjamin informasi belum disalin atau dilihat oleh pihak lain.**

Aktivitas Vendor yang Tidak Sesuai

Insiden dapat pula melibatkan pihak ketiga.

Misalnya, vendor:

**mengunduh database tanpa kewenangan;
menggunakan akun pegawai;
menyalin data pasien ke perangkat pribadi;**

atau tetap mengakses sistem setelah pekerjaannya selesai.

Jika menemukan aktivitas seperti ini, jangan menganggapnya wajar hanya karena dilakukan oleh vendor resmi.

Tidak Semua Kejadian Memiliki Dampak yang Sama

Satu insiden mungkin hanya melibatkan satu dokumen, sedangkan insiden lain dapat melibatkan ribuan data pasien atau menyebabkan sistem tidak tersedia.

Pegawai **tidak perlu menentukan sendiri tingkat keparahannya** sebelum melapor.

ISO/IEC 27002:2022 membedakan kejadian keamanan informasi (*information security event*) dan insiden yang memerlukan respons. Organisasi perlu melakukan penilaian terhadap kejadian tersebut untuk menentukan tindakan yang sesuai (ISO/IEC, 2022).

Prinsip bagi pengguna tetap sederhana:

LIHAT KEJADIAN → JANGAN ABAIKAN → LAPORKAN

INGAT: Insiden keamanan di rumah sakit tidak hanya berupa peretasan. Salah kirim data, kehilangan perangkat, credential bocor, akses tanpa kewenangan, *malware*, data pasien tersebar, dan penyalahgunaan akses oleh pihak ketiga juga perlu diperhatikan. **Jika ragu apakah suatu kejadian termasuk insiden, tetap laporkan agar dapat dinilai oleh pihak yang berwenang.**

11.3 Credential Diketahui atau Digunakan Orang Lain

Credential seperti *username*, *password*, OTP, PIN, atau informasi autentikasi lainnya digunakan untuk memastikan bahwa akses dilakukan oleh pengguna yang berhak.

Jika *credential* diketahui atau digunakan oleh orang lain, kondisi tersebut harus dianggap sebagai **kejadian keamanan yang perlu segera dilaporkan**, meskipun belum diketahui adanya penyalahgunaan.

Jangan Menunggu Akun Disalahgunakan

Pengguna terkadang merasa tidak perlu melapor karena belum melihat aktivitas yang mencurigakan.

Misalnya:

“Password saya memang sempat diketahui teman, tetapi belum digunakan.”

“Saya terlanjur memberikan OTP, tetapi sepertinya tidak terjadi apa-apa.”

“Password sudah saya ganti, jadi masalahnya selesai.”

Jangan membuat kesimpulan sendiri bahwa kejadian sudah aman. Pihak yang berwenang mungkin perlu memeriksa *log*, sesi aktif, atau aktivitas lain yang berkaitan dengan akun tersebut.

Segera Ganti Password Jika Diperlukan

Jika *password* diketahui atau diduga diketahui pihak lain, lakukan perubahan melalui **mekanisme resmi** sesuai prosedur organisasi.

Gunakan *password* baru yang tidak sama dengan *password* sebelumnya dan jangan mengirimkannya kepada orang lain.

Jika akun menggunakan MFA, perubahan *password* tidak berarti kejadian boleh diabaikan. **Insiden tetap perlu dilaporkan** agar dapat dilakukan pemeriksaan lebih lanjut.

OTP yang Terlanjur Diberikan Juga Harus Dilaporkan

OTP biasanya berlaku dalam waktu singkat, tetapi dapat digunakan untuk menyelesaikan proses autentikasi ketika masih aktif.

Jika OTP terlanjur diberikan kepada orang lain, terutama setelah menerima telepon atau pesan mencurigakan, **segera laporkan kejadian tersebut**.

Jangan beranggapan bahwa masalah selesai hanya karena OTP sudah kedaluwarsa.

Waspada Penggunaan Akun Tanpa Sepengetahuan Pemilik

Indikasi akun mungkin telah digunakan pihak lain antara lain:

terdapat aktivitas yang tidak pernah dilakukan;

muncul pemberitahuan *login* yang tidak dikenal;

terjadi perubahan data yang tidak dilakukan;

atau **terdapat permintaan autentikasi yang tidak sedang dilakukan.**

Jika menemukan kondisi tersebut, jangan mencoba melakukan investigasi sendiri. Catat informasi yang diketahui dan segera laporkan.

Jangan Menghapus Bukti

Jika kejadian berawal dari email, WhatsApp, SMS, atau komunikasi mencurigakan, jangan langsung menghapus semua informasi yang berkaitan dengan kejadian.

Pesan, waktu kejadian, alamat pengirim, atau informasi lain dapat membantu proses pemeriksaan.

Ikuti arahan pengelola TI mengenai informasi apa yang perlu disimpan atau disampaikan.

Laporkan dengan Informasi yang Jelas

Ketika melapor, sampaikan secara singkat:

akun yang terdampak;

jenis credential yang diketahui atau diberikan;

kapan kejadian terjadi;

kepada siapa credential diberikan jika diketahui;

dan aktivitas yang sudah dilakukan setelah kejadian.

Semakin cepat informasi diterima, semakin cepat tindakan pengamanan dapat dilakukan.

ISO/IEC 27002:2022 menekankan perlindungan informasi autentikasi serta pelaporan kejadian keamanan informasi secara tepat waktu (ISO/IEC, 2022).

INGAT: Jika password, OTP, atau credential lainnya diketahui atau digunakan orang lain, jangan menunggu sampai terjadi kerusakan. Segera amankan akun dan laporkan melalui mekanisme organisasi agar aktivitas akun dapat diperiksa dan tindakan pengamanan dapat dilakukan.

11.4 Passphrase TTE Diketahui Orang Lain

Passphrase Tanda Tangan Elektronik (TTE) merupakan informasi rahasia yang digunakan dalam proses penandatanganan elektronik. Jika *passphrase* diketahui oleh orang lain, terdapat risiko pihak tersebut **menggunakan TTE tanpa sepengetahuan atau persetujuan pemiliknya.**

Karena itu, *passphrase* yang diketahui atau diduga diketahui pihak lain harus diperlakukan sebagai **kejadian keamanan yang perlu segera ditangani.**

Jangan Menganggap Aman karena Belum Digunakan

Kebocoran *passphrase* dapat terjadi karena berbagai hal, misalnya:

**pernah diberikan kepada staf atau operator;
dikirim melalui WhatsApp atau media komunikasi lain;
dituliskan pada tempat yang dapat dilihat orang lain;
atau dimasukkan pada halaman yang ternyata palsu.**

Walaupun belum ditemukan penyalahgunaan TTE, kejadian tersebut tetap perlu dilaporkan.

Prinsipnya:

Passphrase diketahui orang lain → jangan menunggu sampai TTE disalahgunakan.

Jangan Hanya Mengandalkan Janji untuk Tidak Menggunakannya

Jika *passphrase* pernah diberikan kepada rekan kerja, staf, atau pihak lain, jangan menganggap masalah selesai karena orang tersebut mengatakan:

“Tenang, tidak akan saya gunakan.”

Setelah informasi rahasia diketahui pihak lain, pemilik tidak lagi dapat memastikan sepenuhnya bagaimana informasi tersebut disimpan atau digunakan.

Karena itu, lakukan tindakan pengamanan melalui **mekanisme resmi yang berlaku.**

Segera Laporkan

Jika *passphrase* diketahui atau diduga diketahui orang lain, segera laporkan kepada **pengelola atau pihak yang menangani TTE sesuai prosedur organisasi**.

Sampaikan informasi yang relevan, seperti:

kapan kejadian diketahui;

bagaimana *passphrase* dapat diketahui pihak lain;

siapa yang mungkin mengetahuinya;

dan apakah terdapat aktivitas penandatanganan yang mencurigakan.

Informasi tersebut membantu menentukan tindakan selanjutnya.

Periksa Aktivitas TTE yang Tidak Dikenal

Jika tersedia mekanisme untuk melihat riwayat atau status penandatanganan, perhatikan apakah terdapat dokumen yang **tidak pernah ditandatangani oleh pemilik TTE**.

Jika menemukan aktivitas yang tidak dikenal, segera sampaikan dalam laporan dan jangan mencoba menghapus bukti yang berkaitan dengan kejadian tersebut.

Pemeriksaan lebih lanjut harus dilakukan oleh pihak yang memiliki kewenangan.

Jangan Menitipkan TTE Setelah Kejadian

Jika *passphrase* sebelumnya diketahui orang lain karena kebiasaan menitipkan proses penandatanganan, praktik tersebut harus dihentikan.

Sebagaimana dibahas pada BAB 5:

Dokumen dapat dipersiapkan oleh staf.

Proses penandatanganan dilakukan oleh pemilik TTE sesuai kewenangannya.

Passphrase tidak boleh dibagikan hanya untuk mempercepat proses administrasi.

Ikuti Mekanisme Pengamanan yang Berlaku

Tindakan teknis terhadap TTE dapat berbeda sesuai sistem dan penyelenggara yang digunakan. Karena itu, pengguna tidak perlu mencoba menangani sendiri dengan cara yang tidak resmi.

Laporkan kejadian dan ikuti prosedur organisasi serta mekanisme penyelenggara TTE untuk pengamanan lebih lanjut.

ISO/IEC 27002:2022 menekankan perlindungan informasi autentikasi dan pelaporan kejadian keamanan informasi secara tepat waktu (ISO/IEC, 2022).

INGAT: Jika passphrase TTE diketahui atau diduga diketahui orang lain, anggap sebagai kejadian keamanan. Jangan menunggu sampai ditemukan penyalahgunaan. Segera laporkan, ikuti mekanisme pengamanan yang berlaku, dan periksa apabila terdapat aktivitas penandatanganan yang tidak dikenal.

11.5 Salah Mengirim Data Pasien

Salah mengirim data pasien merupakan salah satu insiden keamanan yang dapat terjadi dalam pekerjaan sehari-hari. Kesalahan dapat terjadi ketika memilih nomor WhatsApp, alamat email, grup percakapan, atau dokumen yang akan dikirim.

Walaupun terjadi tanpa sengaja, **data pasien dapat terungkap kepada pihak yang tidak berhak menerimanya**. Karena itu, salah kirim tidak boleh dianggap selesai hanya dengan menghapus pesan.

Salah Kirim Dapat Terjadi dengan Mudah

Beberapa contoh yang dapat terjadi antara lain:

hasil pemeriksaan dikirim ke pasien yang salah;

dokumen pasien dikirim ke grup WhatsApp yang tidak sesuai;

email dikirim ke alamat yang salah;

lampiran yang dikirim ternyata berisi data pasien lain;

atau **foto dan screenshot SIMRS terkirim kepada pihak yang tidak berkepentingan.**

Kesalahan sederhana dapat menjadi insiden karena informasi sudah berada di luar pihak yang seharusnya menerima.

Jangan Menunggu Penerima Membuka Data

Jika menyadari telah salah mengirim data, **segera lakukan tindakan.**

Jangan menunggu dengan alasan:

“Mungkin belum dibaca.”

“Pesannya sudah saya hapus.”

“Penerimaanya orang yang saya kenal.”

“Cuma satu pasien.”

Data yang sudah dikirim mungkin telah dilihat, disimpan, diteruskan, atau dibuat salinannya.

Segera Laporkan

Salah kirim data pasien perlu segera dilaporkan melalui mekanisme yang ditetapkan organisasi.

Sampaikan informasi penting seperti:

data apa yang terkirim;

kepada siapa data terkirim;

media yang digunakan;

kapan kejadian terjadi;

dan **tindakan apa yang sudah dilakukan.**

Jangan mencoba menyembunyikan kejadian atau menyelesaikannya sendiri tanpa melaporkan.

Batasi Dampak Jika Memungkinkan

Jika media yang digunakan menyediakan fitur untuk menarik atau menghapus pesan, fitur tersebut dapat digunakan **sebagai tindakan awal jika sesuai prosedur.**

Namun, menghapus pesan bukan jaminan bahwa data belum dilihat atau disalin.

Jika perlu menghubungi penerima yang salah, lakukan sesuai arahan organisasi. Jangan memperluas penyebaran data dengan mengirim ulang informasi sensitif kepada lebih banyak pihak.

Jangan Menghapus Bukti yang Dibutuhkan

Informasi mengenai waktu pengiriman, penerima, jenis data, dan komunikasi yang terjadi dapat diperlukan untuk menilai insiden.

Karena itu, jangan menghapus seluruh bukti kejadian sebelum mendapatkan arahan dari pihak yang menangani insiden.

Pencegahan Tetap Penting

Sebelum mengirim data pasien, biasakan melakukan pemeriksaan sederhana:

PERIKSA DATA → PERIKSA PENERIMA → PERIKSA LAMPIRAN → BARU KIRIM

Jika data yang akan dikirim tidak seluruhnya diperlukan, lakukan **minimalisasi data** terlebih dahulu sebagaimana telah dibahas pada BAB 6.

UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi mengatur kewajiban Pengendali Data Pribadi ketika terjadi kegagalan pelindungan Data Pribadi, sehingga kejadian salah kirim yang melibatkan Data Pribadi perlu segera dilaporkan secara internal agar dapat dinilai dan ditangani sesuai ketentuan yang berlaku (Republik Indonesia, 2022).

INGAT: Salah mengirim data pasien merupakan insiden keamanan, meskipun terjadi tanpa sengaja. Jika terlanjur salah kirim, **segera laporkan, batasi dampaknya jika memungkinkan, dan ikuti prosedur penanganan insiden.** Jangan menganggap masalah selesai hanya karena pesan sudah dihapus.

11.6 Perangkat Hilang atau Dicuri

Laptop, ponsel, tablet, *flashdisk*, atau media penyimpanan yang digunakan untuk pekerjaan dapat menyimpan **data pasien, dokumen organisasi, credential, maupun akses ke sistem rumah sakit.**

Jika perangkat tersebut hilang atau dicuri, kejadian harus **segera dilaporkan**, terutama apabila perangkat pernah digunakan untuk mengakses atau menyimpan informasi organisasi.

Jangan Hanya Memikirkan Harga Perangkat

Ketika laptop atau ponsel hilang, kerugian bukan hanya nilai perangkat.

Perangkat tersebut mungkin memiliki:

data pasien yang tersimpan;

email atau dokumen pekerjaan;

sesi aplikasi yang masih aktif;

credential yang tersimpan pada browser;

atau **akses ke sistem dan layanan organisasi.**

Karena itu, kehilangan perangkat dapat berkembang menjadi insiden keamanan informasi.

Segera Laporkan Kehilangan

Jangan menunggu beberapa hari dengan harapan perangkat akan ditemukan.

Segera laporkan melalui mekanisme organisasi dan informasikan:

jenis perangkat yang hilang;

perkiraan waktu dan lokasi kehilangan;

data atau aplikasi yang mungkin terdapat di dalamnya;

akun yang pernah digunakan pada perangkat;

dan pengamanan yang digunakan pada perangkat jika diketahui.

Informasi tersebut membantu pengelola TI menilai risiko dan menentukan tindakan yang diperlukan.

Jangan Menganggap Aman Hanya karena Menggunakan Password

Perangkat yang menggunakan *password*, PIN, atau pengamanan layar memang memiliki perlindungan tambahan. Namun, **kehilangan tetap perlu dilaporkan.**

Pengelola TI mungkin perlu melakukan tindakan terhadap akun, sesi aktif, akses jaringan, atau mekanisme keamanan lainnya.

Jangan membuat keputusan sendiri bahwa:

“Laptop menggunakan password, jadi aman.”

atau:

“Ponsel menggunakan PIN, jadi tidak perlu dilaporkan.”

Perangkat yang Tidak Menyimpan Data Tetap Dapat Memiliki Akses

Sebuah laptop mungkin tidak menyimpan database pasien secara langsung, tetapi dapat memiliki akses ke:

SIMRS;

email organisasi;

penyimpanan dokumen;

VPN;

atau **sistem internal lainnya.**

Karena itu, penilaian insiden tidak hanya melihat data yang tersimpan secara lokal, tetapi juga **akses yang mungkin tersedia melalui perangkat tersebut.**

Jika Perangkat Ditemukan Kembali

Jika perangkat yang sebelumnya dilaporkan hilang kemudian ditemukan, jangan langsung menganggap insiden selesai.

Laporkan bahwa perangkat telah ditemukan dan ikuti arahan pengelola TI. Perangkat mungkin perlu diperiksa untuk memastikan tidak terjadi akses atau perubahan yang mencurigakan selama berada di luar pengawasan.

Pencegahan Sebelum Kehilangan Terjadi

Risiko dapat dikurangi dengan kebiasaan sederhana:

jangan meninggalkan perangkat tanpa pengawasan;

gunakan pengaman layar;

jangan menyimpan data pasien pada perangkat pribadi;

dan **ikuti mekanisme keamanan perangkat yang ditetapkan organisasi.**

ISO/IEC 27002:2022 memberikan perhatian terhadap keamanan perangkat pengguna dan aset yang berada di luar lingkungan organisasi, termasuk perlindungan terhadap kehilangan, pencurian, serta akses yang tidak sah (ISO/IEC, 2022).

Kehilangan *Flashdisk* Juga Perlu Diperhatikan

Perangkat yang kecil sering kali lebih mudah hilang.

Jika *flashdisk* atau media penyimpanan lain yang berisi data pasien hilang, **segera laporkan.** Jangan menganggap kejadian tidak penting hanya karena perangkat tersebut murah atau hanya berisi beberapa file.

Yang perlu dinilai adalah **informasi yang mungkin terdapat di dalamnya**, bukan harga medianya.

INGAT: Perangkat yang hilang atau dicuri dapat berarti data dan akses ikut berisiko. Jangan menunggu perangkat ditemukan sebelum melapor. **Segera laporkan kehilangan agar organisasi**

dapat menilai risiko, mengamankan akses yang diperlukan, dan melakukan tindakan penanganan sesuai prosedur.

11.7 Komputer Diduga Terinfeksi Malware

Komputer yang digunakan untuk mengakses SIMRS, data pasien, email, atau sistem rumah sakit dapat menjadi sasaran *malware*. Jika perangkat menunjukkan tanda-tanda yang mencurigakan, pengguna harus **segera melaporkannya dan menghindari tindakan yang dapat memperburuk keadaan.**

Pengguna tidak perlu memastikan terlebih dahulu apakah komputer benar-benar terinfeksi. **Dugaan adanya infeksi sudah cukup untuk melakukan pelaporan.**

Kenali Tanda yang Mencurigakan

Beberapa kondisi yang perlu diperhatikan antara lain:

antivirus memberikan peringatan;

muncul aplikasi atau jendela yang tidak dikenal;

file tiba-tiba berubah atau tidak dapat dibuka;

komputer menjadi tidak normal setelah membuka file atau tautan tertentu;

browser mengarahkan ke halaman yang tidak diharapkan;

atau muncul pesan tebusan (*ransomware*).

Satu tanda belum tentu membuktikan adanya *malware*, tetapi tetap perlu diperiksa apabila perilaku perangkat tidak seperti biasanya.

Jangan Mencoba Memperbaiki Sendiri

Jika mencurigai adanya *malware*, hindari tindakan seperti:

mengunduh aplikasi pembersih dari internet;

memasang antivirus tambahan tanpa arahan;

menghapus file secara sembarangan;

menonaktifkan antivirus;

atau mencoba berbagai tutorial yang belum diketahui keamanannya.

Tindakan tersebut dapat mengubah kondisi perangkat dan menyulitkan pemeriksaan lebih lanjut.

Hentikan Aktivitas yang Berisiko

Jika kecurigaan muncul setelah membuka lampiran, menjalankan file, atau mengklik tautan tertentu, **jangan melanjutkan aktivitas tersebut.**

Jangan menyalin file yang dicurigai ke *flashdisk* atau mengirimkannya kepada rekan kerja untuk mencoba apakah file tersebut juga bermasalah.

Jika diperlukan tindakan terhadap koneksi jaringan atau perangkat, **ikuti prosedur organisasi atau arahan pengelola TI.**

Segera Laporkan kepada Pengelola TI

Sampaikan informasi sederhana mengenai kejadian, misalnya:

kapan masalah mulai terjadi;

apa yang dilakukan sebelum masalah muncul;

file atau tautan yang sempat dibuka;

peringatan yang muncul;

dan perubahan yang terlihat pada komputer.

Jika memungkinkan, jangan menghilangkan pesan atau informasi yang dapat membantu pemeriksaan.

ISO/IEC 27002:2022 menempatkan perlindungan terhadap *malware* dan pelaporan kejadian keamanan sebagai bagian dari kontrol keamanan informasi (ISO/IEC, 2022).

Jangan Menggunakan Komputer Lain untuk Membuka File yang Sama

Jika masalah muncul setelah membuka sebuah file, jangan mencoba file tersebut pada komputer lain untuk memastikan apakah file memang berbahaya.

Tindakan tersebut justru dapat menyebabkan ancaman menyebar ke perangkat lain.

Serahkan pemeriksaan file kepada pengelola TI menggunakan mekanisme yang sesuai.

Jika Muncul Pesan *Ransomware*

Jika file tidak dapat dibuka dan muncul pesan yang meminta pembayaran atau tebusan, jangan melakukan pembayaran atau mengikuti instruksi pelaku sendiri.

Segera laporkan kejadian tersebut.

Pengelola TI perlu melakukan penanganan berdasarkan kondisi perangkat, sistem, jaringan, serta prosedur respons insiden yang berlaku.

Pelaporan Cepat Membantu Membatasi Dampak

Komputer yang terinfeksi dapat menjadi titik awal gangguan yang lebih luas. Karena itu, semakin cepat kejadian diketahui, semakin cepat organisasi dapat melakukan pemeriksaan dan mengambil tindakan untuk membatasi dampaknya.

Gunakan prinsip sederhana:

CURIGAI → HENTIKAN AKTIVITAS BERISIKO → LAPORKAN → IKUTI ARAHAN

INGAT: Anda tidak perlu memastikan sendiri bahwa komputer benar-benar terkena malware. Jika perangkat menunjukkan aktivitas mencurigakan, jangan mencoba memperbaiki sendiri atau menyebarkan file yang dicurigai. Segera laporkan kepada pengelola TI dan ikuti prosedur penanganan insiden.

11.8 Akun Menunjukkan Aktivitas yang Mencurigakan

Aktivitas yang tidak dikenal pada akun dapat menjadi tanda bahwa **credential telah diketahui pihak lain atau akun sedang digunakan tanpa kewenangan.**

Jika menemukan aktivitas yang tidak pernah dilakukan, pengguna tidak perlu menunggu sampai terjadi kerusakan atau kehilangan data. **Segera laporkan agar akun dapat diperiksa dan diamankan.**

Kenali Aktivitas yang Tidak Biasa

Beberapa tanda yang perlu diperhatikan antara lain:

muncul pemberitahuan *login* yang tidak dikenal;
terdapat perubahan data yang tidak pernah dilakukan;
password tiba-tiba tidak dapat digunakan;

muncul permintaan OTP atau MFA tanpa melakukan *login*;
terdapat email atau pesan yang terkirim tanpa sepengetahuan
pengguna;

atau **tercatat aktivitas pada waktu ketika pengguna tidak menggunakan sistem.**

Kondisi tersebut belum tentu selalu berarti akun telah diambil alih, tetapi **perlu diperiksa.**

Jangan Menyetujui Permintaan MFA yang Tidak Dikenal

Jika tiba-tiba menerima permintaan persetujuan *login*, OTP, atau notifikasi MFA padahal tidak sedang melakukan autentikasi, **jangan menyetujuinya.**

Jangan berpikir:

“Mungkin sistem sedang melakukan verifikasi.”

Permintaan tersebut dapat muncul karena seseorang sedang mencoba masuk menggunakan akun Anda.

Jika kejadian berulang, segera laporkan kepada pengelola TI.

Jangan Mengabaikan Notifikasi *Login*

Beberapa sistem memberikan pemberitahuan ketika akun digunakan dari perangkat atau lokasi tertentu.

Jika menerima pemberitahuan yang tidak sesuai dengan aktivitas Anda, jangan hanya menghapusnya.

Catat informasi yang tersedia dan **laporkan melalui mekanisme organisasi** agar aktivitas akun dapat diperiksa.

Segera Amankan Akun

Jika terdapat dugaan akun digunakan pihak lain, lakukan tindakan pengamanan sesuai prosedur organisasi.

Jika mekanisme memungkinkan dan sesuai arahan, pengguna dapat mengganti *password*. Namun, **mengganti password saja belum tentu menyelesaikan seluruh masalah.**

Pengelola TI mungkin perlu memeriksa sesi yang masih aktif, *log* autentikasi, perubahan data, maupun aktivitas lain yang terjadi menggunakan akun tersebut.

Jangan Menghapus Bukti

Informasi seperti email pemberitahuan, waktu kejadian, *screenshot* notifikasi, atau aktivitas yang tidak dikenal dapat membantu proses pemeriksaan.

Jangan menghapus informasi tersebut sebelum mendapatkan arahan apabila masih diperlukan sebagai bagian dari pemeriksaan insiden.

Sampaikan:

akun yang terdampak;

aktivitas yang tidak dikenal;

waktu kejadian;

dan tindakan yang sudah dilakukan.

Periksa Kemungkinan Dampaknya

Akun yang digunakan pihak lain dapat memberikan akses sesuai kewenangan pemilik akun.

Jika akun memiliki akses ke SIMRS atau sistem lainnya, pihak yang tidak berwenang mungkin dapat melihat atau melakukan tindakan terhadap data yang dapat diakses oleh akun tersebut.

Karena itu, semakin tinggi kewenangan suatu akun, **semakin penting kejadian mencurigakan segera ditangani.**

ISO/IEC 27002:2022 menekankan pentingnya *logging*, pemantauan aktivitas, perlindungan informasi autentikasi, serta respons terhadap insiden keamanan informasi (ISO/IEC, 2022).

Jangan Melakukan Investigasi Sendiri

Pengguna tidak perlu mencoba mencari sendiri siapa yang menggunakan akun atau melakukan tindakan yang dapat mengubah bukti.

Gunakan prinsip:

KENALI → JANGAN SETUJUI AKTIVITAS ASING → AMANKAN → LAPORKAN

Biarkan pemeriksaan teknis dilakukan oleh pihak yang memiliki kewenangan dan akses terhadap *log* sistem.

INGAT: Jika akun menunjukkan aktivitas yang tidak pernah Anda lakukan, jangan mengabaikannya. Jangan menyetujui OTP atau permintaan MFA yang tidak Anda lakukan. **Segera laporkan agar**

akun, sesi aktif, log, dan kemungkinan aktivitas tidak sah dapat diperiksa.

11.9 Segera Laporkan Insiden

Ketika menemukan atau mencurigai adanya insiden keamanan informasi, **segera laporkan melalui mekanisme yang ditetapkan organisasi.**

Jangan menunggu sampai seluruh kejadian dapat dipastikan atau sampai dampaknya terlihat besar. Pelaporan yang cepat memberikan kesempatan kepada organisasi untuk **membatasi dampak dan melakukan penanganan lebih awal.**

Jangan Menunggu Masalah Menjadi Besar

Pengguna terkadang menunda laporan karena merasa kejadian masih kecil.

Misalnya:

“Saya tunggu dulu, mungkin tidak terjadi apa-apa.”

“Hanya satu data pasien yang salah kirim.”

“Komputernya masih bisa digunakan.”

“Password sudah saya ganti sendiri.”

Penilaian mengenai tingkat keparahan insiden sebaiknya dilakukan oleh pihak yang berwenang. Tugas pengguna adalah **melaporkan kejadian yang diketahui atau dicurigai.**

Laporkan Sesegera Mungkin

Insiden yang perlu segera dilaporkan antara lain:

data pasien salah kirim atau terungkap kepada pihak lain;

password, OTP, atau credential diketahui orang lain;

passphrase TTE diduga telah diketahui pihak lain;

perangkat kerja hilang atau dicuri;

komputer menunjukkan tanda-tanda malware atau ransomware;

akun menunjukkan aktivitas yang tidak dikenal;

atau terdapat akses terhadap data tanpa kewenangan.

ISO/IEC 27002:2022 menekankan bahwa personel harus melaporkan kejadian keamanan informasi yang diamati atau dicurigai melalui kanal yang sesuai secara tepat waktu (ISO/IEC, 2022).

Sampaikan Informasi yang Diketahui

Pengguna tidak perlu membuat laporan teknis yang rumit.

Sampaikan informasi yang diketahui, seperti:

apa yang terjadi;

kapan kejadian diketahui;

data, akun, perangkat, atau sistem yang terlibat;

siapa yang mungkin menerima atau memperoleh akses jika diketahui;

dan tindakan yang sudah dilakukan.

Jika ada informasi yang belum diketahui, jangan menebak. Sampaikan sesuai fakta yang tersedia.

Jangan Menyembunyikan Kesalahan

Jika insiden terjadi karena kesalahan sendiri, tetap laporkan.

Misalnya, pengguna terlanjur mengklik tautan *phishing*, memberikan OTP, salah mengirim data pasien, atau membuka lampiran mencurigakan.

Menyembunyikan kejadian dapat menyebabkan penanganan terlambat dan dampak menjadi lebih luas.

Prinsip yang perlu dibangun adalah:

Kesalahan terjadi → segera laporkan → batasi dampak → lakukan perbaikan.

Jangan Menghapus Bukti Sembarangan

Setelah menemukan insiden, jangan terburu-buru menghapus email, pesan, file, *log*, atau informasi lain yang berkaitan dengan kejadian.

Informasi tersebut mungkin diperlukan untuk mengetahui **apa yang terjadi dan seberapa luas dampaknya.**

Simpan informasi yang relevan dan ikuti arahan pihak yang menangani insiden.

Ikuti Arahan Penanganan

Setelah melapor, pengguna perlu mengikuti arahan yang diberikan.

Tindakan dapat berbeda tergantung jenis insiden. Pengelola TI mungkin meminta pengguna mengganti *password*, menghentikan penggunaan perangkat, memberikan informasi tambahan, atau melakukan tindakan lainnya.

Karena itu, hindari melakukan tindakan teknis sendiri yang dapat mengubah kondisi sistem sebelum mendapatkan arahan.

Pelaporan Cepat Membantu Melindungi Pasien dan Organisasi

Dalam insiden yang melibatkan Data Pribadi, organisasi dapat memiliki kewajiban lebih lanjut berdasarkan UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi. Karena itu, **pelaporan internal yang cepat penting agar organisasi dapat menilai kejadian dan menentukan tindakan yang diperlukan** (Republik Indonesia, 2022).

Pegawai tidak perlu menentukan sendiri apakah suatu kejadian memenuhi kategori kegagalan pelindungan Data Pribadi. Laporkan terlebih dahulu agar dapat dilakukan penilaian oleh pihak yang berwenang.

INGAT: Jika melihat, mengalami, atau mencurigai insiden keamanan informasi, segera laporkan. Jangan menunggu sampai dampaknya menjadi besar dan jangan menyembunyikan kesalahan. **Semakin cepat insiden diketahui, semakin cepat organisasi dapat membatasi dampak dan melindungi data pasien.**

11.10 Jangan Menutupi Insiden atau Menghapus Bukti

Ketika terjadi insiden keamanan informasi, tindakan pertama yang perlu dilakukan adalah **melaporkan kejadian dan menjaga informasi yang berkaitan dengan insiden tersebut.**

Jangan menyembunyikan kejadian karena takut disalahkan, dan jangan menghapus bukti dengan tujuan membuat kejadian seolah-

olah tidak pernah terjadi. Tindakan tersebut dapat **menghambat pemeriksaan dan memperlambat penanganan insiden.**

Jangan Menutupi Kesalahan

Insiden dapat terjadi karena kesalahan manusia.

Misalnya:

salah mengirim data pasien;

terlanjur mengklik tautan *phishing*;

memberikan OTP kepada pihak lain;

membuka lampiran mencurigakan;

atau **kehilangan perangkat yang digunakan untuk bekerja.**

Jika hal tersebut terjadi, jangan mencoba menyelesaikannya diam-diam.

Prinsipnya:

Terjadi kesalahan → segera laporkan → bantu proses penanganan.

Jangan Menghapus Bukti Sembarangan

Ketika menyadari telah melakukan kesalahan, pengguna mungkin ingin segera menghapus semua yang berkaitan dengan kejadian.

Namun, email, pesan, file, notifikasi, atau informasi lainnya dapat membantu pihak yang menangani insiden memahami **apa yang sebenarnya terjadi.**

Karena itu, jangan sembarangan:

menghapus email mencurigakan;

menghapus percakapan dengan pelaku;

menghapus file yang diduga menjadi sumber masalah;

membersihkan riwayat aktivitas;

atau **mengubah informasi yang berkaitan dengan kejadian.**

Ikuti arahan pihak yang menangani insiden mengenai informasi yang perlu dipertahankan.

Jangan Mencoba “Membersihkan” Komputer Sendiri

Jika komputer diduga terkena *malware*, jangan terburu-buru melakukan *format*, menginstal ulang sistem operasi, menghapus banyak file, atau memasang berbagai aplikasi pembersih.

Tindakan tersebut dapat **menghilangkan informasi yang diperlukan untuk pemeriksaan.**

Laporkan terlebih dahulu dan ikuti arahan pengelola TI.

Sampaikan Kejadian Sesuai Fakta

Ketika melaporkan insiden, sampaikan apa yang benar-benar terjadi.

Misalnya:

“Saya mengklik tautan dan memasukkan username serta password.”

lebih membantu daripada hanya mengatakan:

“Komputer saya sepertinya bermasalah.”

Demikian pula jika data pasien salah kirim, sampaikan penerima, waktu, jenis data, dan tindakan yang sudah dilakukan sejauh diketahui.

Jangan menambah, mengurangi, atau menyembunyikan informasi penting.

Bukti Membantu Menentukan Dampak

Informasi yang berkaitan dengan insiden dapat membantu organisasi mengetahui:

kapan kejadian terjadi;

akun atau perangkat yang terlibat;

data yang mungkin terdampak;

aktivitas yang telah dilakukan;

dan tindakan penanganan yang diperlukan.

ISO/IEC 27002:2022 mengatur pengumpulan bukti sebagai bagian dari pengelolaan insiden keamanan informasi. Organisasi perlu memiliki prosedur untuk identifikasi, pengumpulan, perolehan, dan preservasi bukti yang berkaitan dengan kejadian keamanan informasi (ISO/IEC, 2022).

Jangan Takut Melaporkan karena Belum Mengetahui Dampaknya

Pengguna tidak harus mengetahui apakah kejadian tersebut merupakan insiden besar atau kecil.

Tugas pengguna adalah **melaporkan kejadian secara cepat dan jujur**. Penilaian tingkat keparahan dan tindakan teknis selanjutnya dilakukan oleh pihak yang memiliki kewenangan.

Menunda laporan atau menghilangkan informasi justru dapat membuat organisasi kehilangan waktu yang diperlukan untuk membatasi dampak.

Ikuti Prosedur Penanganan Insiden

Setelah melapor, jangan melakukan tindakan tambahan yang dapat mengubah kondisi perangkat atau informasi tanpa arahan.

Gunakan prinsip sederhana:

**JANGAN SEMBUNYIKAN → JANGAN HAPUS BUKTI → LAPORKAN
→ IKUTI ARAHAN**

INGAT: Insiden yang ditutupi dapat menjadi lebih sulit ditangani. Jika terjadi kesalahan, segera laporkan secara jujur dan jangan menghapus atau mengubah bukti sembarangan. **Informasi yang masih tersedia dapat membantu organisasi mengetahui apa yang terjadi, membatasi dampak, dan melakukan penanganan dengan tepat.**

11.11 Simpan Informasi yang Diperlukan untuk Penanganan Insiden

Ketika terjadi insiden keamanan informasi, informasi mengenai kejadian perlu **dipertahankan agar dapat digunakan dalam proses pemeriksaan dan penanganan**.

Informasi tersebut dapat membantu organisasi mengetahui apa yang terjadi, kapan kejadian berlangsung, sistem atau data yang terdampak, serta tindakan apa yang perlu dilakukan.

Catat Informasi Dasar Kejadian

Pengguna tidak perlu membuat laporan teknis yang rumit. Jika memungkinkan, catat informasi sederhana seperti:

waktu kejadian diketahui;

perangkat, akun, atau sistem yang terlibat;

aktivitas yang dilakukan sebelum kejadian;

pesan atau peringatan yang muncul;

dan tindakan yang sudah dilakukan setelah kejadian.

Sampaikan informasi sesuai fakta yang diketahui. Jika tidak mengetahui sesuatu, **jangan menebak atau membuat asumsi.**

Pertahankan Pesan yang Mencurigakan

Jika insiden berkaitan dengan *phishing* atau *social engineering*, informasi seperti email, SMS, atau percakapan dapat membantu pemeriksaan.

Misalnya:

alamat atau identitas pengirim;

waktu pesan diterima;

isi permintaan;

tautan atau nama lampiran;

dan komunikasi yang telah dilakukan.

Jangan meneruskan pesan berbahaya kepada rekan kerja hanya untuk menunjukkan contohnya. Gunakan mekanisme pelaporan yang ditetapkan organisasi.

Jangan Mengubah Kondisi Perangkat Sembarangan

Jika komputer diduga terkena *malware*, hindari melakukan tindakan yang dapat mengubah atau menghilangkan informasi penting.

Jangan langsung:

melakukan *format* atau instalasi ulang;

menghapus banyak file;

membersihkan riwayat aktivitas;

atau **memasang aplikasi pembersih sendiri.**

Laporkan terlebih dahulu dan ikuti arahan pengelola TI.

Screenshot Dapat Membantu, tetapi Tetap Hati-hati

Dalam kondisi tertentu, *screenshot* pesan kesalahan atau peringatan dapat membantu menjelaskan kejadian.

Namun, periksa apakah *screenshot* tersebut mengandung **data pasien, password, OTP, atau informasi sensitif lainnya.**

Jangan menyebarkan *screenshot* melalui grup atau media komunikasi yang tidak semestinya. Jika diperlukan sebagai bukti,

kiriman hanya melalui mekanisme penanganan insiden yang ditetapkan organisasi.

Jangan Mengumpulkan Bukti Secara Berlebihan

Pengguna tidak perlu melakukan investigasi sendiri dengan membuka *log*, menyalin database, memeriksa akun orang lain, atau mengakses sistem di luar kewenangannya.

Tugas pengguna cukup:

KENALI → CATAT INFORMASI YANG DIKETAHUI → PERTAHANKAN INFORMASI YANG RELEVAN → LAPORKAN

Pengumpulan bukti teknis lebih lanjut dilakukan oleh pihak yang memiliki kewenangan.

ISO/IEC 27002:2022 mengatur *collection of evidence* sebagai bagian dari pengelolaan insiden keamanan informasi, termasuk identifikasi, pengumpulan, perolehan, dan preservasi bukti (ISO/IEC, 2022).

Informasi Harus Tetap Dilindungi

Bukti insiden dapat mengandung Data Pribadi, informasi sistem, alamat IP, nama akun, maupun informasi sensitif lainnya.

Karena itu, informasi insiden **bukan untuk disebarluaskan secara bebas**. Simpan dan sampaikan hanya kepada pihak yang berwenang melalui mekanisme organisasi.

INGAT: Simpan informasi yang diperlukan untuk membantu penanganan insiden, tetapi jangan melakukan investigasi sendiri. Catat apa yang terjadi, pertahankan informasi yang relevan, jangan mengubah atau menghapus bukti sembarangan, dan segera serahkan penanganan lebih lanjut kepada pihak yang berwenang.

11.12 Containment, Recovery, dan Pencegahan Kejadian Berulang

Penanganan insiden tidak berhenti setelah kejadian dilaporkan. Setelah insiden diketahui, organisasi perlu melakukan tindakan untuk **membatasi dampak (*containment*)**, **memulihkan kondisi (*recovery*)**, dan **mencegah kejadian serupa terulang**.

Tahapan tersebut umumnya dilakukan oleh pengelola TI atau tim yang menangani insiden. Pengguna perlu memahami prinsipnya agar dapat mengikuti arahan dengan benar.

Containment: Membatasi Dampak Insiden

Containment bertujuan **mencegah insiden berkembang atau berdampak lebih luas.**

Tindakan yang dilakukan bergantung pada jenis insiden. Contohnya dapat berupa:

menonaktifkan akun yang diduga disalahgunakan;
membatasi akses tertentu;
mengisolasi perangkat yang terindikasi terkena *malware*;
atau **menghentikan sementara akses pihak yang tidak berwenang.**

Pengguna tidak perlu menentukan sendiri tindakan teknis tersebut. Jika diminta menghentikan penggunaan perangkat atau tidak mengakses suatu sistem sementara waktu, **ikuti arahan pihak yang menangani insiden.**

Recovery: Memulihkan Kondisi dengan Aman

Setelah ancaman berhasil dikendalikan, tahap berikutnya adalah memulihkan sistem atau layanan agar dapat digunakan kembali dengan aman.

Proses *recovery* dapat meliputi:

pemulihan sistem atau data;
penggantian credential;
pembersihan atau pemulihan perangkat;
perbaikan konfigurasi;
atau **pengaktifan kembali layanan setelah dinyatakan aman.**

Jangan menggunakan kembali perangkat atau akun yang sedang ditangani sebelum memperoleh arahan bahwa perangkat atau akun tersebut sudah dapat digunakan.

Jangan Terburu-buru Menganggap Insiden Selesai

Komputer yang kembali normal belum tentu berarti seluruh masalah telah selesai.

Demikian pula, mengganti *password* tidak selalu berarti akun sudah sepenuhnya aman. Masih mungkin diperlukan pemeriksaan terhadap sesi aktif, *log*, perubahan data, atau sistem lain yang berkaitan.

Karena itu:

Gejala hilang ≠ insiden selesai.

Penutupan insiden dilakukan setelah pihak yang berwenang memastikan tindakan penanganan yang diperlukan telah dilakukan.

Pelajari Penyebab Kejadian

Setelah insiden ditangani, organisasi perlu mempelajari kejadian tersebut agar masalah yang sama tidak terus berulang.

ISO/IEC 27002:2022 memasukkan ***learning from information security incidents*** sebagai salah satu kontrol keamanan informasi. Pengetahuan yang diperoleh dari insiden dapat digunakan untuk memperkuat dan meningkatkan pengamanan (ISO/IEC, 2022).

Misalnya, jika insiden terjadi karena email *phishing*, organisasi dapat memperbaiki mekanisme perlindungan dan meningkatkan kesadaran pengguna.

Jika insiden terjadi karena akses vendor yang masih aktif, proses penghakhiran akses dapat diperbaiki.

Perbaikan Tidak Selalu Berupa Teknologi

Pencegahan kejadian berulang dapat dilakukan melalui:

perbaikan prosedur;

perubahan konfigurasi atau kontrol keamanan;

penyesuaian hak akses;

pembaruan sistem;

atau **edukasi kepada pengguna.**

Dengan demikian, tujuan penanganan insiden bukan hanya membuat sistem kembali berfungsi, tetapi juga **membuat organisasi lebih siap menghadapi kejadian berikutnya.**

Pengguna Juga Memiliki Peran

Pengguna mungkin diminta memberikan informasi tambahan, mengganti *password*, mengikuti pelatihan, memperbarui perangkat, atau mengubah kebiasaan kerja setelah sebuah insiden.

Hal tersebut merupakan bagian dari proses perbaikan.

Gunakan prinsip sederhana:

LAPORKAN → BATASI DAMPAK → PULIHKAN → PELAJARI → PERBAIKI

INGAT: Insiden tidak selesai hanya karena sistem kembali normal. Setelah kejadian dilaporkan, organisasi perlu membatasi dampak, memulihkan kondisi dengan aman, mempelajari penyebabnya, dan melakukan perbaikan agar kejadian serupa tidak berulang.

BAB 12 MEMBANGUN BUDAYA KEAMANAN DATA PASIEN

12.1 Keamanan Informasi Adalah Tanggung Jawab Bersama

Keamanan informasi di rumah sakit bukan hanya tanggung jawab pengelola TI. **Setiap orang yang menggunakan sistem, mengakses data pasien, menerima dokumen, menggunakan perangkat kerja, atau berkomunikasi menggunakan informasi organisasi memiliki peran dalam menjaga keamanan.**

Teknologi dapat membantu melindungi sistem, tetapi keamanan juga sangat bergantung pada bagaimana setiap pengguna memperlakukan informasi dalam pekerjaan sehari-hari.

Keamanan Bukan Hanya Tugas Bagian TI

Pengelola TI dapat menerapkan:

firewall dan antivirus;

pengaturan hak akses;

pencatatan aktivitas (*logging*);

pembaruan sistem;

dan **berbagai kontrol keamanan lainnya.**

Namun, kontrol tersebut tidak dapat menggantikan kehati-hatian pengguna.

Jika seseorang memberikan *password* kepada orang lain, salah mengirim data pasien, meninggalkan komputer dalam keadaan *login*, atau mengabaikan pesan *phishing*, risiko keamanan tetap dapat terjadi.

Setiap Peran Memiliki Tanggung Jawab

Tanggung jawab keamanan tidak berarti semua pegawai harus menjadi ahli keamanan siber.

Petugas pelayanan menjaga data yang digunakan dalam pekerjaannya. Administrator mengelola sistem sesuai kewenangan. Pimpinan memberikan contoh dalam mematuhi kebijakan. Vendor menjaga akses dan informasi yang diperoleh selama pekerjaannya.

Prinsipnya:

Setiap orang bertanggung jawab sesuai peran dan kewenangannya.

ISO/IEC 27002:2022 menekankan pentingnya penetapan dan komunikasi peran serta tanggung jawab keamanan informasi sesuai kebutuhan organisasi (ISO/IEC, 2022).

Kebiasaan Sederhana Memiliki Dampak Besar

Kontribusi pengguna terhadap keamanan dapat dimulai dari tindakan sederhana:

gunakan akun sendiri;
jaga password, OTP, dan credential;
akses data hanya untuk kepentingan pekerjaan;
periksa penerima sebelum mengirim data;
kunci komputer ketika ditinggalkan;
waspada pesan mencurigakan;
dan **segera laporkan insiden.**

Tindakan tersebut mungkin terlihat sederhana, tetapi dilakukan setiap hari oleh banyak pengguna sehingga memiliki pengaruh besar terhadap keamanan organisasi.

Jabatan Tidak Menghilangkan Kewajiban Keamanan

Prinsip keamanan berlaku bagi seluruh pihak yang memiliki akses terhadap informasi, baik pegawai, administrator, pimpinan, tenaga kesehatan, maupun pihak ketiga.

Jabatan atau kewenangan yang lebih tinggi **bukan alasan untuk menggunakan akun orang lain, meminta password, atau melewati prosedur keamanan.**

Semakin besar akses yang dimiliki seseorang, semakin penting akses tersebut digunakan secara bertanggung jawab.

Jangan Berpikir “Bukan Urusan Saya”

Jika melihat sesuatu yang mencurigakan, jangan mengabaikannya hanya karena merasa keamanan merupakan tugas bagian TI.

Contohnya:

email *phishing*;

**komputer menunjukkan aktivitas tidak biasa;
dokumen pasien tertinggal;
akun digunakan orang lain;
atau data pasien terkirim kepada pihak yang salah.**

Laporkan melalui mekanisme yang ditetapkan organisasi agar dapat ditangani oleh pihak yang berwenang.

Keamanan Dibangun Bersama

Satu pengguna yang berhati-hati dapat membantu mencegah sebuah insiden. Sebaliknya, satu tindakan yang tidak aman dapat membuka peluang terjadinya kebocoran data atau gangguan sistem.

Karena itu, keamanan informasi perlu menjadi **bagian dari budaya kerja**, bukan sekadar aturan tertulis atau tanggung jawab satu unit tertentu.

INGAT: Keamanan informasi adalah tanggung jawab bersama.
Anda tidak harus menjadi ahli keamanan siber untuk ikut melindungi data pasien. **Gunakan akses sesuai kewenangan, jaga credential, berhati-hati dalam bekerja, dan segera laporkan jika menemukan sesuatu yang mencurigakan.**

12.2 Peran Pengguna Sistem Informasi

Pengguna sistem informasi memiliki peran penting dalam menjaga keamanan data pasien. Setiap aktivitas yang dilakukan melalui SIMRS, Rekam Medis Elektronik, email, maupun sistem lainnya dapat berkaitan dengan **Data Pribadi dan proses pelayanan rumah sakit**.

Karena itu, setiap pengguna harus menggunakan sistem **sesuai tugas, kewenangan, dan kepentingan pekerjaan**.

Gunakan Akun Milik Sendiri

Setiap pengguna harus menggunakan akun yang diberikan kepadanya dan menjaga *credential* akun tersebut.

Hindari:

**meminjam akun rekan kerja;
memberikan password kepada orang lain;**

**menggunakan akun bersama tanpa mekanisme yang jelas;
atau membiarkan orang lain menggunakan sesi yang masih
login.**

Aktivitas pada akun dapat tercatat dalam *log* dan *audit trail*. Karena itu, penggunaan akun individual membantu menjaga **akuntabilitas aktivitas pengguna.**

Akses Data Sesuai Kebutuhan Pekerjaan

Kemampuan membuka data dalam sistem tidak berarti pengguna boleh melihat seluruh data yang tersedia.

Pengguna hanya boleh mengakses informasi yang diperlukan untuk menjalankan tugasnya.

Prinsip yang telah dibahas pada BAB 3 tetap berlaku:

Dapat melihat ≠ berhak melihat.

Memiliki akses ≠ boleh menggunakan untuk semua tujuan.

Prinsip *need-to-know* dan *least privilege* harus menjadi bagian dari kebiasaan penggunaan sistem.

Jaga Kerahasiaan Informasi yang Dilihat

Data yang diperoleh melalui sistem tidak boleh digunakan atau disebar di luar kepentingan pekerjaan.

Jangan mengambil *screenshot*, memfoto layar, menyalin data ke perangkat pribadi, atau membagikan informasi kepada pihak lain tanpa kebutuhan dan kewenangan yang sesuai.

Kewajiban menjaga data tetap berlaku **setelah pengguna keluar dari sistem.**

Gunakan Sistem dengan Aman

Pengguna juga berperan menjaga keamanan perangkat yang digunakan untuk mengakses sistem.

Kebiasaan sederhana yang perlu dilakukan antara lain:

kunci komputer ketika meninggalkan tempat kerja;

lakukan *logout* ketika penggunaan selesai;

jangan memasang aplikasi sembarangan;

jangan menonaktifkan antivirus atau perlindungan keamanan;

dan waspadai tautan serta lampiran yang mencurigakan.

ISO/IEC 27002:2022 menekankan pentingnya kesadaran, pendidikan, dan pelatihan keamanan informasi agar personel memahami tanggung jawabnya dalam melindungi informasi organisasi (ISO/IEC, 2022).

Periksa Sebelum Mengirim Data

Sebelum mengirim data melalui media yang diperbolehkan organisasi, pengguna perlu memastikan:

data yang dikirim memang diperlukan;

penerimanya benar;

lampirannya benar;

dan informasi yang dikirim tidak berlebihan.

Pemeriksaan beberapa detik sebelum menekan tombol **Kirim** dapat membantu mencegah salah kirim data pasien.

Laporkan Kejadian yang Mencurigakan

Pengguna tidak harus mampu menyelesaikan sendiri setiap masalah keamanan.

Jika menemukan aktivitas akun yang tidak dikenal, *phishing*, *malware*, kehilangan perangkat, salah kirim data, atau kejadian lainnya, **segera laporkan melalui mekanisme organisasi**.

Peran pengguna adalah **mengenali, tidak memperburuk keadaan, dan melaporkan** agar pihak yang berwenang dapat melakukan penanganan.

Gunakan Sistem secara Bertanggung Jawab

Pada akhirnya, peran pengguna dapat diringkas menjadi:

AKSES SESUAI KEBUTUHAN → JAGA CREDENTIAL → LINDUNGI DATA → GUNAKAN SISTEM DENGAN AMAN → LAPORKAN INSIDEN

Setiap pengguna mungkin memiliki pekerjaan dan tingkat akses yang berbeda, tetapi prinsip tanggung jawab tersebut berlaku bagi seluruh pengguna sistem informasi.

INGAT: Akun dan akses diberikan untuk mendukung pekerjaan, bukan untuk memberikan kebebasan melihat atau menggunakan seluruh data. Gunakan sistem sesuai kewenangan, lindungi data yang diakses, jaga credential, dan segera laporkan apabila menemukan kejadian yang mencurigakan.

12.3 Peran Pejabat dan Pimpinan

Pejabat dan pimpinan memiliki peran penting dalam membangun budaya keamanan informasi. Selain menggunakan sistem sesuai kewenangan, pimpinan juga perlu **memberikan contoh, mendukung penerapan kebijakan, dan memastikan keamanan informasi menjadi bagian dari pelaksanaan pekerjaan.**

Semakin tinggi kewenangan seseorang, semakin besar pula tanggung jawab dalam menjaga penggunaan akses dan informasi secara tepat.

Pimpinan Harus Memberikan Contoh

Kebijakan keamanan akan sulit diterapkan apabila pimpinan sendiri terbiasa mengabaikannya.

Hindari kebiasaan seperti:

meminta password staf;

meminjam akun pegawai;

meminta OTP kepada bawahan;

menitipkan Tanda Tangan Elektronik dengan memberikan *passphrase*;

atau meminta data pasien dikirim melalui media yang tidak semestinya.

Prinsip keamanan berlaku untuk semua pihak, termasuk pejabat dan pimpinan.

Kewenangan Jabatan Bukan Hak untuk Mengakses Semua Data

Jabatan yang lebih tinggi tidak otomatis berarti seseorang harus dapat melihat seluruh data pasien.

Akses tetap harus berkaitan dengan **tugas, fungsi, kewenangan, dan kebutuhan pekerjaan.**

Prinsipnya:

Jabatan tinggi ≠ akses tanpa batas.

***Need-to-know* dan *least privilege* tetap berlaku.**

Jika suatu informasi tidak diperlukan untuk menjalankan tugas, informasi tersebut tidak perlu diakses hanya karena secara teknis dapat dibuka.

Jangan Meminta Bawahan Melanggar Prosedur

Tekanan dari atasan dapat menyebabkan pegawai merasa harus mengabaikan prosedur keamanan.

Misalnya:

“Kirim saja datanya ke WhatsApp saya.”

“Pakai akun kamu dulu, saya hanya sebentar.”

“Berikan passphrase-nya, nanti staf yang tanda tangan.”

Permintaan seperti ini dapat membentuk kebiasaan kerja yang tidak aman.

Pimpinan perlu memastikan bahwa **target pekerjaan dan kebutuhan pelayanan tidak mendorong pegawai melewati kontrol keamanan yang telah ditetapkan.**

Dukung Pelaporan Insiden

Pimpinan perlu menciptakan lingkungan kerja yang mendorong pegawai **segera melaporkan insiden atau kesalahan.**

Jika pegawai takut dimarahi karena salah mengirim data atau terlanjur mengklik *phishing*, mereka dapat memilih menyembunyikan kejadian. Akibatnya, organisasi kehilangan waktu untuk melakukan penanganan.

Fokus awal ketika insiden terjadi harus pada:

pelaporan → pembatasan dampak → penanganan → evaluasi.

Tanggung jawab atau tindakan administratif, jika memang diperlukan, dapat diproses sesuai ketentuan organisasi setelah fakta kejadian diketahui.

Dukung Sumber Daya dan Pengamanan yang Diperlukan

Keamanan informasi tidak dapat dibebankan hanya kepada pengguna atau pengelola TI.

Pimpinan perlu mendukung kebutuhan organisasi seperti **kebijakan, pengelolaan akses, peningkatan kesadaran pengguna, pengamanan perangkat, pembaruan sistem, pencadangan, dan penanganan insiden** sesuai kebutuhan dan kemampuan organisasi.

ISO/IEC 27002:2022 menekankan pentingnya dukungan manajemen terhadap keamanan informasi serta penetapan peran dan tanggung jawab yang jelas (ISO/IEC, 2022).

Lindungi Credential dan TTE Milik Pimpinan

Akun pejabat dan pimpinan dapat memiliki kewenangan penting sehingga perlu mendapatkan perhatian khusus.

Pimpinan tetap harus:

menjaga password dan OTP;

menggunakan MFA jika tersedia;

tidak menyerahkan akun kepada staf;

dan **melakukan sendiri proses TTE yang menjadi kewenangannya.**

Kemudahan administrasi tidak boleh menjadi alasan untuk menyerahkan identitas digital kepada orang lain.

Bangun Budaya Keamanan melalui Keteladanan

Pegawai cenderung mengikuti kebiasaan yang diterapkan dalam lingkungan kerjanya.

Jika pimpinan melakukan verifikasi sebelum mengirim data, menjaga credential, mematuhi prosedur, dan segera melaporkan insiden, perilaku tersebut membantu membangun **budaya keamanan informasi yang konsisten.**

INGAT: Pimpinan bukan hanya pembuat keputusan, tetapi juga teladan dalam keamanan informasi. Jabatan tidak memberikan akses tanpa batas dan tidak menjadi alasan untuk meminta password, OTP, atau passphrase milik orang lain. **Budaya keamanan yang baik dimulai dari kepatuhan dan keteladanan di setiap tingkat organisasi.**

12.4 Peran Pengelola Teknologi Informasi

Pengelola Teknologi Informasi (TI) memiliki peran penting dalam menyediakan dan menjaga sistem informasi agar dapat digunakan **secara aman, andal, dan sesuai kebutuhan organisasi.**

Namun, kewenangan teknis yang dimiliki pengelola TI bukan berarti bebas mengakses seluruh data. **Akses administratif tetap harus digunakan hanya untuk kepentingan pekerjaan.**

Menjaga Keamanan Sistem

Pengelola TI bertanggung jawab sesuai kewenangannya untuk menerapkan dan memelihara pengamanan sistem, antara lain:

pengelolaan akun dan hak akses;
pembaruan sistem dan perangkat lunak;
perlindungan terhadap malware;
pengamanan jaringan dan server;
pencadangan data;
serta **logging dan pemantauan sistem.**

Pengamanan tersebut perlu disesuaikan dengan risiko dan kebutuhan organisasi.

Mengelola Hak Akses Pengguna

Pengelola TI membantu memastikan pengguna memperoleh akses sesuai tugas dan kewenangannya.

Akses perlu dikelola sepanjang siklus hidup pengguna, mulai dari **pembuatan akun, perubahan hak akses, peninjauan, hingga pencabutan akses ketika tidak lagi diperlukan.**

Prinsipnya:

Berikan akses sesuai kebutuhan → tinjau secara berkala → cabut ketika tidak diperlukan.

ISO/IEC 27002:2022 menempatkan pengendalian akses, pengelolaan identitas, dan pengelolaan hak akses sebagai bagian penting dari keamanan informasi (ISO/IEC, 2022).

Hak Administrator Bukan Hak untuk Melihat Semua Data

Administrator sistem mungkin memiliki kemampuan teknis untuk mengakses server, database, *backup*, atau konfigurasi penting.

Namun:

Mampu mengakses ≠ boleh mengakses tanpa kebutuhan.

Hak administrator harus digunakan hanya untuk kegiatan yang berkaitan dengan tugas dan kewenangan, seperti pemeliharaan, *troubleshooting*, pencadangan, atau penanganan insiden.

Pengelola TI tetap wajib menjaga kerahasiaan informasi yang ditemui selama menjalankan pekerjaannya.

Menjaga Credential dan Akun Administratif

Akun administrator memiliki kewenangan tinggi sehingga perlu dijaga dengan baik.

Pengelola TI tidak seharusnya:

**berbagi password administrator tanpa mekanisme yang sah;
menggunakan akun pengguna lain;
memberikan credential kepada vendor secara sembarangan;
atau membiarkan akses administratif tetap aktif tanpa kebutuhan.**

Jika tersedia, mekanisme autentikasi yang lebih kuat seperti MFA dapat digunakan sesuai kebijakan organisasi.

Mengelola Akses Vendor

Ketika vendor membutuhkan akses, pengelola TI berperan memastikan akses diberikan melalui **mekanisme resmi, terbatas, dan dapat dipertanggungjawabkan.**

Vendor tidak seharusnya memperoleh akses hanya dengan meminjam akun pegawai atau karena mengatakan:

“Saya perlu akses administrator supaya lebih mudah.”

Kebutuhan akses perlu diverifikasi, dibatasi, dipantau sesuai kebutuhan, dan dicabut setelah tidak diperlukan.

Membantu Penanganan Insiden

Ketika terjadi insiden keamanan, pengelola TI dapat berperan dalam **pemeriksaan, pembatasan dampak, pemulihan sistem, dan pengumpulan informasi teknis** sesuai prosedur organisasi.

Karena itu, laporan pengguna mengenai *phishing*, *malware*, akun mencurigakan, kehilangan perangkat, atau kejadian lainnya perlu ditindaklanjuti secara tepat.

Pengelola TI juga perlu menjaga *log* dan informasi lain yang diperlukan dalam proses penanganan insiden.

Membantu Pengguna Bekerja dengan Aman

Peran pengelola TI bukan hanya memasang teknologi keamanan, tetapi juga membantu pengguna memahami cara menggunakan sistem dengan benar.

Jika terdapat perubahan sistem, ancaman baru, atau prosedur keamanan tertentu, informasi yang diperlukan perlu disampaikan dengan bahasa yang mudah dipahami pengguna.

Dengan demikian, pengelola TI berperan sebagai **pengelola teknologi sekaligus pendukung terciptanya perilaku penggunaan sistem yang aman.**

INGAT: Pengelola TI memiliki kewenangan teknis yang besar, tetapi kewenangan tersebut harus digunakan secara bertanggung jawab. Kelola akses sesuai kebutuhan, lindungi akun administratif, awasi akses pihak ketiga, jaga kerahasiaan data, dan dukung pengguna serta organisasi dalam penanganan insiden keamanan.

12.5 Peran Administrator Sistem

Administrator sistem memiliki kewenangan teknis yang lebih tinggi dibandingkan pengguna biasa. Administrator dapat mengelola server, aplikasi, database, akun, konfigurasi, dan berbagai komponen penting lainnya.

Karena memiliki akses yang luas, administrator harus menerapkan prinsip **akses seperlunya, akuntabilitas, dan pemisahan penggunaan akun administratif dari aktivitas biasa.**

Hak Administrator Digunakan Hanya untuk Administrasi

Hak administrator diberikan untuk menjalankan tugas teknis, bukan untuk memberikan kebebasan mengakses seluruh informasi.

Administrator tidak boleh menggunakan kewenangannya untuk:

membuka data pasien tanpa kebutuhan pekerjaan;

menyalin database untuk kepentingan pribadi;

melihat informasi karena rasa ingin tahu;

atau **mengubah data tanpa kewenangan.**

Prinsipnya:

Hak akses tinggi → tanggung jawab lebih tinggi.

Gunakan Akun Administratif Secara Tepat

Jika sistem memungkinkan, aktivitas administratif sebaiknya menggunakan akun yang memang diperuntukkan bagi fungsi administrasi dan dapat dikaitkan dengan administrator yang bersangkutan.

Hindari penggunaan satu akun administrator bersama oleh banyak orang tanpa mekanisme akuntabilitas yang memadai.

ISO/IEC 27002:2022 memberikan perhatian khusus terhadap pengelolaan ***privileged access rights*** karena akun dengan hak istimewa dapat memberikan kemampuan yang lebih besar terhadap sistem dan informasi (ISO/IEC, 2022).

Jangan Menggunakan Hak Administrator untuk Aktivitas Biasa

Hak administratif sebaiknya digunakan ketika memang diperlukan.

Aktivitas sehari-hari yang tidak membutuhkan kewenangan administrator tidak perlu dilakukan menggunakan akun dengan hak akses tinggi.

Prinsip ini membantu mengurangi risiko apabila akun atau sesi pengguna mengalami kompromi.

Credential Administrator Harus Dijaga

Password, token, *private key*, atau informasi autentikasi administratif merupakan *credential* penting.

Administrator tidak boleh membagikan *credential* pribadi kepada pegawai, vendor, maupun administrator lain hanya untuk mempermudah pekerjaan.

Jika beberapa administrator membutuhkan akses, gunakan **mekanisme pengelolaan akses yang ditetapkan organisasi**, bukan saling berbagi *password* pribadi.

Aktivitas Administratif Perlu Dapat Ditelusuri

Perubahan konfigurasi, pengelolaan akun, akses terhadap sistem penting, dan aktivitas administratif lainnya perlu dapat dipertanggungjawabkan.

Logging dan *audit trail* membantu organisasi mengetahui **siapa yang melakukan aktivitas, kapan dilakukan, dan tindakan apa yang tercatat.**

Administrator tidak boleh menghapus atau memanipulasi *log* untuk menyembunyikan aktivitas.

Berhati-hati terhadap Database dan Backup

Administrator mungkin memiliki kemampuan untuk membuat *backup*, mengeksport database, atau mengakses file yang berisi data pasien.

Namun:

Kemampuan teknis ≠ kewenangan untuk menggunakan data secara bebas.

Database dan *backup* tetap harus dilindungi dan hanya digunakan sesuai kebutuhan pekerjaan serta prosedur organisasi.

Akses Darurat Tetap Harus Dipertanggungjawabkan

Dalam kondisi tertentu, administrator mungkin perlu melakukan tindakan cepat untuk memulihkan layanan atau menangani insiden.

Kondisi darurat bukan berarti seluruh kontrol keamanan dapat diabaikan. Aktivitas yang dilakukan tetap perlu **sesuai kewenangan, dapat ditelusuri, dan didokumentasikan sesuai prosedur yang berlaku.**

INGAT: Administrator memiliki akses yang tinggi karena kebutuhan tugas, bukan karena memiliki kebebasan terhadap seluruh sistem dan data. Gunakan hak administratif hanya ketika diperlukan, lindungi credential, hindari akun bersama, dan pastikan aktivitas penting dapat dipertanggungjawabkan.

12.6 Peran Vendor dan Pihak Ketiga

Vendor dan pihak ketiga dapat terlibat dalam pengembangan, pemeliharaan, *troubleshooting*, atau dukungan terhadap sistem informasi rumah sakit. Dalam pelaksanaan pekerjaan tersebut, mereka dapat memperoleh akses terhadap **sistem, perangkat, jaringan, atau data pasien.**

Karena itu, vendor dan pihak ketiga memiliki tanggung jawab untuk **menjaga keamanan dan kerahasiaan informasi yang diperoleh selama menjalankan pekerjaan.**

Akses Hanya Sesuai Kebutuhan

Vendor hanya boleh mengakses sistem dan informasi yang diperlukan untuk pekerjaan yang diberikan.

Status sebagai vendor resmi tidak berarti memiliki hak untuk:

mengakses seluruh sistem;

melihat seluruh data pasien;

mengunduh database;

atau **meminta akses administrator tanpa kebutuhan yang jelas.**

Prinsip *need-to-know* dan *least privilege* tetap berlaku bagi pihak ketiga.

Gunakan Identitas dan Akses Resmi

Vendor tidak seharusnya menggunakan akun milik pegawai untuk melakukan pekerjaannya.

Jika membutuhkan akses, gunakan mekanisme yang ditetapkan organisasi sehingga aktivitas dapat **dikaitkan dengan identitas yang jelas dan dipertanggungjawabkan.**

Vendor juga tidak boleh meminta *password*, OTP, atau *credential* pribadi milik pegawai.

Jaga Kerahasiaan Data

Informasi yang diperoleh selama pekerjaan tidak boleh digunakan untuk tujuan lain.

Data pasien tidak boleh sembarangan:

disalin ke laptop pribadi;

dikirim melalui media pribadi;

digunakan sebagai data demonstrasi;

dibagikan kepada pihak lain;

atau **disimpan setelah tidak lagi diperlukan.**

Jika *troubleshooting* dapat dilakukan menggunakan data uji atau data yang telah diminimalkan, penggunaan data tersebut harus diutamakan.

Patuhi Pengamanan Remote Access

Jika pekerjaan dilakukan dari jarak jauh, vendor harus menggunakan mekanisme *remote access* yang disetujui organisasi.

Jangan membuat jalur akses sendiri, memasang aplikasi *remote* permanen, atau mempertahankan akses setelah pekerjaan selesai tanpa kewenangan.

Akses sementara harus tetap **sementara**.

Laporkan Insiden

Jika vendor mengetahui adanya kehilangan data, salah kirim, *malware*, akses tanpa kewenangan, kebocoran *credential*, atau kejadian keamanan lainnya yang berkaitan dengan sistem rumah sakit, kejadian tersebut harus **segera dilaporkan melalui mekanisme yang telah ditetapkan**.

Insiden tidak boleh disembunyikan hanya karena terjadi pada lingkungan atau perangkat milik vendor.

Tanggung Jawab Tidak Berakhir pada Aspek Teknis

Hubungan dengan pihak ketiga juga perlu mengatur persyaratan keamanan informasi yang relevan. ISO/IEC 27002:2022 menekankan pengelolaan keamanan informasi dalam hubungan dengan pemasok, termasuk penetapan persyaratan keamanan dalam perjanjian dengan pemasok (ISO/IEC, 2022).

Dalam konteks pemrosesan Data Pribadi, UU Nomor 27 Tahun 2022 juga mengatur hubungan antara Pengendali Data Pribadi dan Prosesor Data Pribadi. Prosesor melakukan pemrosesan berdasarkan perintah Pengendali Data Pribadi sesuai ketentuan yang berlaku (Republik Indonesia, 2022).

Setelah Pekerjaan Selesai

Ketika pekerjaan atau kebutuhan akses berakhir, vendor harus mengikuti proses pengakhiran akses dan penanganan data yang ditetapkan organisasi.

Prinsipnya:

**AKSES SESUAI KEBUTUHAN → JAGA KERAHASIAAN →
LAPORKAN INSIDEN → AKHIRI AKSES SETELAH SELESAI**

INGAT: Vendor dan pihak ketiga adalah bagian dari rantai keamanan informasi rumah sakit. Gunakan akses hanya untuk pekerjaan yang diberikan, jangan menggunakan akun pegawai, jaga kerahasiaan data pasien, patuhi mekanisme keamanan organisasi,

dan **jangan mempertahankan data atau akses setelah tidak lagi diperlukan.**

12.7 Biasakan Memverifikasi Sebelum Memberikan Akses atau Data

Banyak insiden keamanan terjadi bukan karena teknologi gagal, tetapi karena seseorang **memberikan akses atau data kepada pihak yang ternyata tidak berhak menerimanya.**

Karena itu, sebelum memberikan data pasien, akses sistem, dokumen, atau informasi penting lainnya, biasakan untuk **memverifikasi identitas penerima, kewenangannya, dan kebutuhan permintaannya.**

Jangan Hanya Mengenali Nama atau Jabatan

Seseorang dapat mengaku sebagai:

pimpinan;

administrator TI;

vendor;

teknisi;

atau **pegawai dari unit lain.**

Nama, foto profil, seragam, jabatan, maupun nomor telepon bukan bukti yang cukup bahwa suatu permintaan sah.

Jika permintaan tidak biasa, lakukan verifikasi melalui **kanal resmi atau pihak yang berwenang.**

Verifikasi Tiga Hal

Sebelum memberikan akses atau data, tanyakan:

Siapa yang meminta?

Pastikan identitas pihak yang meminta.

Apakah dia berwenang?

Pastikan pihak tersebut memang memiliki kewenangan terhadap akses atau data yang diminta.

Apakah data tersebut benar-benar diperlukan?

Berikan hanya informasi yang diperlukan untuk tujuan pekerjaan.

Prinsip sederhananya:

**IDENTITAS → KEWENANGAN → KEBUTUHAN → BARU BERIKAN
Permintaan dari Atasan Tetap Perlu Sesuai Prosedur**

Verifikasi bukan berarti tidak mempercayai atasan atau rekan kerja.

Jika permintaan melibatkan data sensitif, akses sistem, *credential*, atau tindakan yang tidak biasa, pastikan permintaan tersebut **sesuai kewenangan dan prosedur organisasi**.

Jabatan tidak menghilangkan kebutuhan untuk menjaga keamanan informasi.

Vendor Juga Harus Diverifikasi

Kalimat:

“Saya dari vendor SIMRS.”

tidak otomatis menjadi alasan untuk memberikan akses.

Pastikan vendor memang sedang memiliki pekerjaan yang membutuhkan akses tersebut dan ruang lingkup akses sesuai kebutuhannya.

Jika ragu, konfirmasi kepada pengelola TI atau penanggung jawab pekerjaan sebelum memberikan akses.

Jangan Terpengaruh Tekanan Waktu

Pelaku *social engineering* sering menciptakan keadaan mendesak:

“Harus sekarang.”

“Pimpinan sedang menunggu.”

“Kalau tidak segera diberikan, sistem akan bermasalah.”

Tekanan waktu tidak boleh menjadi alasan untuk melewati proses verifikasi.

Sebagaimana telah dibahas pada BAB 9, permintaan yang mendesak dan tidak biasa justru perlu mendapatkan perhatian lebih.

Berikan Data Seminimal Mungkin

Setelah permintaan dinyatakan sah, tetap jangan memberikan data lebih banyak daripada yang diperlukan.

Jika kebutuhan hanya memerlukan satu informasi, jangan memberikan seluruh dokumen atau database.

Prinsip ***need-to-know*** dan ***least privilege*** tetap berlaku:

Permintaan sah ≠ akses tanpa batas.

ISO/IEC 27002:2022 menekankan pengendalian akses berdasarkan kebutuhan bisnis dan keamanan informasi serta pentingnya kesadaran personel terhadap tanggung jawab keamanan (ISO/IEC, 2022).

INGAT: Sebelum memberikan data atau akses, verifikasi siapa yang meminta, apakah memiliki kewenangan, dan apakah informasi tersebut benar-benar diperlukan. Jika masih ragu, jangan langsung memberikan akses atau data. **Konfirmasikan terlebih dahulu melalui mekanisme resmi organisasi.**

12.8 Laporkan Aktivitas yang Mencurigakan

Keamanan informasi tidak hanya bergantung pada kemampuan mendeteksi serangan secara otomatis. Pengguna sering menjadi pihak pertama yang melihat **aktivitas yang tidak biasa atau mencurigakan**.

Karena itu, jika menemukan sesuatu yang tidak wajar pada akun, perangkat, sistem, atau penggunaan data pasien, **segera laporkan melalui mekanisme yang ditetapkan organisasi**.

Kenali Aktivitas yang Mencurigakan

Beberapa contoh yang perlu diperhatikan antara lain:

akun menunjukkan aktivitas yang tidak pernah dilakukan;

muncul permintaan OTP atau MFA tanpa melakukan *login*;

seseorang meminta password atau *passphrase*;

vendor mencoba mengakses sistem di luar kebutuhan pekerjaannya;

terdapat email, tautan, lampiran, atau *QR Code* mencurigakan;

komputer menunjukkan perilaku yang tidak biasa;

atau data pasien terlihat diakses atau dibagikan kepada pihak yang tidak berkepentingan.

Pengguna tidak harus memastikan bahwa kejadian tersebut benar-benar merupakan serangan sebelum melaporkannya.

Jangan Mengabaikan karena Belum Terjadi Kerugian

Aktivitas mencurigakan dapat menjadi tanda awal sebuah insiden.

Hindari berpikir:

“Belum ada data yang hilang.”

“Mungkin hanya kesalahan sistem.”

“Saya tidak mau ikut campur.”

“Bukan tanggung jawab saya.”

Laporan awal dapat membantu organisasi melakukan pemeriksaan sebelum kejadian berkembang menjadi masalah yang lebih besar.

Laporkan Sesuai Fakta

Ketika melapor, sampaikan informasi yang diketahui, misalnya:

apa yang terlihat mencurigakan;

kapan kejadian diketahui;

akun, perangkat, atau sistem yang terlibat;

dan tindakan yang sudah dilakukan.

Jangan menambah informasi berdasarkan dugaan. Jika tidak mengetahui sesuatu, sampaikan bahwa informasi tersebut belum diketahui.

Jangan Melakukan Investigasi Sendiri

Pengguna tidak perlu mencoba membuktikan sendiri bahwa seseorang telah melakukan pelanggaran.

Jangan membuka akun orang lain, mengakses *log* tanpa kewenangan, menyalin data, atau melakukan tindakan teknis di luar tugas hanya untuk mencari bukti.

Prinsipnya:

LIHAT → CATAT → LAPORKAN → IKUTI ARAHAN

Pemeriksaan lebih lanjut dilakukan oleh pihak yang memiliki kewenangan.

Jangan Takut Melaporkan Dugaan

Tidak semua laporan akan terbukti sebagai insiden keamanan. Hal tersebut tidak menjadi alasan untuk mengabaikan aktivitas yang benar-benar terlihat tidak wajar.

Budaya keamanan yang baik mendorong pengguna untuk **melaporkan kejadian secara wajar dan berdasarkan fakta**, sehingga organisasi dapat melakukan penilaian.

ISO/IEC 27002:2022 menekankan pentingnya pelaporan kejadian keamanan informasi yang diamati atau dicurigai melalui saluran yang sesuai secara tepat waktu (ISO/IEC, 2022).

Pelaporan Adalah Bagian dari Tanggung Jawab Bersama

Pengguna tidak dituntut menjadi ahli keamanan siber. Namun, setiap pengguna dapat membantu organisasi dengan **mengenali sesuatu yang tidak biasa dan tidak membiarkannya begitu saja**.

Satu laporan dapat membantu mencegah kejadian yang sama berdampak pada pengguna, sistem, atau data pasien lainnya.

INGAT: Jika melihat aktivitas yang mencurigakan, jangan mengabaikannya dan jangan melakukan investigasi sendiri. Catat informasi yang diketahui dan segera laporkan melalui mekanisme organisasi. Lebih baik suatu kejadian diperiksa dan dinyatakan aman daripada ancaman nyata terlambat diketahui.

12.9 Security Awareness sebagai Pertahanan terhadap Serangan Siber

Teknologi keamanan seperti *firewall*, antivirus, MFA, dan sistem pemantauan sangat penting. Namun, serangan siber juga dapat menargetkan **manusia sebagai pengguna sistem**.

Karena itu, *security awareness* atau kesadaran keamanan merupakan bagian penting dari pertahanan organisasi. Tujuannya adalah membentuk kebiasaan agar pengguna mampu **mengenali risiko, mengambil tindakan yang aman, dan melaporkan kejadian yang mencurigakan**.

Manusia Dapat Menjadi Sasaran Serangan

Penyerang tidak selalu mencoba membobol sistem secara teknis. Mereka dapat mencoba memperoleh akses dengan memanipulasi pengguna.

Contohnya:

email *phishing*;
pesan yang meminta OTP;
telepon yang mengaku sebagai administrator TI;
vendor palsu yang meminta akses;
atau **tautan dan QR Code yang mengarahkan pengguna ke halaman palsu.**

Serangan seperti ini memanfaatkan kepercayaan, rasa takut, rasa ingin membantu, atau tekanan waktu.

Security Awareness Membentuk Kebiasaan Aman

Kesadaran keamanan bukan sekadar mengetahui istilah keamanan siber. Yang lebih penting adalah **menerapkan perilaku aman dalam pekerjaan sehari-hari.**

Misalnya:

tidak memberikan password dan OTP;
memverifikasi permintaan yang tidak biasa;
memeriksa penerima sebelum mengirim data;
mengunci komputer ketika ditinggalkan;
tidak sembarangan membuka tautan dan lampiran;
serta **segera melaporkan aktivitas mencurigakan.**

ISO/IEC 27002:2022 menekankan pentingnya *information security awareness, education and training* agar personel memahami tanggung jawab keamanan informasi dan memperoleh pengetahuan yang sesuai dengan pekerjaannya (ISO/IEC, 2022).

Kesadaran Keamanan Harus Dilakukan Secara Berkelanjutan

Ancaman dan cara kerja organisasi dapat berubah. Karena itu, *security awareness* tidak cukup dilakukan hanya sekali ketika pegawai mulai bekerja.

Kesadaran keamanan perlu dipelihara melalui kegiatan yang sesuai, seperti **sosialisasi, pelatihan, pengingat keamanan, simulasi, atau pembelajaran dari insiden yang pernah terjadi.**

Materi juga perlu disesuaikan dengan risiko yang dihadapi pengguna. Administrator sistem, petugas pelayanan, pimpinan, dan vendor dapat memiliki risiko yang berbeda.

Teknologi dan Manusia Harus Saling Melengkapi

Tidak tepat jika keamanan hanya mengandalkan pengguna. Sebaliknya, teknologi saja juga tidak selalu mampu mencegah setiap kesalahan.

Contohnya, sistem dapat menggunakan MFA, tetapi pengguna tetap harus memahami bahwa **OTP tidak boleh diberikan kepada orang lain.**

Karena itu, pertahanan yang baik menggabungkan:

teknologi + prosedur + pengguna yang sadar keamanan.

Belajar dari Insiden

Insiden keamanan dapat menjadi bahan untuk meningkatkan kesadaran pengguna.

Jika organisasi menemukan pola *phishing* baru, misalnya, informasi tersebut dapat digunakan untuk memperingatkan pengguna agar serangan yang sama tidak berhasil pada pegawai lainnya.

Tujuannya bukan mencari siapa yang harus dipermalukan, tetapi **mengurangi kemungkinan kejadian yang sama terulang.**

Setiap Pengguna Merupakan Bagian dari Pertahanan

Pengguna tidak perlu menjadi ahli keamanan siber. Namun, pengguna perlu mengetahui risiko yang berkaitan dengan pekerjaannya dan tindakan yang harus dilakukan ketika menemukan sesuatu yang mencurigakan.

Prinsip sederhana yang dapat dibiasakan adalah:

KENALI → VERIFIKASI → LINDUNGI → LAPORKAN

INGAT: *Security awareness* merupakan bagian dari pertahanan terhadap serangan siber. Teknologi keamanan harus didukung oleh pengguna yang memahami risiko dan memiliki kebiasaan kerja yang aman. **Kenali ancaman, verifikasi permintaan yang mencurigakan, lindungi data dan credential, serta segera laporkan kejadian keamanan.**

12.10 Dari Kepatuhan Menuju Budaya Keamanan Informasi

Keamanan informasi tidak cukup hanya diwujudkan melalui kebijakan, prosedur, atau aturan tertulis. Perlindungan yang lebih kuat terbentuk ketika perilaku aman menjadi **kebiasaan dalam pekerjaan sehari-hari**.

Pada tahap ini, pegawai tidak menjaga keamanan hanya karena takut melanggar aturan, tetapi karena memahami bahwa tindakannya dapat memengaruhi **data pasien, pelayanan rumah sakit, dan keamanan organisasi**.

Kepatuhan Merupakan Langkah Awal

Kebijakan dan prosedur tetap diperlukan untuk memberikan batasan yang jelas mengenai tindakan yang boleh dan tidak boleh dilakukan.

Contohnya:

**tidak membagikan password dan OTP;
menggunakan akun sendiri;
mengakses data sesuai kebutuhan;
menjaga kerahasiaan data pasien;
dan melaporkan insiden keamanan.**

Namun, kepatuhan akan lebih efektif jika pengguna memahami **mengapa aturan tersebut diperlukan**, bukan sekadar menjalankannya karena diwajibkan.

Budaya Keamanan Terlihat dari Kebiasaan

Budaya keamanan terbentuk ketika perilaku aman dilakukan secara konsisten, bahkan ketika tidak ada orang yang mengawasi.

Misalnya, pengguna terbiasa:

**mengunci komputer sebelum meninggalkan meja;
memeriksa penerima sebelum mengirim data;
memverifikasi permintaan yang tidak biasa;
menolak memberikan credential kepada orang lain;
dan segera melaporkan kesalahan atau kejadian mencurigakan.**

Perilaku tersebut akhirnya menjadi bagian dari cara bekerja.

Budaya Keamanan Berlaku untuk Semua

Budaya keamanan tidak hanya ditujukan kepada pegawai biasa.

Pimpinan, tenaga kesehatan, pengguna sistem, pengelola TI, administrator, vendor, dan pihak ketiga perlu menerapkan prinsip keamanan sesuai peran dan kewenangannya.

Pimpinan memberikan contoh. Pengelola TI menyediakan pengamanan. Pengguna menjaga akses dan data. Vendor mematuhi pembatasan akses dan menjaga kerahasiaan.

Dengan demikian:

Keamanan bukan tugas satu unit → keamanan adalah bagian dari pekerjaan setiap pihak.

Kesalahan Harus Menjadi Bahan Perbaikan

Budaya keamanan yang baik juga mendorong pelaporan ketika terjadi kesalahan.

Jika seseorang salah mengirim data, mengklik *phishing*, atau melakukan kesalahan lainnya, tindakan pertama yang diperlukan adalah **segera melaporkan agar dampaknya dapat dibatasi**.

Insiden juga dapat digunakan sebagai bahan pembelajaran untuk memperbaiki prosedur, teknologi, maupun kesadaran pengguna.

ISO/IEC 27002:2022 menekankan pentingnya kesadaran dan pelatihan keamanan informasi serta pembelajaran dari insiden untuk meningkatkan perlindungan organisasi (ISO/IEC, 2022).

Keamanan Menjadi Bagian dari Cara Bekerja

Tujuan akhirnya bukan membuat pegawai terus-menerus merasa takut melakukan kesalahan.

Tujuannya adalah membentuk kebiasaan sederhana:

BERPIKIR SEBELUM MENGAKSES

PERIKSA SEBELUM MENGIRIM

VERIFIKASI SEBELUM MEMBERIKAN

LINDUNG CREDENTIAL

LAPORKAN JIKA MENCURIGAKAN

Jika kebiasaan tersebut dilakukan secara konsisten, keamanan informasi tidak lagi dipandang sebagai tambahan pekerjaan, tetapi menjadi **bagian dari cara organisasi bekerja**.

INGAT: Kepatuhan membuat kita mengikuti aturan. Budaya keamanan membuat kita tetap melakukan hal yang benar meskipun tidak sedang diawasi. Pelindungan data pasien membutuhkan teknologi dan prosedur, tetapi juga membutuhkan kebiasaan aman dari setiap orang yang bekerja dengan informasi.

DAFTAR PUSTAKA

- International Organization for Standardization & International Electrotechnical Commission. (2022). *ISO/IEC 27002:2022 Information security, cybersecurity and privacy protection — Information security controls*. International Organization for Standardization.
- Joint Task Force. (2020). *Security and privacy controls for information systems and organizations (NIST Special Publication 800-53 Revision 5)*. National Institute of Standards and Technology.
- Kementerian Kesehatan Republik Indonesia. (2022). *Peraturan Menteri Kesehatan Republik Indonesia Nomor 24 Tahun 2022 tentang Rekam Medis*. Kementerian Kesehatan Republik Indonesia.
- Merritt, M., Hansche, S., Ellis, B., Sanchez-Cherry, K., Walden, D., Snyder, J. N., & Walden, J. (2024). *Building a cybersecurity and privacy learning program (NIST Special Publication 800-50 Revision 1)*. National Institute of Standards and Technology.
- Pascoe, C., Quinn, S., & Scarfone, K. (2024). *The NIST Cybersecurity Framework (CSF) 2.0* (NIST Cybersecurity White Paper 29). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.CSWP.29>
- Republik Indonesia. (2019). *Peraturan Pemerintah Republik Indonesia Nomor 71 Tahun 2019 tentang Penyelenggaraan Sistem dan Transaksi Elektronik*. Lembaran Negara Republik Indonesia Tahun 2019 Nomor 185, Tambahan Lembaran Negara Republik Indonesia Nomor 6400.
- Republik Indonesia. (2022). *Undang-Undang Republik Indonesia Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi*. Lembaran Negara Republik Indonesia Tahun 2022 Nomor 196, Tambahan Lembaran Negara Republik Indonesia Nomor 6820.

Temoshok, D., Fenton, J. L., Choong, Y. Y., Lefkovitz, N., Regenscheid, A., Galluzzo, R., & Richer, J. P. (2025). *Digital identity guidelines: Authentication and authenticator management* (NIST Special Publication 800-63B-4). National Institute of Standards and Technology.
<https://doi.org/10.6028/NIST.SP.800-63B-4>